GROUPEMENT INTERBANCAIRE MONÉTIQUE DE L'AFRIQUE CENTRALE

Banque des États de l'Afrique Centrale (BEAC)

Département Exploitation et Supervision (DES)

CAHIER DE CONCEPTION DU PROJET D'ENSEMBLE

ARCHITECTURE LOGICIELLE AXÉE MICROSERVICES ET CONCEPTION DÉTAILLÉE

Plateforme intégrée de suivi, de supervision et de dé-silotage des activités du Département Exploitation et Supervision

Référence	**CC-GIMAC-01 v1.1** (anciennement CCT-GIMAC-02)
Statut	**Document de référence pour implémentation**
Nature	Cahier de conception générale et détaillée
Architecture	Quatorze microservices, confiance nulle, fédération au fournisseur d'identité
Documents amont	CCT-GIMAC-01 v1.1, TDR-GIMAC-01 v1.0, CA-GIMAC-01 v1.1
Établi par	**KOAGNE ISSA RYAN**, Ingénieur **NGOUNOU STEVE DELORS**, Ingénieur
Sous la supervision de	**Mme EKOUTOU GUILEINE** **M. TABANGOLI Anthony** **M. SOSSY Martial**

GIMAC - Siège Social, Yaoundé, République du Cameroun
Plateforme de suivi des activités du DES, version 1.1
Septembre 2026

Fiche d'identification du document

Informations Générales	
Titre	Cahier de conception, plateforme intégrée du DES
Référence	CC-GIMAC-01 v1.1
Version	Version 1.1 (revue de cohérence)
Date d'émission	Septembre 2026
Établi par	KOAGNE ISSA RYAN, Ingénieur ; NGOUNOU STEVE DELORS, Ingénieur
Organisme	Groupement Interbancaire Monétique de l'Afrique Centrale (GIMAC)
Direction métier	Département Exploitation et Supervision (DES)
Validateurs	Direction Générale, Direction Technique, Direction de la Sécurité (RSSI)
Cadre réglementaire	COBAC R-2024/01, COBAC R-2016/04, PCI-DSS v4.0.1, Instruction BEAC 001/GR/2018
Architecture cible	Quatorze microservices découplés, confiance nulle (NIST SP 800-207), fédération au fournisseur d'identité
Diffusion	Direction Générale, DES, DDRM, RSSI, Équipe MOE / Ingénierie logicielle

Historique des versions

Version	Date	Auteur	Description des modifications
v1.0	26/09/2026	KOAGNE ISSA RYAN, NGOUNOU STEVE DELORS	Création du squelette architectural du document de conception.
v1.1	28/09/2026	KOAGNE ISSA RYAN, NGOUNOU STEVE DELORS	Revue de cohérence d'ensemble : périmètre non intrusif, quatorze microservices (ajout de l'audit, de la gestion documentaire, des notifications ; séparation des incidents, du monitoring, du rapprochement et du reporting), chapitres 5 et 6 réécrits par rôle, diagrammes refaits, thème et maquettes réalignés.

Table des matières

1 Introduction **13**

1.1 Contexte du document 13

1.2 Objectif du document 14

1.3 Organisation du document 14

2 Présentation du projet **16**

2.1 Objectifs du système 16

2.2 Interfaces du système 17

2.3 Contraintes générales de conception 19

3 Documents de référence **21**

3.1 Documents du projet 21

3.2 Règlements et instructions prudentielles 22

3.3 Normes et standards technologiques internationaux 22

4 Normes, standards et outils **24**

4.1 Méthodes de conception 24

4.1.1 Démarche de modélisation : Processus 2TUP 24

4.1.2 Langage de modélisation : UML 2.5 25

4.2 Environnement, technologies et outils de développement 25

4.2.1 Choix de l'écosystème technologique et accélération par JHipster . . . 25

4.2.2 Matrice des technologies et composants logiciels 26

4.2.3 Protocoles de communication et formats d'échange 28

4.2.4 Standards de programmation et patrons d'architecture 30

4.3 Plan de Qualité Logicielle 31

5 Conception générale 33

5.1 Dissociation formelle entre suivi de l'homologation et décision de certification . 34

5.1.1 Doctrine de séparation des pouvoirs et conformité ISO/IEC 17065 . . . 34

5.1.2 Le suivi des preuves et des couvertures : MS-HOMOLOGATION . . . 35

5.1.3 La décision et l'attestation : MS-CERTIFICATION 35

5.1.4 Différentiel structurel et modèle Zero Trust 36

5.2 Décomposition en microservices et Domain-Driven Design (DDD) 37

5.2.1 Du domaine d'analyse au microservice : règle de découpage 37

5.2.2 Modélisation des Bounded Contexts et frontières de domaine 38

5.2.3 Autonomie des données et stratégie Database-per-Service 41

5.2.4 Déploiement sans interruption et modèle Expand/Contract 42

5.2.5 Position de la plateforme vis-à-vis du périmètre PCI-DSS 42

5.3 Architecture d'échange et modèles de communication 43

5.3.1 Modèle synchrone sécurisé : interfaces de service et mTLS (RFC 8705) 43

5.3.2 Modèle asynchrone et standardisation événementielle 43

5.3.3 Patrons de résilience distribuée 44

5.4 Architecture générale du système 44

5.5 Diagramme de composants 46

5.6 Zoning réseau, déploiement et haute disponibilité 49

5.6.1 Topologie de sécurité et découpage en cinq zones étanches 49

5.6.2 Mécanismes de haute disponibilité 52

5.6.3 Archivage légal inaltérable et persistance WORM 52

6 Conception détaillée 54

6.1 Conception détaillée par microservice 55

6.1.1 Passerelle d'accès et frontière d'entrée (MS-GATEWAY) 56

6.1.2 Habilitations, annuaire et fédération d'identité (MS-IAM) 70

6.1.3 Registre d'audit inaltérable et arbre de Merkle (MS-AUDIT) 84

6.1.4 Gestion électronique des documents probants (MS-DOCUMENT) . . . 99
6.1.5 Notifications, canaux de remise et escalade (MS-NOTIFICATION) . . 115
6.1.6 Référentiels et gestion des participants (MS-PARTICIPANT) 131
6.1.7 Suivi de l'homologation (MS-HOMOLOGATION) 147
6.1.8 Certification et mise en service (MS-CERTIFICATION) 164
6.1.9 Tickets, incidents et cellule de crise (MS-INCIDENT) 180
6.1.10 Monitoring, astreintes et quarts (MS-MONITORING) 198
6.1.11 Rapprochement et suspens (MS-RAPPROCHEMENT) 214
6.1.12 Tâches, projets et réunions (MS-PILOTAGE) 230
6.1.13 Reporting décisionnel et cockpits (MS-REPORTING) 246
6.1.14 Messagerie et visioconférence (MS-COLLABORATION) 262
6.2 Thème de l'application 279
6.2.1 Identité graphique et logo 279
6.2.2 Palette chromatique 279
6.2.3 Typographie et grille 280
6.2.4 Design des composants d'interface 280
6.3 Maquettes des principales interfaces 282
6.3.1 Structure commune des trois couches 282
6.3.2 Cartographie des écrans de l'application du département 282
6.3.3 Cartographie des écrans du portail des participants 285
6.3.4 Cartographie des écrans de la console d'administration et d'audit 286
6.3.5 Emplacements des maquettes des écrans principaux 287

7 Conclusion 292

7.1 Bilan de la conception 292
7.2 Annonce de la phase suivante 293

List of Figures

5.1 Architecture générale de la plateforme intégrée du DES 45

5.2 Diagramme de composants du système 47

5.3 Diagramme de déploiement de l'architecture logicielle et matérielle 51

6.1 Diagramme de composants internes : passerelle d'accès et frontière d'entrée . . 59

6.2 Diagramme de classes de conception : service MS-GATEWAY 61

6.3 Diagramme d'objets : routage d'une commande avec échange de jeton et inspection 63

6.4 Diagramme de composants internes : habilitations, annuaire et fédération . . . 73

6.5 Diagramme de classes de conception : service MS-IAM 75

6.6 Diagramme d'objets : prise de vacation d'un opérateur de supervision 77

6.7 Diagramme de composants internes : registre d'audit et arbre de Merkle 87

6.8 Diagramme de classes de conception : service MS-AUDIT 89

6.9 Diagramme d'objets : scellement d'une période et vérification par l'auditeur . . 91

6.10 Diagramme de composants internes : gestion électronique des documents en WORM 103

6.11 Diagramme de classes de conception : service MS-DOCUMENT 105

6.12 Diagramme d'objets : nouvelle version d'un rapport de quart et pièce en quarantaine 108

6.13 Diagramme de composants internes : abonnements, canaux, remise et escalade 119

6.14 Diagramme de classes de conception : service MS-NOTIFICATION 121

6.15 Diagramme d'objets : incident critique de nuit, remise multicanal et escalade . 124

6.16 Diagramme de composants internes : référentiels et gestion des participants . . 134

6.17 Diagramme de classes de conception : service MS-PARTICIPANT 136

6.18 Diagramme d'objets : agrément à J-30, institution à régulariser 139

6.19 Diagramme de composants internes : homologation des participants 151
6.20 Diagramme de classes de conception : service MS-HOMOLOGATION 153
6.21 Diagramme d'objets : liaison de paiement mobile en essais 156
6.22 Diagramme de composants internes : certification et mise en service 168
6.23 Diagramme de classes de conception : service MS-CERTIFICATION 170
6.24 Diagramme d'objets : dossier de mise en service complet et scellé 173
6.25 Diagramme de composants internes : tickets, qualification, escalade, clôture et cellule de crise 185
6.26 Diagramme de classes de conception : service MS-INCIDENT 187
6.27 Diagramme d'objets : incident S1 en attente de tiers et cellule de crise constituée 190
6.28 Diagramme de composants internes : alertes, astreintes et relève de quart 202
6.29 Diagramme de classes de conception : service MS-MONITORING 204
6.30 Diagramme d'objets : relève de la vacation de nuit et rapport de quart scellé . . 207
6.31 Diagramme de composants internes : import des états, rapprochement et suspens 218
6.32 Diagramme de classes de conception : service MS-RAPPROCHEMENT 220
6.33 Diagramme d'objets : rapprochement de la journée J et premiers suspens de la Banque B 223
6.34 Diagramme de composants internes : tableaux, tâches, projets, risques et instances de décision 235
6.35 Diagramme de classes de conception : service MS-PILOTAGE 237
6.36 Diagramme d'objets : sortie du comité de pilotage hebdomadaire du DES . . . 239
6.37 Diagramme de composants internes : magasin décisionnel, indicateurs, cockpits et rapports 250
6.38 Diagramme de classes de conception : service MS-REPORTING 252
6.39 Diagramme d'objets : rapport mensuel du pôle exploitation et franchissement de seuil 255
6.40 Diagramme de composants internes : salons chiffrés, terminaux vérifiés, conférences et archives de crise 266
6.41 Diagramme de classes de conception : service MS-COLLABORATION 268
6.42 Diagramme d'objets : salon de crise ouvert et conférence en cours 271

6.43 Application du département : tableau de bord du DES 287
6.44 Application du département : fiche d'une institution membre 288
6.45 Application du département : suivi d'une liaison et de ses opérations 288
6.46 Application du département : dossier de mise en service et circuit des quitus . . 288
6.47 Application du département : qualification et suivi d'un incident 289
6.48 Application du département : grille d'astreinte et relève de quart 289
6.49 Application du département : journée de rapprochement et suspens 289
6.50 Application du département : tableau Kanban du service 290
6.51 Application du département : cockpit de la Direction Générale 290
6.52 Portail des participants : espace de l'institution 290
6.53 Portail des participants : suivi de la liaison et dépôt des preuves 291
6.54 Console d'administration et d'audit : vérification de l'intégrité du journal . . . 291
6.55 Console d'administration et d'audit : rôles, délégations et réexamen des accès . 291

List of Tables

2.1 Inventaire des interfaces techniques externes du système 18

3.1 Répertoire des normes et standards technologiques internationaux 23

4.1 Justification de l'accélération par JHipster pour le socle microservices 26
4.2 Matrice technologique exhaustive de la plateforme GIMAC 27
4.3 Répertoire des protocoles de communication et formats d'échange 29

5.1 Matrice différentielle entre le suivi de l'homologation et la décision de certification 37
5.2 Cartographie des microservices, des modules et des domaines 40
5.3 Patrons de résilience distribuée mis en œuvre sur la plateforme 44
5.4 Matrice des interfaces et flux inter-composants critiques 48
5.5 Dimensionnement et allocation des ressources d'infrastructure 52

6.1 Plan de la conception détaillée par microservice 55
6.2 Fiche de spécification : limitation de débit par fenêtre glissante 65
6.3 Fiche de spécification : échange de jeton et réduction de portée 66
6.4 Fiche de spécification : contrôle de masquage des données de carte 67
6.5 Fiche de spécification : inspection applicative 68
6.6 Fiche de spécification : outbox des décisions et publication 69
6.7 Fiche de spécification : liaison au certificat 78
6.8 Fiche de spécification : synchronisation différentielle de l'annuaire 79
6.9 Fiche de spécification : évaluation des politiques d'accès 80
6.10 Fiche de spécification : outbox et publication 81
6.11 Fiche de spécification : introspection d'un jeton externe 82

6.12 Fiche de spécification : réexamen périodique des accès 83
6.13 Fiche de spécification : inscription d'une feuille et mise à jour incrémentale . . 93
6.14 Fiche de spécification : preuve d'inclusion 94
6.15 Fiche de spécification : preuve de cohérence 95
6.16 Fiche de spécification : scellement de période 96
6.17 Fiche de spécification : vérification par l'auditeur 98
6.18 Types de pièces, origine, règle de masquage et rétention 100
6.19 Fiche de spécification : chaîne de contrôle au dépôt 110
6.20 Fiche de spécification : versionnage sans écrasement 111
6.21 Fiche de spécification : restitution contrôlée 112
6.22 Fiche de spécification : vérification d'intégrité 114
6.23 Niveaux d'urgence, canaux, acquittement, escalade et consolidation 116
6.24 Fiche de spécification : résolution des destinataires et des canaux 126
6.25 Fiche de spécification : remise multicanal avec réessais 127
6.26 Fiche de spécification : acquittement et escalade temporisée 128
6.27 Fiche de spécification : consolidation anti-tempête 130
6.28 Fiche de spécification : automate du cycle de vie et maker-checker 141
6.29 Fiche de spécification : veille des échéances 142
6.30 Fiche de spécification : état de conformité documentaire 143
6.31 Fiche de spécification : outbox et publication des événements participant 145
6.32 Fiche de spécification : signalement d'une non-conformité 146
6.33 Fiche de spécification : tri topologique de Kahn et instanciation du parcours . . 158
6.34 Fiche de spécification : clôture par la règle des quatre éléments 159
6.35 Fiche de spécification : reprise des résultats du simulateur 160
6.36 Fiche de spécification : couvertures et aptitude à la certification 162
6.37 Fiche de spécification : cohérence et migration du référentiel 163
6.38 Fiche de spécification : circuit des quatre quitus 175
6.39 Fiche de spécification : constitution et contrôle de complétude du dossier . . . 176
6.40 Fiche de spécification : scellement et horodatage RFC 3161 178

6.41 Fiche de spécification : génération de l'attestation PDF/A-3 signée PAdES . . . 179
6.42 Engagements de service et paliers d'escalade par sévérité (valeurs paramétrables) 182
6.43 Fiche de spécification : automate d'états des tickets 192
6.44 Fiche de spécification : qualification et délai imputable 193
6.45 Fiche de spécification : escalade temporisée 194
6.46 Fiche de spécification : activation et conduite de la cellule de crise 195
6.47 Fiche de spécification : contrôle des critères de clôture d'un incident 197
6.48 Gravités d'alerte, délais d'acquittement, notification et ticket (valeurs paramétrables) 200
6.49 Fiche de spécification : corrélation, déduplication et acquittement des alertes . . 209
6.50 Fiche de spécification : grille d'astreinte par programmation linéaire 210
6.51 Fiche de spécification : relève de quart et double scellement 212
6.52 Fiche de spécification : évaluation des seuils et de l'état d'une liaison 213
6.53 Fiche de spécification : import et contrôle d'un état 225
6.54 Fiche de spécification : rapprochement par identifiants pivots 226
6.55 Fiche de spécification : typologie et ouverture des suspens 228
6.56 Fiche de spécification : cycle de vie et vieillissement d'un suspens 229
6.57 Événements publiés par MS-PILOTAGE 234
6.58 Fiche de spécification : ordonnancement PERT/CPM et chemin critique 241
6.59 Fiche de spécification : matrice des risques et cycle PDCA 242
6.60 Fiche de spécification : contrôle des limites d'en-cours 244
6.61 Fiche de spécification : conversion des décisions et suivi des échéances 245
6.62 Fiche de spécification : projection idempotente des événements 257
6.63 Fiche de spécification : import et intégration d'un état déclaré 258
6.64 Fiche de spécification : fenêtre glissante, seuil et tendance 260
6.65 Fiche de spécification : génération, signature et dépôt du rapport périodique . . 261
6.66 Types de salons de MS-COLLABORATION 264
6.67 Fiche de spécification : session à double cliquet et clé de session de groupe . . 273
6.68 Fiche de spécification : sur-chiffrement SFrame et rotation des clés médias . . . 274

6.69 Fiche de spécification : ouverture d'un salon de crise sur demande 276

6.70 Fiche de spécification : constitution et scellement de l'archive de crise 277

6.71 Palette chromatique de la plateforme 280

6.72 Cartographie des écrans de l'application du département 283

6.73 Cartographie des écrans du portail des participants 285

6.74 Cartographie des écrans de la console d'administration et d'audit 286

CHAPITRE 1

Introduction

Le présent chapitre introduit le cahier de conception (CC-GIMAC-01 v1.1) dédié à la Plateforme intégrée de suivi, de supervision et de dé-silotage des activités du Département Exploitation et Supervision (DES) du Groupement Interbancaire Monétique de l'Afrique Centrale (GIMAC). Il formalise le contexte opérationnel d'ingénierie logicielle, définit les objectifs cardinaux du présent livrable et expose les grandes lignes de son organisation structurelle.

1.1 Contexte du document

Le GIMAC opère en tant qu'Infrastructure de Marché Financier (FMI) systémique pour la Communauté Économique et Monétaire de l'Afrique Centrale (CEMAC). À travers son réseau régional unifié GIMACPAY, il fédère plus de 120 établissements participants (banques commerciales, établissements de microfinance, établissements de paiement, opérateurs de monnaie électronique et Trésors publics nationaux). Cette infrastructure commute chaque année des flux dont la valeur excède 600 milliards de francs CFA.

À la suite de la validation formelle des termes de référence (TDR-GIMAC-01), du cahier de charges techniques (CCT-GIMAC-01 v1.1) et du cahier d'analyse (CA-GIMAC-01 v1.1), le projet aborde sa phase pivot d'ingénierie : la conception générale et détaillée. La plateforme est un outil de suivi et de dé-silotage des activités du département : elle lit, référence et trace, et ne s'interpose jamais dans les flux du commutateur, dont la disponibilité contractuelle (99,95 %) reste du ressort des systèmes de production. Pour ses propres exigences de disponibilité (99,9 %), de modularité et d'évolution, le système abandonne toute logique monolithique au profit d'une **architecture microservices résiliente, modulaire et orientée domaine (Domain-Driven Design)**.

1.2 Objectif du document

Le présent cahier de conception a pour vocation fondamentale de traduire les spécifications fonctionnelles arrêtées dans le CA-GIMAC-01 en une solution logicielle et matérielle directement implémentable par l'équipe d'ingénierie. Il répond aux objectifs suivants :

- Expliciter les objectifs techniques et les interfaces système externes non graphiques (fournisseur d'identité, simulateur de certification, dispositif de gestion des changements, messagerie électronique, dépôt de publication des racines d'audit, autorité d'horodatage) ;
- Consigner les contraintes générales de conception, notamment la conformité aux règlements prudentiels COBAC R-2024/01 (Cybersécurité), COBAC R-2016/04 (Contrôle interne) et au standard PCI-DSS v4.0.1 ;
- Arrêter les méthodes de conception logicielle (démarche 2TUP et modélisation UML 2.5), les standards de programmation et le plan d'assurance qualité logicielle (ISO 12207, IEEE 730, IEEE 1059, IEEE 1028, ISO 27005) ;
- Établir la conception générale du système en justifiant formellement le découpage des sept domaines fonctionnels et des dix-sept modules en quatorze microservices autonomes et découplés, dont ceux du socle (passerelle, habilitations, audit, gestion documentaire, notifications) ;
- Détailler la conception de chaque microservice avec son diagramme de composants, son diagramme de classes de conception typé, son diagramme d'objets et ses algorithmes clés, la fédération au fournisseur d'identité institutionnel assurant l'authentification unique ;
- Fixer l'identité visuelle de la plateforme (Design System GIMAC) et préparer les emplacements des maquettes graphiques des interfaces utilisateurs.

1.3 Organisation du document

Le présent document est articulé en sept chapitres complémentaires :

- **Chapitre 1 : Introduction** : Pose le contexte, l'objectif et la structure du cahier de conception ;
- **Chapitre 2 : Présentation du projet** : Expose les objectifs opérationnels, la typologie des interfaces externes du système et les contraintes globales d'ingénierie ;

- **Chapitre 3 : Documents de référence** : Dresse l'inventaire exhaustif des normes, règlements et documents amont opposables ;
- **Chapitre 4 : Normes, standards et outils** : Formalise la démarche 2TUP, l'environnement technologique retenu, les standards de code et le plan qualité logicielle ; c'est le seul chapitre qui nomme des technologies, les chapitres de conception désignant chaque composant par son rôle ;
- **Chapitre 5 : Conception générale** : Présente l'identification des modules et des quatorze microservices, la justification de la transition des domaines vers les microservices, le diagramme de composants et le diagramme de déploiement ;
- **Chapitre 6 : Conception détaillée** : Analyse unitairement chaque microservice (composants, classes de conception, objets, algorithmes), puis fixe le thème graphique et la cartographie des maquettes ;
- **Chapitre 7 : Conclusion** : Dresse le bilan de la conception et annonce la phase d'implémentation logicielle.

CHAPITRE 2

Présentation du projet

Ce chapitre expose les fondements opérationnels du système à implémenter, détaille ses interfaces techniques externes et caractérise l'ensemble des contraintes environnementales et réglementaires influençant sa conception.

2.1 Objectifs du système

La plateforme intégrée du Département Exploitation et Supervision poursuit les objectifs stratégiques et techniques suivants :

- **Dé-silotage intégral des flux d'exploitation :** Rompre avec la gestion asynchrone et cloisonnée des activités du DES en interconnectant les modules d'homologation, d'exploitation 24/7, de gestion des incidents, de pilotage et de collaboration souveraine ;
- **Suivi industrialisé des homologations :** Suivre chaque liaison selon un référentiel d'opérations ordonné en graphe orienté acyclique (DAG), reprendre sans recalcul les résultats du simulateur de certification, calculer les couvertures de certification et de mise en service, sceller les preuves selon la règle des quatre éléments et recueillir les quatre quitus ;
- **Soutien à la continuité opérationnelle :** Outiller la supervision continue des liaisons et des plateformes, la qualification des incidents par automate à états finis (FSM), la génération des astreintes et un protocole de relève de quart contradictoire sous double signature électronique, la plateforme elle-même visant 99,9 % de disponibilité ;
- **Pilotage exécutif et amélioration continue :** Transposer numériquement la boucle PDCA (ISO 9001/ISO 20000-1), orchestrer les activités par tableaux Kanban en flux tiré avec respect des limites WIP et alimenter un cockpit décisionnel en temps réel (Data Mart en schéma en étoile) ;

- **Souveraineté et sécurité Zero Trust :** Protéger l'ensemble des communications et accès par une passerelle d'accès Zero Trust (NIST SP 800-207), sceller toute action dans un registre d'audit inaltérable publié hors de la plateforme, et déployer une cellule de crise chiffrée de bout en bout (E2EE) confinée au réseau local.

2.2 Interfaces du système

Conformément aux directives d'ingénierie logicielle, les interfaces du système désignent exclusivement les points de raccordement techniques, protocolaires et applicatifs au travers desquels la plateforme communique avec son environnement externe, à l'exclusion formelle des interfaces graphiques utilisateurs. Elles sont celles des cinq applications tierces du cahier de charges techniques, complétées par l'autorité d'horodatage et par une passerelle SMS facultative. Le commutateur GIMACPAY et les systèmes de règlement de la BEAC n'y figurent pas : la plateforme ne s'y raccorde jamais, elle importe des états qu'ils produisent.

Le tableau 2.1 récapitule les principales interfaces système identifiées :

Interface	Protocole / Format	Description et Rôle Fonctionnel
Fournisseur d'identité du groupement	OpenID Connect ou SAML 2.0 sur TLS 1.3, jetons liés au certificat (RFC 8705)	Authentification déléguée de tous les utilisateurs, second facteur, attributs et rattachements de l'annuaire ; la plateforme ne détient aucun mot de passe.
Simulateur de certification	Interface de service sur liaison mutuellement authentifiée, lecture seule	Reprise de l'avancement des campagnes d'essais et du résultat de chaque scénario, avec horodatage et référence de trace ; aucun message monétique ne transite.
Dispositif de gestion des changements	Interface de service sous mTLS, lecture et référencement	Lecture de la référence et de l'état d'approbation des fiches de changement, et des fenêtres de maintenance ; aucune création de fiche.
Messagerie électronique du groupement	Protocole de messagerie sur TLS, émission seule	Courriels de notification, convocations, rapports ; un lien vers la plateforme, jamais de donnée sensible dans le corps.
Dépôt de publication des racines d'audit	Écriture seule sur liaison mutuellement authentifiée	Publication, à chaque période, de la racine de l'arbre de Merkle et de son jeton d'horodatage, hors de portée des administrateurs de la plateforme.
Autorité d'horodatage	RFC 3161 (protocole d'horodatage)	Obtention de jetons d'horodatage pour les racines de période, les rapports de quart, les dossiers de mise en service et les archives de crise.
Passerelle SMS (extension facultative)	Interface de service sécurisée, émission seule	Messages courts d'alerte critique vers les numéros d'astreinte, lorsque le groupement raccorde une passerelle ; sans elle, le courriel et le canal poussé suffisent.
Navigateurs des utilisateurs	TLS 1.3, jetons signés, WebAuthn pour la console	Accès aux trois couches de présentation par la passerelle d'accès.

TABLE 2.1: *Inventaire des interfaces techniques externes du système*

2.3 Contraintes générales de conception

L'architecture du système est soumise à un ensemble de contraintes réglementaires, architecturales, matérielles et opérationnelles strictes :

1. **Contraintes réglementaires prudentielles (COBAC et BEAC) :**
    - Application du Règlement COBAC R-2024/01 relatif à la gouvernance des SI et à la cybersécurité (cloisonnement réseau, gestion stricte des accès à privilèges, notification des incidents de sécurité sous 24h à 72h) ;
    - Application du Règlement COBAC R-2016/04 relatif au contrôle interne (traçabilité inaltérable des incidents majeurs selon l'Article 41) ;
    - Respect de l'Instruction BEAC 001/GR/2018 relative aux systèmes de paiement et du principe PFMI n°17 (disponibilité opérationnelle cible de 99,95 %).
2. **Contraintes de sécurité des données bancaires (PCI-DSS v4.0.1) :**
    - Aucune donnée de carte dans la plateforme ; interdiction formelle de transmission ou d'affichage en clair d'un PAN qui figurerait dans une pièce ou un état importé (Exigences 3 et 4), avec masquage irréversible au dépôt (6 premiers et 4 derniers chiffres uniquement) ;
    - Authentification multifacteur résistante au phishing (FIDO2/WebAuthn) obligatoire pour les accès d'administration et accès distants (Exigences 8.3 et 8.4) ;
    - Révocation déterministe des sessions après 15 minutes d'inactivité (Exigence 8.2.8).
3. **Contraintes de souveraineté et d'hébergement on-premise :**
    - Proscription absolue de dépendance vis-à-vis des services cloud publics tiers pour le cœur de commutation et les communications de crise (immunité face aux coupures de câbles sous-marins et protection contre le *Cloud Act*) ;
    - Déploiement souverain sur site dans les datacenters du GIMAC avec réplication synchrone/asynchrone vers le site de secours distant (PRA).
4. **Contraintes de fédération au fournisseur d'identité :**
    - La plateforme ne gère aucun référentiel de mots de passe : l'authentification est déléguée au fournisseur d'identité institutionnel, qui s'appuie sur l'annuaire d'entreprise du groupement, pour une authentification unique de tout utilisateur du domaine ;

- Synchronisation unidirectionnelle sécurisée de l'annuaire (protocole d'annuaire sur TLS) avec mise en correspondance des groupes d'annuaire et des rôles applicatifs RBAC ; le chapitre 4 fixe les produits retenus.

5. **Contraintes de non-intrusion :**

   - La plateforme n'écrit ni dans le commutateur, ni dans le simulateur, ni dans le dispositif de gestion des changements ; elle ne route, ne compense et ne règle rien ; elle ne détient aucune clé monétique, ses seules clés étant ses certificats d'authentification mutuelle et sa clé de signature des attestations ;
   - Toute action de production (mise en service, suspension technique, régularisation d'un suspens) est exécutée hors de la plateforme et attestée dans celle-ci par une pièce.

CHAPITRE 3

Documents de référence

La conception technique du système s'appuie sur un corpus documentaire structuré, associant les livrables d'ingénierie produits en amont, les textes législatifs et prudentiels de la sous-région CEMAC, ainsi que les standards internationaux de l'industrie financière et logicielle.

3.1 Documents du projet

Les spécifications techniques et fonctionnelles du présent cahier de conception sont directement dérivées des documents contractuels suivants :

1. **TDR-GIMAC-01 v1.0 :** Termes de Référence pour la mise en place d'une plateforme intégrée de suivi, d'automatisation et de dé-silotage des activités du Département Exploitation et Supervision du GIMAC ;

2. **CCT-GIMAC-01 v0.3 puis v1.1 :** Cahier de charges techniques, dans sa version initiale validée puis dans sa version exhaustive revue, fixant l'expression des besoins métiers, les contraintes d'architecture, les cinq applications tierces et les exigences contractuelles ;

3. **CA-GIMAC-01 v1.1 :** Cahier d'analyse formalisant les besoins fonctionnels (BF-01 à BF-29, BF-ADMIN), les besoins non fonctionnels, les acteurs, les cas d'utilisation textuels, les classes d'analyse et les diagrammes de séquence système pour les sept domaines fonctionnels ;

4. **CR-CERT-GIMAC-01 v1.7 :** Compte rendu d'entretien de cadrage sur le parcours de certification des participants, source du référentiel d'opérations, des types de liaison et de la règle des quatre éléments ;

5. **REF-AGT-GIMAC-01 v1.1 et DOC-AMA-01 v3.1 :** Référentiel de pratiques de l'agent et guide d'intégration des participants, sources des étapes de certification mobile, de la vérification du code QR marchand et du dossier de mise en service.

3.2 Règlements et instructions prudentielles

Le système s'inscrit en conformité absolue avec les textes réglementaires régionaux régissant les établissements financiers de la zone CEMAC :

1. **Règlement COBAC R-2024/01 :** Règlement relatif à la gouvernance des systèmes d'information et à la gestion du risque informatique au sein des entités assujetties ;
2. **Règlement COBAC R-2016/04 :** Règlement relatif au contrôle interne et à la gestion des risques des établissements de crédit et holdings financières (notamment Article 41 sur la traçabilité des incidents) ;
3. **Instruction BEAC N°001/GR/2018 :** Instruction portant organisation, fonctionnement et surveillance des systèmes de paiement monétique dans la CEMAC ;
4. **Cadre régional de migration vers ISO 20022 :** Textes de la BEAC encadrant l'adoption de la norme de messagerie financière ISO 20022 pour les systèmes de paiement régionaux, qui modifient le contenu des certifications suivies sans modifier le rôle de la plateforme ;
5. **CPMI-IOSCO PFMI :** Principes pour les Infrastructures de Marchés Financiers publiés par la Banque des Règlements Internationaux (Principes 2 sur la gouvernance et 17 sur le risque opérationnel).

3.3 Normes et standards technologiques internationaux

La conception logicielle, architecturale et cryptographique mobilise les standards internationaux répertoriés au tableau 3.1 :

Référence Standard	Organisme Émetteur	Objet et Domaine d'Application
PCI-DSS v4.0.1	PCI Security Standards Council	Standard de sécurité des données de l'industrie des cartes de paiement (Exigences 3, 4, 8, 10).
NIST SP 800-207	National Institute of Standards and Technology	Définition de l'architecture sans confiance (Zero Trust Architecture : ZTA).
ISO 8583	Organisation Internationale de Normalisation	Messages d'échange de transactions par carte ; contexte des campagnes de certification carte exécutées dans le simulateur.
ISO 20022	Organisation Internationale de Normalisation	Schéma universel de messages financiers ; contexte des certifications des services concernés par la migration.
RFC 9162	IETF	Certificate Transparency version 2.0 : arbre de Merkle, séparation de domaine, preuves d'inclusion et de cohérence.
EMV QRCPS 1.1	EMVCo	Codes QR de paiement présentés par le marchand ; contexte de la vérification du code QR d'un acquéreur.
ISO/IEC 12207:2017	ISO / IEEE	Ingénierie des systèmes et du logiciel : Processus du cycle de vie du logiciel.
ISO 9001:2015	Organisation Internationale de Normalisation	Systèmes de management de la qualité : Transposition du cycle d'amélioration continue PDCA.
ISO/IEC 20000-1:2018	ISO / CEI	Gestion des services informatiques (ITSM) : Exigences relatives au système de management.
ISO/IEC 27005:2022	ISO / CEI	Sécurité de l'information, cybersécurité : Gestion des risques liés à la sécurité de l'information.
RFC 8705	IETF	OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens.
RFC 8693	IETF	OAuth 2.0 Token Exchange (Downscoping et délégation sécurisée).
RFC 3161	IETF	Internet X.509 Public Key Infrastructure Time-Stamp Protocol (TSP).

TABLE 3.1: *Répertoire des normes et standards technologiques internationaux*

CHAPITRE 4

Normes, standards et outils

Ce chapitre explicite la méthodologie de conception retenue, détaille les environnements matériels, logiciels et cadriciels de développement, et consigne le plan d'assurance qualité logicielle encadrant l'ensemble du cycle de vie du projet. Il est le seul chapitre du cahier à nommer des produits : les chapitres 5 et 6 désignent chaque composant par son rôle (fournisseur d'identité, bus d'événements, base relationnelle, dépôt objet WORM, cache distribué, moteur de politiques), de sorte que la conception reste valable si l'un des produits ci-dessous est remplacé. Conformément aux choix d'ingénierie arrêtés, l'architecture repose sur un écosystème **Java 21 / Spring Boot 3** industrialisé par l'accélérateur et générateur de socle **JHipster**, une interface utilisateur monopage développée en **React**, et une dorsale événementielle asynchrone orchestrée par **Apache Kafka**.

4.1 Méthodes de conception

4.1.1 Démarche de modélisation : Processus 2TUP

Pour concilier l'indépendance de l'analyse fonctionnelle vis-à-vis des technologies sous-jacentes avec la rigueur d'une implémentation microservices distribuée, le projet adopte la démarche **2TUP (Two Track Unified Process)**.

Le processus 2TUP scinde le développement en deux branches d'ingénierie conduites en parallèle :

- **La branche fonctionnelle :** Capitalise sur les exigences métiers du DES formalisées dans le CA-GIMAC-01 (cas d'utilisation, classes d'analyse, séquences système) indépendamment des contraintes techniques ;
- **La branche technique :** Identifie les contraintes matérielles, d'interopérabilité (Active Directory, Keycloak, Kafka), de sécurité (Zero Trust, mTLS) et d'infrastructure locale on-premise ;

- **La phase de synthèse (Conception) :** Fusionne les deux branches pour produire l'architecture microservices détaillée, où chaque domaine fonctionnel trouve son instanciation dans un composant technique optimisé.

4.1.2 Langage de modélisation : UML 2.5

La modélisation de l'ensemble des artefacts d'ingénierie logicielle s'appuie sur le métamodèle standardisé **UML 2.5 (Unified Modeling Language)** normalisé par l'OMG. Les diagrammes sont produits en texte PlantUML, versionnés avec le document, selon une charte graphique sobre (fond blanc, angles droits, monochrome) adaptée aux exigences des documents d'ingénierie bancaire.

4.2 Environnement, technologies et outils de développement

L'efficacité d'un projet de cette envergure repose sur la sélection rigoureuse d'un socle technique moderne, éprouvé dans le secteur bancaire et hautement productif.

4.2.1 Choix de l'écosystème technologique et accélération par JHipster

Afin d'accélérer drastiquement la mise en place du socle technique (*scaffolding*), d'homogénéiser les structures de code entre les différents microservices et de réduire les délais de mise sur le marché (*Time-to-Market*), le projet capitalise sur le générateur d'applications d'entreprise **JHipster**.

JHipster fournit une assise robuste combinant un backend **Java 21** et **Spring Boot 3.x** avec un frontend **React** moderne, intégrant nativement la gestion des conteneurs Docker, la sécurité OpenID Connect via Keycloak, les migrations de schémas par Liquibase et les architectures distribuées d'entreprise.

Le tableau 4.1 détaille les bénéfices architecturaux et opérationnels de l'utilisation de JHipster pour le système GIMAC :

Axe d'Ingénierie	Capacité JHipster	Bénéfice Opérationnel pour le GIMAC
Génération du Socle Microservices	Modèle d'architecture distribuée Spring Cloud / Gateway	Instanciation rapide des squelettes de services avec gestion de configuration centralisée, découplage strict et cohérence structurelle inter-équipes.
Intégration Sécurité OIDC / Keycloak	Support natif de l'authentification OAuth 2.0 / OpenID Connect	Configuration prête à l'emploi de Spring Security pour la validation des jetons JWT émis par Keycloak, facilitant la fédération avec l'Active Directory.
Persistance et Versionnement DB	Intégration automatisée de Liquibase sous PostgreSQL	Gestion traçable, incrémentale et reproductible des évolutions de schémas de base de données pour chaque microservice, essentielle pour les audits bancaires.
Frontend React Standardisé	Génération d'une SPA React 18 avec TypeScript et Redux Toolkit	Échafaudage immédiat des formulaires CRUD, gestion d'état unifiée, typage statique rigoureux et intégration sécurisée des API REST backend.
Déploiement et Conteneurisation	Génération automatique des fichiers Docker Compose	Capacité de déployer localement en un clic l'intégralité de la constellation (microservices, Kafka, Keycloak, PostgreSQL) pour les développements et tests.

TABLE 4.1: *Justification de l'accélération par JHipster pour le socle microservices*

4.2.2 Matrice des technologies et composants logiciels

Le tableau 4.2 récapitule l'ensemble de la pile technologique arrêtée pour la mise en œuvre de la plateforme :

TABLE 4.2: *Matrice technologique exhaustive de la plateforme GIMAC*

Couche Système	Technologie / Framework	Justification et Rôle Technique
Socle Backend	Java 21 LTS / Spring Boot 3.x (via JHipster)	Langage et framework d'entreprise de référence dans le secteur bancaire ; haute performance, ramasse-miettes ZGC, Virtual Threads (Project Loom) et robustesse transactionnelle.
Couche Frontend	React 18 / TypeScript / Redux Toolkit	Application monopage (SPA) fluide et typée ; architecture Backend-For-Frontend (BFF), cookies `HttpOnly` et séparation stricte du DOM pour la conformité PCI-DSS v4.0.1.
Dorsale Asynchrone	Apache Kafka 3.x (Cluster distribué)	Bus de messages événementiel à très haut débit ; découplage temporel des microservices, garantie d'idempotence des consommateurs et traçabilité des événements interbancaires.
Gestion des Identités	Keycloak 24+ (IdP OIDC / OAuth 2.0)	Serveur d'authentification souverain ; gestion centralisée des jetons JWT (RFC 9068), support FIDO2/WebAuthn et fédération avec l'Active Directory.
Annuaire d'Entreprise	Samba 4 Active Directory Domain Services (AD DS)	Annuaire LDAP/Kerberos interne déployé pour centraliser les identités, les groupes et les habilitations professionnelles des collaborateurs du GIMAC.
Passerelle d'Accès ZTA	Spring Cloud Gateway / Envoy Proxy	Point de contrôle d'accès (PEP) Zero Trust (NIST SP 800-207) ; terminaison TLS 1.3, filtrage WAF Coraza (OWASP CRS), limitation de débit et routage mTLS.
Moteur d'Autorisation	Open Policy Agent (OPA)	Évaluation déclarative des politiques contextuelles ABAC/RBAC en langage Rego avec latence sub-milliseconde.

Couche Système	Technologie / Framework	Justification et Rôle Technique
Bases de Données	PostgreSQL 16 + Patroni	Persistance relationnelle robuste (modèle *Database-per-Service*) avec support du cloisonnement *Row-Level Security* (RLS) et gestion des migrations par Liquibase.
Cache et Verrous	Redis Cluster 7.x	Stockage clé-valeur en mémoire pour la liste de révocation des jetons (TRL), le maintien des compteurs de Rate Limiting et le verrouillage distribué (Mutex).
Stockage WORM	MinIO (édition serveur)	Dépôt objet immuable avec verrouillage de rétention en mode conformité pour la conservation légale décennale des pièces probantes.
Horodatage et signature	Bibliothèque cryptographique BouncyCastle, client RFC 3161	Jetons d'horodatage, signatures des attestations (PAdES) et des rapports, empreintes SHA-256.
Optimisation	OptaPlanner (Timefold)	Résolution du programme linéaire en nombres entiers de la grille d'astreinte.
Collaboration Locale	Matrix Synapse / LiveKit WebRTC	Messagerie souveraine chiffrée E2EE (Olm/Megolm) et pont de visioconférence local chiffré par SFrame (RFC 9605).

4.2.3 Protocoles de communication et formats d'échange

L'interopérabilité interne et externe repose sur un ensemble de protocoles standardisés couvrant les dimensions transactionnelles, applicatives et de sécurité. Le tableau 4.3 recense l'inventaire exhaustif de ces protocoles :

TABLE 4.3: *Répertoire des protocoles de communication et formats d'échange*

Usage / Canal	Protocole / Standard	Spécifications et Format des Données
Simulateur de certification	Interface de service (REST / JSON) sur mTLS, lecture seule	Avancement des campagnes et résultats des scénarios ; aucune trame monétique ne transite vers la plateforme.
États importés	Fichiers structurés (CSV, XML) déposés ou lus, contrôle de masquage	États de rapprochement et états périodiques produits par le commutateur et les participants.
API Synchrones	REST (OpenAPI 3.0) / JSON	Échanges synchrones inter-services et exposition des endpoints pour le client web React sous TLS 1.3.
Flux Haute Vélocité	gRPC / HTTP/2 (Protocol Buffers)	Communications internes à faible latence pour l'introspection des jetons et l'évaluation des politiques d'accès.
Événements Asynchrones	Apache Kafka Protocol / TCP	Publication et souscription d'événements métiers formatés selon le standard CloudEvents v1.0 avec schémas validés.
Streaming Web	WebSockets (WSS) / SSE	Tunnels persistants sécurisés pour la diffusion d'alertes temps réel et la mise à jour dynamique des tableaux Kanban sans rechargement.
Authentification	OAuth 2.0 / OpenID Connect (OIDC)	Émission et validation de jetons JWT signés (RFC 9068), échange de jetons RFC 8693 (downscoping) et protocole FIDO2/WebAuthn.
Sécurisation Réseau	mTLS (Mutual TLS 1.3) / RFC 8705	Chiffrement mutuel systématique avec liaison cryptographique certificat client et jeton JWT (`cnf.x5t#S256`).
Annuaire Interne	LDAPS (Port 636) / Kerberos v5	Protocole sécurisé de synchronisation d'annuaire et d'authentification unique (SSO) avec Samba 4 Active Directory.

Usage / Canal	Protocole / Standard	Spécifications et Format des Données
Horodatage Légal	RFC 3161 (TSP) / ASN.1 DER	Requêtes `TimeStampReq` et jetons certifiés `TimeStampToken` pour l'ancrage temporel non répudiable des preuves d'audit.
Collaboration Chiffrée	Olm / Megolm / SFrame (RFC 9605)	Chiffrement de bout en bout (E2EE) par double cliquet pour la messagerie Matrix et sur-chiffrement des trames médias WebRTC LiveKit.

4.2.4 Standards de programmation et patrons d'architecture

L'implémentation logicielle obéit strictement aux patrons d'architecture et standards de qualité suivants :

- **Clean Architecture et Domain-Driven Design (DDD) :** Séparation étanche en quatre couches :
  1. *Domain Layer :* Entités métiers, agrégats, objets valeurs (*Value Objects*) et règles invariantes pures, sans dépendance à aucun framework ;
  2. *Application Layer :* Services applicatifs implémentant les cas d'utilisation, orchestrant les flux métiers et gérant les transactions ;
  3. *Infrastructure Layer :* Adaptateurs de persistance (Spring Data JPA / PostgreSQL), connecteurs Kafka, clients HTTP et intégrations externes ;
  4. *Presentation Layer :* Contrôleurs REST Spring Boot exposant les contrats d'API documentés sous OpenAPI 3.0.
- **Principes SOLID :** Respect scrupuleux des cinq principes fondamentaux de conception orientée objet :
  - *Single Responsibility Principle (SRP) :* Chaque classe n'assume qu'une seule et unique responsabilité métier ;
  - *Open/Closed Principle (OCP) :* Les modules sont ouverts à l'extension mais fermés à la modification ;
  - *Liskov Substitution Principle (LSP) :* Les sous-classes se substituent rigoureusement à leurs classes de base ;

  - *Interface Segregation Principle (ISP) :* Interfaces ciblées et modulaires évitant aux composants d'implémenter des méthodes inutilisées ;
  - *Dependency Inversion Principle (DIP) :* Les modules de haut niveau dépendent d'abstractions (interfaces) et non d'implémentations concrètes.

- **Patrons de Résilience Distribuée :**
  - *Transactional Outbox Pattern :* Garantie d'atomicité entre l'écriture en base de données PostgreSQL et la publication de l'événement sur le bus Kafka, prévenant toute perte de message lors d'une panne réseau ;
  - *Circuit Breaker et Retry (Resilience4j) :* Isolement des pannes lors des appels vers des systèmes tiers lents ou défaillants avec bascule automatique en mode dégradé ;
  - *Idempotent Consumer Pattern :* Tables de déduplication transactionnelles garantissant qu'un événement Kafka rejoué n'entraîne aucun double traitement.

- **The Twelve-Factor App :** Conformité rigoureuse aux douze facteurs régissant les applications cloud-native (séparation stricte code/configuration via variables d'environnement, processus sans état et parité stricte développement/production).

4.3 Plan de Qualité Logicielle

Le plan de qualité est articulé autour du référentiel normatif international **ISO/IEC/IEEE 12207:2017** régissant les processus du cycle de vie logiciel. Il mobilise cinq axes complémentaires :

1. **Assurance Qualité Logicielle (AQL) selon l'IEEE 730 :** Définition des plans d'assurance qualité, revues régulières des livrables documentaires, traçabilité continue des exigences fonctionnelles du CA-GIMAC-01 vers le code source via une matrice de traçabilité des exigences ;

2. **Vérification et Validation (V&V) selon l'IEEE 1059 :** Mise en œuvre de tests automatisés à tous les niveaux de la pyramide des tests :
   - Tests unitaires automatisés (JUnit 5, AssertJ, Mockito) couvrant au minimum 80 % des branches de code métier ;
   - Tests d'intégration inter-services adossés à des conteneurs éphémères (*Testcontainers*) instanciant de réelles bases PostgreSQL, instances Kafka et dépôts MinIO ;
   - Tests de contrats d'API (Spring Cloud Contract / Pact) vérifiant la compatibilité des schémas d'échanges entre microservices producteurs et consommateurs.

3. **Revues et Audits formels selon l'IEEE 1028 :** Conduite systématique de revues de code par les pairs (*Peer Code Reviews*) préalablement à toute fusion de branche dans le référentiel Git central, sous le modèle de branches GitFlow ;

4. **Gestion des configurations :** Traçabilité intégrale du code, des descripteurs d'infrastructure (Docker Compose, Helm charts) et des scripts de migration de bases de données (Liquibase) sous Git, avec politique stricte de nommage sémantique des versions (SemVer) ;

5. **Gestion des risques selon l'ISO 27005 :** Analyse continue des dépendances tierces (SCA via OWASP Dependency-Check et Snyk), analyse statique de sécurité du code (SAST via SonarQube avec profil qualité renforcé) et audits périodiques de conformité réglementaire.

CHAPITRE 5

Conception générale

Le secteur financier et monétique de la Communauté Économique et Monétaire de l'Afrique Centrale (CEMAC) traverse une mutation structurelle d'une ampleur inédite. Sous l'impulsion de la Banque des États de l'Afrique Centrale (BEAC) et de son Instruction 001/GR/2018 imposant l'interopérabilité des services de paiement, le Groupement Interbancaire Monétique de l'Afrique Centrale (GIMAC) est placé au centre des flux financiers sous-régionaux à travers son commutateur régional multicanal, GIMACPAY. Face à l'accroissement des volumes issus de la monnaie électronique, des cartes bancaires et des virements instantanés, l'outillage des équipes qui exploitent et supervisent ce commutateur se doit d'évoluer. Le projet de « Plateforme intégrée de suivi, de supervision et de dé-silotage des activités du Département Exploitation et Supervision (DES) » constitue la réponse à ce besoin.

Ce chapitre de conception générale formalise une architecture logicielle conçue pour s'inscrire dans un écosystème réglementaire d'une sévérité croissante. L'ingénierie de cette plateforme est dictée par trois piliers normatifs fondamentaux :

1. **Le Règlement COBAC R-2016/04** relatif au contrôle interne dans les établissements assujettis, qui exige une structuration rigoureuse des processus de maîtrise des risques, une piste d'audit inaltérable et un rapport circonstancié de chaque incident ;
2. **Le Règlement COBAC R-2024/01** relatif à la gestion du risque informatique, qui instaure des exigences fortes en matière de cyber-résilience, de détection des incidents et de protection des données critiques ;
3. **Le standard international PCI-DSS v4.0.1**, qui régit la manipulation des données des porteurs de cartes ; la plateforme ne traite aucune de ces données, mais ses utilisateurs exploitent l'environnement qui les traite, ce qui impose la journalisation inaltérable des accès (Exigence 10) et le masquage de toute donnée de carte qui figurerait par accident dans une pièce.

Un principe précède tous les autres et gouverne l'ensemble des choix de ce chapitre : **la plateforme lit, référence et trace ; elle n'écrit jamais dans les systèmes de production**. Elle

n'est raccordée ni au commutateur, ni aux systèmes de règlement de la BEAC ; elle ne route, ne compense et ne règle rien ; elle ne détient aucune clé monétique. Les cinq applications tierces avec lesquelles elle s'articule sont celles du cahier de charges techniques : le fournisseur d'identité, le simulateur de certification, le dispositif de gestion des changements, la messagerie électronique et le dépôt de publication des racines d'audit. Toute action de production (mise en service d'un participant, suspension technique, régularisation d'un suspens) est exécutée hors de la plateforme, par les équipes de production, et attestée dans la plateforme par une pièce.

L'analyse déconstruit les choix architecturaux selon quatre axes : la dissociation entre le suivi de l'homologation et la décision de certification, la modélisation en microservices selon les préceptes du Domain-Driven Design (DDD), la conception des échanges synchrones et asynchrones résilients, et enfin la structuration des zones réseau et des mécanismes de haute disponibilité.

5.1 Dissociation formelle entre suivi de l'homologation et décision de certification

La doctrine architecturale de la plateforme repose sur une ségrégation stricte des responsabilités (*Segregation of Duties*, SoD). Ce principe de contrôle interne bancaire, érigé en obligation par le Règlement COBAC R-2016/04, trouve ici une application logicielle directe : le service qui tient les preuves de l'homologation technique d'un participant ne peut, sous aucun prétexte, être le service qui délivre l'autorisation de mise en service.

5.1.1 Doctrine de séparation des pouvoirs et conformité ISO/IEC 17065

L'admission d'une nouvelle entité (banque, établissement de microfinance, établissement de paiement, opérateur de monnaie électronique) sur le réseau interbancaire GIMACPAY s'apparente conceptuellement et juridiquement à un processus d'évaluation de la conformité d'un service. L'ingénierie de la plateforme s'aligne donc sur le standard international ISO/IEC 17065, qui régit les organismes de certification de produits, de procédés et de services, et dont la clause 4.2 traite du management de l'impartialité.

Cette norme stipule que les activités d'évaluation et d'analyse des résultats doivent être formellement séparées des activités de décision et d'octroi de la certification. Dans le contexte du GIMAC, l'évaluation technique elle-même est réalisée par le simulateur de certification (application tierce) et par les ingénieurs d'homologation ; la plateforme en tient le suivi et les preuves. La décision, elle, résulte de quatre quitus et d'une fiche de changement approuvée par le comité des changements du groupement. Autoriser un même composant à tenir les preuves, à calculer les couvertures, puis à générer de manière autonome l'attestation de mise en service

introduirait une vulnérabilité systémique en violant l'indépendance de la décision.

En conséquence, la séparation en deux microservices distincts, **MS-HOMOLOGATION** et **MS-CERTIFICATION**, devient une exigence de conformité. Cette dichotomie prévient les risques de collusion interne ou d'exploitation d'une vulnérabilité logicielle visant à produire des attestations frauduleuses. L'architecture garantit ainsi que toute autorisation de mise en service est le fruit d'une décision collégiale indépendante des preuves préalablement tenues de manière déterministe.

5.1.2 Le suivi des preuves et des couvertures : MS-HOMOLOGATION

Le microservice `MS-HOMOLOGATION` tient, pour chaque liaison d'un participant, le parcours d'homologation et ses preuves. Son périmètre fonctionnel (*Bounded Context*) est confiné au référentiel d'opérations, aux opérations instanciées, aux résultats repris du simulateur, aux preuves déposées et aux couvertures :

- **Référentiel d'opérations par type de projet :** Le référentiel décrit, pour chaque type de liaison (carte interbancaire, paiement mobile, délégataire), le tronc commun et les branches métier, et ordonne les opérations en graphe orienté acyclique (DAG) ; le tri topologique de Kahn en garantit l'acyclicité et en déduit, à tout instant, les opérations éligibles ;
- **Reprise des résultats du simulateur :** Le connecteur de lecture du simulateur de certification reprend, pour chaque scénario exécuté, l'identifiant, le résultat, l'horodatage et la référence de la trace, et les rapproche de l'opération correspondante du référentiel ; aucun résultat n'est recalculé, aucun message n'est décodé, aucune donnée de carte ne transite ;
- **Règle des quatre éléments :** Une opération n'est close que par la réunion de son responsable, de sa preuve scellée en gestion documentaire, de son horodatage et de sa validation par le superviseur habilité (BF-11) ; le verrou est appliqué au niveau de l'interface de service ;
- **Couvertures :** La couverture de certification et la couverture de mise en service se calculent service par service, à partir du périmètre contractualisé, et alimentent le portail du participant et les cockpits.

5.1.3 La décision et l'attestation : MS-CERTIFICATION

À l'autre extrémité, le `MS-CERTIFICATION` incarne l'organe de décision, de gouvernance et de scellement à valeur probante. Son exécution est asynchrone et ne peut être déclenchée que

lorsque MS−HOMOLOGATION a publié une couverture de certification de 100 % sur le chemin critique et sur le périmètre contractualisé. La mise en service d'un participant nécessite alors une validation collégiale par des autorités humaines, formalisée par la règle des **quatre quitus** :

1. **Le quitus technique (chef du DES) :** Atteste de la couverture de certification de 100 % et de la clôture de toutes les opérations du chemin critique ;
2. **Le quitus de sécurité (RSSI) :** Délivré sur la base des pièces de sécurité du dossier (certificats échangés, attestations de conformité déclarées, résultats des essais de sécurité) ;
3. **Le quitus de conformité (fonction conformité) :** Contrôle l'existence et la validité de l'agrément en cours, la signature de la convention de raccordement et la conformité documentaire tenue par MS−PARTICIPANT ;
4. **Le quitus de la Direction Générale :** Sanctionne la décision d'admission au regard des trois quitus précédents.

La mise en service reste, en outre, subordonnée à la référence d'une fiche de changement approuvée par le comité des changements du groupement, lue dans le dispositif de gestion des changements ; la plateforme ne crée ni n'approuve cette fiche.

Pour conférer une opposabilité juridique aux attestations produites, MS−CERTIFICATION s'appuie sur deux mécanismes normalisés : l'horodatage qualifié selon la RFC 3161, obtenu d'une autorité d'horodatage, qui lie l'empreinte SHA-256 de chaque quitus et du dossier à une heure certifiée ; et la pérennité documentaire du standard PDF/A-3 (ISO 19005-3), les attestations encapsulant les pièces brutes du dossier et portant une signature électronique avancée (PAdES) apposée avec la clé de signature de la plateforme, délivrée par l'autorité de certification interne. Cette clé de signature est la seule clé applicative que la plateforme détient ; elle n'a aucun rapport avec les clés monétiques du commutateur, qui restent hors de son périmètre.

5.1.4 Différentiel structurel et modèle Zero Trust

La séparation architecturale entre ces deux microservices est renforcée par l'analyse de leurs caractéristiques intrinsèques (tableau 5.1). L'application de la doctrine Zero Trust exige que chaque composant soit considéré comme potentiellement vulnérable : si un attaquant parvenait à compromettre le connecteur de lecture du simulateur dans MS−HOMOLOGATION, l'étanchéité garantit qu'il n'obtiendrait ni la clé de signature des attestations ni le circuit des quitus hébergés dans MS−CERTIFICATION.

Vecteur d'Analyse	MS-HOMOLOGATION (suivi)	MS-CERTIFICATION (décision)
Profil de charge	Écritures fréquentes lors des campagnes (reprise des scénarios, recalcul des couvertures), lectures nombreuses depuis le portail des participants.	Volume faible, fortement orienté flux de travail humain et opérations cryptographiques asynchrones.
Surface d'attaque	Expose le connecteur de lecture du simulateur et les dépôts de preuves des participants (via la gestion documentaire).	Confiné en zone interne ; ne reçoit aucune requête externe ; n'interagit qu'avec des services internes authentifiés.
Modèle de persistance	Données vivantes de campagne, historisées ; conservation des preuves déléguée à la gestion documentaire WORM.	Persistance immuable à long terme des quitus, des dossiers et des attestations ; piste d'audit sur dix ans.
Secrets et clés	Aucun secret applicatif ; certificats d'authentification mutuelle seulement.	Détient l'accès à la clé de signature des attestations de la plateforme (autorité interne), jamais une clé monétique.

TABLE 5.1: *Matrice différentielle entre le suivi de l'homologation et la décision de certification*

5.2 Décomposition en microservices et Domain-Driven Design (DDD)

Pour répondre aux enjeux combinés d'évolution par vagues, de vélocité de déploiement et de maintenabilité, la plateforme adopte l'approche stratégique et tactique du **Domain-Driven Design (DDD)**. Les sept domaines fonctionnels du cahier d'analyse et les dix-sept modules du cahier de charges techniques sont projetés en contextes délimités et étanches (*Bounded Contexts*), matérialisés par un écosystème de **quatorze microservices indépendants**.

5.2.1 Du domaine d'analyse au microservice : règle de découpage

Un domaine d'analyse n'est pas nécessairement un microservice. Trois critères ont conduit au découpage retenu : l'unité de responsabilité (un service porte un vocabulaire et des règles de gestion homogènes), le rythme de changement (un module livré à une vague ultérieure ne doit pas être couplé à un module de la première phase) et le profil d'exploitation (un service sollicité

en continu par des alertes n'a pas le même profil qu'un service de reporting). Ainsi, le socle transverse, un seul domaine d'analyse, donne cinq microservices parce que ses quatre modules et la passerelle ont des responsabilités, des rythmes et des profils distincts ; l'exploitation, un seul domaine, donne trois microservices pour les mêmes raisons ; à l'inverse, le pilotage et la collaboration restent proches de leurs domaines. Le tableau 5.2 en donne la correspondance.

5.2.2 Modélisation des Bounded Contexts et frontières de domaine

Chaque microservice est conçu autour d'une capacité métier spécifique, encapsulant sa propre logique, ses propres règles de validation et son propre modèle de données :

1. **MS-GATEWAY (passerelle d'accès et frontière d'entrée) :** Point d'entrée exclusif des trois couches de présentation. Assure la terminaison TLS 1.3, l'inspection applicative, la limitation de débit, la vérification des jetons et de leur liaison au certificat, la réduction de portée des jetons vers le service cible, le routage en mTLS, le modèle *Backend-For-Frontend* et le canal poussé vers les couches de présentation ;

2. **MS-IAM (habilitations et annuaire) :** Fédération au fournisseur d'identité institutionnel, annuaire des collaborateurs et de leurs rattachements, matrice des rôles et permissions à cinq niveaux, délégations temporaires, sessions et révocations, revue périodique des accès, disponibilités (BF-ADMIN) ;

3. **MS-AUDIT (registre d'audit inaltérable) :** Registre en ajout seul structuré en arbre de Merkle (RFC 9162), scellement des périodes, preuves d'inclusion et de cohérence, publication des racines dans le dépôt externe ; alimenté par tous les autres services par événement ;

4. **MS-DOCUMENT (gestion électronique des documents) :** Réception, analyse antivirale, contrôle de masquage, calcul d'empreinte, versionnage sans écrasement, rétention en mode conformité dans le dépôt objet WORM, journal de consultation ;

5. **MS-NOTIFICATION (notifications) :** Abonnements et règles de destinataires, niveaux d'urgence, préférences de canal, remise dans la plateforme, sur le canal poussé, par la messagerie électronique et, en extension, par la passerelle SMS, traces de remise, réessais et escalade ;

6. **MS-PARTICIPANT (institutions membres) :** Cycle de vie institutionnel des membres (automate d'états), fiche, conventions, services souscrits, correspondants, pièces légales et veille des échéances, journal des interactions, annuaire d'escalade ; aucune donnée de routage monétique ;

7. **MS-HOMOLOGATION (suivi de la certification) :** Liaisons, référentiel d'opérations, périmètre contractualisé, opérations et règle des quatre éléments, reprise des résultats du simulateur, couvertures, vérification du code QR marchand ;

8. **MS-CERTIFICATION (décision et attestation) :** Quatre quitus, lecture de la fiche de changement, dossier de mise en service, attestation signée et horodatée ;

9. **MS-INCIDENT (tickets, incidents et cellule de crise) :** Tickets de toute nature et leur automate d'états, qualification et escalade des incidents, gel d'engagement, critères de clôture, rapport circonstancié, cellule de crise et main courante de crise, rapport post-incident ;

10. **MS-MONITORING (monitoring, astreintes et quarts) :** Liaisons et plateformes supervisées, réception et acquittement des alertes, génération de la grille d'astreinte par programmation linéaire, vacations, main courante, rapport de quart à double signature ;

11. **MS-RAPPROCHEMENT (rapprochement monétique) :** Import des états du commutateur et des participants, détection des écarts par identifiants pivots, dossiers de suspens, conciliation, attestation de régularisation ;

12. **MS-PILOTAGE (tâches, projets, réunions) :** Tableaux Kanban et tâches nominatives, projets et jalons (PERT/CPM), cartographie des risques, comités et conversion des décisions en tâches, fiches d'action PDCA ;

13. **MS-REPORTING (reporting et cockpits) :** Magasin de données décisionnel alimenté par les événements des autres services et par les états importés, indicateurs et seuils, cockpits de la Direction Générale et du DES, rapports hebdomadaires et mensuels ;

14. **MS-COLLABORATION (messagerie et visioconférence) :** Salons chiffrés de bout en bout, vérification des terminaux, conférences audio et vidéo locales, salons de crise et archives de crise.

Le tableau 5.2 synthétise la cartographie de ces microservices et leur correspondance avec les modules et les domaines d'analyse.

TABLE 5.2: *Cartographie des microservices, des modules et des domaines*

Microservice	Modules portés	Domaine d'analyse	Persistance	Livraison
MS-GATEWAY	Passerelle, trois couches de présentation, flux poussé	7	Sans état ; cache distribué	Itération 1
MS-IAM	Habilitations et annuaire ; disponibilités	1	Schéma propre	Itération 1
MS-AUDIT	Audit inaltérable	1	Schéma propre en ajout seul ; dépôt externe des racines	Itération 1
MS-DOCUMENT	Gestion documentaire	1	Schéma propre ; dépôt objet WORM	Itération 2
MS-NOTIFICATION	Notifications	1	Schéma propre	Itération 2
MS-PARTICIPANT	Institutions membres	2	Schéma propre	Itération 2
MS-HOMOLOGATION	Suivi de la certification (liaisons, opérations, couvertures)	3	Schéma propre	Itérations 3 et 4
MS-CERTIFICATION	Suivi de la certification (quitus, mise en service)	3	Schéma propre ; attestations en WORM	Itération 4
MS-INCIDENT	Tickets et demandes ; incidents monétiques ; cellule de crise	4	Schéma propre	Vague suivante

Microservice	Modules portés	Domaine d'analyse	Persistance	Livraison
MS-MONITORING	Monitoring et astreintes	4	Schéma propre ; séries de mesures	Itération 2
MS-RAPPRO-CHEMENT	Rapprochement monétique	4	Schéma propre	Vague suivante
MS-PILOTAGE	Tâches ; projets ; réunions	5	Schéma propre	Vague suivante
MS-REPORTING	Reporting	5	Magasin décisionnel propre	Itération 3 (hebdomadaire), puis vagues
MS-COLLABO-RATION	Messagerie instantanée ; visioconférence	6	Schéma propre ; serveur de messagerie fédérée	Vague suivante

5.2.3 Autonomie des données et stratégie Database-per-Service

Le couplage par la base de données de persistance est universellement reconnu comme l'un des anti-patrons les plus destructeurs dans l'ingénierie des microservices. Partager un schéma unique brise l'encapsulation, ralentit les déploiements et complique le partitionnement futur.

La plateforme met en œuvre le patron **Database-per-Service**, instancié, dans un souci d'optimisation de l'empreinte d'infrastructure, selon la topologie *Shared Database Cluster, Schema-per-Service* : chaque microservice se voit attribuer son propre schéma au sein de la grappe relationnelle, avec des identifiants de connexion dépourvus de tout privilège sur les schémas des autres services. Toute tentative de requête entre schémas est bloquée au niveau du moteur. Lorsque des données doivent transiter entre domaines, l'architecture interdit les jointures directes et impose la propagation asynchrone par événements métier (*Event-Carried State Transfer*) : un service ne conserve d'une entité étrangère que sa référence et les attributs dont il a besoin, reçus par événement.

Trois services font exception à la persistance relationnelle pure : `MS-AUDIT` tient son registre en ajout seul, sans mise à jour ni suppression possibles, et publie ses racines hors de la plateforme ; `MS-DOCUMENT` et `MS-CERTIFICATION` confient les pièces et les attestations au dépôt

objet WORM, dont le verrouillage de rétention en mode conformité interdit toute modification ou suppression avant échéance, y compris par un administrateur ; `MS-REPORTING` tient un magasin décisionnel en schéma en étoile, alimenté en écriture seule par les événements.

5.2.4 Déploiement sans interruption et modèle Expand/Contract

Le DES exigeant un outil disponible 24 heures sur 24, toute fenêtre de maintenance avec interruption de service est proscrite. L'évolution des schémas relationnels s'opère par l'outil de migration de schéma retenu au chapitre 4, selon le patron **Expand and Contract**, en trois phases :

1. **Expansion :** Les scripts de migration ajoutent la nouvelle structure (colonne ou table facultative) sans altérer l'existant. Une nouvelle version du microservice est déployée avec une logique de double écriture ; la lecture s'effectue toujours sur l'ancienne structure ;
2. **Migration des données historiques :** Un traitement asynchrone migre en arrière-plan l'ensemble des données historiques vers la nouvelle structure ;
3. **Contraction :** Une seconde version du microservice bascule la lecture et l'écriture sur la nouvelle structure ; un ultime script supprime l'ancienne structure lors d'une itération ultérieure.

5.2.5 Position de la plateforme vis-à-vis du périmètre PCI-DSS

Le standard PCI-DSS v4.0.1 impose des contrôles d'une grande sévérité concernant le stockage, le traitement et la transmission des données de porteurs de cartes. La plateforme ne reçoit aucune de ces données : elle n'est raccordée ni au commutateur ni au simulateur en émission, et le simulateur ne lui restitue que des identifiants de scénario, des résultats et des références de trace. Elle se situe donc hors de l'environnement des données de titulaires de cartes (CDE), ce qui réduit considérablement sa charge de conformité.

Deux précautions sont néanmoins conçues, parce que les utilisateurs de la plateforme exploitent le CDE et que des pièces ou des états importés pourraient contenir par accident un numéro de carte : `MS-DOCUMENT` applique au dépôt de toute pièce un contrôle de masquage (détection des séquences de 13 à 19 chiffres validées par l'algorithme de Luhn, masquage central), et `MS-GATEWAY` applique le même contrôle aux corps de réponse qu'il relaie. Conformément à l'exigence 8.4.2, tout accès administratif requiert une authentification multifacteur forte via `MS-IAM`.

5.3 Architecture d'échange et modèles de communication

La plateforme associe un modèle synchrone sécurisé pour les processus nécessitant une cohérence immédiate, à une dorsale asynchrone événementielle pour les traitements distribués tolérants à la latence.

5.3.1 Modèle synchrone sécurisé : interfaces de service et mTLS (RFC 8705)

Les interfaces synchrones reposent sur des interfaces de service documentées (contrat d'interface ouvert) pour les accès frontaux et sur un protocole binaire à faible latence pour les invocations internes critiques (introspection des jetons, évaluation des politiques). Pour satisfaire aux exigences du Règlement COBAC R-2024/01 contre l'interception et le rejeu, l'intégralité des flux internes est chiffrée par mTLS 1.3 avec liaison des jetons au certificat du client (RFC 8705) :

1. Le client et le microservice établissent une session mTLS en s'authentifiant mutuellement par leurs certificats X.509, délivrés par l'autorité de certification interne ;
2. Lors de l'émission du jeton, `MS-IAM` calcule l'empreinte SHA-256 du certificat client et l'injecte dans la revendication `cnf.x5t#S256` ;
3. Le microservice cible valide la signature du jeton et vérifie que l'empreinte présente correspond au certificat actif sur la couche de transport.

Ce mécanisme immunise la plateforme contre le vol de jetons : un jeton exfiltré est inutilisable sans la clé privée associée au certificat client légitime.

5.3.2 Modèle asynchrone et standardisation événementielle

Les échanges asynchrones inter-domaines s'effectuent via le bus d'événements, assurant le découplage temporel et la résilience face aux pics de charge. Afin de prévenir toute hétérogénéité, la plateforme impose une enveloppe d'événement standardisée (CloudEvents v1.0 : identifiant, source, type, type de contenu, horodatage), un registre de schémas et un identifiant de corrélation propagé de bout en bout. Trois consommateurs transverses s'abonnent à tous les sujets : `MS-AUDIT`, qui scelle toute action à effet ; `MS-NOTIFICATION`, qui décide de notifier ; `MS-REPORTING`, qui alimente le magasin décisionnel. Les sujets sont nommés par domaine et versionnés (`participant.cycle-de-vie.v1`, `homologation.operation-close.v1`, `incident.etat.v1`, etc.).

5.3.3 Patrons de résilience distribuée

La stabilité de la plateforme face aux pannes partielles s'articule autour de quatre patrons de conception, synthétisés dans le tableau 5.3.

Patron	Mécanisme	Problématique résolue
Boîte d'envoi transactionnelle	Table d'envoi dans le schéma du service, capture des changements ou relève périodique	Évite l'incohérence de double écriture entre la base et le bus : la mutation métier et l'enregistrement de l'événement partagent la même transaction ; l'événement est publié avec garantie de livraison au moins une fois.
Consommateur idempotent	Table de déduplication par identifiant d'événement	Neutralise les doublons du bus : un événement déjà consommé est ignoré sans effet de bord.
Disjoncteur	Machine à états (fermé, ouvert, semi-ouvert) sur fenêtre glissante	Prévient les tempêtes de requêtes en cascade vers un service ou un tiers dégradé, avec délestage préventif.
Limitation de débit distribuée	Fenêtre glissante dans le cache distribué, scripts atomiques	Immunise contre les dénis de service et l'épuisement des ressources, sans condition de course entre nœuds de passerelle.

TABLE 5.3: *Patrons de résilience distribuée mis en œuvre sur la plateforme*

5.4 Architecture générale du système

Le schéma d'architecture générale fournit la vision synoptique de bout en bout de la plateforme au sein du système d'information du GIMAC. Il met en scène l'articulation entre les acteurs (agents du DES, participants, administrateurs et auditeurs), les trois couches de présentation, la passerelle d'accès, les quatorze microservices regroupés par domaine, le bus d'événements, les couches de persistance (grappe relationnelle, cache distribué, dépôt objet WORM) et les applications tierces, avec le sens de chaque flux. Il rend visible ce que la plateforme ne fait pas : aucune flèche ne part de la plateforme vers le commutateur ou vers les systèmes de règlement.

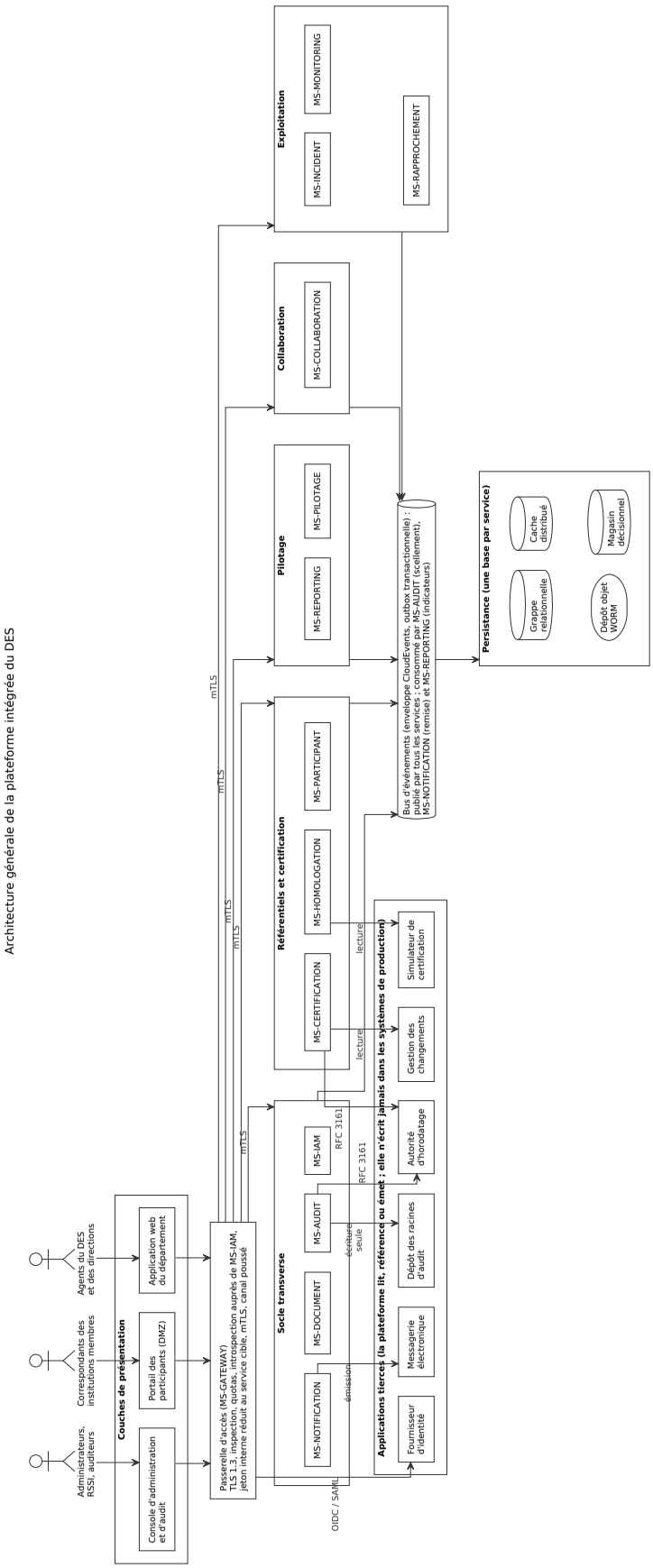


FIGURE 5.1: *Architecture générale de la plateforme intégrée du DES*

5.5 Diagramme de composants

Le diagramme de composants modélise la structuration modulaire de l'architecture logicielle, la délimitation des responsabilités, ainsi que l'ensemble des interfaces fournies et requises reliant les microservices entre eux et avec les tiers.

L'architecture logicielle est structurée selon une organisation en cinq couches étanches :

1. **Couche de présentation :** Comprend l'application web du département (réservée aux opérateurs et superviseurs), le portail des participants (restreint aux institutions membres pour leurs dossiers, leurs preuves et leurs demandes) et la console d'administration et d'audit (dédiée aux administrateurs, au RSSI et aux auditeurs). Ces applications monopages, sans état ni secret, communiquent exclusivement avec la passerelle d'accès ;

2. **Couche passerelle d'accès :** Matérialisée par `MS-GATEWAY`, elle constitue le point d'ancrage Zero Trust unique interceptant l'intégralité du trafic entrant, assurant la terminaison cryptographique, la vérification des jetons auprès de `MS-IAM`, l'évaluation des politiques, la réduction de portée et la limitation de débit ;

3. **Couche cœur métier :** Héberge les treize microservices applicatifs autonomes, regroupés en socle (habilitations, audit, documents, notifications), référentiels et certification (institutions, homologation, certification), exploitation (incidents, monitoring, rapprochement), pilotage (pilotage, reporting) et collaboration. Chaque microservice expose une interface de service documentée pour les commandes synchrones et consomme ou publie des événements ;

4. **Couche événementielle :** Constituée du bus d'événements, elle véhicule les événements métier standardisés. Ce bus permet un découplage temporel strict, chaque microservice publiant ses changements d'état dans des sujets dédiés, consommés de manière idempotente par les services abonnés ;

5. **Couche persistance et stockage souverain :** Regroupe la grappe relationnelle (un schéma par service, réplication synchrone), le cache distribué (révocations, quotas, verrous), le dépôt objet immuable en mode WORM (pièces, rapports, attestations, archives) et le magasin décisionnel.

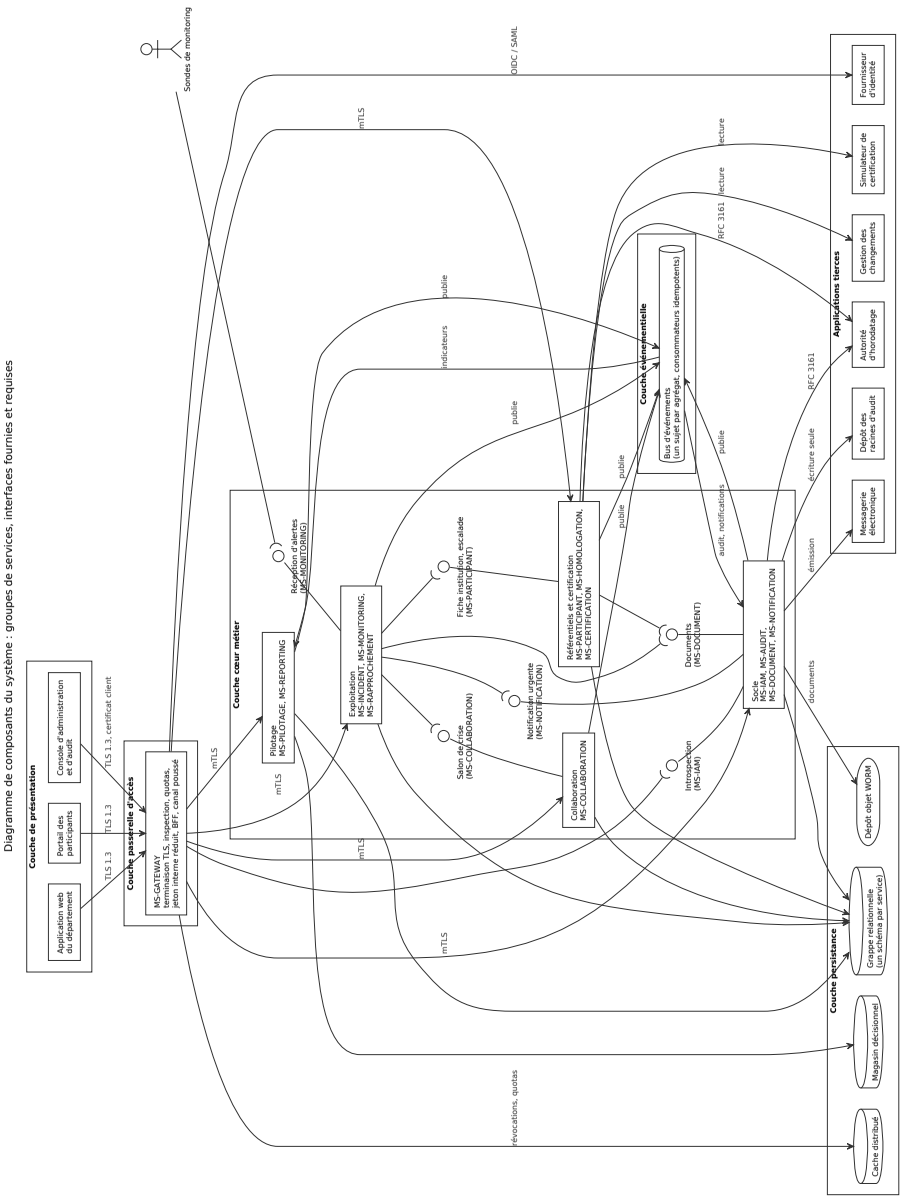


FIGURE 5.2: *Diagramme de composants du système*

Le tableau 5.4 détaille les interfaces d'échange et les protocoles régissant les interactions inter-composants les plus critiques de la plateforme.

TABLE 5.4: *Matrice des interfaces et flux inter-composants critiques*

Source	Cible	Canal	Nature des flux et données échangées
Couches de présentation	MS-GATEWAY	TLS 1.3	Requêtes applicatives, témoins de session chiffrés, canal poussé.
MS-GATEWAY	Fournisseur d'identité	OIDC / SAML sur TLS	Délégation de l'authentification, réception du jeton externe.
MS-GATEWAY	MS-IAM	Protocole binaire, mTLS	Introspection du jeton, vérification de la liaison au certificat, permissions par service.
MS-GATEWAY	Microservices	mTLS	Routage des commandes avec le jeton interne réduit au service cible et l'identifiant de corrélation.
Tous les services	Bus d'événements	Protocole du bus, mTLS	Publication des événements métier depuis la boîte d'envoi transactionnelle.
Bus d'événements	MS-AUDIT, MS-NOTIFICATION, MS-REPORTING	Protocole du bus	Consommation transverse de tous les sujets : scellement, notification, indicateurs.
MS-HOMOLOGATION	Simulateur de certification	Interface de service, mTLS, lecture	Avancement des campagnes, résultats des scénarios, références de trace.
MS-HOMOLOGATION	MS-DOCUMENT	Interface de service, mTLS	Dépôt et référence des preuves des opérations.
MS-CERTIFICATION	Dispositif de gestion des changements	Interface de service, mTLS, lecture	Référence et état d'approbation de la fiche de changement.
MS-CERTIFICATION	Autorité d'horodatage	RFC 3161	Jetons d'horodatage des quitus et des dossiers.

Source	Cible	Canal	Nature des flux et données échangées
MS-AUDIT	Dépôt de publication des racines	Écriture seule, mTLS	Racine et jeton d'horodatage de chaque période.
MS-NOTIFICATION	Messagerie électronique, passerelle SMS	Protocole de messagerie sur TLS ; interface sécurisée	Courriels et messages courts sortants.
MS-MONITORING	Sondes de monitoring	Interface de réception, mTLS	Alertes et mesures des liaisons et plateformes supervisées.
MS-RAPPROCHEMENT	États importés	Dépôt de fichiers contrôlé	États du commutateur et des participants, après contrôle de masquage.
MS-COLLABORATION	Serveur de messagerie fédérée, unité de distribution sélective	TLS 1.3 local	Salons chiffrés de bout en bout, flux audio et vidéo sur-chiffrés.

5.6 Zoning réseau, déploiement et haute disponibilité

La solidité du code applicatif s'effondre sans une fondation d'infrastructure sécurisée et redondante. La conception physique et logique satisfait simultanément aux guides de segmentation reconnus, aux exigences de cloisonnement du Règlement COBAC R-2024/01 et à la contrainte d'isolement du cahier de charges techniques.

5.6.1 Topologie de sécurité et découpage en cinq zones étanches

L'architecture s'affranchit des modèles périmétriques simples au profit d'une segmentation en profondeur en cinq zones étanches, isolées par des pare-feux réseau et applicatifs en politique de refus par défaut :

1. **Zone démilitarisée (DMZ) :** Bouclier frontal exposé aux participants. Abrite exclusivement les mandataires inverses durcis, la passerelle `MS-GATEWAY` et le conteneur du portail des participants. Aucune logique métier ni donnée sensible ne réside dans cette enclave ;

2. **Zone applicative :** Centre de traitement hébergeant la grappe d'orchestration de conteneurs et les treize microservices métier, segmentés par des politiques réseau entre socle, référentiels et certification, exploitation, pilotage et collaboration ;

3. **Zone de persistance :** Enclave coupée de tout accès direct, abritant la grappe relationnelle, le cache distribué, les courtiers du bus d'événements, le dépôt objet WORM et le magasin décisionnel. L'accès n'est autorisé qu'aux seuls services habilités de la zone applicative ;

4. **Zone d'administration :** Segment hors bande, sans route vers Internet, portant la console d'administration et d'audit, l'autorité de certification interne et les postes durcis des administrateurs et auditeurs ;

5. **Zone d'exploitation (salle de supervision du DES) :** Réseau local des postes durcis et des murs d'écrans, qui n'accède à la plateforme que par la passerelle, en TLS 1.3.

Les applications tierces (fournisseur d'identité, simulateur, dispositif de gestion des changements, messagerie électronique, dépôt de publication des racines, autorité d'horodatage) résident dans le réseau du groupement, hors de ces zones, et ne sont jointes que par des liaisons mutuellement authentifiées ouvertes depuis la zone applicative. Un site de secours reproduit les zones applicative, de persistance et d'administration.

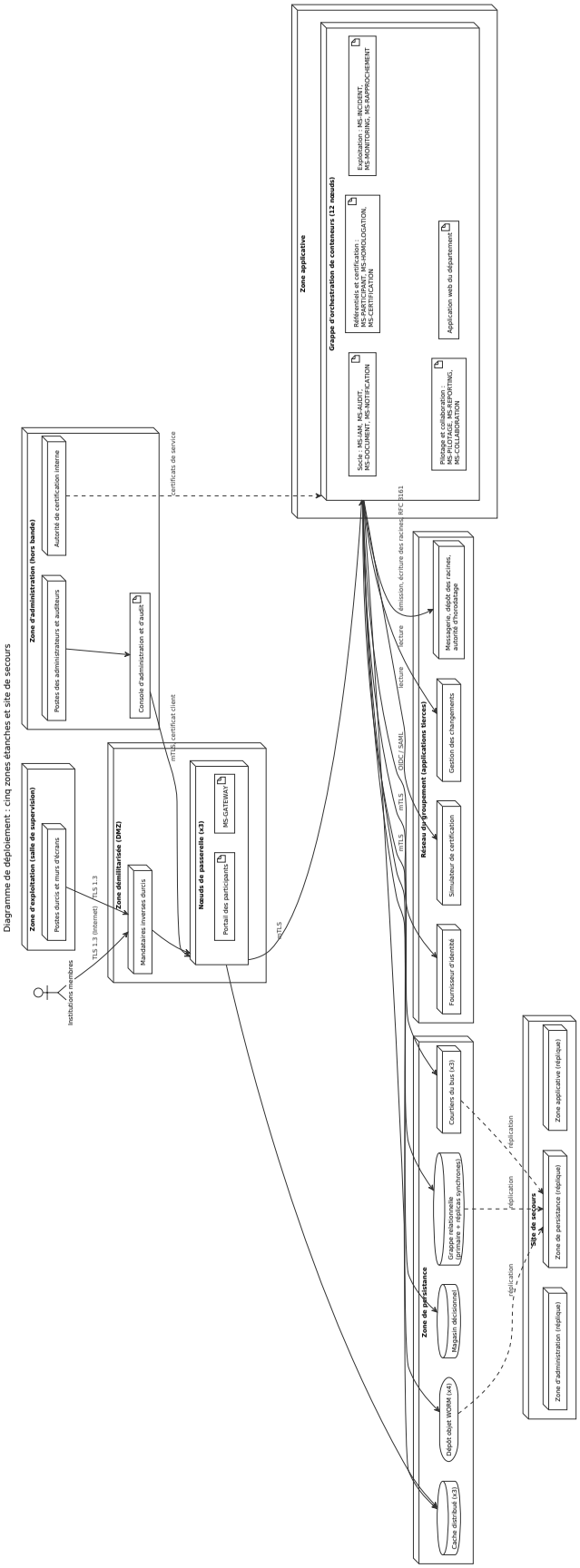


FIGURE 5.3: *Diagramme de déploiement de l'architecture logicielle et matérielle*

5.6.2 Mécanismes de haute disponibilité

L'objectif de disponibilité de la plateforme (99,9 %) et ses objectifs de reprise (perte de données maximale de 15 minutes, interruption maximale d'une heure) reposent sur :

- **Tolérance aux pannes de la grappe relationnelle :** Un nœud primaire et des réplicas synchrones, orchestrés par un gestionnaire de haute disponibilité à consensus distribué ; en cas de défaillance du primaire, le réplica le plus avancé est promu automatiquement, sans perte de données validée ;
- **Résilience du bus d'événements :** Courtiers répliqués avec métadonnées gérées par consensus interne, sans point de défaillance externe ; chaque sujet est répliqué sur trois courtiers ;
- **Réplication du dépôt objet :** Réplication du dépôt WORM vers le site de secours, avec conservation des verrous de rétention ;
- **Sans état :** La passerelle et les couches de présentation ne conservent aucun état ; leur multiplication et leur remplacement sont sans effet sur les sessions.

5.6.3 Archivage légal inaltérable et persistance WORM

Les pièces des dossiers, les rapports de quart, les procès-verbaux, les attestations de mise en service et les archives de crise doivent être conservés dix ans au minimum. Pour garantir l'intégrité de ces archives, l'architecture déploie le dépôt objet retenu au chapitre 4 avec verrouillage de rétention en mode conformité : une fois l'objet déposé et verrouillé, aucun utilisateur, ni même l'administrateur de l'infrastructure, ne peut le modifier, l'écraser ou le supprimer avant l'échéance. Ce verrouillage, joint à l'ancrage des empreintes dans le registre d'audit, garantit l'inviolabilité des preuves face aux contrôles de la COBAC.

Le tableau 5.5 récapitule l'allocation des ressources d'infrastructure par zone, pour le site principal ; le site de secours reproduit les zones applicative, de persistance et d'administration avec la même allocation.

TABLE 5.5: *Dimensionnement et allocation des ressources d'infrastructure*

Zone	Rôle	Ressources allouées	Composants hébergés et sécurité
DMZ	Deux nœuds de bordure	2 x (8 vCPU, 16 Go, 200 Go)	Mandataires inverses, MS-GATEWAY, portail des participants, pare-feu applicatif.

Zone	Rôle	Ressources allouées	Composants hébergés et sécurité
Applicative	Quatre nœuds de calcul	4 x (16 vCPU, 64 Go, 500 Go)	Orchestrateur de conteneurs, treize microservices métier, application du département.
Persistance	Trois nœuds relationnels	3 x (16 vCPU, 64 Go, 2 To)	Grappe relationnelle, un schéma par service, réplication synchrone, magasin décisionnel.
Persistance	Trois courtiers	3 x (8 vCPU, 32 Go, 1 To)	Bus d'événements, métadonnées par consensus.
Persistance	Quatre nœuds objet	4 x (8 vCPU, 32 Go, 8 To)	Dépôt objet WORM, chiffrement au repos, réplication inter-sites.
Persistance	Trois nœuds de cache	3 x (4 vCPU, 16 Go, 100 Go)	Cache distribué : révocations, quotas, verrous.
Administration	Deux nœuds	2 x (8 vCPU, 16 Go, 300 Go)	Console d'administration et d'audit, autorité de certification interne, outillage de déploiement hors ligne.
Exploitation	Postes durcis	8 vCPU, 16 Go, 256 Go par poste	Postes de la salle de supervision, clés matérielles FIDO2, accès par la passerelle en TLS 1.3.

CHAPITRE 6

Conception détaillée

Le chapitre précédent a fixé la conception générale : quatorze microservices répartis sur sept domaines, une passerelle d'accès unique, un bus d'événements, une base de données par service, cinq zones réseau et un site de secours. Le présent chapitre descend au niveau de chaque microservice et livre les quatre éléments que le cahier de conception doit fournir : les diagrammes de classes de conception, avec des attributs typés et des signatures de méthodes ; les algorithmes des principales fonctions ; le thème de l'application ; la cartographie et les emplacements des maquettes des principales interfaces.

L'architecture étant axée microservices, la conception détaillée est organisée service par service. Chaque section suit un plan identique afin que le lecteur retrouve, pour tout service, la même séquence : les responsabilités métier, le cadrage réglementaire et les principes directeurs ; le diagramme de composants internes, qui projette l'architecture hexagonale (ports et adaptateurs) sur le service ; le diagramme de classes de conception ; un diagramme d'objets qui fixe l'état du service à un instant représentatif ; les algorithmes fondamentaux, chacun accompagné d'une fiche de spécification (entrées, sorties, complexité, standard) et d'un déroulement procédural. Les algorithmes sont numérotés en continu dans le chapitre (Algorithme 6.1 à 6.63) et référencés entre services lorsqu'un traitement en prolonge un autre.

Trois règles gouvernent la rédaction de ce chapitre. Premièrement, aucun nom de produit n'y figure : les choix technologiques sont arrêtés au chapitre 4 et les sections qui suivent ne parlent que de rôles (la base relationnelle du service, le bus d'événements, le cache distribué, le dépôt objet WORM, le coffre de clés, le fournisseur d'identité, le moteur de politiques), de sorte que la conception reste valable si un produit est remplacé par un autre de même rôle. Deuxièmement, la plateforme est non intrusive : les algorithmes lisent, rapprochent, tracent et notifient, mais n'écrivent jamais dans le commutateur, le simulateur de certification ou le dispositif de gestion des changements, et ne recalculent jamais un verdict du simulateur. Troisièmement, les entités du cahier d'analyse sont reprises une à une comme classes de conception, avec un type par attribut et des méthodes signées ; les classes techniques (ports, adaptateurs, objets-valeurs, événements d'outbox) s'y ajoutent sans les remplacer.

Le tableau 6.1 donne l'ordre des sections et la correspondance entre chaque microservice, les

modules qu'il porte et le domaine d'analyse dont il est issu.

Sect.	Microservice	Modules portés	Domaine
6.1.1	MS-GATEWAY	Passerelle d'accès, trois couches de présentation, canal poussé	7
6.1.2	MS-IAM	Habilitations et annuaire, disponibilités (BF-ADMIN)	1
6.1.3	MS-AUDIT	Journal d'audit inaltérable	1
6.1.4	MS-DOCUMENT	Gestion électronique des documents (WORM)	1
6.1.5	MS-NOTIFICATION	Notifications multicanal	1
6.1.6	MS-PARTICIPANT	Institutions membres, échéances, annuaire d'escalade	2
6.1.7	MS-HOMO-LOGATION	Suivi de la certification : liaisons, opérations, reprise du simulateur, couvertures	3
6.1.8	MS-CERT-IFICATION	Suivi de la certification : quitus, fiche de changement, attestation	3
6.1.9	MS-INCIDENT	Tickets et demandes, incidents, cellule de crise	4
6.1.10	MS-MONITORING	Monitoring, astreintes, quarts	4
6.1.11	MS-RAPP-ROCHEMENT	Rapprochement monétique et suspens	4
6.1.12	MS-PILOTAGE	Tâches, projets, réunions et PDCA	5
6.1.13	MS-REPORTING	Reporting décisionnel et cockpits	5
6.1.14	MS-COLL-ABORATION	Messagerie instantanée, visioconférence	6

TABLE 6.1: *Plan de la conception détaillée par microservice*

6.1 Conception détaillée par microservice

6.1.1 Passerelle d'accès et frontière d'entrée (MS-GATEWAY)

Le service `MS-GATEWAY` est le point d'entrée exclusif de la plateforme intégrée du Département Exploitation et Supervision (DES). Les trois couches de présentation (application web du département, portail des participants en DMZ, console d'administration et d'audit en zone d'administration) ne dialoguent qu'avec lui, et aucun microservice métier n'est joignable autrement. Placé en bordure de l'enclave isolée, il matérialise le Point d'Application de Politique (*Policy Enforcement Point*) de l'architecture Zero Trust décrite par le NIST SP 800-207 : terminaison TLS 1.3, inspection applicative, limitation de débit distribuée, vérification des jetons externes et de leur liaison au certificat client (RFC 8705), réduction de portée vers le seul service cible (RFC 8693, patron Phantom Token), routage en mTLS, agrégation par couche selon le modèle Backend-For-Frontend, diffusion du canal poussé et contrôle de masquage des données de carte sur les charges utiles relayées. Le service ne détient aucune donnée métier, aucune session applicative et aucune règle d'habilitation propre : la décision d'identité appartient à `MS-IAM`, la journalisation probante à `MS-AUDIT`, le contenu des notifications à `MS-NOTIFICATION`. Il ne fait ni routage monétique, ni traitement de message de paiement : il aiguille des commandes applicatives et rien d'autre.

6.1.1.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Rupture protocolaire et point d'application de politique unique Le modèle de sécurité périmétrique, fondé sur des zones de confiance implicite, est écarté au profit du principe « ne jamais faire confiance, toujours vérifier » :

- **Terminaison cryptographique (RFC 8446) :** la passerelle agit en mandataire inverse d'interception complète. Chaque flux externe est terminé en TLS 1.3 avec des suites à confidentialité persistante, puis une session mTLS distincte est ouverte vers le microservice aval. Aucune connexion de transport ne traverse la passerelle de bout en bout, ce qui ferme les attaques par fragmentation et les canaux cachés.
- **Évaluation en contexte :** chaque requête est confrontée à une politique d'accès (rôle, adresse de l'appelant, terminal, vacation) compilée une fois au démarrage et évaluée en mémoire. La passerelle applique la décision ; elle ne définit pas les habilitations, qui restent la propriété de `MS-IAM`.
- **Alignement PCI-DSS v4.0.1 :** bien que la plateforme se situe hors de l'environnement des données de titulaires de cartes, la passerelle en constitue la ligne de démarcation côté utilisateurs. Elle applique l'exigence 1 (segmentation par rupture protocolaire, aucune route directe entre les zones), l'exigence 3 (contrôle de masquage des numéros de carte apparus par accident dans une charge utile), l'exigence 6 (inspection applicative de toutes

les requêtes) et les exigences 8.4 et 8.5 (rejet des flux anonymes, certificat client et jeton lié au certificat selon la RFC 8705).

- **Auditabilité COBAC R-2024/01 :** chaque décision d'accès (admise, refusée, limitée, bloquée par l'inspection) est journalisée avec son identifiant de corrélation et publiée vers `MS-AUDIT`, qui l'inscrit comme feuille de l'arbre de Merkle (RFC 9162). La passerelle ne tient pas de registre probant elle-même.

Trois couches de présentation et modèle Backend-For-Frontend La passerelle connaît trois couches de présentation, chacune décrite par une entité `PresentationLayer` (nom, zone réseau, exigence d'authentification) :

- **Application web du département :** zone du département, réservée aux opérateurs de supervision, aux ingénieurs d'homologation et aux responsables ; authentification forte FIDO2 et certificat client requis ;
- **Portail des participants :** zone démilitarisée, restreint aux représentants des institutions membres pour leurs dossiers, leurs preuves et leurs demandes ; toute requête y est rattachée à une institution et filtrée sur ce périmètre ;
- **Console d'administration et d'audit :** zone d'administration, dédiée aux administrateurs de la plateforme, au RSSI et aux auditeurs ; accessible uniquement depuis les postes de la salle de contrôle du DES.

Pour chaque couche, un adaptateur Backend-For-Frontend expose des routes d'agrégation qui composent, en une seule réponse, les lectures de plusieurs services (par exemple la fiche d'une institution, l'avancement de sa liaison et ses dernières pièces). L'agrégation se fait toujours avec des jetons internes réduits, un par service consulté ; la passerelle n'obtient jamais plus de droits que l'utilisateur qu'elle représente. Les couches de présentation restent sans état et sans secret : les témoins de session sont chiffrés et signés par la passerelle.

Patron Phantom Token et échange de jeton Les jetons externes émis par le fournisseur d'identité ne pénètrent jamais le réseau interne :

1. **Introspection :** la passerelle extrait le jeton externe et le certificat client de la session mTLS, calcule l'empreinte SHA-256 du certificat et interroge `MS-IAM` par son port d'introspection (protocole binaire, mTLS). `MS-IAM` vérifie la signature, l'absence de révocation, la liaison au certificat (revendication `cnf.x5t#S256`, RFC 8705) et retourne les permissions par service.

2. **Réduction de portée (RFC 8693) :** la passerelle forge un jeton interne signé par une clé privée non exportable du coffre de clés, dont l'audience est le seul service cible de la route et dont les permissions sont l'intersection des droits de l'utilisateur et des permissions requises par la route. L'empreinte du certificat est reportée dans le jeton interne.

3. **Validation sans état en aval :** chaque microservice valide localement la signature du jeton interne à l'aide du trousseau de clés publiques (JWKS) publié par la passerelle, sans appel réseau, ce qui isole le cœur métier des indisponibilités du fournisseur d'identité.

Inspection applicative et contrôle de masquage des données de carte Le pare-feu applicatif, adossé à un jeu de règles ouvert, évalue un score d'anomalie cumulé en quatre phases (en-têtes de requête, corps de requête, en-têtes de réponse, corps de réponse). Le seuil de blocage entrant est fixé à 5 : une seule règle critique suffit à interrompre la requête. Le contrôle de masquage balaye les corps textuels (JSON, XML, formulaires) à la recherche de séquences de 13 à 19 chiffres validées par la formule de Luhn ; toute séquence confirmée est masquée en conservant les six premiers et les quatre derniers chiffres, et l'événement est journalisé. Ce contrôle ne constitue pas un traitement de données de carte : il empêche qu'un numéro apparu par erreur dans une pièce ou un état ne soit relayé en clair.

Limitation de débit, résilience et canal poussé

- **Fenêtre glissante distribuée :** l'historique des requêtes est tenu dans le cache distribué par clé (utilisateur ou institution, route) et évalué atomiquement, ce qui supprime les rafales aux frontières de fenêtres fixes. Les quotas dépendent du niveau d'habilitation et de la couche : 1000 requêtes par minute pour l'administration, 500 pour l'application du département, 100 pour le portail des participants.

- **Disjoncteurs et délestage :** l'appel d'introspection et les appels aval sont encapsulés dans des disjoncteurs ; en cas d'ouverture, la passerelle délestera la charge par un code 503 plutôt que de propager la panne.

- **Canal poussé :** les couches de présentation ouvrent une connexion persistante vers la passerelle et déclarent un abonnement (`PushSubscription`) filtré par profil et par institution. Les événements à pousser sont produits par `MS-NOTIFICATION` et consommés par la passerelle sur le bus d'événements ; elle ne diffuse un événement qu'aux abonnements dont les filtres l'acceptent, ce qui interdit toute fuite entre institutions.

- **Corrélation :** tout passage reçoit un identifiant de corrélation unique, propagé dans les en-têtes vers chaque service aval, repris dans les événements et restitué dans la réponse. Un incident se reconstitue ainsi de bout en bout à partir d'un seul identifiant.

6.1.1.2 Diagramme de composants internes de MS-GATEWAY

La Figure 6.1 présente l'organisation interne du service en architecture hexagonale : les adaptateurs pilotes reçoivent le trafic des couches de présentation, le cœur de domaine porte les règles de la passerelle, et les adaptateurs pilotés dialoguent avec `MS-IAM`, le cache distribué, le coffre de clés, le journal d'outbox, le bus d'événements et les microservices cibles.

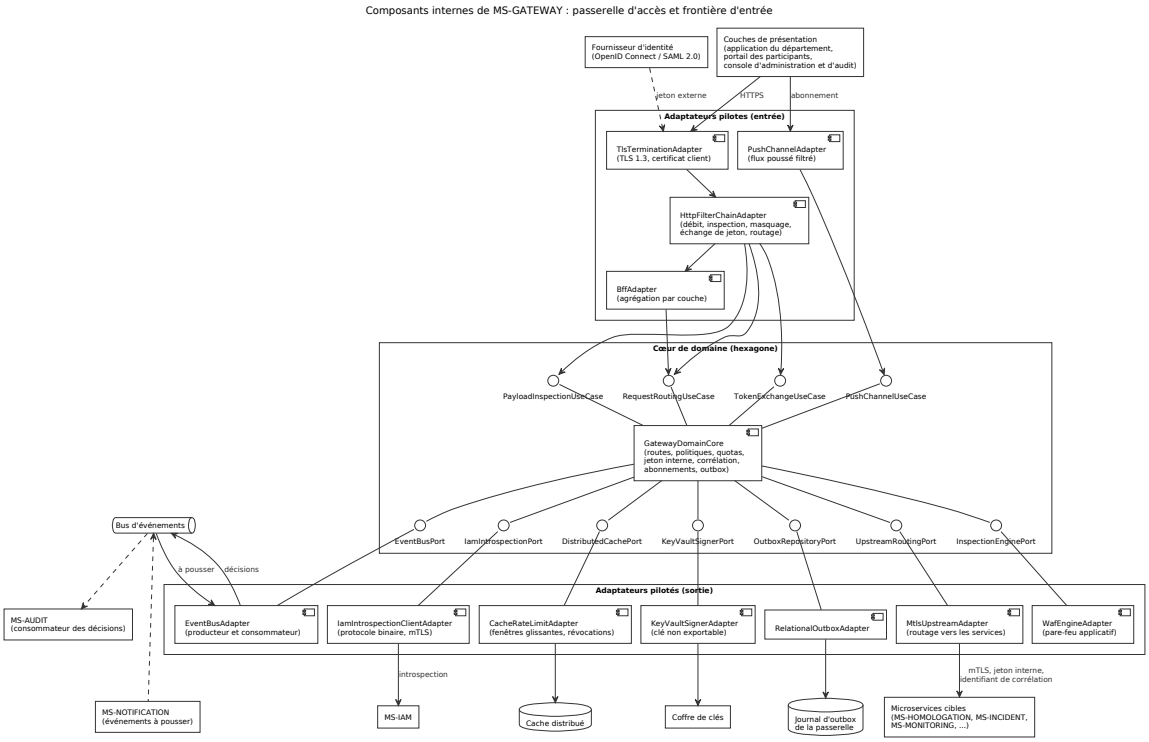


FIGURE 6.1: *Diagramme de composants internes : passerelle d'accès et frontière d'entrée*

- **Adaptateurs pilotes (entrée) :** `TlsTerminationAdapter` termine TLS 1.3 et extrait le certificat client ; `HttpFilterChainAdapter` enchaîne la limitation de débit, l'inspection, le masquage, l'échange de jeton et le routage ; `BffAdapter` compose les réponses agrégées par couche ; `PushChannelAdapter` tient les connexions persistantes du canal poussé.
- **Cœur de domaine :** `GatewayDomainCore` expose quatre ports primaires (`RequestRoutingUseCase`, `TokenExchangeUseCase`, `PayloadInspectionUseCase`, `PushChannelUseCase`) et porte les entités du domaine 7 : couches, routes, requêtes, politiques d'accès, jetons internes, révocations, abonnements, ainsi que l'outbox des décisions.
- **Adaptateurs pilotés (sortie) :** `IamIntrospectionClientAdapter` (introspection en protocole binaire sous mTLS), `CacheRateLimitAdapter` (fenêtres glissantes et liste de révocation), `KeyVaultSignerAdapter` (signature par clé non exportable),

`RelationalOutboxAdapter` (journal d'outbox), `EventBusAdapter` (publication des décisions, consommation des événements à pousser), `MtlsUpstreamAdapter` (routage vers les services avec jeton interne et identifiant de corrélation), `WafEngineAdapter` (pare-feu applicatif).

- **Interactions :** `MS-IAM` pour l'introspection ; `MS-AUDIT` consomme `gateway.access-decided.v1` ; `MS-NOTIFICATION` publie `notification.push-requested.v1` ; le fournisseur d'identité délivre le jeton externe aux couches de présentation, jamais à la passerelle directement.

6.1.1.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.2 détaille les classes du domaine, les ports et les adaptateurs. Les sept entités du domaine 7 du cahier d'analyse y sont reprises avec leurs types et leurs signatures.

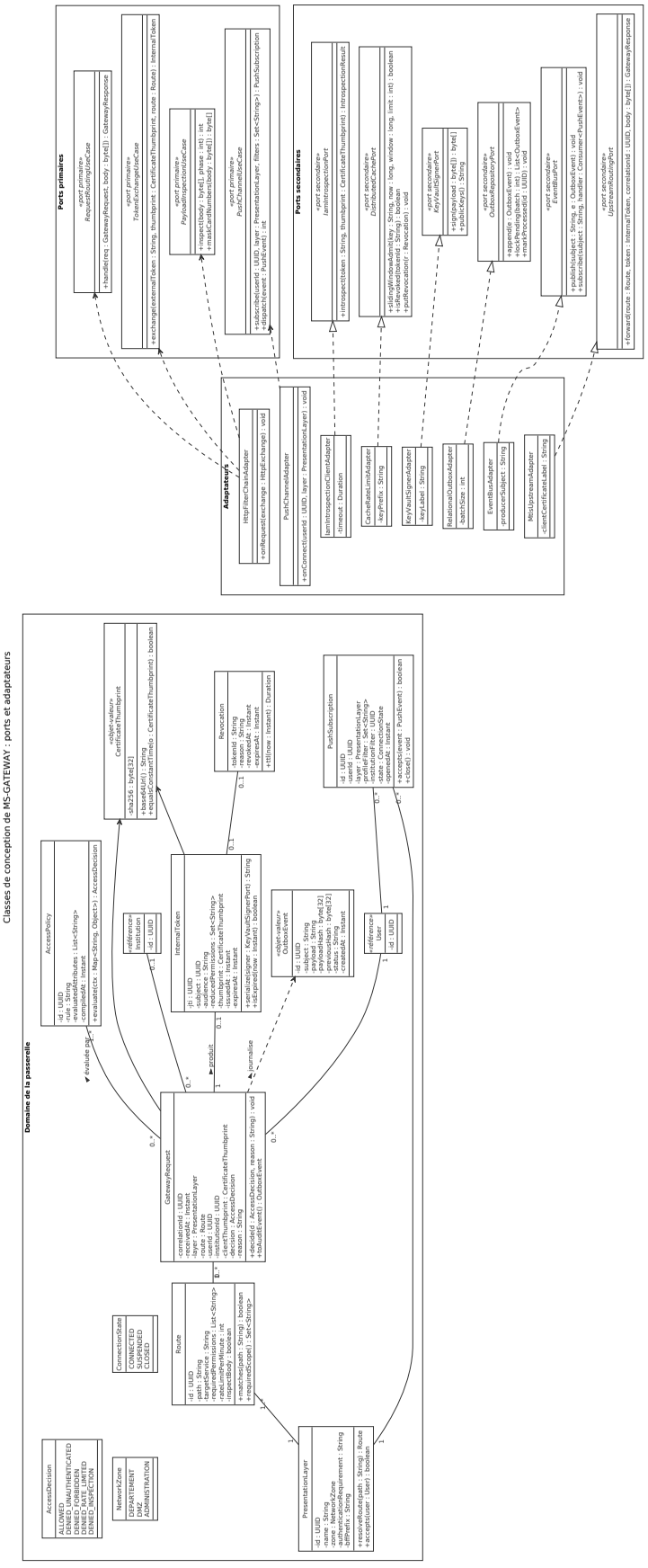


FIGURE 6.2: *Diagramme de classes de conception : service MS-GATEWAY*

- **Entités :** `PresentationLayer` (`name : String`, `zone : NetworkZone`, `authenticationRequirement : String`, `bffPrefix : String`) ; `Route` (`path : String`, `targetService : String`, `requiredPermissions : List<String>`, `rateLimitPerMinute : int`) ; `GatewayRequest` (`correlationId : UUID`, `receivedAt : Instant`, `userId : UUID`, `institutionId : UUID`, `decision : AccessDecision`, `reason : String`) ; `AccessPolicy` (`rule : String`, `evaluatedAttributes : List<String>`, `compiledAt : Instant`) ; `InternalToken` (`subject : UUID`, `audience : String`, `reducedPermissions : Set<String>`, `expiresAt : Instant`) ; `Revocation` (`tokenId : String`, `reason : String`, `expiresAt : Instant`) ; `PushSubscription` (`profileFilter : Set<String>`, `institutionFilter : UUID`, `state : ConnectionState`).
- **Objets-valeurs et références :** `CertificateThumbprint` (`sha256 : byte[32]`, comparaison en temps constant) ; `OutboxEvent` (`payloadHash : byte[32]`, `previousHash : byte[32]`) ; `User` et `Institution` ne sont conservés que par leur identifiant, reçus de `MS-IAM` et de `MS-PARTICIPANT`.
- **Ports primaires :** `RequestRoutingUseCase` (méthode `handle`), `TokenExchangeUseCase` (`exchange`), `PayloadInspectionUseCase` (`inspect`, `maskCardNumbers`) et `PushChannelUseCase` (`subscribe`, `dispatch`).
- **Ports secondaires :** `IamIntrospectionPort`, `DistributedCachePort` (`slidingWindowAdmit`, `isRevoked`), `KeyVaultSignerPort`, `OutboxRepositoryPort`, `EventBusPort`, `UpstreamRoutingPort`.
- **Adaptateurs :** `HttpFilterChainAdapter` et `PushChannelAdapter` pilotent les ports primaires ; `IamIntrospectionClientAdapter`, `CacheRateLimitAdapter`, `KeyVaultSignerAdapter`, `RelationalOutboxAdapter`, `EventBusAdapter` et `MtlsUpstreamAdapter` réalisent les ports secondaires.

6.1.1.4 Diagramme d'objets du service MS-GATEWAY

La Figure 6.3 capture l'instant où un ingénieur d'homologation, depuis l'application web du département, soumet la clôture d'une opération à `MS-HOMOLOGATION` : la requête a franchi la limitation de débit, l'inspection et le contrôle de masquage, le jeton interne réduit vient d'être forgé et la décision est en attente de publication vers `MS-AUDIT`.

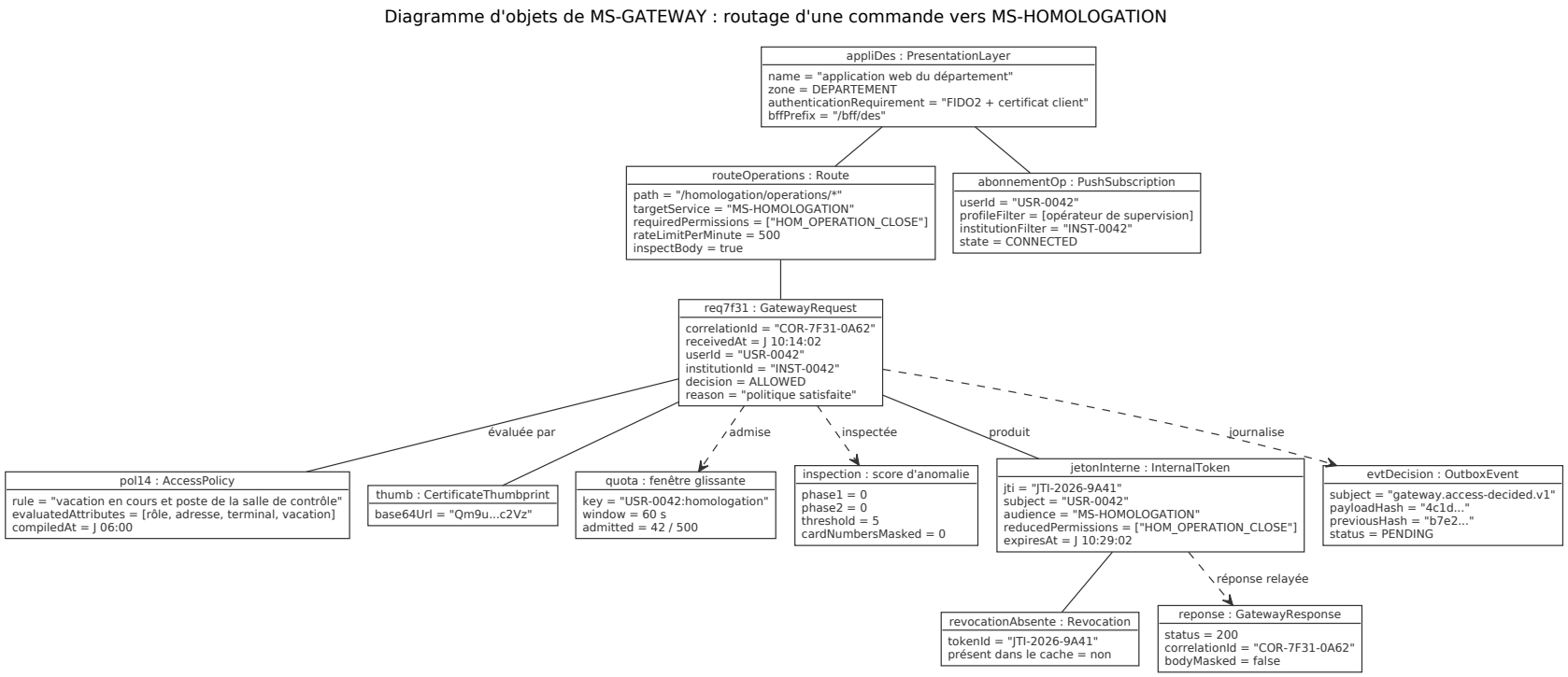


FIGURE 6.3: *Diagramme d'objets : routage d'une commande avec échange de jeton et inspection*

- `appliDes : PresentationLayer`, zone `DEPARTEMENT`, exigence FIDO2 et certificat client, préfixe d'agrégation `/bff/des` ;
- `routeOperations : Route` vers `MS-HOMOLOGATION`, permission requise `HOM_OPERATION_CLOSE`, 500 requêtes par minute, corps inspecté ;
- `req7f31 : GatewayRequest`, identifiant de corrélation `COR-7F31-0A62`, utilisateur `USR-0042`, institution `INST-0042`, décision `ALLOWED` ;
- `pol14 : AccessPolicy`, règle « vacation en cours et poste de la salle de contrôle », attributs rôle, adresse, terminal, vacation ;
- `quota`, fenêtre de 60 secondes, 42 requêtes admises sur 500 ; `inspection`, score nul aux deux phases entrantes, aucun numéro de carte masqué ;
- `jetonInterne : InternalToken`, audience `MS-HOMOLOGATION`, permission réduite à `HOM_OPERATION_CLOSE`, expiration à quinze minutes ; `revocationAbsente` confirme que l'identifiant de jeton n'est pas dans le cache ;
- `evtDecision : OutboxEvent`, sujet `gateway.access-decided.v1`, statut `PENDING`, chaîné à l'empreinte précédente ;
- `abonnementOp : PushSubscription`, connecté, filtré sur le profil d'opérateur de supervision et l'institution `INST-0042` ; `reponse` relayée avec le même identifiant de corrélation.

6.1.1.5 Algorithmes fondamentaux de MS-GATEWAY

Cette section formalise les cinq algorithmes qui régissent la limitation de débit, l'échange de jeton, le contrôle de masquage, l'inspection applicative et la journalisation des décisions du service `MS-GATEWAY`.

Algorithme 6.1 : Limitation de débit distribuée par fenêtre glissante Cet algorithme admet ou rejette une requête selon le nombre de requêtes déjà admises pour la même clé dans la fenêtre courante. Son exécution est atomique dans le cache distribué, ce qui rend la décision cohérente entre toutes les instances de la passerelle et supprime les rafales aux frontières de fenêtres fixes.

Spécification formelle de l'algorithme 6.1 : limitation de débit par fenêtre glissante	
Entrées	K : clé (appelant, route) ; t_{now} : horodatage en millisecondes ; W : largeur de fenêtre ; L : limite ; r : identifiant de requête.
Sorties	Admission (1) ou rejet (0, réponse 429 avec délai de réessai).
Complexité	$\mathcal{O}(\log N + M)$, N entrées de la fenêtre, M entrées purgées.
Garantie	Exécution atomique d'un seul bloc dans le cache distribué ; clé colocalisée sur un même nœud.

TABLE 6.2: *Fiche de spécification : limitation de débit par fenêtre glissante*

Déroulement procédural étape par étape :

1. **Calcul de la borne d'obsolescence :** déterminer l'instant au-delà duquel une requête ne compte plus dans la fenêtre :
$$t_{\text{obs}} = t_{\text{now}} - W \tag{6.1}$$
2. **Purge atomique :** supprimer de l'ensemble ordonné associé à K toutes les entrées dont le score (horodatage) est inférieur à t_{obs}, de sorte que seul l'intervalle $[t_{\text{now}} - W,\ t_{\text{now}}]$ subsiste.
3. **Dénombrement :** lire la cardinalité C de l'ensemble après purge.
4. **Arbitrage :** si $C \geq L$, retourner 0 sans modifier l'ensemble ; la passerelle répond 429 en indiquant le délai avant la prochaine admission possible, égal à l'écart entre le plus ancien horodatage conservé et t_{obs}.
5. **Enregistrement :** sinon, insérer r avec le score t_{now}, fixer l'expiration de la clé à $\lceil W/1000 \rceil + 10$ secondes pour éviter toute fuite mémoire, et retourner 1.
6. **Journalisation :** en cas de rejet, produire une décision `DENIED_RATE_LIMITED` vers l'outbox (algorithme 6.5).

Algorithme 6.2 : Échange de jeton et réduction de portée (RFC 8693) Cet algorithme convertit le jeton externe présenté par une couche de présentation en un jeton interne dont l'audience et les permissions sont restreintes au seul service cible de la route. La vérification d'identité est déléguée à `MS-IAM` par introspection ; la passerelle ne conserve rien.

Spécification formelle de l'algorithme 6.2 : échange de jeton et réduction de portée	
Entrées	T_{ext} : jeton externe ; C : certificat client de la session mTLS ; R : route résolue ; t_{now}.
Sorties	T_{int} : jeton interne signé, ou rejet 401 (liaison invalide) / 403 (portée vide).
Complexité	$\mathcal{O}(\lvert C\rvert + \lvert\mathscr{P}\rvert)$: un hachage du certificat et une intersection d'ensembles.
Standard	RFC 8693 (échange de jeton), RFC 8705 (liaison au certificat), RFC 9068 (profil JWT), RFC 7519.

TABLE 6.3: *Fiche de spécification : échange de jeton et réduction de portée*

Déroulement procédural étape par étape :

1. **Empreinte du certificat :** calculer l'empreinte canonique du certificat client selon la section 3.1 de la RFC 8705 :

$$H_C = \text{Base64Url}\big(\text{SHA256}(\text{DER}(C))\big) \tag{6.2}$$

2. **Consultation de la liste de révocation :** si l'identifiant du jeton externe figure dans la liste de révocation du cache distribué, rejeter (401) sans appel réseau.

3. **Introspection :** invoquer `IamIntrospectionPort.introspect`(T_{ext}, H_C) sous disjoncteur. `MS-IAM` vérifie la signature, la validité temporelle, la correspondance de H_C avec la revendication `cnf.x5t#S256` et retourne le sujet s et l'ensemble des permissions $\mathscr{P}_{\text{glob}}$ ventilées par service. Toute décision défavorable entraîne un rejet 401.

4. **Réduction de portée :** calculer l'intersection avec les permissions requises par la route :

$$\mathscr{P}_{\text{red}} = \mathscr{P}_{\text{glob}}(R.\text{targetService}) \cap R.\text{requiredPermissions} \tag{6.3}$$

   Si $\mathscr{P}_{\text{red}}$ est vide, rejeter (403) et journaliser `DENIED_FORBIDDEN`.

5. **Forgeage du jeton interne :** assembler la charge utile (émetteur : la passerelle ; sujet s ; audience R.targetService ; permissions $\mathscr{P}_{\text{red}}$; `cnf.x5t#S256` $= H_C$; identifiant de corrélation ; `iat` $= t_{\text{now}}$; `exp` $= t_{\text{now}} + 900$ s) et la signer par `KeyVaultSignerPort.sign`, la clé privée ne quittant jamais le coffre de clés.

6. **Propagation :** substituer l'en-tête d'autorisation par T_{int}, ajouter l'en-tête de corrélation et transmettre la requête par `UpstreamRoutingPort.forward` sous mTLS.

Algorithme 6.3 : Contrôle de masquage des données de carte (formule de Luhn) Cet algorithme inspecte les corps de requête et de réponse relayés pour détecter les numéros de

carte apparus par accident et les masquer avant transmission, conformément à l'exigence 3 de PCI-DSS v4.0.1. Il partage sa règle avec le contrôle appliqué par `MS-DOCUMENT` au dépôt des pièces.

Spécification formelle de l'algorithme 6.3 : contrôle de masquage des données de carte	
Entrées	B : corps textuel (JSON, XML, formulaire) ; $n_{\min} = 13$, $n_{\max} = 19$.
Sorties	B' : corps masqué ; k : nombre de séquences masquées ; en-tête de longueur recalculé.
Complexité	$\mathcal{O}(\lvert B\rvert)$: un balayage linéaire et une somme de Luhn par candidat.
Contrôles	Formule de Luhn (modulo 10) ; conservation des six premiers et des quatre derniers chiffres.

TABLE 6.4: *Fiche de spécification : contrôle de masquage des données de carte*

Déroulement procédural étape par étape :

1. **Extraction des candidats :** balayer B avec une expression régulière précompilée et retenir toute suite de 13 à 19 chiffres, séparateurs (espaces, tirets) admis.
2. **Normalisation :** pour chaque candidat, retirer les séparateurs et former le vecteur $D = [d_1, \ldots, d_n]$.
3. **Somme de Luhn :** parcourir D de droite à gauche en doublant un chiffre sur deux :

$$v_i = \begin{cases} d_i & \text{si } i \text{ est de rang impair depuis la droite} \\ 2d_i - 9 & \text{si } i \text{ est de rang pair et } 2d_i > 9 \\ 2d_i & \text{sinon} \end{cases} \qquad S = \sum_{i=1}^{n} v_i \tag{6.4}$$

4. **Décision :** si $S \not\equiv 0 \pmod{10}$, le candidat est un identifiant technique et reste intact. Sinon, il est traité comme un numéro de carte.
5. **Masquage :** remplacer les chiffres de rang 7 à $n-4$ par des astérisques :

$$D' = d_1 \ldots d_6 \underbrace{* \cdots *}_{n-10} d_{n-3} \ldots d_n \tag{6.5}$$

6. **Substitution et journalisation :** écrire D' dans B', recalculer la longueur du corps, incrémenter k et, si $k > 0$, produire un événement de masquage vers l'outbox pour `MS-AUDIT`, sans jamais y inscrire la séquence d'origine.

Algorithme 6.4 : Inspection applicative par score d'anomalie cumulé Cet algorithme évalue chaque requête et chaque réponse à travers le pare-feu applicatif, en quatre phases, et interrompt le traitement dès que le score d'anomalie atteint le seuil. Il protège les microservices contre les injections et empêche la fuite d'informations techniques dans les réponses.

Spécification formelle de l'algorithme 6.4 : inspection applicative	
Entrées	Requête (méthode, chemin, en-têtes, corps) ; réponse aval ; seuil $\theta = 5$.
Sorties	Poursuite du traitement, ou interruption 403 (entrée) / 500 générique (sortie) avec décision journalisée.
Complexité	$\mathcal{O}(\lvert Req\rvert \cdot \lvert\mathscr{R}\rvert)$, $\mathscr{R}$ étant le jeu de règles compilé.
Standard	PCI-DSS v4.0.1 exigence 6 ; jeu de règles ouvert de référence pour les pare-feu applicatifs.

TABLE 6.5: *Fiche de spécification : inspection applicative*

Déroulement procédural étape par étape :

1. **Transaction d'inspection isolée :** instancier un contexte d'inspection propre à la requête, identifié par son identifiant de corrélation, afin qu'aucun état ne soit partagé entre requêtes concurrentes.

2. **Phase 1 (en-têtes de requête) :** soumettre méthode, chemin et en-têtes au moteur ; obtenir le score partiel S_1. Si $S_1 \geq \theta$, interrompre immédiatement (403) sans lire le corps.

3. **Phase 2 (corps de requête) :** mettre le corps en tampon borné (taille maximale par route), le soumettre au moteur et obtenir S_2. Évaluer :

$$S_{\text{in}} = S_1 + S_2 \geq \theta \;\Rightarrow\; \text{rejet 403} \tag{6.6}$$

4. **Contrôle de masquage :** appliquer l'algorithme 6.3 au corps admis avant transmission.

5. **Phases 3 et 4 (réponse) :** inspecter les en-têtes et le corps de la réponse aval ; si $S_3 + S_4 \geq \theta$ (traces de pile, messages d'erreur verbeux), substituer une réponse générique 500 et conserver la réponse d'origine uniquement dans la décision journalisée.

6. **Journalisation :** toute interruption produit une décision `DENIED_INSPECTION` avec les identifiants des règles déclenchées, transmise par l'algorithme 6.5.

Algorithme 6.5 : Journalisation transactionnelle des décisions vers MS-AUDIT Cet algorithme garantit qu'aucune décision d'accès n'est perdue entre la passerelle et le registre

d'audit : chaque décision est d'abord écrite localement dans une transaction, chaînée à la précédente, puis publiée sur le bus d'événements avec livraison au moins une fois. `MS-AUDIT` consomme ces événements de façon idempotente et les inscrit comme feuilles de l'arbre de Merkle.

Spécification formelle de l'algorithme 6.5 : outbox des décisions et publication	
Entrées	E : décision d'accès (corrélation, couche, route, sujet, décision, motif) ; H_{n-1} : empreinte de l'entrée précédente.
Sorties	Entrée d'outbox validée puis marquée `PROCESSED` après acquittement du bus.
Complexité	$\mathcal{O}(1)$ par décision ; publication par lots de 100.
Garantie	Livraison au moins une fois ; consommateur idempotent sur l'identifiant d'événement ; enveloppe CloudEvents.

TABLE 6.6: *Fiche de spécification : outbox des décisions et publication*

Déroulement procédural étape par étape :

1. **Empreinte de la décision :** sérialiser E sous forme canonique et calculer :

$$h_E = \mathrm{SHA256}(E), \qquad H_n = \mathrm{SHA256}(H_{n-1} \parallel h_E) \tag{6.7}$$

   Le chaînage local permet de détecter toute altération de l'outbox avant sa publication ; il ne se substitue pas au registre de `MS-AUDIT`.

2. **Écriture transactionnelle :** dans une transaction locale, insérer l'entrée (identifiant, sujet `gateway.access-decided.v1`, charge utile, h_E, H_n, statut `PENDING`, horodatage) et valider. En cas d'échec, annuler intégralement.

3. **Sélection d'un lot :** un processus d'arrière-plan verrouille jusqu'à 100 entrées en attente par ordre de création, avec verrouillage non bloquant (`SELECT ... FOR UPDATE SKIP LOCKED`), ce qui autorise plusieurs instances concurrentes.

4. **Publication :** envoyer chaque entrée sur le bus d'événements avec l'identifiant de corrélation comme clé de partition et attendre l'acquittement de toutes les répliques synchronisées.

5. **Acquittement :** marquer l'entrée `PROCESSED` avec l'horodatage de publication ; en cas d'échec, incrémenter le compteur de tentatives avec délai exponentiel, et au-delà de cinq tentatives, marquer `FAILED` et lever une alerte vers `MS-MONITORING`.

6. **Consommation :** `MS-AUDIT` rejette tout événement dont l'identifiant a déjà été inscrit, puis calcule la feuille $\mathrm{SHA256}(0x00 \parallel \text{data})$ conformément à la RFC 9162.

6.1.2 Habilitations, annuaire et fédération d'identité (MS-IAM)

Le service MS−IAM est l'autorité d'habilitation de la plateforme intégrée du Département Exploitation et Supervision (DES). Il fédère l'authentification au fournisseur d'identité institutionnel du groupement (OpenID Connect ou SAML 2.0), tient l'annuaire des collaborateurs et l'historique de leurs rattachements, porte la matrice des rôles et des permissions à cinq niveaux, gère les délégations temporaires, les sessions et leurs révocations, conduit le réexamen périodique des accès et tient le registre des disponibilités du volet administratif (BF-ADMIN) qui alimente les astreintes de MS−MONITORING. Il constitue le Point de Décision de Politique de l'architecture Zero Trust (NIST SP 800-207), interrogé par MS−GATEWAY à chaque requête entrante. Le service ne détient aucun mot de passe : les secrets d'authentification restent chez le fournisseur d'identité et les clés de signature dans le coffre de clés. Il ne journalise pas lui-même de façon probante : chaque décision à effet est publiée vers MS−AUDIT.

6.1.2.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : COBAC R-2024/01, PCI-DSS v4.0.1 et Zero Trust

- **Règlement COBAC R-2024/01 :** le contrôle d'accès est nominatif, dynamique et tracé. L'identité et le contexte de l'opérateur sont réévalués à chaque requête, les canaux sont chiffrés en TLS 1.3 et toute décision d'habilitation (octroi, délégation, révocation, réexamen) est publiée vers MS−AUDIT, qui l'inscrit dans l'arbre de Merkle (RFC 9162) et en fournit des preuves d'inclusion aux auditeurs.
- **PCI-DSS v4.0.1, exigence 7 :** l'accès aux composants du système est restreint au besoin d'en connaître ; les habilitations sont attribuées par rôle, approuvées par un responsable, et réexaminées périodiquement. MS−IAM outille ce réexamen par des campagnes de recertification scellées.
- **PCI-DSS v4.0.1, exigence 8 :** authentification multifacteur pour tout accès administratif (8.4), résistance au rejeu et au hameçonnage (8.5) par des authentificateurs FIDO2 / WebAuthn (clé de sécurité matérielle), verrouillage après dix tentatives infructueuses (8.3), identification individuelle de chaque compte.
- **NIST SP 800-207 :** MS−IAM est le Point de Décision de Politique ; l'annuaire d'entreprise et le fournisseur d'identité sont ses Points d'Information ; MS−GATEWAY est le Point d'Application.

Fédération, annuaire et synchronisation différentielle L'annuaire d'entreprise du groupement demeure le référentiel maître des identités physiques ; le fournisseur d'identité y adosse

l'authentification. `MS-IAM` ne crée pas de comptes : il projette les identités fédérées dans son propre schéma et y ajoute ce que l'annuaire ne connaît pas (niveau d'habilitation, rôles applicatifs, affectations, disponibilités). La cohérence avec l'annuaire est assurée par une synchronisation différentielle sur LDAPS : le service mémorise un curseur de modification strictement croissant fourni par l'annuaire, ne lit que les entrées modifiées depuis ce curseur, par pages (RFC 2696), et intercepte les objets supprimés pour révoquer immédiatement les sessions concernées. L'authentification unique des postes de la salle de contrôle du DES est assurée par le fournisseur d'identité ; `MS-IAM` ne fait que valider l'assertion reçue (signature vérifiée à l'aide des clés publiées par le fournisseur, audience, fenêtre de validité) avant d'ouvrir une session.

Rôles, permissions et cinq niveaux d'habilitation Les groupes d'appartenance institutionnels sont traduits en rôles applicatifs, eux-mêmes composés de permissions (ressource, action, domaine cible) ventilées par microservice. Cinq niveaux ordonnent la matrice :

1. *Administrateur de la plateforme* : configuration des connecteurs, gestion des comptes et des rôles, sans accès aux données métier ;
2. *Responsable* (chef du DES, RSSI, Direction Générale) : validation des rapports de quart, approbation des délégations, quitus de certification, clôture des campagnes de recertification ;
3. *Opérateur de supervision* : réception et acquittement des alertes, main courante de quart, tickets, accès borné à sa vacation ;
4. *Ingénieur d'homologation* : suivi des liaisons et des opérations, reprise en lecture des résultats du simulateur, dépôt des preuves ;
5. *Lecteur / auditeur* : consultation en lecture seule des registres, vérification des preuves d'inclusion et de cohérence.

Un rôle porte un périmètre de visibilité (toutes institutions, une institution, un service) qui se projette jusqu'à la persistance par des politiques de lignes dans chaque service consommateur.

Délégations temporaires, affectations et disponibilités

- **Délégations :** un collaborateur peut demander l'exercice temporaire d'un niveau supérieur (suppléance du chef de quart, absence d'un responsable). La délégation est bornée dans le temps, motivée, approuvée par un responsable de niveau au moins égal au niveau délégué, et expire d'elle-même ; son approbation et son expiration sont publiées. Une délégation ne modifie jamais les rôles permanents.

- **Affectations :** l'historique des rattachements (service, pôle, dates) est immuable ; une nouvelle affectation clôt la précédente sans l'effacer, ce qui permet de reconstituer qui appartenait à quelle équipe à une date donnée.
- **Disponibilités (BF-ADMIN) :** congés, absences et justificatifs sont déclarés puis validés par un responsable. Chaque validation est publiée (`iam.availability-validated.v1`) et consommée par `MS-MONITORING`, dont la grille d'astreinte exclut les collaborateurs indisponibles.

Sessions, liaison au certificat et révocation Une session est ouverte après validation de l'assertion fédérée et de l'authentificateur FIDO2 ; elle est liée au certificat client de la session mTLS : l'empreinte SHA-256 de l'encodage DER du certificat est inscrite dans la revendication `cnf.x5t#S256` (RFC 8705) du jeton, structuré selon le profil JWT de la RFC 9068 et signé par une clé privée non exportable du coffre de clés. Un jeton exfiltré est ainsi inutilisable sans la clé privée du certificat. La révocation (déconnexion, verrouillage, suppression dans l'annuaire, décision administrative) inscrit l'identifiant de session dans la liste de révocation du cache distribué, avec une durée de vie égale à la validité résiduelle du jeton, et publie `iam.session-revoked.v1` ; `MS-GATEWAY` consulte cette liste avant tout appel d'introspection.

Contrôle d'accès par attributs et cohérence événementielle

- **Politiques compilées :** le modèle RBAC est complété par un moteur de politiques qui évalue le contexte : méthode d'authentification (`amr` contenant `fido2` et `mtls`), appartenance de l'adresse de l'appelant au sous-réseau de la salle de contrôle, cohérence de l'instant avec la vacation de l'opérateur (matin de 06h00 à 14h00, après-midi de 14h00 à 22h00, nuit de 22h00 à 06h00). Les politiques sont compilées une fois au démarrage puis évaluées en mémoire, en temps quasi constant.
- **Transactional Outbox :** toute mutation (compte, rôle, délégation, session, affectation, disponibilité, recertification) écrit, dans la même transaction, l'état et l'événement correspondant dans la table d'outbox ; un processus d'arrière-plan publie ensuite sur le bus d'événements avec livraison au moins une fois. Les sujets suivent la convention `iam.<agrégat>-<événement>.v1`.

6.1.2.2 Diagramme de composants internes de MS-IAM

La Figure 6.4 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les appels de `MS-GATEWAY`, du fournisseur d'identité et de la console d'administration ; le cœur

porte les entités du domaine 1 ; les adaptateurs pilotés dialoguent avec la base relationnelle du service, l'annuaire d'entreprise, le fournisseur d'identité, le cache distribué, le coffre de clés, le moteur de politiques et le bus d'événements.

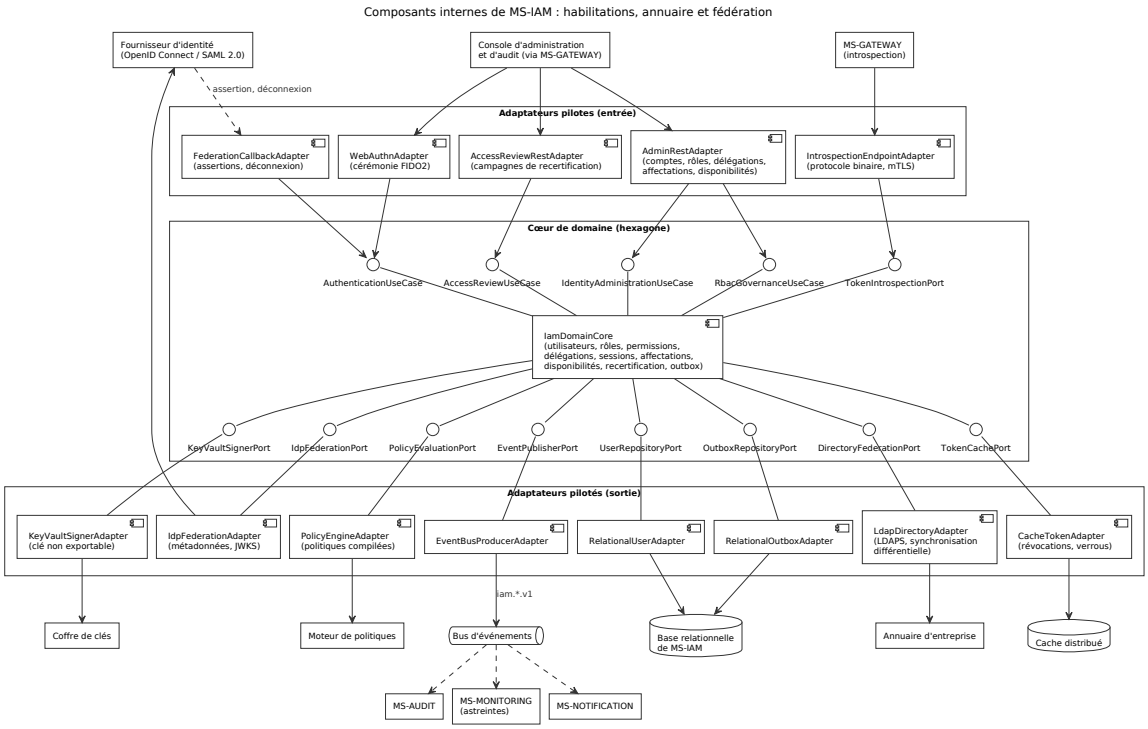


FIGURE 6.4: *Diagramme de composants internes : habilitations, annuaire et fédération*

- **Adaptateurs pilotes (entrée) :** `IntrospectionEndpointAdapter` (protocole binaire sous mTLS, appelé par la passerelle) ; `FederationCallbackAdapter` (réception des assertions et des déconnexions du fournisseur d'identité) ; `WebAuthnAdapter` (cérémonie FIDO2) ; `AdminRestAdapter` (comptes, rôles, délégations, affectations, disponibilités) ; `AccessReviewRestAdapter` (campagnes de recertification).
- **Cœur de domaine :** `IamDomainCore` expose `TokenIntrospectionPort`, `AuthenticationUseCase`, `IdentityAdministrationUseCase`, `RbacGovernanceUseCase` et `AccessReviewUseCase`, et requiert huit ports secondaires.
- **Adaptateurs pilotés (sortie) :** `RelationalUserAdapter` et `RelationalOutboxAdapter` (base relationnelle du service) ; `LdapDirectoryAdapter` (LDAPS, synchronisation différentielle) ; `IdpFederationAdapter` (métadonnées et clés publiques du fournisseur) ; `CacheTokenAdapter` (révocations, verrous) ; `KeyVaultSignerAdapter` (signature par clé non exportable) ; `PolicyEngineAdapter` (politiques compilées) ; `EventBusProducerAdapter`.

- **Interactions :** `MS-GATEWAY` en introspection synchrone ; `MS-AUDIT`, `MS-MONITORING` et `MS-NOTIFICATION` en consommateurs des événements `iam.*.v1`.

6.1.2.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.5 détaille les classes du domaine, les ports et les adaptateurs. Les huit entités du domaine 1 relevant des habilitations y sont reprises avec leurs types et leurs signatures.

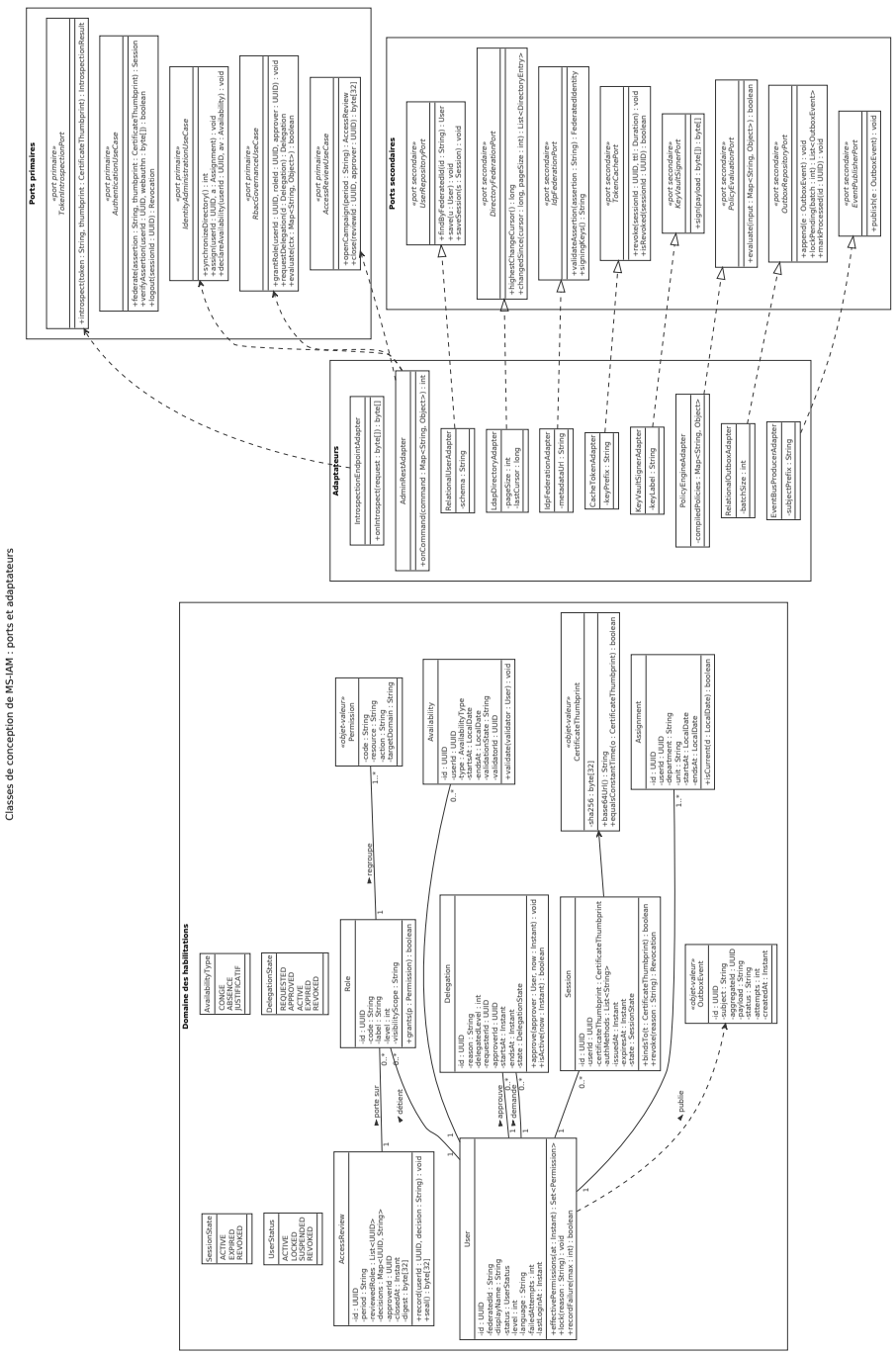


FIGURE 6.5: *Diagramme de classes de conception : service MS-IAM*

- **Entités :** `User` (`federatedId : String`, `status : UserStatus`, `level : int`, `failedAttempts : int`, `lastLoginAt : Instant`) ; `Role` (`code`, `label`, `level : int`, `visibilityScope`) ; `Delegation` (`delegatedLevel : int`, `requesterId`, `approverId : UUID`, `startsAt`, `endsAt : Instant`, `state : DelegationState`) ; `Session` (`certificateThumbprint`, `authMethods : List<String>`, `expiresAt : Instant`, `state : SessionState`) ; `Assignment` (`department`, `unit`, `startsAt`, `endsAt : LocalDate`) ; `AccessReview` (`period`, `reviewedRoles : List<UUID>`, `decisions : Map<UUID, String>`, `digest : byte[32]`) ; `Availability` (`type : AvailabilityType`, `validationState`, `validatorId`).
- **Objets-valeurs :** `Permission` (`code`, `resource`, `action`, `targetDomain`) ; `CertificateThumbprint` (`sha256 : byte[32]`, comparaison en temps constant) ; `OutboxEvent` (`subject`, `aggregateId`, `status`, `attempts`).
- **Ports primaires :** `TokenIntrospectionPort` (`introspect`) ; `AuthenticationUseCase` (`federate`, `verifyAssertion`, `logout`) ; `IdentityAdministrationUseCase` (`synchronizeDirectory`, `assign`, `declareAvailability`) ; `RbacGovernanceUseCase` (`grantRole`, `requestDelegation`, `evaluate`) ; `AccessReviewUseCase` (`openCampaign`, `close`).
- **Ports secondaires :** `UserRepositoryPort`, `DirectoryFederationPort` (`highestChangeCursor`, `changedSince`), `IdpFederationPort`, `TokenCachePort`, `KeyVaultSignerPort`, `PolicyEvaluationPort`, `OutboxRepositoryPort`, `EventPublisherPort`.
- **Adaptateurs :** `IntrospectionEndpointAdapter` et `AdminRestAdapter` pilotent les ports primaires ; `RelationalUserAdapter`, `LdapDirectoryAdapter`, `IdpFederationAdapter`, `CacheTokenAdapter`, `KeyVaultSignerAdapter`, `PolicyEngineAdapter`, `RelationalOutboxAdapter` et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.2.4 Diagramme d'objets du service MS-IAM

La Figure 6.6 capture l'instant de la prise de vacation du matin d'un opérateur de supervision : sa session vient d'être ouverte et liée à son certificat, une délégation de suppléance du chef de quart est active pour la vacation, une disponibilité future validée attend sa publication, et la passerelle vient d'obtenir une décision d'introspection favorable.

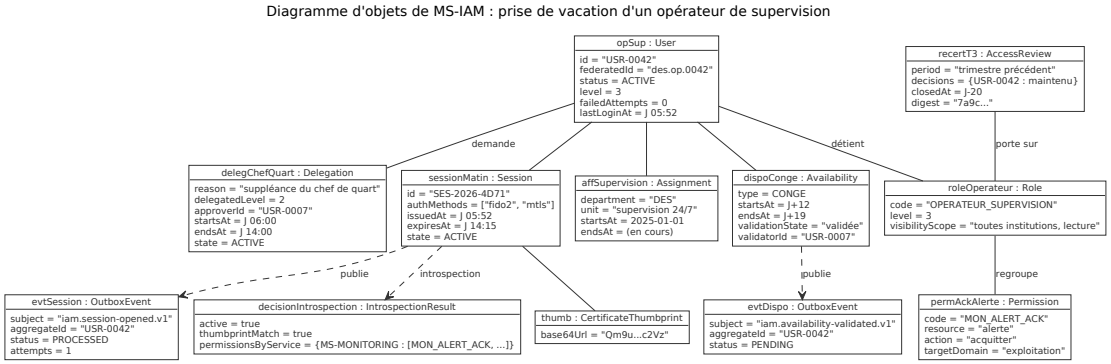


FIGURE 6.6: *Diagramme d'objets : prise de vacation d'un opérateur de supervision*

- `opSup : User`, identifiant `USR-0042`, niveau 3, actif, aucun échec d'authentification ;
- `roleOperateur : Role`, code `OPERATEUR_SUPERVISION`, niveau 3, visibilité en lecture sur toutes les institutions, regroupant `permAckAlerte : Permission` (acquitter une alerte du domaine exploitation) ;
- `delegChefQuart : Delegation`, niveau délégué 2, approuvée par `USR-0007`, active de 06h00 à 14h00 ;
- `sessionMatin : Session`, méthodes `fido2` et `mtls`, expiration à 14h15, liée à `thumb : CertificateThumbprint` ;
- `affSupervision : Assignment`, service DES, pôle supervision 24/7, en cours ; `dispoConge : Availability`, congé validé de J+12 à J+19 ;
- `recertT3 : AccessReview`, trimestre précédent, décision « maintenu » pour l'opérateur, empreinte scellée ;
- `evtSession : OutboxEvent`, sujet `iam.session-opened.v1`, publié ; `evtDispo : OutboxEvent`, sujet `iam.availability-validated.v1`, en attente ;
- `decisionIntrospection : IntrospectionResult`, session active, empreinte concordante, permissions ventilées par service.

6.1.2.5 Algorithmes fondamentaux de MS-IAM

Cette section formalise les six algorithmes qui régissent la liaison des jetons au certificat, la synchronisation de l'annuaire, l'évaluation des politiques, la publication des événements, l'introspection au service de la passerelle et le réexamen périodique des accès.

Algorithme 6.6 : Vérification de la liaison cryptographique au certificat (RFC 8705) Cet algorithme établit qu'un jeton présenté avec un certificat client est bien celui qui a été émis pour ce certificat. Il est invoqué par l'introspection (algorithme 6.10) et, localement, par chaque microservice qui reçoit un jeton interne.

Spécification formelle de l'algorithme 6.6 : liaison au certificat	
Entrées	T : jeton (JWT compact) ; H_C : empreinte du certificat client présenté ; t_{now}.
Sorties	VRAI (liaison prouvée) ou FAUX (rejet et révocation de la session).
Complexité	$\mathcal{O}(\lvert T\rvert)$ pour la vérification de signature ; comparaison en temps constant.
Standard	RFC 8705 (section 3.1), RFC 9068, RFC 7519, NIST SP 800-207.

TABLE 6.7: *Fiche de spécification : liaison au certificat*

Déroulement procédural étape par étape :

1. **Validation syntaxique et temporelle :** décoder T, vérifier sa signature avec la clé publique de l'émetteur et rejeter si $t_{\text{now}} \geq T.\text{exp}$ ou si $T.\text{nbf} > t_{\text{now}}$.
2. **Extraction de la revendication de confirmation :** lire $H_{\text{ref}} = T.\text{cnf.}\texttt{x5t\#S256}$; si elle est absente, rejeter : la politique impose des jetons liés à l'expéditeur.
3. **Empreinte du certificat présenté :** si H_C n'est pas fournie, la calculer à partir de l'encodage DER du certificat de la session de transport :

$$H_C = \text{Base64Url}\big(\text{SHA256}(\text{DER}(C))\big) \tag{6.8}$$

4. **Comparaison en temps constant :** évaluer $\text{ConstantTimeEquals}(H_{\text{ref}}, H_C)$ afin d'écarter les attaques par analyse temporelle.
5. **Décision :** en cas d'égalité, retourner VRAI. Sinon, retourner FAUX, inscrire l'identifiant de session dans la liste de révocation et publier `iam.session-revoked.v1` avec le motif « divergence de certificat », événement consommé par `MS-AUDIT` et par `MS-NOTIFICATION` (alerte au RSSI).

Algorithme 6.7 : Synchronisation différentielle de l'annuaire d'entreprise Cet algorithme aligne le schéma de `MS-IAM` sur l'annuaire d'entreprise sans extraction globale : seules les entrées modifiées depuis le dernier curseur sont lues, par pages, et les suppressions sont interceptées pour révoquer immédiatement les sessions.

Spécification formelle de l'algorithme 6.7 : synchronisation différentielle	
Entrées	c_{local} : dernier curseur de modification traité ; $p = 500$: taille de page.
Sorties	c_{new} : curseur persisté ; événements d'outbox (modifications, révocations).
Complexité	$\mathcal{O}(N)$, N étant le nombre d'entrées modifiées depuis c_{local}.
Contrôles	LDAPS sur TLS 1.3 ; pagination RFC 2696 ; interception des objets supprimés.

TABLE 6.8: *Fiche de spécification : synchronisation différentielle de l'annuaire*

Déroulement procédural étape par étape :

1. **Lecture du curseur de l'annuaire :** ouvrir la session LDAPS et lire, dans l'entrée racine, le curseur de modification le plus élevé validé c_{max}. Si $c_{\text{local}} \geq c_{\text{max}}$, aucun changement : terminer.

2. **Recherche différentielle paginée :** formuler le filtre « objets de classe utilisateur dont le curseur de modification est compris dans $]c_{\text{local}},\ c_{\text{max}}]$ », attacher le contrôle de pagination (RFC 2696, p entrées) et le contrôle d'inclusion des objets supprimés.

3. **Traitement de chaque entrée :**

   - objet supprimé : marquer l'utilisateur `REVOKED`, inscrire ses sessions actives dans la liste de révocation, insérer `iam.session-revoked.v1` et `iam.user-changed.v1` dans l'outbox ;
   - objet modifié : mettre à jour les attributs projetés (état de verrouillage, groupes, service) et insérer `iam.user-changed.v1` ; si un groupe détermine un rôle, appliquer la traduction et insérer `iam.role-granted.v1` ou `iam.role-revoked.v1`.

   Chaque page est traitée dans une transaction propre.

4. **Page suivante :** transmettre le témoin de pagination retourné par l'annuaire jusqu'à épuisement.

5. **Avancement du curseur :** persister $c_{\text{local}} \leftarrow c_{\text{max}}$ dans la même transaction que la dernière page, de sorte qu'une panne rejoue au pire la dernière page (traitement idempotent par identifiant fédéré).

Algorithme 6.8 : Évaluation des politiques d'accès par attributs Cet algorithme décide, en contexte, si une action est autorisée. Les politiques sont compilées une seule fois puis évaluées en mémoire, ce qui rend la décision indépendante de la charge.

Spécification formelle de l'algorithme 6.8 : évaluation des politiques	
Entrées	Contexte Ctx : sujet, rôles effectifs, délégations actives, `amr`, adresse, terminal, t_{now}, ressource R, action A.
Sorties	AUTORISE ou REFUSE, avec la règle décisive pour l'audit.
Performance	Évaluation en mémoire sur politiques compilées, inférieure à la milliseconde.

TABLE 6.9: *Fiche de spécification : évaluation des politiques d'accès*

Déroulement procédural étape par étape :

1. **Compilation au démarrage :** charger les politiques déclaratives depuis le dépôt versionné, les analyser et les compiler en structures d'évaluation ; cette opération n'est exécutée qu'une fois, puis à chaque rechargement signé.
2. **Permissions effectives :** calculer l'union des permissions des rôles permanents et des délégations actives à t_{now} :

$$\mathscr{P}_{\text{eff}} = \bigcup_{r \in \text{roles}} \mathscr{P}(r) \cup \bigcup_{d \in \text{deleg},\ d.\text{isActive}(t_{\text{now}})} \mathscr{P}(\text{niveau}(d)) \tag{6.9}$$

3. **Document d'entrée :** construire l'entrée (`sub`, $\mathscr{P}_{\text{eff}}$, `amr`, adresse, terminal, t_{now}, cible (R,A)) sans copie superflue.
4. **Critères contextuels :** vérifier la présence de `fido2` et `mtls` dans `amr` pour toute action de niveau 1 ou 2, l'appartenance de l'adresse au sous-réseau de la salle de contrôle pour la console d'administration, et la concordance de t_{now} avec la vacation de l'opérateur pour les actions de quart.
5. **Décision et trace :** invoquer l'évaluation compilée ; si elle refuse, retourner REFUSE avec l'identifiant de la règle décisive et insérer `iam.access-denied.v1` dans l'outbox. Sinon retourner AUTORISE.

Algorithme 6.9 : Transactional Outbox et publication sur le bus d'événements Cet algorithme garantit la cohérence à terme entre la base relationnelle de `MS-IAM` et les services abonnés, sans double écriture ni validation à deux phases.

Spécification formelle de l'algorithme 6.9 : outbox et publication	
Entrées	Mutation métier (compte, rôle, délégation, session, affectation, disponibilité, recertification).
Sorties	État persisté ; événement publié et acquitté par le bus ; entrée marquée `PROCESSED`.
Garantie	Livraison au moins une fois ; ordre par agrégat ; consommateurs idempotents ; enveloppe CloudEvents.

TABLE 6.10: *Fiche de spécification : outbox et publication*

Déroulement procédural étape par étape :

1. **Transaction locale :** ouvrir une transaction ; appliquer la mutation aux tables du domaine ; construire l'événement (identifiant, sujet `iam.<agrégat>-<événement>.v1`, identifiant d'agrégat, horodatage, charge utile) ; l'insérer dans la table d'outbox avec le statut `PENDING` ; valider. Toute erreur annule l'ensemble : aucun événement orphelin ne peut exister.
2. **Sélection d'un lot :** un processus d'arrière-plan verrouille jusqu'à 100 entrées en attente par ordre de création, sans bloquer les autres instances (`SELECT ... FOR UPDATE SKIP LOCKED`).
3. **Publication :** envoyer chaque entrée avec l'identifiant d'agrégat comme clé de partition, ce qui préserve l'ordre des événements d'un même utilisateur, et attendre l'acquittement de toutes les répliques synchronisées.
4. **Acquittement :** marquer `PROCESSED` avec l'horodatage ; en cas d'échec, incrémenter le compteur de tentatives avec délai exponentiel ; au-delà de cinq tentatives, marquer `FAILED` et lever une alerte vers `MS-MONITORING`.
5. **Consommation idempotente :** chaque consommateur (`MS-AUDIT`, `MS-MONITORING`, `MS-NOTIFICATION`, services applicatifs) mémorise les identifiants déjà traités et ignore les doublons.

Algorithme 6.10 : Introspection d'un jeton externe pour la passerelle Cet algorithme répond à `MS-GATEWAY` lorsqu'elle intercepte une requête : il établit la validité du jeton externe, sa liaison au certificat client et la liste des permissions effectives du sujet, ventilées par service, à partir desquelles la passerelle forge le jeton interne réduit (algorithme 6.2).

Spécification formelle de l'algorithme 6.10 : introspection	
Entrées	T_{ext} : jeton externe ; H_C : empreinte du certificat client ; t_{now}.
Sorties	D : décision (active, sujet, session, permissions par service, vacation) ou inactive avec motif.
Complexité	$\mathcal{O}(\lvert T_{\text{ext}}\rvert + \lvert \mathscr{P}_{\text{eff}}\rvert)$; une lecture du cache, une lecture de la base.
Standard	RFC 7662 (introspection), RFC 8705, RFC 9068 ; transport binaire sous mTLS.

TABLE 6.11: *Fiche de spécification : introspection d'un jeton externe*

Déroulement procédural étape par étape :

1. **Authentification de l'appelant :** n'accepter la demande que si le certificat client de la session mTLS est celui de `MS-GATEWAY` ; sinon rejeter sans réponse détaillée.
2. **Révocation :** extraire l'identifiant de session *sid* de T_{ext} ; si `TokenCachePort.isRevoked`(*sid*), répondre D.active $=$ FAUX avec le motif « session révoquée ».
3. **Validité et liaison :** appliquer l'algorithme 6.6 à (T_{ext}, H_C) ; en cas d'échec, répondre inactive avec le motif correspondant.
4. **Session et sujet :** charger la session et l'utilisateur ; vérifier `status` = `ACTIVE` et `state` = `ACTIVE` ; mettre à jour la date de dernière activité.
5. **Permissions par service :** calculer $\mathscr{P}_{\text{eff}}$ comme dans l'algorithme 6.8, puis la ventiler par domaine cible :

$$D.\text{permissions}[s] = \{\, p \in \mathscr{P}_{\text{eff}} \mid p.\text{targetDomain} = s \,\} \tag{6.10}$$

   en y joignant la vacation en cours, le périmètre de visibilité le plus large des rôles et l'identifiant d'institution lorsque le sujet est un représentant d'un participant.
6. **Réponse :** retourner D ; la réponse n'est pas mise en cache par `MS-IAM`, mais la passerelle peut la conserver au plus 30 secondes par (sid, H_C), la révocation restant vérifiée à chaque requête.

Algorithme 6.11 : Réexamen périodique des accès (campagne de recertification) Cet algorithme outille l'exigence 7 de PCI-DSS v4.0.1 : à chaque période, les habilitations en vigueur sont présentées aux responsables, qui confirment, réduisent ou révoquent chacune d'elles ; la campagne est ensuite scellée par une empreinte et publiée vers `MS-AUDIT`.

Spécification formelle de l'algorithme 6.11 : réexamen périodique des accès	
Entrées	Période P ; ensemble des couples (utilisateur, rôle) et des délégations actives ; responsables approbateurs.
Sorties	`AccessReview` close, empreinte δ, mutations appliquées, événement `iam.access-review-closed.v1`.
Complexité	$\mathcal{O}(U \cdot R)$ pour la constitution, $\mathcal{O}(n \log n)$ pour le scellement de n décisions.
Standard	PCI-DSS v4.0.1 exigence 7 ; ISO/IEC 27001 (contrôle des accès) ; RFC 9162 pour la preuve.

TABLE 6.12: *Fiche de spécification : réexamen périodique des accès*

Déroulement procédural étape par étape :

1. **Ouverture de la campagne :** créer `AccessReview`(P) et y figer la liste des habilitations en vigueur (rôles permanents, délégations actives, comptes sans connexion depuis 90 jours signalés) ; publier `iam.access-review-opened.v1`, consommé par `MS-NOTIFICATION` pour convoquer les responsables.

2. **Répartition :** affecter chaque habilitation au responsable de l'affectation courante de l'utilisateur ; un responsable ne peut pas réexaminer ses propres accès, qui reviennent au chef du DES ou au RSSI.

3. **Décisions :** pour chaque habilitation, enregistrer `maintenu`, `réduit` (nouveau rôle) ou `révoqué`, avec l'identifiant du décideur et l'horodatage ; chaque décision est une mutation passée par l'outbox (algorithme 6.9).

4. **Application :** à la clôture, appliquer les réductions et révocations, révoquer les sessions concernées et vérifier qu'aucune habilitation figée n'est restée sans décision ; dans le cas contraire, la campagne ne peut pas être close.

5. **Scellement :** trier les décisions par identifiant et calculer l'empreinte :

$$\delta = \mathrm{SHA256}\big(P \parallel d_1 \parallel d_2 \parallel \cdots \parallel d_n\big) \tag{6.11}$$

   puis clore la campagne avec δ, l'approbateur et l'horodatage.

6. **Publication :** insérer `iam.access-review-closed.v1` portant δ ; `MS-AUDIT` l'inscrit comme feuille de l'arbre de Merkle, ce qui permet à un auditeur de vérifier ultérieurement que les décisions présentées correspondent bien à la campagne scellée.

6.1.3 Registre d'audit inaltérable et arbre de Merkle (MS-AUDIT)

Le service `MS-AUDIT` est le registre probant de la plateforme intégrée du Département Exploitation et Supervision (DES). Il reçoit, par le bus d'événements, chaque événement à effet publié par les treize autres services (décision d'accès, octroi d'habilitation, clôture d'une opération d'homologation, quitus, changement d'état d'un ticket, scellement d'un document, remise d'une notification), l'inscrit dans un registre en ajout seul et le fait entrer comme feuille dans un arbre de Merkle conforme à la RFC 9162, avec séparation de domaine entre feuilles et nœuds internes. À la clôture de chaque période, il calcule la racine de l'arbre, la fait horodater par l'autorité d'horodatage (RFC 3161) et la publie dans le dépôt de publication des racines, hors de la plateforme. Il produit sur demande des preuves d'inclusion et de cohérence et consigne les vérifications conduites par les auditeurs. Le service ne porte aucune logique métier, ne modifie jamais une entrée et n'en supprime aucune : ses droits SQL sont limités à l'insertion, un déclencheur rejette toute mise à jour ou suppression, et la rétention légale de dix ans s'applique à l'ensemble du registre. Il n'est pas non plus le journal technique de la plateforme (pile d'observabilité) : seuls les événements à effet y entrent.

6.1.3.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : COBAC, PCI-DSS v4.0.1, ISO/IEC 27001

- **Règlements COBAC R-2016/04 et R-2024/01 :** le dispositif de contrôle interne et de sécurité des systèmes d'information exige une piste d'audit complète, conservée et opposable, que l'autorité de supervision peut examiner lors d'inspections de routine ou inopinées. `MS-AUDIT` fournit cette piste et, au-delà, le moyen de démontrer qu'elle n'a pas été altérée depuis sa publication.
- **PCI-DSS v4.0.1, exigence 10 :** toute action d'un utilisateur disposant de privilèges administratifs et tout accès aux composants du périmètre sont journalisés ; les journaux sont protégés contre la modification et conservés ; leur intégrité est contrôlée. Le registre en ajout seul, l'arbre de Merkle et la publication externe des racines répondent respectivement à la journalisation, à la protection et au contrôle d'intégrité.
- **ISO/IEC 27001 :** la journalisation des événements, la protection des informations journalisées et la synchronisation des horloges sont des mesures attendues du système de management ; l'horodatage qualifié des racines par une autorité tierce en apporte la preuve indépendante.
- **RFC 9162 et RFC 3161 :** la structure de l'arbre, la séparation de domaine, les preuves d'inclusion et de cohérence suivent la RFC 9162 (*Certificate Transparency*, version 2.0) ;

le jeton d'horodatage suit la RFC 3161 et sa chaîne de certification est vérifiée selon la RFC 5280.

Registre en ajout seul et séparation de domaine Chaque événement d'audit reçoit un index strictement croissant i et une empreinte de feuille calculée sur sa forme canonique (enveloppe CloudEvents sérialisée avec clés triées, sans espace superflu, selon la RFC 8259) :

$$\mathrm{Hash}_{\mathrm{leaf}}(e_i) = \mathrm{SHA256}\big(0x00 \parallel \mathrm{canon}(e_i)\big) \tag{6.12}$$

Un nœud interne consolidant deux sous-arbres reçoit l'empreinte :

$$\mathrm{Hash}_{\mathrm{node}} = \mathrm{SHA256}\big(0x01 \parallel \mathrm{Hash}_{\mathrm{gauche}} \parallel \mathrm{Hash}_{\mathrm{droite}}\big) \tag{6.13}$$

Le préfixe distinct des feuilles et des nœuds interdit de faire passer un nœud interne pour une feuille (attaque de seconde préimage sur les arbres de hachage). La racine d'un arbre de n feuilles $D[n] = \{e_0, \ldots, e_{n-1}\}$ se définit récursivement, avec k la plus grande puissance de deux strictement inférieure à n :

$$\mathrm{MTH}(D[n]) = \mathrm{SHA256}\big(0x01 \parallel \mathrm{MTH}(D[0:k]) \parallel \mathrm{MTH}(D[k:n])\big) \tag{6.14}$$

avec, pour une seule feuille, $\mathrm{MTH}(\{e\}) = \mathrm{Hash}_{\mathrm{leaf}}(e)$. Le registre est physiquement protégé : le compte de service ne détient que le droit d'insertion sur les tables du registre, des nœuds et de la déduplication ; un déclencheur de la base relationnelle rejette toute instruction de mise à jour ou de suppression, y compris émise par un administrateur de la base ; aucune tâche de purge n'existe pour ces tables, la rétention légale de dix ans étant portée par la conservation de la base et de ses sauvegardes.

Consommation idempotente de tous les événements à effet `MS-AUDIT` s'abonne à l'ensemble des sujets `<service>.<agrégat>-<événement>.v1` du bus. Le bus livre au moins une fois ; l'idempotence est obtenue par une table de déduplication dont la clé unique est l'identifiant CloudEvents de l'enveloppe. L'insertion de l'événement d'audit, de l'entrée de déduplication et des nœuds de l'arbre a lieu dans une même transaction : une relivraison est détectée avant tout calcul et acquittée sans effet ; une panne entre l'insertion et l'acquittement provoque une relivraison, elle-même absorbée. L'ordre d'inscription est l'ordre de réception ; l'horodatage d'occurrence de l'événement, fourni par le producteur, est conservé à côté de l'horodatage d'inscription, de sorte qu'un retard de livraison reste visible sans ambiguïté.

Scellement périodique, horodatage et publication externe

- **Période :** la période de scellement est quotidienne ; elle est close à minuit par l'ordonnanceur du service. La racine de période fige la taille de l'arbre n_p et la racine $\mathrm{MTH}(D[n_p])$; les événements inscrits après la clôture appartiennent à la période suivante.
- **Horodatage :** l'empreinte SHA256(racine $\|$ n_p $\|$ priode) est soumise à l'autorité d'horodatage (RFC 3161) ; le jeton retourné, signé par l'autorité et portant l'instant de génération, est conservé avec la racine et rend impossible l'antidatage d'un scellement.
- **Publication :** la racine, la taille et le jeton sont écrits dans le dépôt de publication des racines par un adaptateur en écriture seule : la plateforme ne peut ni relire ni modifier ce qu'elle y a déposé, ce qui rend la publication opposable à la plateforme elle-même. La référence de publication retournée est conservée, et l'événement `audit.root-published.v1` est publié, consommé par `MS-REPORTING` (indicateur de continuité des scellements) et par `MS-NOTIFICATION` en cas d'échec.
- **Cohérence entre périodes :** chaque racine de période référence la précédente ; une preuve de cohérence entre les deux tailles est calculée au scellement et conservée, de sorte qu'un auditeur peut vérifier que la période nouvelle prolonge la précédente sans réécriture.

Preuves, vérification par l'auditeur et principes de conception

- **Preuve d'inclusion :** pour un événement d'index m dans un arbre de taille n, le service assemble le chemin d'audit (liste des empreintes frères du bas vers le haut), de longueur au plus $\lceil \log_2 n \rceil$, qui permet de recalculer la racine sans accès au registre.
- **Preuve de cohérence :** pour deux tailles $m < n$, la preuve démontre que l'arbre de taille n contient l'arbre de taille m comme préfixe, c'est-à-dire qu'aucune feuille passée n'a été modifiée ni retirée.
- **Vérification :** l'auditeur (COBAC ou audit interne, niveau 5) obtient depuis la console d'administration et d'audit un dossier de preuve (feuille, chemin, racine, jeton, référence de publication), recalcule hors plateforme et consigne son résultat ; le procès-verbal de vérification est lui-même un événement d'audit, feuille de l'arbre. Une divergence déclenche une notification critique au RSSI par le port synchrone de `MS-NOTIFICATION`.
- **Lecture :** la console d'administration et d'audit lit le registre par index, par filtre (acteur, domaine, type d'action, intervalle) et par période ; toute lecture passe par `MS-GATEWAY` avec un jeton interne réduit portant la permission de niveau 5. Le service n'expose aucune écriture aux couches de présentation : ses seules écritures viennent du bus, de l'ordonnanceur et des procès-verbaux de vérification.

6.1.3.2 Diagramme de composants internes de MS-AUDIT

La Figure 6.7 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les événements du bus, les requêtes de lecture et de preuve de la console d'administration et d'audit, et l'impulsion de l'ordonnanceur de périodes ; le cœur porte les trois entités d'analyse du domaine 1 (événement d'audit, racine de période, preuve d'inclusion) et les objets qui les complètent ; les adaptateurs pilotés dialoguent avec la base relationnelle du service, l'autorité d'horodatage, le dépôt de publication des racines et le bus d'événements.

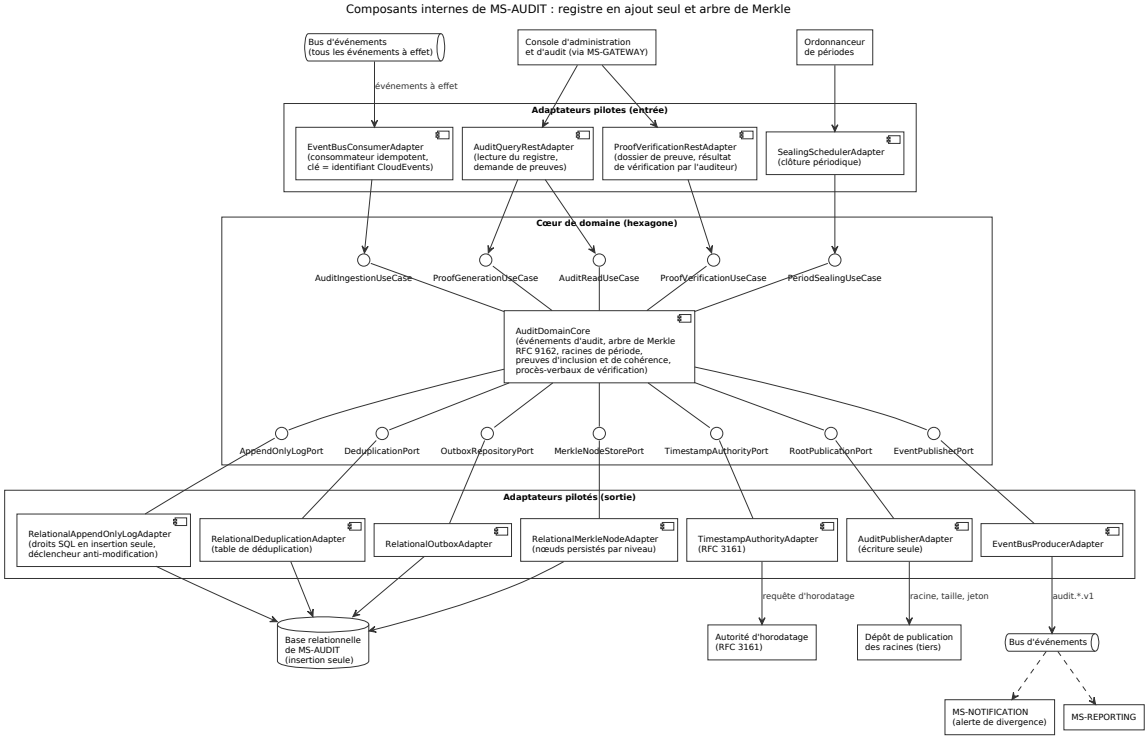


FIGURE 6.7: *Diagramme de composants internes : registre d'audit et arbre de Merkle*

- **Adaptateurs pilotes (entrée) :** `EventBusConsumerAdapter` (abonnement à tous les sujets `*.v1`, consommation idempotente par identifiant CloudEvents) ; `AuditQueryRestAdapter` (lecture du registre et des racines, demande de preuves d'inclusion et de cohérence) ; `ProofVerificationRestAdapter` (constitution du dossier de preuve, enregistrement du résultat de la vérification par l'auditeur) ; `SealingSchedulerAdapter` (clôture périodique).
- **Cœur de domaine :** `AuditDomainCore` expose `AuditIngestionUseCase`, `AuditReadUseCase`, `ProofGenerationUseCase`, `ProofVerificationUseCase` et `PeriodSealingUseCase`, et requiert sept ports secondaires.
- **Adaptateurs pilotés (sortie) :** `RelationalAppendOnlyLogAdapter` (insertion

seule, déclencheur anti-modification) ; `RelationalDeduplicationAdapter` (table de déduplication) ; `RelationalMerkleNodeAdapter` (nœuds persistés par niveau et position) ; `TimestampAuthorityAdapter` (RFC 3161) ; `AuditPublisherAdapter` (écriture seule vers le dépôt de publication) ; `RelationalOutboxAdapter` et `EventBusProducerAdapter` (événements `audit.*.v1`).

- **Interactions :** tous les services en producteurs d'événements à effet ; `MS-GATEWAY` en relais de la console d'administration et d'audit ; `MS-REPORTING` et `MS-NOTIFICATION` en consommateurs de `audit.root-published.v1` et `audit.verification-recorded.v1` ; l'autorité d'horodatage et le dépôt de publication des racines en applications tierces.

6.1.3.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.8 détaille les classes du domaine, les ports et les adaptateurs. Les entités d'analyse *Événement d'audit*, *Racine de période* et *Preuve d'inclusion* y sont reprises avec leurs types et leurs signatures ; les nœuds de l'arbre, la preuve de cohérence, le jeton d'horodatage, l'entrée de déduplication et le procès-verbal de vérification les complètent.

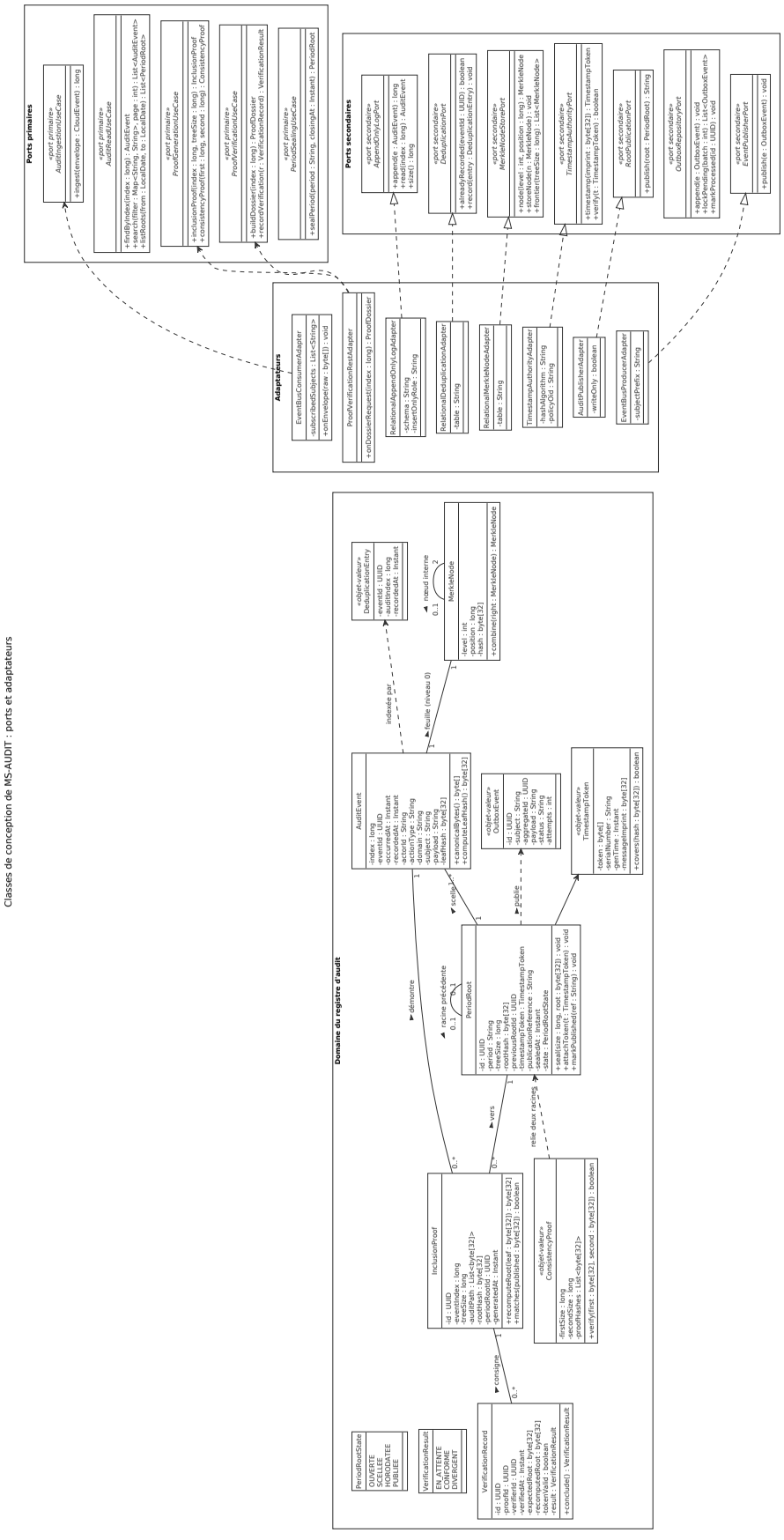


FIGURE 6.8: *Diagramme de classes de conception : service MS-AUDIT*

- **Entités :** `AuditEvent` (`index : long`, `eventId : UUID`, `occurredAt`, `recordedAt : Instant`, `actorId`, `actionType`, `domain`, `subject`, `payload : String`, `leafHash : byte[32]`) ; `MerkleNode` (`level : int`, `position : long`, `hash : byte[32]`) ; `PeriodRoot` (`period : String`, `treeSize : long`, `rootHash : byte[32]`, `previousRootId : UUID`, `timestampToken`, `publicationReference : String`, `state : PeriodRootState`) ; `InclusionProof` (`eventIndex`, `treeSize : long`, `auditPath : List<byte[32]>`, `rootHash : byte[32]`) ; `VerificationRecord` (`verifierId : UUID`, `expectedRoot`, `recomputedRoot : byte[32]`, `tokenValid : boolean`, `result : VerificationResult`).

- **Objets-valeurs :** `ConsistencyProof` (`firstSize`, `secondSize : long`, `proofHashes : List<byte[32]>`, méthode `verify`) ; `TimestampToken` (`token : byte[]`, `serialNumber`, `genTime : Instant`, `messageImprint : byte[32]`) ; `DeduplicationEntry` (`eventId : UUID`, `auditIndex : long`) ; `OutboxEvent`.

- **Énumérations :** `PeriodRootState` (`OUVERTE`, `SCELLEE`, `HORODATEE`, `PUBLIEE`) ; `VerificationResult` (`EN_ATTENTE`, `CONFORME`, `DIVERGENT`).

- **Ports primaires :** `AuditIngestionUseCase` (`ingest`) ; `AuditReadUseCase` (`findByIndex`, `search`, `listRoots`) ; `ProofGenerationUseCase` (`inclusionProof`, `consistencyProof`) ; `ProofVerificationUseCase` (`buildDossier`, `recordVerification`) ; `PeriodSealingUseCase` (`sealPeriod`).

- **Ports secondaires :** `AppendOnlyLogPort` (`append`, `read`, `size`, sans méthode de mise à jour ni de suppression), `DeduplicationPort`, `MerkleNodeStorePort` (`node`, `storeNode`, `frontier`), `TimestampAuthorityPort` (`timestamp`, `verify`), `RootPublicationPort` (`publish`, écriture seule), `OutboxRepositoryPort`, `EventPublisherPort`.

- **Adaptateurs :** `EventBusConsumerAdapter` et `ProofVerificationRestAdapter` pilotent les ports primaires ; `RelationalAppendOnlyLogAdapter`, `RelationalDeduplicationAdapter`, `RelationalMerkleNodeAdapter`, `TimestampAuthorityAdapter`, `AuditPublisherAdapter` et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.3.4 Diagramme d'objets du service MS-AUDIT

La Figure 6.9 capture la matinée qui suit le scellement de la période de la veille : la clôture d'une opération d'homologation, publiée peu avant minuit, a été inscrite comme feuille d'index 184 212 ; la racine de la période a été calculée sur 184 213 feuilles, horodatée et publiée ; un auditeur interne a demandé la preuve d'inclusion de cette clôture ainsi que la preuve de cohérence avec la période précédente, a recalculé la racine hors plateforme et vient de consigner un résultat conforme.

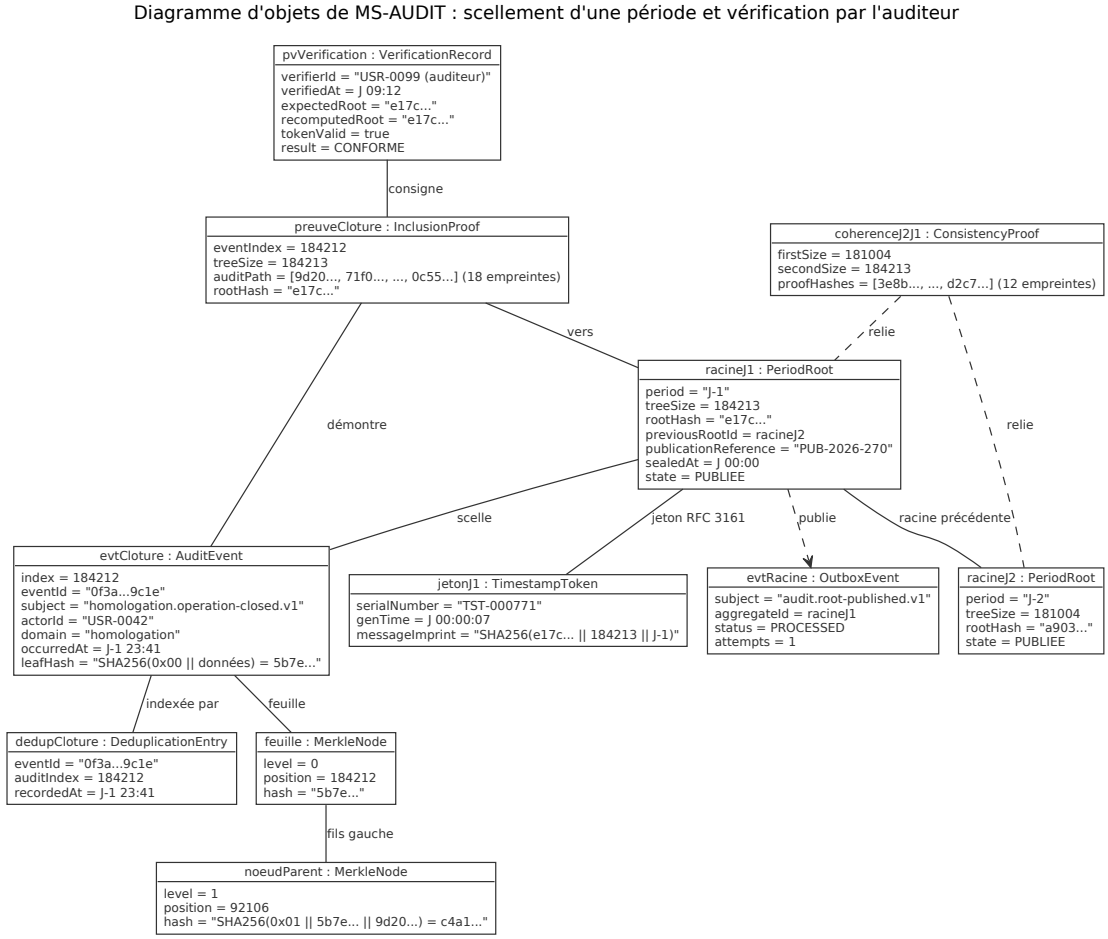


FIGURE 6.9: *Diagramme d'objets : scellement d'une période et vérification par l'auditeur*

- `evtCloture : AuditEvent`, index 184 212, sujet `homologation.operation-closed.v1`, acteur `USR-0042`, domaine homologation, empreinte de feuille calculée avec le préfixe `0x00` ;
- `dedupCloture : DeduplicationEntry`, même identifiant CloudEvents, pointant vers l'index 184 212 : toute relivraison de l'événement est absorbée ;
- `feuille : MerkleNode` (niveau 0, position 184 212) et `noeudParent : MerkleNode` (niveau 1, position 92 106), dont l'empreinte combine les deux fils avec le

préfixe `0x01` ;

- `racineJ1 : PeriodRoot`, période J-1, taille 184 213, état `PUBLIEE`, référence de publication `PUB-2026-270`, liée à `racineJ2 : PeriodRoot` (période J-2, taille 181 004) ;
- `jetonJ1 : TimestampToken`, numéro de série `TST-000771`, généré sept secondes après minuit, couvrant l'empreinte de la racine, de la taille et de la période ;
- `preuveCloture : InclusionProof`, chemin d'audit de dix-huit empreintes (borne $\lceil \log_2 184\,213 \rceil = 18$), racine attendue `e17c...` ;
- `coherenceJ2J1 : ConsistencyProof`, entre les tailles 181 004 et 184 213, douze empreintes ;
- `pvVerification : VerificationRecord`, vérificateur `USR-0099`, racine recalculée égale à la racine publiée, jeton valide, résultat `CONFORME` ;
- `evtRacine : OutboxEvent`, sujet `audit.root-published.v1`, publié et acquitté.

6.1.3.5 Algorithmes fondamentaux de MS-AUDIT

Cette section formalise les cinq algorithmes qui régissent l'inscription idempotente d'une feuille et la mise à jour incrémentale de l'arbre, la production d'une preuve d'inclusion, la production d'une preuve de cohérence entre deux racines, le scellement d'une période avec horodatage et publication, et la vérification conduite par l'auditeur.

Algorithme 6.12 : Inscription idempotente d'une feuille et mise à jour incrémentale de l'arbre Cet algorithme traite chaque événement livré par le bus : il écarte les doublons, calcule l'empreinte de feuille avec séparation de domaine et met à jour l'arbre sans le recalculer, en ne conservant que la frontière des sous-arbres complets. Le tout est exécuté dans une transaction unique de la base relationnelle, en insertion seule.

Spécification formelle de l'algorithme 6.12 : inscription d'une feuille	
Entrées	Enveloppe CloudEvents E (identifiant *id*, sujet, source, horodatage, charge utile) ; taille courante n de l'arbre.
Sorties	Événement d'audit d'index n ; nœuds insérés ; entrée de déduplication ; nouvelle taille $n+1$; acquittement au bus.
Complexité	$\mathcal{O}(1)$ amorti par feuille, $\mathcal{O}(\log n)$ au pire ; une transaction, aucune lecture globale.
Standard	RFC 9162 (section 2.1.1, empreintes de feuille et de nœud) ; RFC 8259 (forme canonique) ; enveloppe CloudEvents.

TABLE 6.13: *Fiche de spécification : inscription d'une feuille et mise à jour incrémentale*

Déroulement procédural étape par étape :

1. **Déduplication :** ouvrir la transaction ; si `DeduplicationPort` signale *id* comme déjà inscrit (`alreadyRecorded`), valider la transaction vide et acquitter le message : l'événement a déjà été inscrit. Sinon, insérer l'entrée de déduplication, dont la contrainte d'unicité sur *id* protège contre deux consommateurs concurrents.

2. **Forme canonique et empreinte de feuille :** sérialiser E sous forme canonique (clés triées, encodage UTF-8, sans espace superflu) puis calculer :

$$h_0 = \mathrm{SHA256}\big(0x00 \parallel \mathrm{canon}(E)\big) \tag{6.15}$$

3. **Inscription de l'événement :** construire `AuditEvent` d'index n avec l'acteur, le type d'action et le domaine extraits de l'enveloppe, l'horodatage d'occurrence fourni par le producteur et l'horodatage d'inscription courant ; l'insérer par `AppendOnlyLogPort.append`, qui ne dispose d'aucune instruction de mise à jour.

4. **Mise à jour incrémentale :** insérer la feuille $(0, n, h_0)$ puis, tant que la position courante p est impaire au niveau ℓ, lire le frère gauche $(\ell, p-1)$ et insérer le parent :

$$h_{\ell+1} = \mathrm{SHA256}\big(0x01 \parallel h_\ell^{\text{gauche}} \parallel h_\ell\big), \qquad p \leftarrow \lfloor p/2 \rfloor,\ \ell \leftarrow \ell+1 \tag{6.16}$$

   Seuls les sous-arbres complets sont matérialisés ; la racine d'un arbre de taille quelconque se calcule à la demande à partir de la frontière (algorithme 6.15). Le nombre de nœuds insérés pour la feuille n est le nombre de bits de poids faible à 1 de $n+1$: deux en moyenne, $\log_2 n$ au pire.

5. **Validation et acquittement :** valider la transaction ; acquitter le message au bus seulement après validation. Une panne entre les deux entraîne une relivraison, absorbée à l'étape

1. Toute erreur d'insertion (dont le rejet par le déclencheur anti-modification) annule l'ensemble et laisse le message en attente.

6. **Événements dérivés :** si l'événement reçu est un procès-verbal de vérification divergent ou un échec de scellement, insérer dans l'outbox une demande de notification critique (`audit.notification-requested.v1`) à destination du RSSI.

Algorithme 6.13 : Production d'une preuve d'inclusion (chemin d'audit) Cet algorithme assemble, pour un événement d'index m et une taille d'arbre n, la liste des empreintes frères nécessaires pour recalculer la racine $\mathrm{MTH}(D[n])$ à partir de la seule feuille. Le vérificateur n'a besoin ni du registre ni de la confiance dans la plateforme : la preuve est autoportante.

Spécification formelle de l'algorithme 6.13 : preuve d'inclusion	
Entrées	Index m de l'événement ; taille $n > m$ de l'arbre (taille scellée d'une période, de préférence).
Sorties	`InclusionProof` : chemin d'audit $\mathrm{PATH}(m, D[n])$, racine attendue, racine de période associée.
Complexité	$\mathcal{O}(\log n)$ lectures de nœuds ; longueur du chemin au plus $\lceil \log_2 n \rceil$.
Standard	RFC 9162, section 2.1.3 (preuves d'inclusion) ; feuille avec préfixe `0x00`, nœuds avec préfixe `0x01`.

TABLE 6.14: *Fiche de spécification : preuve d'inclusion*

Déroulement procédural étape par étape :

1. **Contrôle des bornes :** vérifier $0 \le m < n \le$ `AppendOnlyLogPort.size()` ; si n correspond à une racine de période scellée, l'attacher à la preuve, ce qui permet au vérificateur de comparer la racine recalculée à une racine publiée et horodatée.

2. **Définition récursive du chemin :** appliquer la définition de la RFC 9162 sur l'intervalle $D[n]$, avec k la plus grande puissance de deux strictement inférieure à n :

$$\mathrm{PATH}(m, D[n]) = \begin{cases} \mathrm{PATH}(m, D[0:k]) \parallel \mathrm{MTH}(D[k:n]) & \text{si } m < k \\ \mathrm{PATH}(m-k, D[k:n]) \parallel \mathrm{MTH}(D[0:k]) & \text{si } m \ge k \end{cases} \tag{6.17}$$

   avec $\mathrm{PATH}(0, \{e\}) = \{\}$.

3. **Résolution des empreintes :** chaque terme $\mathrm{MTH}(D[a:b])$ dont l'intervalle est un sous-arbre complet est lu directement dans `MerkleNodeStorePort` ; un intervalle

incomplet (bord droit de l'arbre) est recalculé à partir de sa frontière, sans jamais relire de feuille.

4. **Assemblage :** constituer `InclusionProof` avec m, n, le chemin ordonné du bas vers le haut et la racine $\mathrm{MTH}(D[n])$; la preuve est un objet dérivé, recalculable à l'identique, et n'est pas inscrite dans le registre.

5. **Recalcul côté vérificateur :** le vérificateur part de $h = \mathrm{SHA256}(0x00 \parallel \mathrm{canon}(e_m))$ puis, pour chaque empreinte s du chemin, en suivant les bits de m du poids faible au poids fort, calcule $h \leftarrow \mathrm{SHA256}(0x01 \parallel s \parallel h)$ si e_m est dans le sous-arbre droit, et $h \leftarrow \mathrm{SHA256}(0x01 \parallel h \parallel s)$ sinon ; il compare h à la racine publiée.

Algorithme 6.14 : Preuve de cohérence entre deux racines Cet algorithme démontre que l'arbre de taille n prolonge l'arbre de taille $m < n$ sans qu'aucune feuille de $D[m]$ ait été modifiée, réordonnée ou retirée. Il est calculé à chaque scellement entre la période précédente et la nouvelle, et à la demande d'un auditeur entre deux racines publiées quelconques.

Spécification formelle de l'algorithme 6.14 : preuve de cohérence	
Entrées	Tailles m et n avec $0 < m < n$; racines publiées R_m et R_n fournies par le vérificateur.
Sorties	`ConsistencyProof` : liste $\mathrm{PROOF}(m, D[n])$; résultat VRAI ou FAUX à la vérification.
Complexité	$\mathcal{O}(\log n)$ lectures de nœuds ; preuve de longueur au plus $\lceil \log_2 n \rceil + 1$.
Standard	RFC 9162, section 2.1.4 (preuves de cohérence).

TABLE 6.15: *Fiche de spécification : preuve de cohérence*

Déroulement procédural étape par étape :

1. **Cas trivial :** si $m = n$, la preuve est vide et les racines doivent être égales. Sinon, poser $\mathrm{PROOF}(m, D[n]) = \mathrm{SP}(m, D[n], \text{vrai})$, où SP désigne la sous-preuve.

2. **Sous-preuve récursive :** avec k la plus grande puissance de deux strictement inférieure à n et b le drapeau indiquant que le sous-arbre courant est entièrement contenu dans $D[m]$:

$$\mathrm{SP}(m, D[n], b) = \begin{cases} \{\} & \text{si } m = n,\ b \\ \{\mathrm{MTH}(D[n])\} & \text{si } m = n,\ \neg b \\ \mathrm{SP}(m, D[0:k], b) \parallel \mathrm{MTH}(D[k:n]) & \text{si } m \leq k \\ \mathrm{SP}(m-k, D[k:n], \text{faux}) \parallel \mathrm{MTH}(D[0:k]) & \text{si } m > k \end{cases} \tag{6.18}$$

3. **Résolution :** comme pour l'inclusion, chaque MTH de sous-arbre complet est lu dans le magasin de nœuds ; les bords droits sont recalculés depuis la frontière.

4. **Vérification :** le vérificateur reconstruit deux valeurs à partir de la preuve : la racine R'_m de l'ancien arbre, obtenue en combinant les empreintes qui appartiennent à $D[m]$, et la racine R'_n du nouvel arbre, obtenue en combinant toutes les empreintes ; il retourne VRAI si et seulement si $R'_m = R_m$ et $R'_n = R_n$.

5. **Conservation :** la preuve calculée au scellement est conservée avec la racine de période nouvelle ; toute preuve demandée par un auditeur est jointe au dossier de preuve, et le résultat de sa vérification est consigné (algorithme 6.16).

Algorithme 6.15 : Scellement d'une période, horodatage et publication de la racine Cet algorithme clôt une période, calcule la racine sur la taille figée, obtient un jeton d'horodatage de l'autorité tierce, publie la racine dans le dépôt externe par un adaptateur en écriture seule et diffuse l'événement de publication. Il est idempotent : une relance après panne reprend à l'étape non encore franchie.

Spécification formelle de l'algorithme 6.15 : scellement de période	
Entrées	Identifiant de période p ; instant de clôture t_p ; racine de la période précédente R_{p-1} de taille n_{p-1}.
Sorties	`PeriodRoot` à l'état `PUBLIEE` (taille n_p, racine R_p, jeton, référence) ; preuve de cohérence (n_{p-1}, n_p) ; événement `audit.root-published.v1`.
Complexité	$\mathcal{O}(\log n_p)$ pour la racine depuis la frontière ; deux appels réseau (autorité d'horodatage, dépôt de publication).
Standard	RFC 9162 (racine) ; RFC 3161 (jeton) ; RFC 5280 (chaîne de l'autorité) ; enveloppe CloudEvents.

TABLE 6.16: *Fiche de spécification : scellement de période*

Déroulement procédural étape par étape :

1. **Fixation de la taille :** à t_p, lire $n_p =$ `AppendOnlyLogPort.size()` dans une transaction qui insère `PeriodRoot`(p, n_p) à l'état `OUVERTE` ; les feuilles d'index $\geq n_p$ appartiennent à la période suivante, même si leur inscription est concurrente.

2. **Racine depuis la frontière :** lire `MerkleNodeStorePort.frontier`(n_p), c'est-à-dire les racines des sous-arbres complets correspondant aux bits à 1 de n_p, ordonnées du

plus grand au plus petit, puis les replier de droite à gauche :

$$R_p = \mathrm{fold}\big(f_1, \ldots, f_j\big), \qquad \mathrm{fold}(f_1, \ldots, f_j) = \mathrm{SHA256}\big(0x01 \parallel f_1 \parallel \mathrm{fold}(f_2, \ldots, f_j)\big) \tag{6.19}$$

avec $\mathrm{fold}(f_j) = f_j$. Le résultat est identique à $\mathrm{MTH}(D[n_p])$. Passer l'état à `SCELLEE` et insérer la preuve de cohérence (n_{p-1}, n_p) (algorithme 6.14).

3. **Horodatage :** calculer l'empreinte $\iota = \mathrm{SHA256}(R_p \parallel n_p \parallel p)$ et l'envoyer à `TimestampAuthorityPort.timestamp`(ι) ; vérifier que le jeton retourné couvre ι, que sa signature est valide et que sa chaîne de certification remonte à l'ancre de confiance configurée ; conserver le jeton et passer l'état à `HORODATEE`. En cas d'indisponibilité de l'autorité, réessayer avec retard exponentiel (borne : une heure) ; au-delà, insérer une demande de notification urgente au chef du DES sans bloquer les inscriptions.

4. **Publication externe :** appeler `RootPublicationPort.publish` avec $(p, n_p, R_p, \text{jeton})$; l'adaptateur ne dispose que du droit d'écriture sur le dépôt de publication des racines ; conserver la référence retournée et passer l'état à `PUBLIEE`.

5. **Diffusion :** insérer `audit.root-published.v1` dans l'outbox avec p, n_p, R_p, le numéro de série du jeton et la référence de publication ; cet événement est consommé par `MS-REPORTING` et, comme tout événement à effet, réinscrit comme feuille de la période suivante, ce qui chaîne les périodes à l'intérieur même de l'arbre.

6. **Reprise :** au redémarrage, tout `PeriodRoot` qui n'est pas à l'état `PUBLIEE` est repris à l'étape correspondant à son état ; une racine jamais recalculée pour une taille donnée produit toujours la même valeur, ce qui rend la reprise sans effet de bord.

Algorithme 6.16 : Vérification d'intégrité par l'auditeur et consignation du résultat Cet algorithme outille le cas d'utilisation de contrôle de la piste d'audit décrit dans le cahier d'analyse : l'auditeur reçoit un dossier de preuve, recalcule hors plateforme, puis consigne son résultat, lui-même inscrit dans le registre. La plateforme fournit les éléments mais ne se substitue pas au vérificateur.

Spécification formelle de l'algorithme 6.16 : vérification par l'auditeur	
Entrées	Index m sélectionné ; identité du vérificateur (niveau 5) ; racine publiée R_{pub} et jeton lus par l'auditeur dans le dépôt de publication.
Sorties	Dossier de preuve ; `VerificationRecord` au résultat `CONFORME` ou `DIVERGENT` ; événement `audit.verification-recorded.v1`.
Complexité	$\mathcal{O}(\log n)$ pour le dossier ; recalcul de $\mathcal{O}(\log n)$ empreintes côté auditeur.
Contrôles	Permission de niveau 5 ; jeton RFC 3161 vérifié selon la RFC 5280 ; comparaison en temps constant des racines.

TABLE 6.17: *Fiche de spécification : vérification par l'auditeur*

Déroulement procédural étape par étape :

1. **Constitution du dossier :** sur demande depuis la console d'administration et d'audit, lire l'événement e_m, produire `InclusionProof`(m, n_p) vers la racine de la période qui contient m (algorithme 6.13), joindre R_p, le jeton d'horodatage, la référence de publication et, si demandé, la preuve de cohérence avec une période antérieure (algorithme 6.14). Le dossier est restitué sous une forme autoportante et sa restitution est elle-même un événement à effet.

2. **Recalcul hors plateforme :** l'auditeur recalcule $h = \text{SHA256}(0x00 \parallel \text{canon}(e_m))$, replie le chemin d'audit et obtient R' ; il lit R_{pub} et le jeton directement dans le dépôt de publication des racines, sans passer par la plateforme.

3. **Vérification du jeton :** contrôler que le jeton couvre $\text{SHA256}(R_{\text{pub}} \parallel n_p \parallel p)$, que sa signature est valide, que le certificat de l'autorité d'horodatage est dans sa période de validité et non révoqué, et que l'instant de génération est postérieur à l'horodatage d'inscription de e_m.

4. **Consignation :** l'auditeur saisit son résultat ; le service construit `VerificationRecord` avec R_p attendue, R' recalculée, la validité du jeton et le résultat :

$$\text{result} = \begin{cases} \texttt{CONFORME} & \text{si } R' = R_p = R_{\text{pub}} \text{ et jeton valide} \\ \texttt{DIVERGENT} & \text{sinon} \end{cases} \tag{6.20}$$

   et insère `audit.verification-recorded.v1` dans l'outbox ; le procès-verbal devient une feuille de l'arbre (algorithme 6.12).

5. **Divergence :** si le résultat est `DIVERGENT`, appeler le port synchrone de `MS-NOTIFICATION` pour une notification critique au RSSI et au chef du DES, avec

acquittement obligatoire et escalade ; la plateforme n'entreprend aucune correction du registre, qui n'en admet aucune : le constat est instruit comme incident de sécurité dans `MS-INCIDENT`.

6.1.4 Gestion électronique des documents probants (MS-DOCUMENT)

Le service `MS-DOCUMENT` est la gestion électronique des documents (GED) de la plateforme intégrée du Département Exploitation et Supervision (DES). Il reçoit les pièces probantes, qu'elles soient produites par les services (rapport de quart de `MS-MONITORING`, attestation de `MS-CERTIFICATION`, archive de crise de `MS-COLLABORATION`, rapport périodique de `MS-REPORTING`) ou déposées par un utilisateur (pièce légale d'une institution depuis le portail des participants, preuve d'une opération d'homologation depuis l'application du département), les soumet à une chaîne de contrôle (analyse antivirale, contrôle de masquage des données de carte, empreinte SHA-256, classification), les dépose dans le dépôt objet WORM sous verrou de rétention en mode conformité, en conserve les métadonnées dans sa base relationnelle, journalise chaque consultation et restitue chaque pièce sous contrôle de permission et d'institution. Chaque version est un objet distinct : rien n'est jamais écrasé. Le service ne produit aucun document lui-même, ne signe rien (la signature d'une attestation relève de `MS-CERTIFICATION`) et n'interprète pas le contenu des pièces au-delà des contrôles de sécurité ; il ne détient aucune donnée de carte, une pièce qui en contiendrait étant rejetée ou masquée avant tout dépôt.

6.1.4.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : COBAC, PCI-DSS v4.0.1, ISO/IEC 27001 et ISO 19005-3

- **Règlements COBAC R-2016/04 et R-2024/01 :** les pièces qui fondent une décision de supervision, une mise en service ou une passation de responsabilité doivent être conservées de façon intègre et restituables à l'autorité de supervision pendant la durée légale. La rétention par défaut est de dix ans, en mode conformité, sans possibilité de raccourcissement, même par un administrateur.
- **PCI-DSS v4.0.1, exigence 3 :** aucune donnée de carte en clair ne doit être stockée hors des systèmes du périmètre monétique. La plateforme n'appartient pas à ce périmètre : le contrôle de masquage au dépôt (formule de Luhn sur toute séquence de treize à dix-neuf chiffres, à l'image de l'algorithme 6.3 appliqué par `MS-GATEWAY` aux charges utiles) rejette ou masque toute pièce contenant un numéro de carte plausible.
- **PCI-DSS v4.0.1, exigence 5 :** tout contenu entrant est analysé par l'antivirus de la plateforme avant d'être rendu accessible ; une détection place la pièce en quarantaine, hors de tout accès, et déclenche une notification au RSSI.

- **ISO/IEC 27001 :** la classification de l'information, la protection des enregistrements et la journalisation des accès sont des mesures attendues ; chaque pièce porte un type, une politique de rétention et un périmètre de visibilité, et chaque consultation est inscrite dans un journal en insertion seule.
- **ISO 19005-3 (PDF/A-3) :** les documents générés par les services (rapports, attestations) sont attendus au format d'archivage PDF/A-3 ; `MS-DOCUMENT` vérifie la déclaration de conformité du fichier sans en modifier le contenu.

Chaîne de contrôle au dépôt Toute pièce, quelle que soit son origine, suit la même chaîne avant d'être scellée : réception en flux avec limite de taille ; analyse antivirale en flux (quarantaine et rejet du dépôt en cas de détection) ; contrôle de masquage des données de carte sur le texte extractible (rejet pour les pièces produites par les services, qui ne doivent jamais en contenir, masquage avec journalisation pour les pièces déposées par un utilisateur lorsque le type de pièce l'autorise) ; calcul de l'empreinte SHA-256 sur le contenu tel qu'il sera déposé ; classification (type de pièce, politique de rétention associée, mode de rétention conformité) ; dépôt dans le dépôt objet WORM sous une clé propre à la version, avec verrou de rétention en mode conformité jusqu'à l'échéance ; inscription des métadonnées ; publication de `document.document-sealed.v1`, consommé par `MS-AUDIT`, qui inscrit le dépôt (référence, empreinte, déposant) comme feuille de l'arbre de Merkle. La référence de document renvoyée au service appelant (identifiant, lignée, version, empreinte) est la seule chose que les autres services conservent : ils ne stockent jamais le contenu. Le tableau 6.18 fixe, pour chaque type de pièce, son origine, la règle de masquage applicable et la rétention associée.

Type de pièce	Origine (appelant)	Masquage	Rétention
Rapport de quart	`MS-MONITORING`, généré et visé	rejet	10 ans, conformité
Attestation	`MS-CERTIFICATION`, signée PAdES, PDF/A-3	rejet	10 ans, conformité
Archive de crise	`MS-COLLABORATION`, scellée	rejet	10 ans, conformité
Rapport périodique	`MS-REPORTING`, généré et signé	rejet	10 ans, conformité
Procès-verbal	`MS-PILOTAGE`, comités	rejet	10 ans, conformité
Preuve d'homologation	ingénieur d'homologation, application du département	masquage	10 ans, conformité
Pièce légale	représentant d'un participant, portail	masquage	10 ans, conformité
État importé	`MS-RAPPROCHEMENT`, fichiers déposés	masquage	5 ans, conformité

TABLE 6.18: *Types de pièces, origine, règle de masquage et rétention*

Versionnage sans écrasement et lignées

- **Lignée :** une lignée regroupe les versions successives d'une même pièce logique (le rapport de quart d'une vacation, la pièce légale d'une institution). Chaque version est un document distinct, avec son propre objet dans le dépôt WORM, sa propre empreinte et son propre verrou ; la version précédente passe à l'état `REMPLACE` mais reste lisible et restituable, avec son journal de consultation.
- **Version courante :** la lignée porte le numéro et l'identifiant de la version courante ; sa résolution est déterministe et ne dépend d'aucun ordre d'écriture concurrent (verrou de lignée lors de l'attribution du numéro de version).
- **Immutabilité :** aucune opération ne permet de réécrire l'objet d'une version ; une correction est une version nouvelle. Les métadonnées modifiables se limitent à l'état et à la levée éventuelle d'une conservation légale.

Restitution contrôlée, journal de consultation et cloisonnement par institution

- **Permission et périmètre :** toute lecture exige la permission de consultation du type de pièce, portée par le jeton interne réduit forgé par `MS-GATEWAY` ; le périmètre de visibilité (toutes institutions, une institution, un service) y est joint. Un représentant d'un participant, depuis le portail, ne voit que les pièces de son institution : la condition est appliquée dans le domaine et projetée en politique de lignes dans la base relationnelle, de sorte qu'une requête mal formée ne puisse pas la contourner.
- **Journal de consultation :** chaque lecture, téléchargement ou consultation de la liste des versions est inscrit (document, utilisateur, institution, action, canal, instant, identifiant de corrélation) dans un journal en insertion seule, puis publié (`document.document-consulted.v1`) et scellé dans `MS-AUDIT`. La restitution n'a lieu qu'après l'inscription.
- **Restitution :** le contenu est servi en flux depuis le dépôt objet, sans copie intermédiaire, avec l'empreinte attendue en en-tête, ce qui permet à la couche de présentation de vérifier l'intégrité du transfert.

Rétention, purge à quatre yeux et vérification d'intégrité

- **Verrou de rétention en mode conformité :** le dépôt objet WORM refuse toute suppression ou réécriture d'un objet verrouillé avant l'échéance, y compris par son administrateur ; l'échéance est calculée à partir de la date de dépôt et de la durée de la politique. Une conservation légale (litige, inspection) suspend l'échéance sans limite de durée.

- **Purge :** à l'échéance, la suppression n'est jamais automatique : elle exige une demande motivée par un responsable et une approbation par un second responsable distinct (chef du DES et RSSI, ou responsable conformité), enregistrées, publiées et scellées ; le service ne supprime alors que l'objet, les métadonnées et le journal de consultation étant conservés avec l'état `PURGE`.
- **Vérification d'intégrité périodique :** chaque nuit, un échantillon de documents est relu depuis le dépôt objet, leur empreinte recalculée et comparée à l'empreinte enregistrée ; toute divergence ou tout objet illisible déclenche une notification critique au RSSI et l'ouverture d'un incident de sécurité dans `MS-INCIDENT`.

6.1.4.2 Diagramme de composants internes de MS-DOCUMENT

La Figure 6.10 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les dépôts et consultations des utilisateurs (via `MS-GATEWAY`), les dépôts et lectures synchrones des services, les procédures de purge et l'impulsion de l'ordonnanceur ; le cœur porte les deux entités d'analyse du domaine 1 (document, consultation) et les objets qui les complètent ; les adaptateurs pilotés dialoguent avec l'antivirus de la plateforme, le dépôt objet WORM, la base relationnelle du service et le bus d'événements.

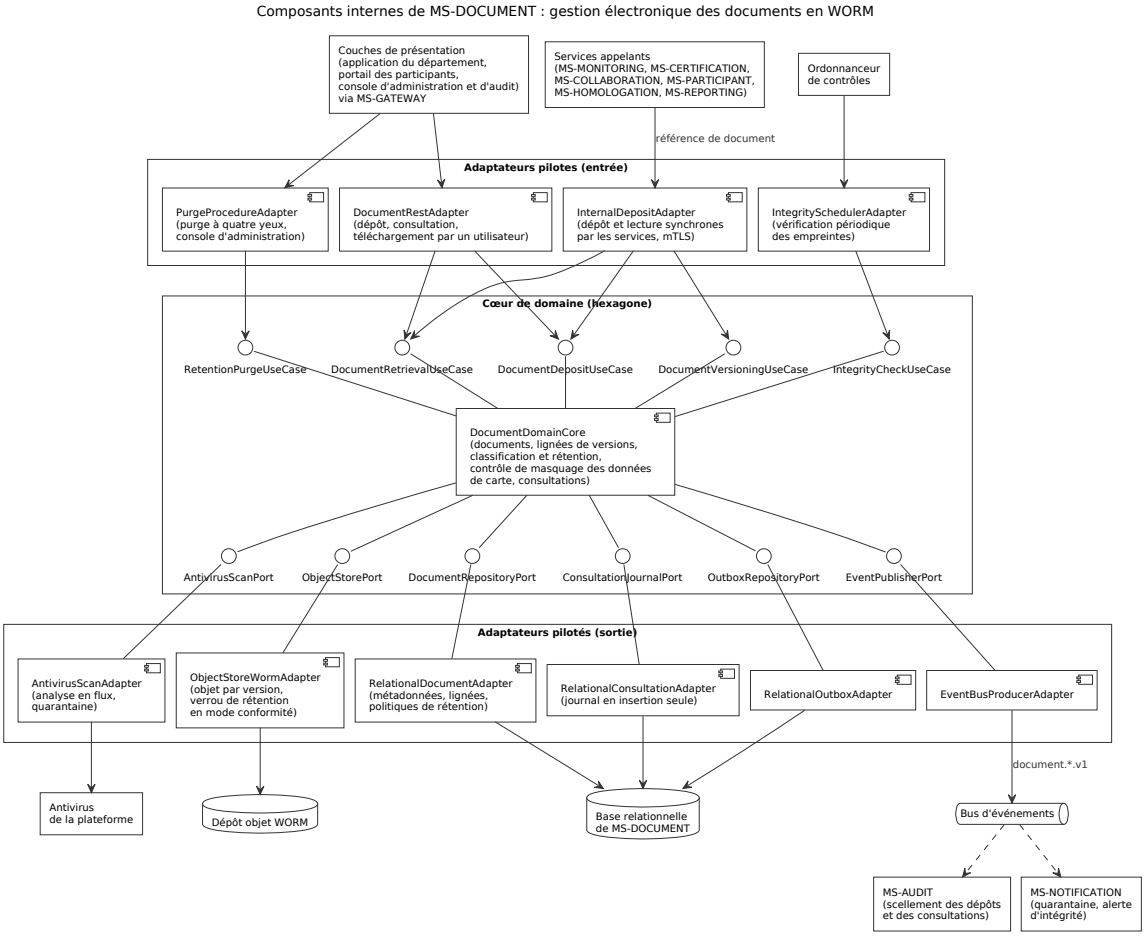


FIGURE 6.10: *Diagramme de composants internes : gestion électronique des documents en WORM*

- **Adaptateurs pilotes (entrée) :** `DocumentRestAdapter` (dépôt, consultation et téléchargement par un utilisateur des trois couches de présentation) ; `InternalDepositAdapter` (dépôt, versionnage et lecture synchrones par les services, sous mTLS, avec liste des appelants autorisés) ; `PurgeProcedureAdapter` (demande et approbation de purge depuis la console d'administration et d'audit) ; `IntegritySchedulerAdapter` (vérification périodique).

- **Cœur de domaine :** `DocumentDomainCore` expose `DocumentDepositUseCase`, `DocumentRetrievalUseCase`, `DocumentVersioningUseCase`, `RetentionPurgeUseCase` et `IntegrityCheckUseCase`, et requiert six ports secondaires ; le contrôle de masquage des données de carte est un service de domaine interne au cœur, sans dépendance externe.

- **Adaptateurs pilotés (sortie) :** `AntivirusScanAdapter` (analyse en flux, mise en quarantaine) ; `ObjectStoreWormAdapter` (un objet par version, verrou de rétention en mode conformité) ; `RelationalDocumentAdapter` (métadonnées, lignées, politiques de rétention, demandes de purge) ;

`RelationalConsultationAdapter` (journal en insertion seule) ; `RelationalOutboxAdapter` et `EventBusProducerAdapter` (événements `document.*.v1`).

- **Interactions :** `MS-MONITORING`, `MS-CERTIFICATION`, `MS-COLLABORATION`, `MS-PARTICIPANT`, `MS-HOMOLOGATION` et `MS-REPORTING` en appelants synchrones, qui ne conservent que la référence de document ; `MS-AUDIT` en consommateur de tous les événements `document.*.v1` ; `MS-NOTIFICATION` pour les quarantaines et les alertes d'intégrité ; `MS-GATEWAY` en relais des couches de présentation.

6.1.4.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.11 détaille les classes du domaine, les ports et les adaptateurs. Les entités d'analyse *Document* et *Consultation* y sont reprises avec leurs types et leurs signatures ; la lignée de versions, la politique et le verrou de rétention, la référence de document, les verdicts d'analyse et de masquage, la demande de purge et le contrôle d'intégrité les complètent.

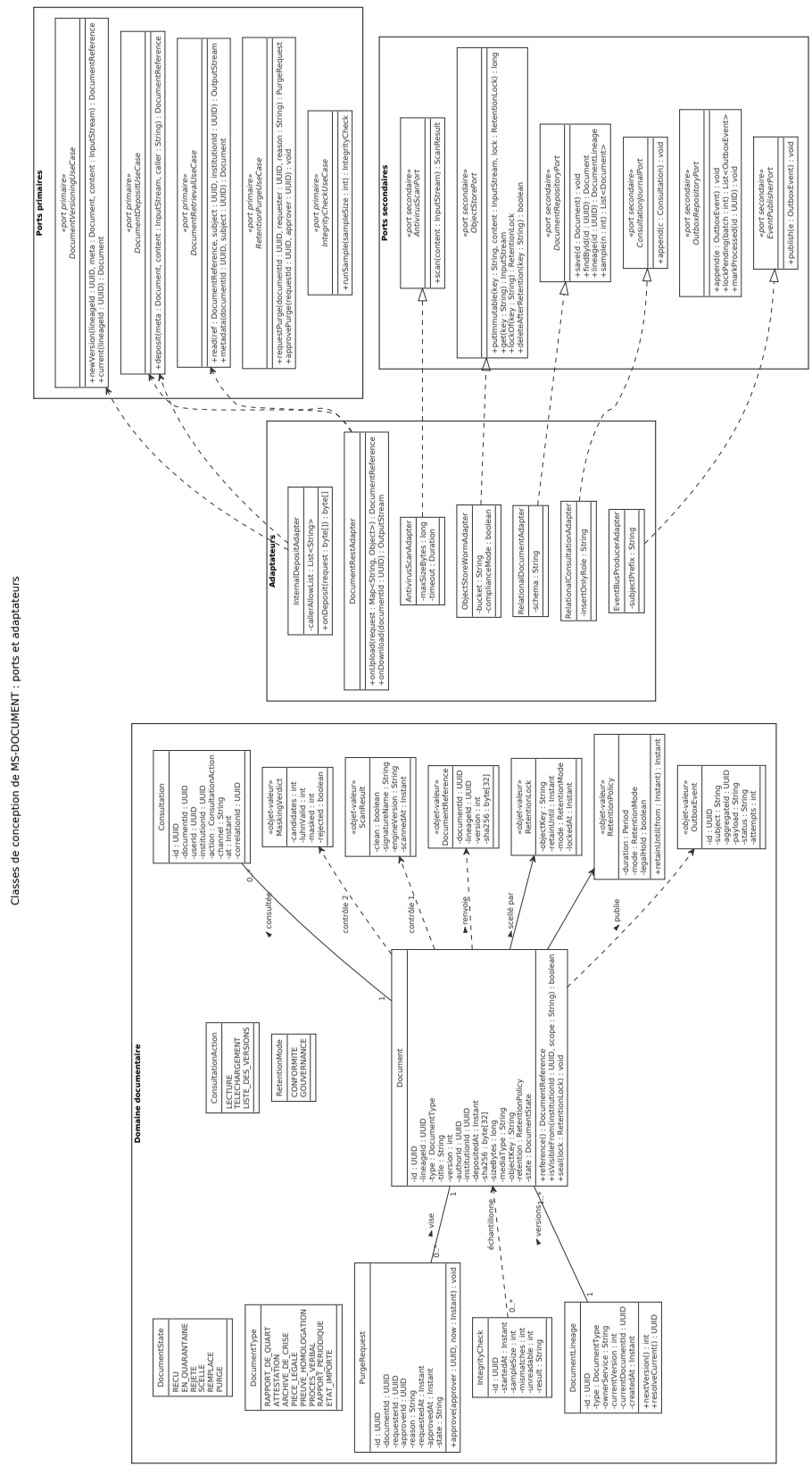


FIGURE 6.11: *Diagramme de classes de conception : service MS-DOCUMENT*

- **Entités :** `Document` (`lineageId : UUID`, `type : DocumentType`, `title : String`, `version : int`, `authorId`, `institutionId : UUID`, `depositedAt : Instant`, `sha256 : byte[32]`, `sizeBytes : long`, `mediaType`, `objectKey : String`, `retention : RetentionPolicy`, `state : DocumentState`) ; `DocumentLineage` (`type`, `ownerService : String`, `currentVersion : int`, `currentDocumentId : UUID`) ; `Consultation` (`documentId`, `userId`, `institutionId : UUID`, `action : ConsultationAction`, `channel : String`, `at : Instant`, `correlationId : UUID`) ; `PurgeRequest` (`requesterId`, `approverId : UUID`, `reason : String`, `state`) ; `IntegrityCheck` (`sampleSize`, `mismatches`, `unreadable : int`, `result : String`).

- **Objets-valeurs :** `RetentionPolicy` (`duration : Period`, `mode : RetentionMode`, `legalHold : boolean`, méthode `retainUntil`) ; `RetentionLock` (`objectKey`, `retainUntil : Instant`, `mode`) ; `DocumentReference` (`documentId`, `lineageId : UUID`, `version : int`, `sha256 : byte[32]`) ; `ScanResult` (`clean : boolean`, `signatureName`, `engineVersion`) ; `MaskingVerdict` (`candidates`, `luhnValid`, `masked : int`, `rejected : boolean`) ; `OutboxEvent`.

- **Énumérations :** `DocumentType` (rapport de quart, attestation, archive de crise, pièce légale, preuve d'homologation, procès-verbal, rapport périodique, état importé) ; `DocumentState` (`RECU`, `EN_QUARANTAINE`, `REJETE`, `SCELLE`, `REMPLACE`, `PURGE`) ; `RetentionMode` (`CONFORMITE`, `GOUVERNANCE`) ; `ConsultationAction` (`LECTURE`, `TELECHARGEMENT`, `LISTE_DES_VERSIONS`).

- **Ports primaires :** `DocumentDepositUseCase` (`deposit`) ; `DocumentRetrievalUseCase` (`read`, `metadata`) ; `DocumentVersioningUseCase` (`newVersion`, `current`) ; `RetentionPurgeUseCase` (`requestPurge`, `approvePurge`) ; `IntegrityCheckUseCase` (`runSample`).

- **Ports secondaires :** `AntivirusScanPort` (`scan`) ; `ObjectStorePort` (`putImmutable`, `get`, `lockOf`, `deleteAfterRetention`) ; `DocumentRepositoryPort` (`save`, `findById`, `lineage`, `sample`) ; `ConsultationJournalPort` (`append` seulement) ; `OutboxRepositoryPort` ; `EventPublisherPort`.

- **Adaptateurs :** `DocumentRestAdapter` et `InternalDepositAdapter` pilotent les ports primaires ; `AntivirusScanAdapter`, `ObjectStoreWormAdapter`,

`RelationalDocumentAdapter`, `RelationalConsultationAdapter` et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.4.4 Diagramme d'objets du service MS-DOCUMENT

La Figure 6.12 capture la matinée qui suit une vacation de nuit : `MS-MONITORING` a déposé une seconde version du rapport de quart (correction visée par le chef de quart), qui a franchi la chaîne de contrôle et est devenue la version courante de sa lignée, la première version restant lisible ; le chef du DES vient de la consulter ; au même instant, une pièce légale déposée depuis le portail par l'établissement de paiement `INST-0042` a été placée en quarantaine par l'antivirus ; le contrôle d'intégrité de la nuit, portant sur deux cents documents, n'a relevé aucune divergence.

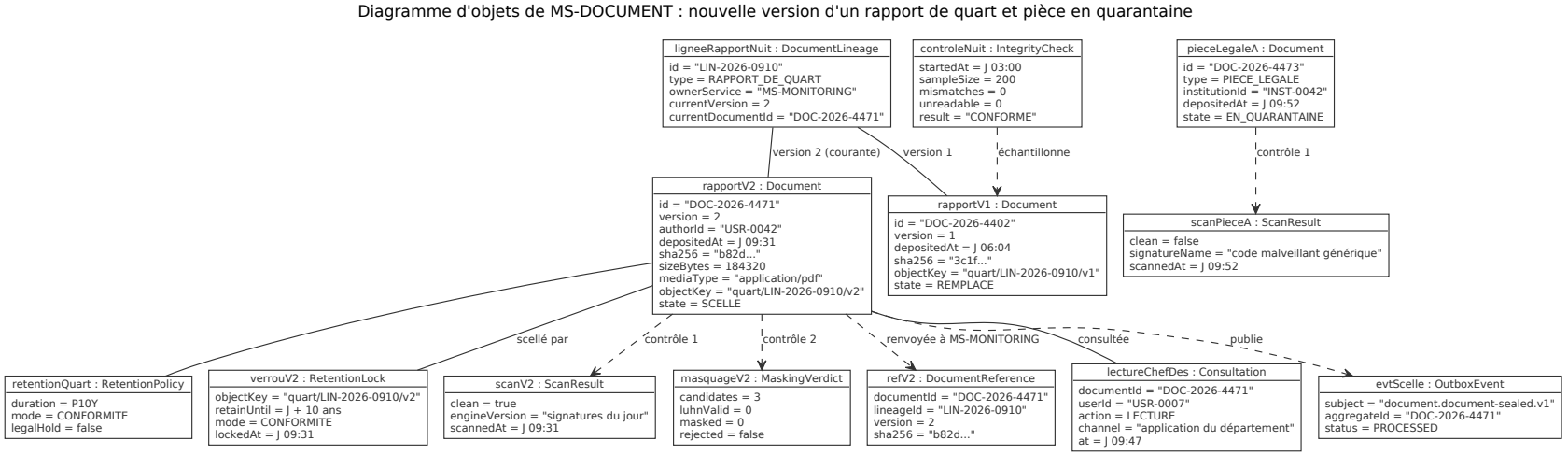


FIGURE 6.12: *Diagramme d'objets : nouvelle version d'un rapport de quart et pièce en quarantaine*

- `ligneeRapportNuit : DocumentLineage`, identifiant `LIN-2026-0910`, type rapport de quart, service propriétaire `MS-MONITORING`, version courante 2 ;
- `rapportV1 : Document`, identifiant `DOC-2026-4402`, version 1, déposé à 06h04, état `REMPLACE`, objet conservé sous sa propre clé ; `rapportV2 : Document`, identifiant `DOC-2026-4471`, version 2, déposé à 09h31 par `USR-0042`, 184 320 octets, état `SCELLE` ;
- `retentionQuart : RetentionPolicy`, dix ans, mode conformité, sans conservation légale ; `verrouV2 : RetentionLock`, sur la clé de la version 2, jusqu'à J + 10 ans ;
- `scanV2 : ScanResult`, contenu sain ; `masquageV2 : MaskingVerdict`, trois séquences candidates, aucune ne satisfaisant la formule de Luhn, rien à masquer ;
- `refV2 : DocumentReference`, renvoyée à `MS-MONITORING` avec l'empreinte `b82d...` ; `lectureChefDes : Consultation`, lecture par `USR-0007` à 09h47 depuis l'application du département ;
- `evtScelle : OutboxEvent`, sujet `document.document-sealed.v1`, publié et acquitté ;
- `pieceLegaleA : Document`, identifiant `DOC-2026-4473`, pièce légale de `INST-0042`, état `EN_QUARANTAINE`, liée à `scanPieceA : ScanResult`, détection d'un code malveillant générique ;
- `controleNuit : IntegrityCheck`, lancé à 03h00, échantillon de 200 documents, aucune divergence, aucun objet illisible.

6.1.4.5 Algorithmes fondamentaux de MS-DOCUMENT

Cette section formalise les quatre algorithmes qui régissent la chaîne de contrôle au dépôt, le versionnage sans écrasement et la résolution de la version courante, la restitution contrôlée avec journalisation, et la vérification périodique d'intégrité.

Algorithme 6.17 : Chaîne de contrôle au dépôt d'une pièce Cet algorithme traite toute pièce entrante, qu'elle vienne d'un service ou d'un utilisateur, et ne la rend accessible qu'après cinq contrôles successifs. Il est exécuté en flux, sans jamais écrire le contenu brut sur un support persistant avant le verdict antiviral et le verdict de masquage.

Spécification formelle de l'algorithme 6.17 : chaîne de contrôle au dépôt	
Entrées	Métadonnées déclarées (type, titre, institution, lignée éventuelle) ; flux de contenu F ; appelant (service ou sujet) ; t_{now}.
Sorties	`DocumentReference` (identifiant, lignée, version, empreinte) ou rejet motivé ; document à l'état `SCELLE`, `EN_QUARANTAINE` ou `REJETE`.
Complexité	$\mathcal{O}(\lvert F\rvert)$: une passe pour l'analyse antivirale, une pour le masquage et l'empreinte, une pour le dépôt.
Standard	PCI-DSS v4.0.1 exigences 3 et 5 ; ISO 19005-3 pour les pièces générées ; SHA-256 ; verrou WORM en mode conformité.

TABLE 6.19: *Fiche de spécification : chaîne de contrôle au dépôt*

Déroulement procédural étape par étape :

1. **Admission :** vérifier l'appelant (service de la liste autorisée sous mTLS, ou sujet porteur de la permission de dépôt pour le type de pièce et l'institution déclarée), la taille annoncée et le type de média admis pour le type de pièce ; créer `Document` à l'état `RECU` dans une zone de transit chiffrée, sans clé d'objet.

2. **Analyse antivirale :** transmettre F à `AntivirusScanPort.scan` ; si `clean` est faux, passer à `EN_QUARANTAINE`, isoler le contenu hors de tout chemin de restitution, insérer `document.quarantined.v1` (notification au RSSI et, s'il s'agit du portail, information au correspondant de l'institution) et retourner un rejet sans détail sur la signature détectée.

3. **Contrôle de masquage :** extraire le texte du contenu (texte brut, texte des documents PDF, cellules des états tabulaires) et rechercher toute séquence de 13 à 19 chiffres, avec ou sans séparateurs ; pour chaque candidate D, appliquer la formule de Luhn :

$$\Big(\sum_{i=0}^{L-1} f_i(d_{L-1-i})\Big) \bmod 10 = 0, \qquad f_i(d) = \begin{cases} d & i \text{ pair} \\ 2d - 9\,[2d > 9] & i \text{ impair} \end{cases} \tag{6.21}$$

   Si une candidate satisfait la formule : rejeter la pièce (`REJETE`) lorsqu'elle vient d'un service ou lorsque le type de pièce interdit toute donnée de carte ; sinon la masquer (six premiers et quatre derniers chiffres conservés) dans une copie de travail, et consigner le verdict (`MaskingVerdict`). Le contenu rejeté est détruit de la zone de transit.

4. **Empreinte et classification :** calculer $\sigma = \mathrm{SHA256}(F')$ sur le contenu final F' ; attribuer la politique de rétention du type de pièce (dix ans en mode conformité par défaut) et

calculer l'échéance $t_{\text{ret}} = t_{\text{now}} + \text{duration}$; pour une pièce générée, vérifier la déclaration PDF/A-3.

5. **Version et clé d'objet :** obtenir le numéro de version par l'algorithme 6.18 et construire la clé d'objet propre à la version.

6. **Dépôt et verrou :** appeler `ObjectStorePort.putImmutable` avec la clé κ, le contenu F' et un verrou de rétention $(t_{\text{ret}}, \texttt{CONFORMITE})$; relire le verrou par $\texttt{lockOf}(\kappa)$ et vérifier que l'échéance et le mode sont bien posés ; à défaut, considérer le dépôt comme échoué et ne pas sceller.

7. **Scellement et référence :** dans une transaction, enregistrer les métadonnées (état `SCELLE`, σ, clé, taille, type de média), mettre à jour la lignée et insérer `document.document-sealed.v1` (référence, σ, déposant, type) dans l'outbox ; retourner `DocumentReference`. `MS-AUDIT` inscrit l'événement comme feuille de l'arbre de Merkle.

Algorithme 6.18 : Versionnage sans écrasement et résolution de la version courante Cet algorithme attribue un numéro de version strictement croissant au sein d'une lignée, crée un objet distinct pour chaque version et rend la résolution de la version courante déterministe, même en présence de dépôts concurrents.

Spécification formelle de l'algorithme 6.18 : versionnage sans écrasement	
Entrées	Identifiant de lignée λ (ou absence, pour une pièce nouvelle) ; document en cours de dépôt ; appelant.
Sorties	Numéro de version v ; clé d'objet ; lignée mise à jour ; version précédente à l'état `REMPLACE`.
Complexité	$\mathcal{O}(1)$: un verrou de ligne sur la lignée, deux écritures.
Garantie	Aucune réécriture d'objet ; unicité de (λ, v) par contrainte ; toute version reste lisible et restituable.

TABLE 6.20: *Fiche de spécification : versionnage sans écrasement*

Déroulement procédural étape par étape :

1. **Lignée nouvelle ou existante :** si λ est absent, créer `DocumentLineage` avec le type de pièce et le service ou l'utilisateur propriétaire, et poser $v = 1$. Sinon, charger la lignée avec un verrou de ligne (`SELECT ... FOR UPDATE`) et vérifier que l'appelant est bien son propriétaire ou porte la permission de versionnage pour ce type.

2. **Attribution du numéro :** poser $v = \text{currentVersion} + 1$; la contrainte d'unicité sur (λ, v) dans la table des documents rend impossible l'attribution du même numéro par deux transactions, la seconde étant rejetée et rejouée.

3. **Clé d'objet :** construire la clé $\kappa = \text{type}/\lambda/\text{v}v$; la clé est nouvelle par construction et le dépôt objet refuse toute écriture sur une clé existante : l'écrasement est impossible au niveau du domaine comme au niveau du dépôt.

4. **Mise à jour de la lignée :** après le dépôt et le scellement (algorithme 6.17), positionner `currentVersion` $= v$ et `currentDocumentId` sur le nouveau document, et passer la version $v-1$ à l'état `REMPLACE` sans toucher à son objet, à son verrou ni à son journal de consultation ; libérer le verrou de lignée.

5. **Résolution de la version courante :** `current`(λ) retourne le document désigné par `currentDocumentId` ; la liste des versions est obtenue par (λ, v) croissant ; une référence de document portant un numéro de version désigne toujours le même objet et la même empreinte, ce qui permet à un service appelant (règle des quatre éléments, dossier de mise en service) de figer une preuve à une version précise.

Algorithme 6.19 : Restitution contrôlée et journalisation des consultations Cet algorithme sert une pièce à un utilisateur ou à un service après vérification de la permission et du périmètre d'institution, et n'entame la restitution qu'après avoir journalisé la consultation. Il est identique pour la lecture, le téléchargement et la liste des versions.

Spécification formelle de l'algorithme 6.19 : restitution contrôlée	
Entrées	Référence de document ; jeton interne réduit (sujet, permissions, périmètre, institution éventuelle) ; action demandée ; identifiant de corrélation.
Sorties	Flux de contenu avec empreinte attendue, ou refus ; `Consultation` inscrite ; événement `document.document-consulted.v1`.
Complexité	$\mathcal{O}(1)$ pour la décision ; $\mathcal{O}(\lvert F \rvert)$ pour la restitution en flux.
Contrôles	Permission par type de pièce ; périmètre d'institution en domaine et en politique de lignes ; journal en insertion seule avant restitution.

TABLE 6.21: *Fiche de spécification : restitution contrôlée*

Déroulement procédural étape par étape :

1. **Chargement sous périmètre :** lire les métadonnées du document par `DocumentRepositoryPort.findById`, la session de base relationnelle ayant préalablement reçu le périmètre du jeton (institution, service) pour l'application de la

politique de lignes ; une pièce hors périmètre est simplement introuvable, sans indication de son existence.

2. **Décision :** refuser si l'état n'est pas `SCELLE` ou `REMPLACE`, si le jeton ne porte pas la permission de consultation du type de pièce, ou si le document porte une institution différente de celle du sujet lorsque celui-ci est un représentant d'un participant :

$$\text{autoris} = (\text{state} \in \{\texttt{SCELLE}, \texttt{REMPLACE}\}) \wedge (p_{\text{type}} \in \mathscr{P}_{\text{jeton}}) \wedge \text{visible}(\text{inst}, \text{prim}) \quad (6.22)$$

   Tout refus est journalisé comme consultation refusée et publié.

3. **Journalisation préalable :** insérer `Consultation` (document, sujet, institution, action, canal, t_{now}, identifiant de corrélation) par `ConsultationJournalPort.append` et `document.document-consulted.v1` dans l'outbox, dans une même transaction validée avant toute lecture de contenu.

4. **Restitution en flux :** ouvrir `ObjectStorePort.get`(κ), transmettre l'empreinte attendue σ et le type de média en en-tête, puis relayer le flux sans copie intermédiaire ; calculer l'empreinte au fil du flux et, en cas de divergence en fin de transfert, signaler l'anomalie (`document.integrity-alert.v1`) sans possibilité de correction côté service.

5. **Liste des versions :** pour l'action `LISTE_DES_VERSIONS`, retourner les couples $(v, \text{tat}, \sigma_v, \text{depositedAt})$ de la lignée filtrés par le même périmètre, chaque version restant restituable individuellement.

Algorithme 6.20 : Vérification périodique d'intégrité par échantillonnage Cet algorithme relit chaque nuit un échantillon de documents depuis le dépôt objet, recalcule leur empreinte et la compare à l'empreinte scellée ; il détecte une corruption de support, une altération hors des chemins applicatifs ou une perte d'objet, et en rend compte.

Spécification formelle de l'algorithme 6.20 : vérification d'intégrité	
Entrées	Taille d'échantillon s (200 par défaut) ; stratification : tout document déposé depuis la dernière vérification, puis tirage aléatoire parmi le reste.
Sorties	`IntegrityCheck` (échantillon, divergences, illisibles, résultat) ; événement `document.integrity-checked.v1` ; alerte critique en cas de divergence.
Complexité	$\mathcal{O}(\sum \lvert F_i \rvert)$ sur l'échantillon ; borne de durée et de débit pour ne pas concurrencer la production.
Standard	PCI-DSS v4.0.1 exigence 11 (détection des modifications non autorisées) ; SHA-256 ; comparaison en temps constant.

TABLE 6.22: *Fiche de spécification : vérification d'intégrité*

Déroulement procédural étape par étape :

1. **Constitution de l'échantillon :** sélectionner par `DocumentRepositoryPort.sample`(s) tous les documents scellés depuis la dernière vérification (couverture complète des dépôts récents), complétés par un tirage uniforme parmi les documents plus anciens jusqu'à atteindre s ; sur une année, chaque document ancien est ainsi relu plusieurs fois.

2. **Relecture et recalcul :** pour chaque document i, ouvrir `ObjectStorePort.get`(κ_i) et calculer $\sigma'_i = \mathrm{SHA256}(F_i)$ en flux ; un objet introuvable ou illisible est compté comme `unreadable` ; vérifier également que `lockOf`(κ_i) retourne un verrou en mode conformité dont l'échéance n'est pas antérieure à celle enregistrée.

3. **Comparaison :** évaluer $\mathrm{ConstantTimeEquals}(\sigma'_i, \sigma_i)$; toute inégalité incrémente `mismatches` et est consignée avec l'identifiant, la clé et les deux empreintes.

4. **Résultat et publication :** enregistrer `IntegrityCheck` avec le résultat (`CONFORME` si aucune divergence ni objet illisible, `DIVERGENT` sinon) et insérer `document.integrity-checked.v1` dans l'outbox ; `MS-AUDIT` scelle le résultat et `MS-REPORTING` alimente l'indicateur de fiabilité de la GED.

5. **Alerte :** en cas de résultat `DIVERGENT`, appeler le port synchrone de `MS-NOTIFICATION` pour une notification critique au RSSI et au chef du DES avec acquittement obligatoire, et demander l'ouverture d'un incident de sécurité dans `MS-INCIDENT` ; le service ne tente aucune réparation, la copie de référence devant être restaurée par la procédure de reprise depuis le site de secours, sous contrôle du RSSI.

6.1.5 Notifications, canaux de remise et escalade (MS-NOTIFICATION)

Le service `MS-NOTIFICATION` est le point de passage unique de tout ce que la plateforme intégrée du Département Exploitation et Supervision (DES) doit porter à la connaissance d'une personne : alerte de monitoring, escalade d'incident, échéance documentaire d'une institution, tâche assignée, demande de quitus, campagne de réexamen des accès, divergence d'audit. Il reçoit les demandes de notification par le bus d'événements (sujets `*.notification-requested.v1`, consommés de façon idempotente) ou, pour les urgences de sévérité S1, par un port synchrone ; il résout les destinataires à partir des abonnements et des règles (par rôle, par institution, par service du DES, par objet), applique les préférences de canal de chaque utilisateur et le niveau d'urgence, met les messages en forme à partir de gabarits, les remet sur quatre canaux (centre de notifications de la plateforme, canal poussé vers les couches de présentation par le port de `MS-GATEWAY`, messagerie électronique du groupement et, en extension facultative, passerelle SMS), trace chaque remise, réessaie, exige un acquittement pour les niveaux urgent et critique et escalade vers le suppléant à l'expiration du délai. Il regroupe les rafales de notifications de même origine pour éviter les tempêtes. Le service ne décide de rien : il ne qualifie pas les incidents, ne calcule pas les échéances, ne choisit pas les suppléants ; il lit l'annuaire d'escalade dans `MS-PARTICIPANT` et la matrice d'escalade interne dans `MS-IAM`, et remet. Aucune donnée sensible ne quitte la plateforme : les canaux externes ne transportent qu'un message minimal renvoyant vers la plateforme.

6.1.5.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : COBAC, PCI-DSS v4.0.1 et ISO/IEC 27001

- **Règlements COBAC R-2016/04 et R-2024/01 :** le dispositif de gestion des incidents et de continuité exige que les responsables soient informés sans délai des événements significatifs et que l'information soit tracée ; la remise, l'acquittement et l'escalade de chaque notification urgente ou critique sont journalisés, publiés et scellés dans `MS-AUDIT`.
- **PCI-DSS v4.0.1, exigence 12 :** le plan de réponse aux incidents prévoit l'alerte immédiate du personnel désigné et des procédures d'escalade ; `MS-NOTIFICATION` en est l'outil, avec délai d'acquittement et suppléance automatique.
- **PCI-DSS v4.0.1, exigence 4, et ISO/IEC 27001 :** aucune donnée de compte ni donnée sensible ne transite par un canal non maîtrisé ; la messagerie électronique et la passerelle SMS ne reçoivent qu'un message minimal (type, niveau, identifiant de notification, invitation à se connecter). Les informations détaillées ne sont visibles que dans la plateforme, après authentification.

- **Journalisation :** chaque trace de remise, acquittement et escalade est un événement à effet, publié sous `notification.<agrégat>-<événement>.v1` et consommé par `MS-AUDIT` et `MS-REPORTING` (délais de prise en compte des alertes).

Abonnements, règles de destinataires et niveaux d'urgence

- **Règles :** un abonnement associe un type de notification à une règle de destinataires : par rôle (tous les opérateurs de supervision en vacation), par institution (les correspondants déclarés d'un participant), par service du DES (le pôle homologation) ou par objet (les personnes liées à un ticket, à une liaison, à une tâche). Les destinataires nominatifs sont résolus à l'instant de la demande, jamais stockés dans l'abonnement, de sorte qu'un changement d'affectation dans `MS-IAM` ou de correspondant dans `MS-PARTICIPANT` est pris en compte immédiatement.
- **Niveaux d'urgence :** quatre niveaux ordonnés, *information*, *avertissement*, *urgent*, *critique*. Le niveau est fixé par le service émetteur (une escalade d'incident S1 est critique, une échéance documentaire à J-90 est une information) et ne peut être abaissé par le service de notification. Les niveaux urgent et critique exigent un acquittement dans un délai (dix minutes pour critique, trente minutes pour urgent, paramétrables par type) et déclenchent l'escalade à défaut.
- **Préférences de canal :** chaque utilisateur règle, pour chacun des canaux externes, le niveau minimal à partir duquel il souhaite être joint et une plage horaire ; le centre de notifications de la plateforme et le canal poussé ne sont pas débrayables ; les niveaux urgent et critique ignorent la plage horaire pour les collaborateurs en vacation ou d'astreinte, l'astreinte étant lue dans `MS-MONITORING` par l'événement de grille publié.

Le tableau 6.23 récapitule, pour chaque niveau d'urgence, les canaux mobilisés, l'exigence d'acquittement, le délai avant escalade et l'éligibilité à la consolidation.

Niveau	Canaux mobilisés	Acquittement	Escalade	Consolidation
Information	plateforme, canal poussé	lecture	aucune	oui
Avertissement	plateforme, canal poussé, messagerie selon préférence	lecture	aucune	oui
Urgent	plateforme, canal poussé, messagerie, SMS si présent	explicite	30 min	non
Critique	tous les canaux disponibles, plage horaire ignorée	explicite	10 min	non

TABLE 6.23: *Niveaux d'urgence, canaux, acquittement, escalade et consolidation*

Canaux de remise et gabarits

- **Centre de notifications :** remise dans la plateforme, consultable depuis les trois couches de présentation ; la lecture vaut acquittement pour les niveaux information et avertissement, jamais pour urgent et critique, qui exigent un acquittement explicite.
- **Canal poussé :** le service publie `notification.push-requested.v1`, consommé par le port de canal poussé de `MS-GATEWAY`, qui ne diffuse l'événement qu'aux abonnements dont les filtres (profil, institution) l'acceptent ; la charge poussée contient l'identifiant de notification, le niveau et un titre, jamais le corps.
- **Messagerie électronique :** émission par l'adaptateur vers le serveur de messagerie du groupement, en TLS, avec un message minimal issu d'un gabarit marqué comme tel ; l'adresse est lue dans `MS-IAM` ou `MS-PARTICIPANT` au moment de la remise et n'est pas conservée.
- **Passerelle SMS :** extension facultative, absente par défaut ; l'adaptateur est débrayable et le port répond `isAvailable() = faux` en son absence, auquel cas le canal est simplement ignoré dans la résolution.
- **Gabarits :** un gabarit par type de notification et par canal, avec variables nommées (identifiant d'objet, niveau, libellé, échéance) ; les gabarits des canaux externes sont contraints au message minimal par une propriété vérifiée au chargement.

Traces de remise, réessais, rebut et consolidation

- **Trace :** chaque couple (destinataire, canal) produit une trace dont l'état est `EN_ATTENTE`, `REMISE`, `ECHOUEE` ou `ACQUITTEE`, avec le nombre de tentatives, l'instant de la prochaine tentative, la dernière erreur et les horodatages de remise et d'acquittement.
- **Réessais :** une remise échouée est réessayée avec retard exponentiel (30 s, 60 s, 120 s, ..., plafond de 15 minutes), jusqu'à six tentatives ; au-delà, la trace passe à `ECHOUEE`, la notification est publiée sur le sujet de rebut `notification.delivery-failed.v1`, consommé par `MS-MONITORING` qui lève une alerte sur le canal défaillant. L'échec d'un canal n'empêche jamais la remise sur les autres.
- **Consolidation anti-tempête :** les notifications de niveau information ou avertissement partageant une même clé de regroupement (type et objet, par exemple les alertes de monitoring d'une même liaison) sont retenues dans une fenêtre de consolidation de cinq minutes puis remises en une notification de synthèse ; les niveaux urgent et critique ne sont jamais consolidés.

Acquittement, escalade et principes de conception

- **Acquittement :** l'acquittement est une action explicite de l'utilisateur dans la plateforme (ou par le canal poussé), authentifiée, horodatée et publiée ; il clôt la notification pour tous les canaux et annule l'escalade programmée.
- **Escalade :** à l'expiration du délai sans acquittement, le service lit le suppléant du destinataire : pour un collaborateur, dans la matrice d'escalade interne de `MS-IAM` (chef de quart, puis chef du DES, puis Direction Générale) ; pour le correspondant d'une institution, dans l'annuaire d'escalade de `MS-PARTICIPANT` (correspondant suppléant, puis responsable désigné). Le suppléant reçoit la notification avec la mention de l'escalade, un nouveau délai court, et l'escalade se poursuit jusqu'au dernier niveau, où elle est signalée à `MS-INCIDENT`.
- **Idempotence et outbox :** le consommateur mémorise l'identifiant CloudEvents de chaque demande traitée ; les mutations du service passent par la table d'outbox, selon le même schéma que dans les autres services (algorithme 6.9).
- **Port synchrone :** réservé aux urgences S1 des services de la liste autorisée (`MS-INCIDENT`, `MS-AUDIT`, `MS-DOCUMENT`, `MS-MONITORING`) ; il retourne les traces de remise initiales, ce qui permet à l'appelant de constater que la notification a été prise en charge avant de poursuivre.

6.1.5.2 Diagramme de composants internes de MS-NOTIFICATION

La Figure 6.13 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les demandes du bus et du port synchrone, les actions des utilisateurs (centre de notifications, préférences, acquittements) via `MS-GATEWAY` et les impulsions de l'ordonnanceur ; le cœur porte les deux entités d'analyse du domaine 1 (notification, préférence de canal) et les objets qui les complètent ; les adaptateurs pilotés dialoguent avec la base relationnelle du service, `MS-IAM`, `MS-PARTICIPANT`, `MS-GATEWAY`, la messagerie électronique du groupement, la passerelle SMS facultative et le bus d'événements.

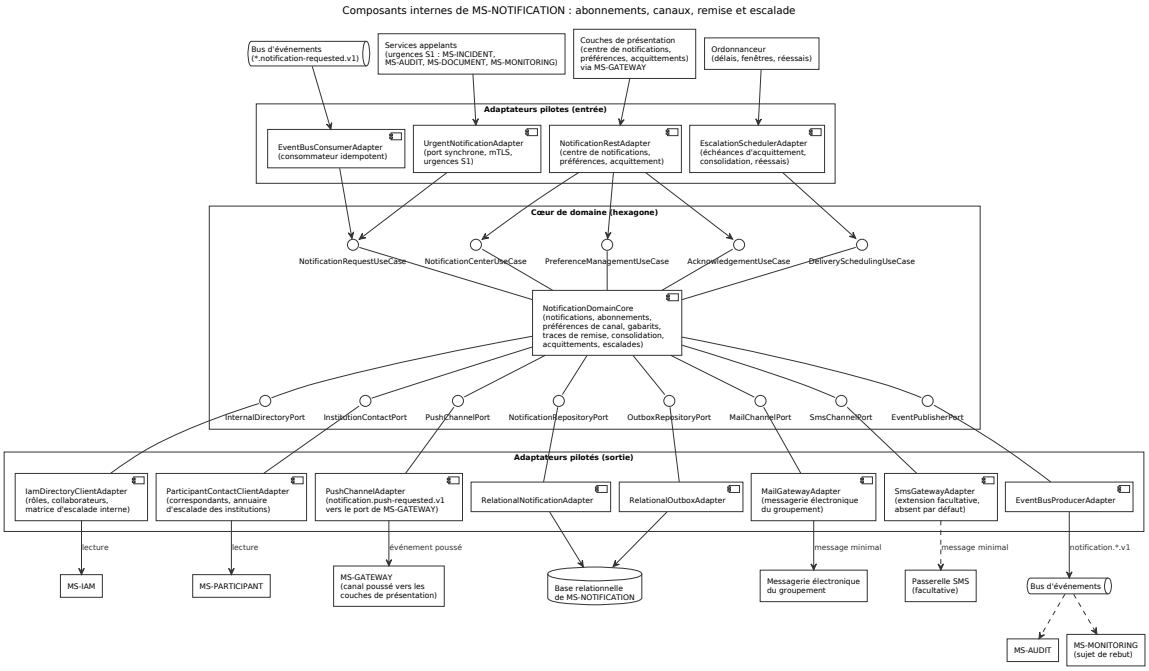


FIGURE 6.13: *Diagramme de composants internes : abonnements, canaux, remise et escalade*

- **Adaptateurs pilotes (entrée) :** `EventBusConsumerAdapter` (sujets `*.notification-requested.v1`, consommation idempotente par identifiant CloudEvents) ; `UrgentNotificationAdapter` (port synchrone sous mTLS pour les urgences S1, liste d'appelants autorisés) ; `NotificationRestAdapter` (centre de notifications, préférences de canal, abonnements, acquittements) ; `EscalationSchedulerAdapter` (échéances d'acquittement, fermeture des fenêtres de consolidation, réessais dus).

- **Cœur de domaine :** `NotificationDomainCore` expose `NotificationRequestUseCase`, `NotificationCenterUseCase`, `PreferenceManagementUseCase`, `AcknowledgementUseCase` et `DeliverySchedulingUseCase`, et requiert huit ports secondaires.

- **Adaptateurs pilotés (sortie) :** `RelationalNotificationAdapter` (notifications, abonnements, préférences, gabarits, traces, fenêtres, escalades) ; `IamDirectoryClientAdapter` (rôles, collaborateurs d'un service, matrice d'escalade interne, en lecture) ; `ParticipantContactClientAdapter` (correspondants et annuaire d'escalade des institutions, en lecture) ; `PushChannelAdapter` (`notification.push-requested.v1` vers le port de canal poussé de `MS-GATEWAY`) ; `MailGatewayAdapter` (messagerie électronique du groupement) ; `SmsGatewayAdapter` (extension facultative, absente par défaut) ; `RelationalOutboxAdapter` et `EventBusProducerAdapter`.

- **Interactions :** tous les services en producteurs de demandes ; `MS-IAM` et `MS-PARTICIPANT` en lecture pour la résolution des destinataires et des suppléants ; `MS-GATEWAY` pour le canal poussé ; `MS-AUDIT` en consommateur de toutes les traces ; `MS-MONITORING` en consommateur du sujet de rebut ; `MS-REPORTING` pour les délais d'acquittement.

6.1.5.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.14 détaille les classes du domaine, les ports et les adaptateurs. Les entités d'analyse *Notification* et *Préférence de canal* y sont reprises avec leurs types et leurs signatures ; l'abonnement, le destinataire résolu, le gabarit, la trace de remise, l'escalade et la fenêtre de consolidation les complètent.

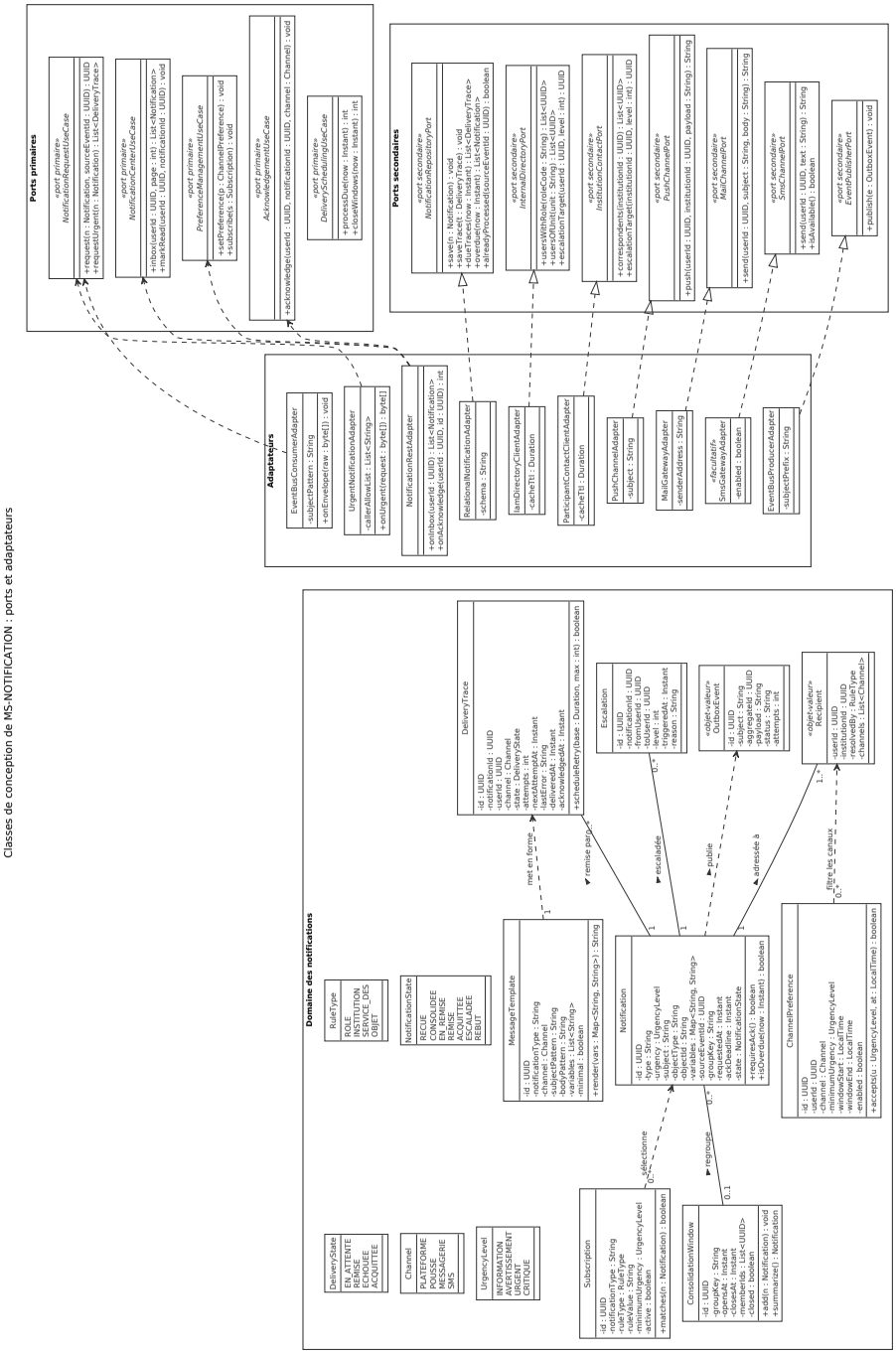


FIGURE 6.14: *Diagramme de classes de conception : service MS-NOTIFICATION*

- **Entités :** `Notification` (`type : String`, `urgency : UrgencyLevel`, `subject`, `objectType`, `objectId : String`, `variables : Map<String, String>`, `sourceEventId : UUID`, `groupKey : String`, `requestedAt`, `ackDeadline : Instant`, `state : NotificationState`, méthodes `requiresAck`, `isOverdue`) ; `Subscription` (`notificationType`, `ruleType : RuleType`, `ruleValue`, `minimumUrgency`, méthode `matches`) ; `ChannelPreference` (`userId : UUID`, `channel : Channel`, `minimumUrgency : UrgencyLevel`, `windowStart`, `windowEnd : LocalTime`, `enabled : boolean`, méthode `accepts`) ; `MessageTemplate` (`channel`, `subjectPattern`, `bodyPattern`, `variables : List<String>`, `minimal : boolean`, méthode `render`) ; `DeliveryTrace` (`channel`, `state : DeliveryState`, `attempts : int`, `nextAttemptAt`, `deliveredAt`, `acknowledgedAt : Instant`, `lastError : String`, méthode `scheduleRetry`) ; `Escalation` (`fromUserId`, `toUserId : UUID`, `level : int`, `triggeredAt : Instant`, `reason`) ; `ConsolidationWindow` (`groupKey`, `opensAt`, `closesAt`, `memberIds : List<UUID>`, `closed`, méthodes `add`, `summarize`).
- **Objets-valeurs :** `Recipient` (`userId`, `institutionId : UUID`, `resolvedBy : RuleType`, `channels : List<Channel>`) ; `OutboxEvent`.
- **Énumérations :** `UrgencyLevel` (`INFORMATION`, `AVERTISSEMENT`, `URGENT`, `CRITIQUE`) ; `Channel` (`PLATEFORME`, `POUSSE`, `MESSAGERIE`, `SMS`) ; `DeliveryState` (`EN_ATTENTE`, `REMISE`, `ECHOUEE`, `ACQUITTEE`) ; `NotificationState` (`RECUE`, `CONSOLIDEE`, `EN_REMISE`, `REMISE`, `ACQUITTEE`, `ESCALADEE`, `REBUT`) ; `RuleType` (`ROLE`, `INSTITUTION`, `SERVICE_DES`, `OBJET`).
- **Ports primaires :** `NotificationRequestUseCase` (`request`, `requestUrgent`) ; `NotificationCenterUseCase` (`inbox`, `markRead`) ; `PreferenceManagementUseCase` (`setPreference`, `subscribe`) ; `AcknowledgementUseCase` (`acknowledge`) ; `DeliverySchedulingUseCase` (`processDue`, `closeWindows`).
- **Ports secondaires :** `NotificationRepositoryPort` (`save`, `saveTrace`, `dueTraces`, `overdue`, `alreadyProcessed`) ; `InternalDirectoryPort` (`usersWithRole`, `usersOfUnit`, `escalationTarget`) ; `InstitutionContactPort` (`correspondents`, `escalationTarget`) ; `PushChannelPort` (`push`) ; `MailChannelPort` (`send`) ; `SmsChannelPort` (`send`, `isAvailable`) ; `OutboxRepositoryPort` ; `EventPublisherPort`.

- **Adaptateurs :** `EventBusConsumerAdapter`, `UrgentNotificationAdapter` et `NotificationRestAdapter` pilotent les ports primaires ; `RelationalNotificationAdapter`, `IamDirectoryClientAdapter`, `ParticipantContactClientAdapter`, `PushChannelAdapter`, `MailGatewayAdapter`, `SmsGatewayAdapter` (stéréotype « facultatif ») et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.5.4 Diagramme d'objets du service MS-NOTIFICATION

La Figure 6.15 capture une nuit de vacation : `MS-INCIDENT` a escaladé en sévérité S1 un incident sur la liaison `LIA-2026-017` et a demandé une notification critique par le port synchrone ; l'opérateur de supervision en vacation a été résolu par la règle de rôle ; la remise dans la plateforme et sur le canal poussé a réussi immédiatement, la remise par messagerie électronique est en réessai après une indisponibilité du serveur ; dix minutes plus tard, en l'absence d'acquittement, l'escalade vers le chef de quart a été déclenchée. Quelques minutes plus tôt, douze alertes de monitoring de la même liaison, de niveau avertissement, avaient été regroupées dans une fenêtre de consolidation désormais close.

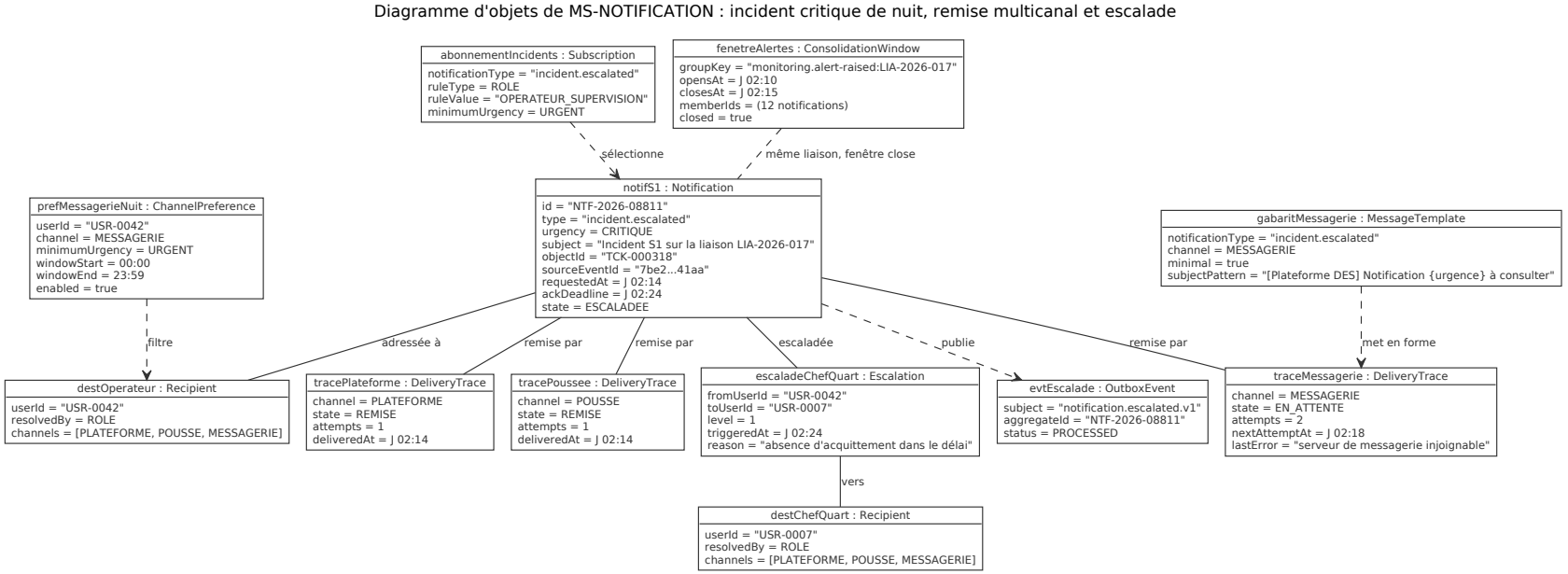


FIGURE 6.15: *Diagramme d'objets : incident critique de nuit, remise multicanal et escalade*

- `notifS1 : Notification`, identifiant `NTF-2026-08811`, type `incident.escalated`, niveau `CRITIQUE`, objet `TCK-000318`, demandée à 02h14, délai d'acquittement à 02h24, état `ESCALADEE` ;
- `abonnementIncidents : Subscription`, règle par rôle `OPERATEUR_SUPERVISION`, niveau minimal `URGENT`, qui a sélectionné `destOperateur : Recipient` (`USR-0042`, canaux plateforme, poussé et messagerie ; le canal SMS est absent) ;
- `prefMessagerieNuit : ChannelPreference`, messagerie électronique à partir du niveau `URGENT`, sans restriction horaire ;
- `gabaritMessagerie : MessageTemplate`, canal messagerie, message minimal : le sujet ne porte que le niveau et une invitation à consulter la plateforme ;
- `tracePlateforme` et `tracePoussee : DeliveryTrace`, remises à 02h14 en une tentative ; `traceMessagerie : DeliveryTrace`, en attente, deuxième tentative programmée à 02h18 après un serveur de messagerie injoignable ;
- `escaladeChefQuart : Escalation`, de `USR-0042` vers `USR-0007`, niveau 1, déclenchée à 02h24 pour absence d'acquittement, adressée à `destChefQuart : Recipient` ;
- `fenetreAlertes : ConsolidationWindow`, clé `monitoring.alert-raised:LIA-2026-017`, ouverte à 02h10, close à 02h15, douze notifications regroupées en une synthèse ;
- `evtEscalade : OutboxEvent`, sujet `notification.escalated.v1`, publié et acquitté.

6.1.5.5 Algorithmes fondamentaux de MS-NOTIFICATION

Cette section formalise les quatre algorithmes qui régissent la résolution des destinataires et des canaux, la remise multicanal avec réessais et rebut, l'acquittement et l'escalade temporisée, et la consolidation anti-tempête.

Algorithme 6.21 : Résolution des destinataires et des canaux Cet algorithme transforme une demande de notification en un ensemble de couples (destinataire, canal) à partir des abonnements, des annuaires de `MS-IAM` et de `MS-PARTICIPANT`, des préférences de canal et du niveau d'urgence. Il est exécuté à la réception de la demande, jamais à l'avance.

Spécification formelle de l'algorithme 6.21 : résolution des destinataires	
Entrées	Demande N (type, niveau u, objet, variables, institution éventuelle, identifiant CloudEvents) ; t_{now} ; canaux disponibles $\mathscr{C}_{\text{disp}}$.
Sorties	Ensemble $\mathscr{R}$ de `Recipient` avec leurs canaux ; notification persistée à l'état `RECUE` ; ou absorption si doublon.
Complexité	$\mathscr{O}(\lvert S\rvert + \lvert U\rvert \cdot \lvert\mathscr{C}\rvert)$ pour $\lvert S\rvert$ abonnements du type et $\lvert U\rvert$ utilisateurs résolus.
Contrôles	Idempotence par identifiant CloudEvents ; annuaires lus à l'instant de la demande ; canaux externes limités au message minimal.

TABLE 6.24: *Fiche de spécification : résolution des destinataires et des canaux*

Déroulement procédural étape par étape :

1. **Idempotence :** si le port `NotificationRepositoryPort` signale l'identifiant source comme déjà traité (`alreadyProcessed`), acquitter le message sans effet ; sinon persister N à l'état `RECUE` avec l'identifiant source dans la même transaction, la contrainte d'unicité protégeant contre deux consommateurs concurrents.

2. **Sélection des abonnements :** charger les abonnements actifs S dont le type et le niveau minimal acceptent N ; pour chacun, résoudre les utilisateurs selon la règle :

$$U = \bigcup_{s \in S} \rho(s), \qquad \rho(s) = \begin{cases} \text{usersWithRole}(s.v) & s.\text{type} = \texttt{ROLE} \\ \text{correspondents}(s.v) & s.\text{type} = \texttt{INSTITUTION} \\ \text{usersOfUnit}(s.v) & s.\text{type} = \texttt{SERVICE_DES} \\ \text{lis}(N.\text{objet}) & s.\text{type} = \texttt{OBJET} \end{cases} \tag{6.23}$$

   Les règles par institution ne s'appliquent que si N porte une institution, et ne résolvent que les correspondants de celle-ci : aucune notification relative à un participant n'atteint un autre participant.

3. **Restriction de vacation :** pour les règles par rôle d'opérateur de supervision, ne retenir que les collaborateurs en vacation ou d'astreinte à t_{now} (grille reçue de `MS-MONITORING`) ; si l'ensemble est vide, retenir le chef de quart.

4. **Canaux par destinataire :** pour chaque $x \in U$, partir des canaux obligatoires $\{\texttt{PLATEFORME}, \texttt{POUSSE}\}$ puis ajouter chaque canal externe $c \in \mathscr{C}_{\text{disp}}$ dont la préférence p de x (niveau minimal $u_{\min}$, plage $[t_{\text{db}}, t_{\text{fin}}]$) accepte (u, t_{now}) :

$$\text{accepte}(p,u,t) = p.\text{enabled} \wedge (u \geq p.u_{\min}) \wedge \big(t \in [p.t_{\text{db}},\ p.t_{\text{fin}}] \vee u \geq \texttt{URGENT}\big) \tag{6.24}$$

Le canal SMS n'est considéré que si `SmsChannelPort.isAvailable()` est vrai.

5. **Dédoublonnage et constitution :** un utilisateur atteint par plusieurs règles ne reçoit qu'une notification, avec l'union de ses canaux ; construire `Recipient` pour chacun, persister, puis remettre à l'algorithme 6.22. Si U est vide, publier `notification.unresolved.v1`, consommé par `MS-MONITORING` : une notification urgente sans destinataire est une anomalie de configuration.

Algorithme 6.22 : Remise multicanal avec réessais et rebut Cet algorithme remet une notification à chaque destinataire sur chacun de ses canaux, de façon indépendante, avec réessais à retard exponentiel et publication sur le sujet de rebut en cas d'échec définitif. Il garantit que l'échec d'un canal n'affecte ni les autres canaux ni les autres destinataires.

Spécification formelle de l'algorithme 6.22 : remise multicanal	
Entrées	Notification N ; destinataires $\mathscr{R}$; gabarits par canal ; paramètres $b = 30$ s (base), $k_{\max} = 6$ (tentatives), $\Delta_{\max} = 15$ min.
Sorties	Traces de remise par (destinataire, canal) ; événements de remise (`delivered`) ou de rebut (`delivery-failed`).
Complexité	$\mathscr{O}(\lvert\mathscr{R}\rvert \cdot \lvert\mathscr{C}\rvert)$ remises ; réessais bornés par $k_{\max}$ par trace.
Garantie	Remise au moins une fois par canal disponible ; message minimal sur les canaux externes ; aucune trace perdue.

TABLE 6.25: *Fiche de spécification : remise multicanal avec réessais*

Déroulement procédural étape par étape :

1. **Création des traces :** pour chaque (x, c) avec $x \in \mathscr{R}$ et $c \in x.\text{channels}$, insérer `DeliveryTrace` à l'état `EN_ATTENTE`, tentative 0, prochaine tentative immédiate ; passer N à `EN_REMISE`.

2. **Mise en forme :** charger le gabarit $(N.\text{type}, c)$ et le rendre avec les variables de N ; pour $c \in \{\texttt{MESSAGERIE}, \texttt{SMS}\}$, vérifier que le gabarit est marqué minimal et que le rendu ne contient ni identifiant d'institution en clair, ni donnée d'incident, ni libellé d'objet : seulement le type, le niveau, l'identifiant de notification et l'invitation à se connecter.

3. **Tentative de remise :** appeler le port du canal : `PLATEFORME` (écriture dans le centre de notifications, toujours réussie dans la transaction), `POUSSE` (`PushChannelPort.push`, qui publie `notification.push-requested.v1` filtré par utilisateur et institution vers `MS-GATEWAY`), `MESSAGERIE` (`MailChannelPort.send`), `SMS` (`SmsChannelPort.send`). Une

réponse positive passe la trace à `REMISE` avec l'horodatage et insère `notification.delivered.v1`.

4. **Réessai :** sur erreur, incrémenter k et, si $k < k_{\max}$, programmer la prochaine tentative :

$$t_{k+1} = t_{\text{now}} + \min\left(b \cdot 2^k, \Delta_{\max}\right) + \eta, \qquad \eta \sim \mathscr{U}(0,\ b) \tag{6.25}$$

le terme aléatoire η évitant la synchronisation des réessais après une panne du canal ; conserver la dernière erreur dans la trace.

5. **Rebut :** lorsque $k = k_{\max}$, passer la trace à `ECHOUEE` et insérer `notification.delivery-failed.v1` (destinataire, canal, dernière erreur) ; `MS-MONITORING` lève une alerte sur le canal ; si toutes les traces externes d'une notification urgente ou critique sont en échec alors que la remise dans la plateforme a réussi, l'escalade (algorithme 6.23) se poursuit sur la seule base du délai d'acquittement.

6. **État de la notification :** N passe à `REMISE` dès qu'une trace au moins est `REMISE` ; à `REBUT` si toutes le sont `ECHOUEE`, ce qui ne peut arriver que par échec d'écriture dans le centre de notifications, cas traité comme incident de la plateforme.

Algorithme 6.23 : Acquittement obligatoire et escalade temporisée vers le suppléant Cet algorithme impose, pour les niveaux urgent et critique, un acquittement explicite dans un délai, et escalade vers le suppléant lu dans l'annuaire compétent lorsque le délai expire. Il est déclenché par l'ordonnanceur, qui examine périodiquement les notifications en retard.

Spécification formelle de l'algorithme 6.23 : acquittement et escalade	
Entrées	Notification N de niveau $\geq$ `URGENT` ; délai δ_u (10 min critique, 30 min urgent) ; niveau d'escalade courant ℓ ; $L_{\max} = 3$.
Sorties	`Escalation` et nouveau destinataire, ou clôture par `ACQUITTEE` ; événements `notification.acknowledged.v1`, `notification.escalated.v1`.
Complexité	$\mathscr{O}(1)$ par notification en retard ; une lecture d'annuaire par escalade.
Contrôles	Acquittement authentifié et horodaté ; suppléant lu dans `MS-IAM` ou `MS-PARTICIPANT` ; dernier niveau signalé à `MS-INCIDENT`.

TABLE 6.26: *Fiche de spécification : acquittement et escalade temporisée*

Déroulement procédural étape par étape :

1. **Fixation du délai :** à la création de N, si N.urgency $\geq$ `URGENT`, poser N.ackDeadline $=$ N.requestedAt $+ \delta_u$ et $\ell = 0$; la lecture dans le centre de notifications ne vaut pas acquittement à ces niveaux.

2. **Acquittement :** sur `acknowledge`(x, N, c), vérifier que x est l'un des destinataires courants de N (initial ou suppléant) et que le jeton interne porte son identité ; passer toutes les traces de x à `ACQUITTEE`, N à `ACQUITTEE`, insérer `notification.acknowledged.v1` (destinataire, canal, délai écoulé) et annuler toute escalade programmée. Le délai écoulé alimente l'indicateur de réactivité de `MS-REPORTING`.

3. **Détection du retard :** l'ordonnanceur appelle `NotificationRepositoryPort.overdue`(t_{now}) ; pour chaque N retournée avec $\ell < L_{\max}$, passer à l'étape suivante.

4. **Lecture du suppléant :** pour chaque destinataire x sans acquittement, lire le suppléant y :

$$y = \begin{cases} \text{InternalDirectory.escalationTarget}(x, \ell+1) & x \text{ collaborateur} \\ \text{InstitutionContact.escalationTarget}(x.\text{inst}, \ell+1) & x \text{ correspondant} \end{cases} \tag{6.26}$$

   Si aucun suppléant n'est défini, retenir le chef du DES pour un collaborateur, ou le correspondant principal de l'institution et l'ingénieur d'homologation référent pour un participant.

5. **Escalade :** insérer `Escalation`$(N, x, y, \ell+1, t_{\text{now}})$, résoudre les canaux de y (algorithme 6.21, étape 4), remettre à y avec la mention de l'escalade (algorithme 6.22), poser N.ackDeadline $= t_{\text{now}} + \delta_u/2$, $\ell \leftarrow \ell + 1$, passer N à `ESCALADEE` et insérer `notification.escalated.v1`. Le destinataire initial conserve la notification et peut encore l'acquitter.

6. **Dernier niveau :** lorsque $\ell = L_{\max}$ sans acquittement, insérer `notification.escalation-exhausted.v1`, consommé par `MS-INCIDENT`, qui ouvre ou requalifie un ticket, et par `MS-REPORTING` ; aucune escalade supplémentaire n'est tentée.

Algorithme 6.24 : Consolidation anti-tempête par fenêtre de regroupement Cet algorithme retient, pendant une fenêtre de courte durée, les notifications de faible niveau partageant une même clé de regroupement, et les remet en une synthèse unique ; il protège les destinataires des rafales (alertes répétées d'une même liaison, tâches créées en lot) sans jamais retarder une notification urgente ou critique.

Spécification formelle de l'algorithme 6.24 : consolidation anti-tempête	
Entrées	Notification N de niveau $\leq$ `AVERTISSEMENT` avec clé $g = (\text{type}, \text{objet})$; durée de fenêtre $w = 5$ min ; seuil $m = 3$.
Sorties	Remise immédiate, ou rattachement à une fenêtre et remise d'une synthèse à sa fermeture ; événement `notification.consolidated.v1`.
Complexité	$\mathcal{O}(1)$ par notification ; une remise par fenêtre au lieu de $\lvert W \rvert$.
Garantie	Aucune notification perdue (chaque membre reste consultable) ; latence bornée par w ; niveaux urgent et critique jamais consolidés.

TABLE 6.27: *Fiche de spécification : consolidation anti-tempête*

Déroulement procédural étape par étape :

1. **Éligibilité :** si N.urgency $\geq$ `URGENT` ou si N ne porte pas de clé de regroupement, remettre immédiatement (algorithme 6.22) ; sinon calculer g.

2. **Fenêtre ouverte :** chercher la fenêtre non close de clé g ; si elle existe, y ajouter N (état `CONSOLIDEE`) et terminer : la notification reste consultable individuellement dans le centre de notifications, mais n'est pas remise sur les canaux externes.

3. **Première occurrence :** sinon, remettre N normalement et ouvrir une fenêtre $W(g)$ de $[t_{\text{now}},\ t_{\text{now}} + w]$; les occurrences suivantes de g pendant la fenêtre seront retenues.

4. **Fermeture :** à $t_{\text{now}} + w$, l'ordonnanceur clôt $W(g)$; si $\lvert W \rvert \geq m$, construire la synthèse (type, objet, nombre d'occurrences, première et dernière, niveau maximal des membres) et la remettre comme une notification unique ; si $\lvert W \rvert < m$, remettre individuellement les membres retenus. Insérer `notification.consolidated.v1` avec la liste des membres.

5. **Fenêtre glissante :** si des occurrences continuent d'arriver, ouvrir une nouvelle fenêtre dont la durée double à chaque fermeture consécutive de même clé, jusqu'à un plafond de trente minutes, puis revenir à w après une fenêtre vide ; le nombre de remises pour une rafale de n occurrences sur une durée T est ainsi borné par $\mathcal{O}(\log T)$.

6. **Changement de niveau :** si une occurrence de clé g arrive avec un niveau urgent ou critique, elle est remise immédiatement et la fenêtre en cours est close par anticipation, sa synthèse étant jointe à la notification urgente.

6.1.6 Référentiels et gestion des participants (MS-PARTICIPANT)

Le service `MS-PARTICIPANT` tient le registre institutionnel des membres du réseau GIMAC-PAY : banques, établissements de microfinance, établissements de paiement, opérateurs de monnaie électronique et Trésors publics des six pays de la CEMAC. Il porte le cycle de vie de chaque institution par un automate d'états dont toute transition est approuvée selon le principe du maker-checker, la fiche institutionnelle, les conventions, les services souscrits, les correspondants, les pièces légales et la veille de leurs échéances (J-90, J-60, J-30, J-0), le journal des interactions et l'annuaire d'escalade. Il est la clé pivot des autres domaines : `MS-HOMOLOGATION`, `MS-INCIDENT`, `MS-RAPPROCHEMENT` et `MS-REPORTING` ne détiennent de l'institution que son identifiant et lisent la fiche par un appel synchrone. Le service ne détient aucune donnée de routage monétique (ni plage d'identification d'émetteur, ni table ni code de routage), aucune clé et aucune donnée de carte : il ne participe à aucun flux transactionnel. Lorsqu'une institution cesse d'être conforme, la plateforme le signale à la production monétique et à la Direction, trace la décision, mais ne suspend rien techniquement : la suspension effective est décidée et exécutée hors de la plateforme, puis attestée par une transition de statut approuvée. Le scellement probant des décisions est confié à `MS-AUDIT`, qui consomme les événements publiés par le service.

6.1.6.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : COBAC, PCI-DSS v4.0.1 et ISO/IEC 27001

- **Règlements COBAC R-2016/04 et R-2024/01 :** l'admission, le maintien et le retrait d'un membre du réseau reposent sur des pièces légales (agrément, arrêté, attestation) dont la validité doit être suivie et dont l'expiration doit être signalée à la tutelle et à la Direction. Toute décision relative au statut d'un membre est nominative, motivée, approuvée par une seconde personne et publiée vers `MS-AUDIT`, qui l'inscrit comme feuille de l'arbre de Merkle (RFC 9162) et en fournit des preuves d'inclusion aux auditeurs.
- **PCI-DSS v4.0.1, exigence 12.8 :** le groupement tient l'inventaire des tiers avec lesquels des données de compte sont échangées, la description du service rendu et le suivi de leur conformité. La fiche institutionnelle, les services souscrits et l'état de conformité documentaire outillent cet inventaire ; le service reste hors de l'environnement des données de titulaires de cartes, puisqu'il ne stocke ni PAN ni plage d'identification d'émetteur.
- **ISO/IEC 27001 :** les relations avec les tiers sont encadrées par des conventions dont les échéances sont surveillées ; les correspondants et contacts d'escalade sont désignés, joignables et tenus à jour.
- **NIST SP 800-207 :** le service n'est joignable que par `MS-GATEWAY` (couches de

présentation) ou en mTLS avec un jeton interne réduit (services internes) ; il ne dialogue jamais directement avec le fournisseur d'identité ni avec l'annuaire d'entreprise.

Registre institutionnel, conventions et services souscrits La fiche d'une institution porte sa dénomination, son sigle, son code participant, son code d'identification, son pays, sa catégorie, son mode d'adhésion (direct, ou indirect par l'intermédiaire d'une banque marraine), sa banque de règlement, sa date d'adhésion, son statut et son état de conformité documentaire. Les conventions (adhésion, service, délégation) attestent du lien contractuel : chacune référence la pièce déposée dans `MS-DOCUMENT` par son identifiant et son empreinte SHA-256, sans copie locale du document. Les services souscrits (transfert de compte à compte, retrait, paiement marchand par code QR, paiement de proximité par carte, entre autres) décrivent ce à quoi le membre a souscrit ; leur souscription est publiée (`participant.service-subscribed.v1`) et consommée par `MS-HOMOLOGATION`, qui en déduit le périmètre contractualisé de la liaison. Les correspondants nomment, pour chaque fonction (direction, monétique, exploitation 24/7, sécurité), qui contacter et par quel canal ; leur clé publique, lorsqu'elle est fournie, sert à vérifier les documents signés que l'institution dépose.

Automate d'états du cycle de vie institutionnel et principe du maker-checker Le cycle de vie est régi par un automate à six états : `CANDIDAT` (dossier déposé), `EN_HOMOLOGATION` (convention signée, liaison ouverte dans `MS-HOMOLOGATION`), `ACTIF` (attestation de mise en service émise par `MS-CERTIFICATION`), `A_REGULARISER` (état de surveillance du cahier d'analyse : pièce expirant à J-30 ou non-conformité constatée), `SUSPENDU` (suspension décidée et exécutée hors de la plateforme, attestée dans le registre) et `RETIRE` (état terminal). Les transitions autorisées sont : `CANDIDAT` vers `EN_HOMOLOGATION` ; `EN_HOMOLOGATION` vers `ACTIF` (sous condition des événements `certification.attestation-issued.v1` puis `certification.go-live-authorized.v1` reçus pour l'institution) ; `ACTIF` vers `A_REGULARISER`, `SUSPENDU` ou `RETIRE` ; `A_REGULARISER` vers `ACTIF` ou `SUSPENDU` ; `SUSPENDU` vers `ACTIF` ou `RETIRE`. Toute transition est une entité `StatusTransition` proposée par un demandeur (maker) et approuvée ou rejetée par un approbateur (checker) de niveau d'habilitation 2, distinct du demandeur ; l'automate rejette toute proposition dont l'approbateur est le demandeur. La transition vers `SUSPENDU` n'a aucun effet technique : elle consigne qu'une suspension a été décidée et exécutée par la production monétique.

Pièces légales, veille des échéances et état de conformité documentaire

- **Dépôt :** une pièce légale est déposée par le portail des participants ou par l'application web du DES ; le fichier transite par `MS-DOCUMENT` (analyse antivirale, contrôle de masquage, empreinte SHA-256, rétention en mode conformité dans le dépôt objet WORM,

dix ans). `MS-PARTICIPANT` n'enregistre que la référence, l'empreinte, le type, les dates de délivrance et d'expiration et l'état de la pièce, puis arme quatre échéances.

- **Veille :** un balayage quotidien évalue le délai restant de chaque pièce et déclenche, à J-90, une information au correspondant ; à J-60, un courrier à la direction du membre ; à J-30, une mise en demeure et la proposition de transition vers `A_REGULARISER` ; à J-0, le signalement de non-conformité à la production monétique et à la Direction (algorithme 6.29).
- **État de conformité :** l'état `CONFORME`, `A_REGULARISER` ou `NON_CONFORME` est calculé par agrégation des pièces légales, des conventions et de leurs échéances (algorithme 6.27) ; tout changement est publié (`participant.compliance-changed.v1`).

Annuaire d'escalade et journal des interactions L'annuaire d'escalade associe à chaque institution, pour chaque sévérité S1 à S4, une liste ordonnée de contacts : correspondant titulaire, suppléant et délai d'acquittement. Il est lu par `MS-NOTIFICATION`, qui escalade vers le suppléant en l'absence d'acquittement dans le délai, et par `MS-INCIDENT`, qui y puise les destinataires d'un incident ou d'une cellule de crise. Le journal des interactions consigne en ajout seul chaque échange avec le membre (courrier, réunion, mise en demeure, appel), son auteur, sa date et sa référence (ticket, liaison, réunion) ; `MS-INCIDENT` et `MS-HOMOLOGATION` y inscrivent leurs propres interactions par événement.

Non-intrusion et cohérence événementielle

- **Aucune donnée de routage, aucune action sur la production :** le modèle ne contient ni plage d'identification d'émetteur, ni adresse de raccordement, ni certificat de production, ni table de routage. Le commutateur et le simulateur de certification ne sont jamais appelés par ce service.
- **Transactional Outbox :** toute mutation (fiche, convention, service souscrit, correspondant, pièce, échéance, interaction, contact d'escalade, transition) écrit, dans la même transaction, l'état et l'événement correspondant dans la table d'outbox ; un processus d'arrière-plan publie sur le bus d'événements (enveloppe CloudEvents, livraison au moins une fois, ordre par institution).
- **Sujets publiés :** six sujets sont émis :
  - `participant.status-changed.v1` (transition approuvée) ;
  - `participant.document-expiring.v1` (seuil d'échéance atteint) ;

- `participant.compliance-changed.v1` (état de conformité recalculé) ;
- `participant.service-subscribed.v1` (service souscrit ou résilié) ;
- `participant.interaction-recorded.v1` (journal des interactions) ;
- `participant.notification-requested.v1` (demande de notification).

`MS-AUDIT` consomme tous les événements à effet ; `MS-HOMOLOGATION`, `MS-NOTIFICATION` et `MS-REPORTING` consomment ceux qui les concernent.

6.1.6.2 Diagramme de composants internes de MS-PARTICIPANT

La Figure 6.16 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les commandes de l'application web du DES et du portail des participants (via `MS-GATEWAY`), les lectures synchrones des services internes, le réveil quotidien de l'ordonnanceur et les événements du bus ; le cœur porte les neuf entités du domaine 2 ; les adaptateurs pilotés dialoguent avec la base relationnelle du service, `MS-DOCUMENT`, `MS-NOTIFICATION` et le bus d'événements.

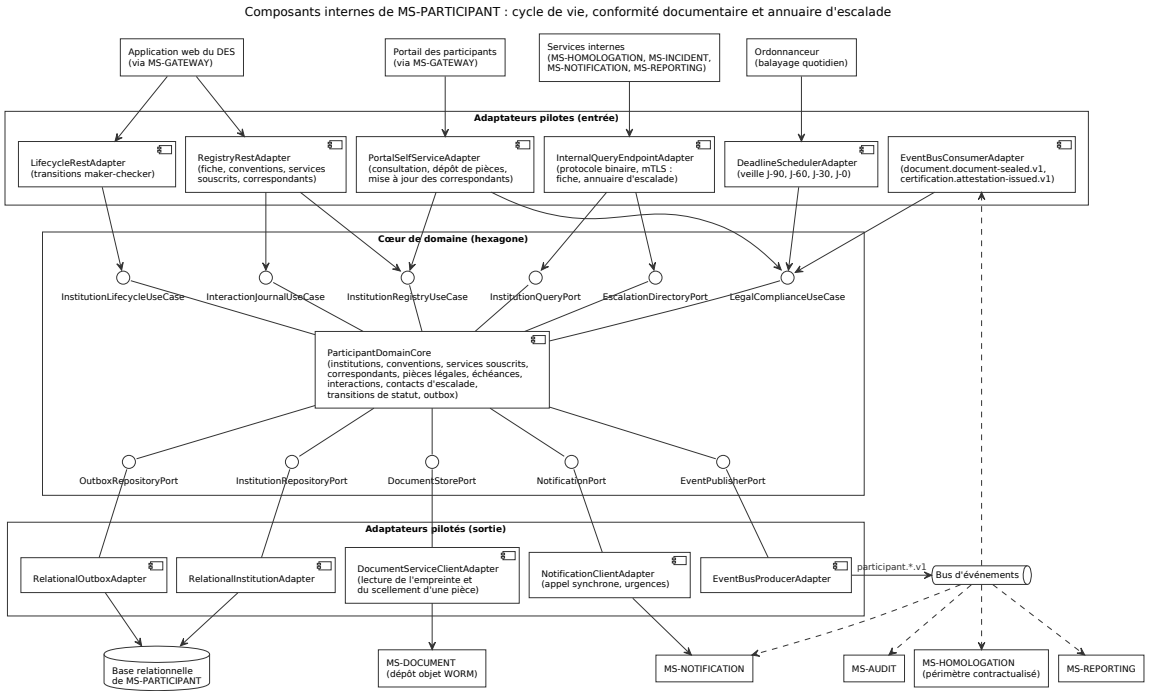


FIGURE 6.16: *Diagramme de composants internes : référentiels et gestion des participants*

- **Adaptateurs pilotes (entrée) :** `RegistryRestAdapter` (fiche, conventions, services souscrits, correspondants, interactions) ; `LifecycleRestAdapter` (proposition, approbation et rejet des transitions) ; `PortalSelfServiceAdapter` (consultation de la fiche par le représentant du participant, dépôt de pièces, mise à jour des correspondants, dans le périmètre de sa seule institution) ; `InternalQueryEndpointAdapter`

(protocole binaire sous mTLS : lecture de la fiche, des services souscrits et de l'annuaire d'escalade) ; `DeadlineSchedulerAdapter` (balayage quotidien des échéances) ; `EventBusConsumerAdapter` (`document.document-sealed.v1` pour rattacher l'empreinte d'une pièce, `certification.attestation-issued.v1` comme prérequis de l'activation).

- **Cœur de domaine :** `ParticipantDomainCore` expose `InstitutionRegistryUseCase`, `InstitutionLifecycleUseCase`, `LegalComplianceUseCase`, `InteractionJournalUseCase`, `InstitutionQueryPort` et `EscalationDirectoryPort`, et requiert cinq ports secondaires.
- **Adaptateurs pilotés (sortie) :** `RelationalInstitutionAdapter` et `RelationalOutboxAdapter` (base relationnelle du service, politiques de lignes par institution) ; `DocumentServiceClientAdapter` (lecture de l'empreinte et de l'état de scellement d'une pièce dans `MS-DOCUMENT`) ; `NotificationClientAdapter` (appel synchrone au port de `MS-NOTIFICATION` pour les signalements urgents) ; `EventBusProducerAdapter`.
- **Interactions :** `MS-HOMOLOGATION`, `MS-INCIDENT`, `MS-NOTIFICATION` et `MS-REPORTING` en lecture synchrone de la fiche et de l'annuaire d'escalade ; `MS-AUDIT`, `MS-HOMOLOGATION`, `MS-NOTIFICATION` et `MS-REPORTING` en consommateurs des événements `participant.*.v1`.

6.1.6.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.17 détaille les classes du domaine, les ports et les adaptateurs. Les neuf entités du domaine 2 du cahier d'analyse y sont reprises avec leurs types et leurs signatures ; aucune classe de routage n'y figure.

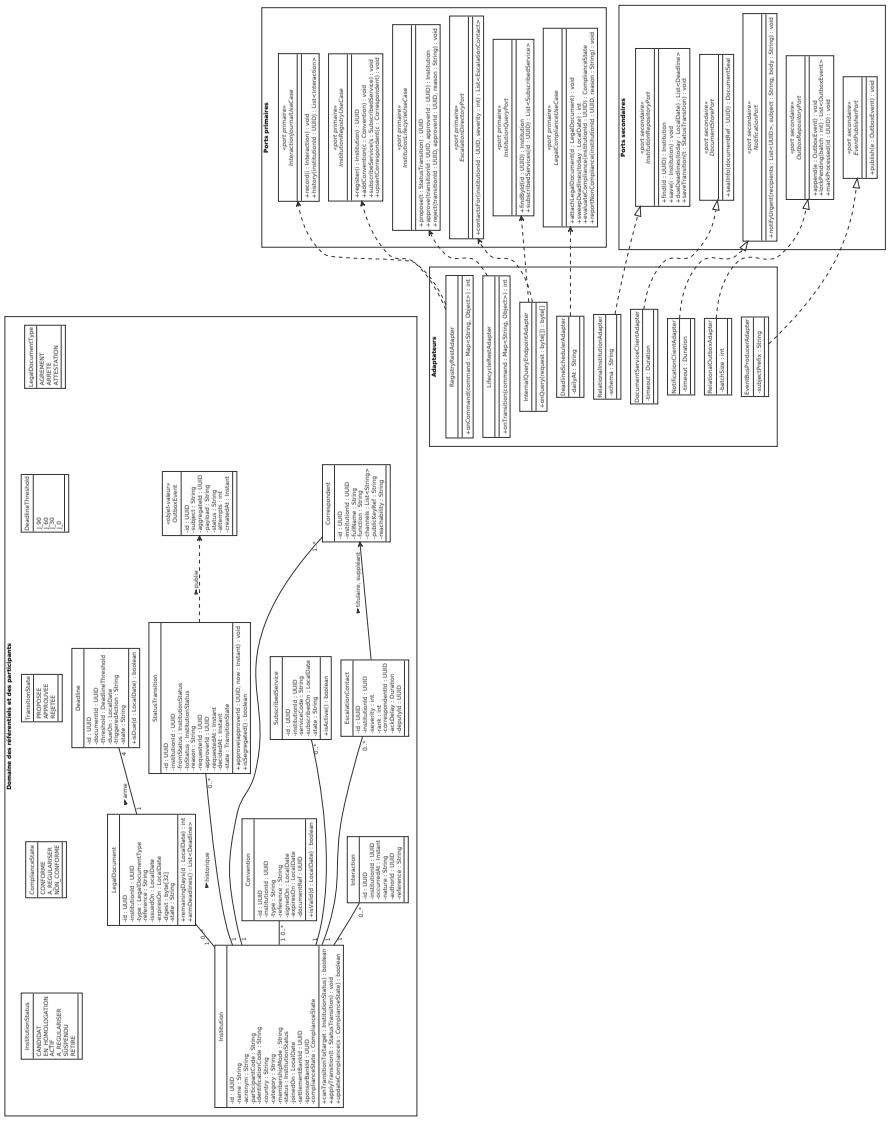


FIGURE 6.17: *Diagramme de classes de conception : service MS-PARTICIPANT*

- **Entités :** `Institution` (`participantCode`, `identificationCode`, `country`, `category`, `membershipMode` : `String`, `status` : `InstitutionStatus`, `joinedOn` : `LocalDate`, `settlementBankId`, `sponsorBankId` : `UUID`, `complianceState` : `ComplianceState`, méthodes `canTransitionTo`, `applyTransition`, `updateCompliance`) ; `Convention` (`type`, `reference`, `signedOn`, `expiresOn` : `LocalDate`, `documentRef` : `UUID`) ; `SubscribedService` (`serviceCode`, `subscribedOn`, `state`) ; `Correspondent` (`function`, `channels` : `List<String>`, `publicKeyRef`, `reachability`) ; `LegalDocument` (`type` : `LegalDocumentType`, `reference`, `issuedOn`, `expiresOn`, `digest` : `byte[32]`, `state`, méthodes `remainingDays`, `armDeadlines`) ; `Deadline` (`threshold` : `DeadlineThreshold`, `dueOn`, `triggeredAction`, `state`) ; `Interaction` (`occurredAt` : `Instant`, `nature`, `authorId`, `reference`) ; `EscalationContact` (`severity`, `rank` : `int`, `correspondentId`, `deputyId` : `UUID`, `ackDelay` : `Duration`) ; `StatusTransition` (`fromStatus`, `toStatus`, `reason`, `requesterId`, `approverId`, `requestedAt`, `decidedAt`, `state` : `TransitionState`, méthodes `approve`, `isSegregated`).
- **Énumérations et objets-valeurs :** `InstitutionStatus` (six états), `ComplianceState`, `TransitionState`, `DeadlineThreshold` (`J_90`, `J_60`, `J_30`, `J_0`), `LegalDocumentType` ; `OutboxEvent` (`subject`, `aggregateId`, `payload`, `status`, `attempts`).
- **Ports primaires :** `InstitutionRegistryUseCase` (`register`, `addConvention`, `subscribeService`, `upsertCorrespondent`) ; `InstitutionLifecycleUseCase` (`propose`, `approve`, `reject`) ; `LegalComplianceUseCase` (`attachLegalDocument`, `sweepDeadlines`, `evaluateCompliance`, `reportNonCompliance`) ; `InteractionJournalUseCase` (`record`, `history`) ; `InstitutionQueryPort` (`findById`, `subscribedServices`) ; `EscalationDirectoryPort` (`contactsFor`).
- **Ports secondaires :** `InstitutionRepositoryPort` (`find`, `save`, `dueDeadlines`, `saveTransition`), `DocumentStorePort` (`sealInfo`), `NotificationPort` (`notifyUrgent`), `OutboxRepositoryPort`, `EventPublisherPort`.
- **Adaptateurs :** `RegistryRestAdapter`, `LifecycleRestAdapter`, `InternalQueryEndpointAdapter` et `DeadlineSchedulerAdapter`

pilotent les ports primaires ; `RelationalInstitutionAdapter`, `DocumentServiceClientAdapter`, `NotificationClientAdapter`, `RelationalOutboxAdapter` et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.6.4 Diagramme d'objets du service MS-PARTICIPANT

La Figure 6.18 capture l'instant qui suit le balayage quotidien des échéances : l'agrément de l'Établissement de paiement A expire dans trente jours, l'échéance J-30 vient d'être déclenchée, la mise en demeure a été consignée dans le journal des interactions, la transition de `ACTIF` vers `A_REGULARISER` a été proposée par le responsable normes et agréments et approuvée par le chef du DES, et l'événement de changement d'état de conformité attend sa publication.

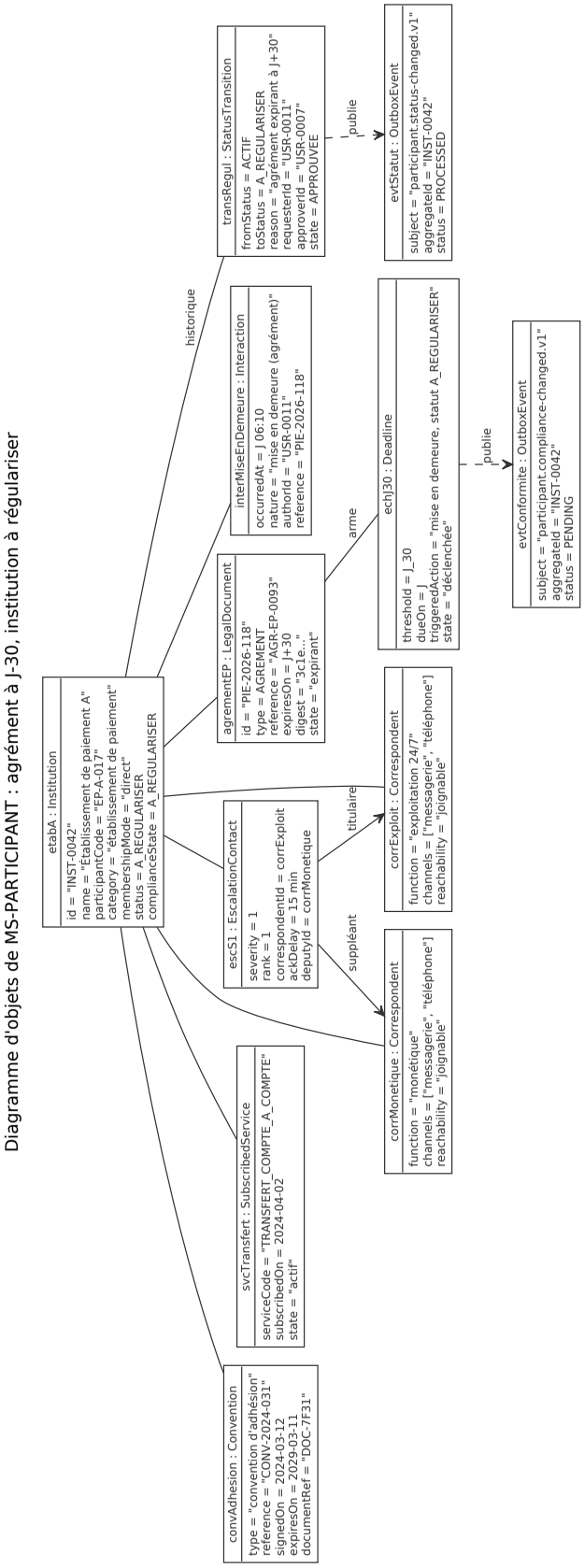


FIGURE 6.18: *Diagramme d'objets : agrément à J-30, institution à régulariser*

- `etabA : Institution`, identifiant `INST-0042`, dénomination « Établissement de paiement A », code participant `EP-A-017`, adhésion directe, statut `A_REGULARISER`, état de conformité `A_REGULARISER` ;
- `convAdhesion : Convention`, convention d'adhésion `CONV-2024-031`, signée en mars 2024, valable jusqu'en mars 2029, pièce `DOC-7F31` ; `svcTransfert : SubscribedService`, service de transfert de compte à compte, actif ;
- `corrMonetique` et `corrExploit : Correspondent`, fonctions monétique et exploitation 24/7, joignables par messagerie et téléphone ;
- `agrementEP : LegalDocument`, agrément `AGR-EP-0093`, identifiant `PIE-2026-118`, expirant à J+30, empreinte connue, état « expirant » ; `echJ30 : Deadline`, seuil `J_30`, échue ce jour, action « mise en demeure, statut `A_REGULARISER` », déclenchée ;
- `escS1 : EscalationContact`, sévérité 1, rang 1, titulaire `corrExploit`, suppléant `corrMonetique`, délai d'acquittement de quinze minutes ;
- `interMiseEnDemeure : Interaction`, mise en demeure consignée à 06h10 par `USR-0011`, référence `PIE-2026-118` ;
- `transRegul : StatusTransition`, de `ACTIF` vers `A_REGULARISER`, demandée par `USR-0011`, approuvée par `USR-0007` ;
- `evtStatut : OutboxEvent`, sujet `participant.status-changed.v1`, publié ; `evtConformite : OutboxEvent`, sujet `participant.compliance-changed.v1`, en attente.

6.1.6.5 Algorithmes fondamentaux de MS-PARTICIPANT

Cette section formalise les cinq algorithmes qui régissent l'automate du cycle de vie et sa validation maker-checker, la veille des échéances, le calcul de l'état de conformité documentaire, la publication des événements et le signalement d'une non-conformité à la production monétique.

Algorithme 6.25 : Automate d'états du cycle de vie institutionnel et validation maker-checker Cet algorithme garantit qu'aucune transition de statut ne survient hors de la relation de transition de l'automate, que toute transition est approuvée par une seconde personne habilitée et distincte du demandeur, et que les prérequis propres à chaque état d'arrivée sont vérifiés avant persistance.

Spécification formelle de l'algorithme 6.25 : automate et maker-checker	
Entrées	Institution I d'état s ; proposition $T = (s, s', \text{motif}, \text{demandeur})$; décision (approbateur, verdict) ; t_{now}.
Sorties	I.status $= s'$ persisté, `StatusTransition` approuvée, événement `participant.status-changed.v1` ; ou rejet motivé.
Complexité	$\mathcal{O}(1)$ par transition (relation de transition en mémoire, une lecture et une écriture en base).
Contrôles	Relation δ fermée ; approbateur de niveau 2 ; approbateur $\neq$ demandeur ; prérequis par état d'arrivée.

TABLE 6.28: *Fiche de spécification : automate du cycle de vie et maker-checker*

Déroulement procédural étape par étape :

1. **Vérification de la relation de transition :** l'automate est défini par $\mathscr{A} = (S, \delta)$ avec S l'ensemble des six états et $\delta \subset S \times S$ la relation autorisée :

$$\begin{aligned}\delta = \{&(\texttt{CAN}, \texttt{HOM}),\ (\texttt{HOM}, \texttt{ACT}),\ (\texttt{ACT}, \texttt{REG}),\ (\texttt{ACT}, \texttt{SUS}),\ (\texttt{ACT}, \texttt{RET}),\\ &(\texttt{REG}, \texttt{ACT}),\ (\texttt{REG}, \texttt{SUS}),\ (\texttt{SUS}, \texttt{ACT}),\ (\texttt{SUS}, \texttt{RET})\}\end{aligned} \tag{6.27}$$

   Si $(s, s') \notin \delta$, rejeter la proposition avec le motif « transition non autorisée » sans créer d'entité.

2. **Enregistrement de la proposition :** créer `StatusTransition` à l'état `PROPOSEE` avec le demandeur, le motif et t_{now} ; insérer `participant.notification-requested.v1` dans l'outbox pour convoquer un approbateur de niveau 2. Une seule proposition peut être en attente par institution.

3. **Séparation des pouvoirs :** à la réception de la décision, vérifier dans le jeton interne réduit que l'approbateur possède le niveau 2 et que approbateur $\neq$ demandeur ; sinon rejeter la décision, la journaliser (`participant.transition-rejected.v1`) et laisser la proposition en attente d'un autre approbateur.

4. **Prérequis de l'état d'arrivée :** pour `EN_HOMOLOGATION`, exiger une convention d'adhésion valide et au moins un correspondant par fonction ; pour `ACTIF`, exiger les événements `certification.attestation-issued.v1` et `certification.go-live-authorized.v1` reçus pour l'institution et un état de conformité `CONFORME` ; pour `SUSPENDU`, exiger la référence de la décision prise hors de la plateforme (procès-verbal ou courrier déposé dans `MS-DOCUMENT`) ; pour `RETIRE`, exiger l'absence de liaison ouverte dans `MS-HOMOLOGATION` et de dossier de suspens ouvert dans `MS-RAPPROCHEMENT`, connus par événement.

5. **Persistance atomique :** dans une même transaction, passer la proposition à `APPROUVEE` avec l'approbateur et t_{now}, mettre à jour $I.\text{status} \leftarrow s'$, consigner une interaction « changement de statut » et insérer `participant.status-changed.v1` dans l'outbox (algorithme 6.28).

6. **Publication et effets :** l'événement est consommé par `MS-AUDIT` (feuille de l'arbre), par `MS-HOMOLOGATION` (ouverture ou gel de la liaison), par `MS-NOTIFICATION` (information des correspondants) et par `MS-REPORTING`. Aucun effet n'est produit sur le commutateur.

Algorithme 6.26 : Veille des échéances des agréments et des pièces légales Cet algorithme planifié évalue chaque jour le délai restant des pièces légales et des conventions, déclenche les actions graduées des seuils J-90, J-60, J-30 et J-0 et arme les échéances à chaque dépôt. Il ne suspend rien : il informe, met en demeure, propose une transition et, à J-0, déclenche le signalement.

Spécification formelle de l'algorithme 6.26 : veille des échéances	
Entrées	Date du jour d ; ensemble $\mathscr{E}_d$ des échéances dont `dueOn` $\leq d$ et `state` $=$ `ARMEE`.
Sorties	Échéances passées à `DECLENCHEE` ; événements `participant.document-expiring.v1` ; propositions de transition ; signalements.
Complexité	$\mathcal{O}(\lvert\mathscr{E}_d\rvert)$, avec un index sur (`state`, `dueOn`) ; exécution idempotente.
Périodicité	Quotidienne, hors vacation de nuit ; relance manuelle possible par le responsable conformité.

TABLE 6.29: *Fiche de spécification : veille des échéances*

Déroulement procédural étape par étape :

1. **Armement au dépôt :** lorsqu'une pièce ou une convention d'expiration D est enregistrée, créer quatre échéances de seuils $k \in \{90, 60, 30, 0\}$:

$$\text{dueOn}_k = D - k \text{ jours}, \qquad \text{state}_k = \texttt{ARMEE} \tag{6.28}$$

   Une échéance dont la date est déjà passée au moment du dépôt est créée directement à l'état `OBSOLETE`.

2. **Sélection du jour :** charger $\mathscr{E}_d$ par le port `dueDeadlines`(d) ; le traitement de chaque échéance est une transaction propre, ce qui rend un rejeu partiel inoffensif.

3. **Action graduée :** selon le seuil de l'échéance,
   - J-90 : insérer `participant.document-expiring.v1` (urgence faible) à destination du correspondant de la fonction concernée ;
   - J-60 : même événement avec urgence moyenne, destinataires étendus à la direction du membre ;
   - J-30 : consigner une interaction « mise en demeure », émettre l'événement en urgence élevée et proposer la transition vers `A_REGULARISER` (algorithme 6.25) ;
   - J-0 : invoquer le calcul de conformité (algorithme 6.27) puis, si l'état devient `NON_CONFORME`, le signalement (algorithme 6.29).
4. **Clôture de l'échéance :** passer l'échéance à `DECLENCHEE` avec la date et l'action effectuée dans la même transaction que l'insertion en outbox.
5. **Renouvellement :** à la réception d'une pièce renouvelée du même type, passer les échéances non déclenchées de l'ancienne pièce à `OBSOLETE`, marquer l'ancienne pièce « remplacée », armer les échéances de la nouvelle et relancer le calcul de conformité, qui peut proposer le retour à `ACTIF`.

Algorithme 6.27 : Calcul de l'état de conformité documentaire d'une institution Cet algorithme agrège les pièces légales exigées, les conventions et leurs échéances en un état unique `CONFORME`, `A_REGULARISER` ou `NON_CONFORME`, détermine l'effet sur le statut et notifie les parties. Il est invoqué à chaque dépôt, à chaque échéance déclenchée et sur demande du responsable conformité.

Spécification formelle de l'algorithme 6.27 : état de conformité documentaire	
Entrées	Institution I ; ensemble $\mathscr{R}(I.\text{category})$ des types de pièces exigés ; pièces $\mathscr{P}$, conventions $\mathscr{C}$; date d.
Sorties	État $c \in \{\texttt{CONFORME}, \texttt{A_REGULARISER}, \texttt{NON_CONFORME}\}$; événement `participant.compliance-changed.v1` si c change.
Complexité	$\mathscr{O}(\lvert\mathscr{P}\rvert + \lvert\mathscr{C}\rvert)$; fonction pure de l'état persisté, donc rejouable.
Standard	PCI-DSS v4.0.1 exigence 12.8 ; règlements COBAC R-2016/04 et R-2024/01 (pièces d'agrément).

TABLE 6.30: *Fiche de spécification : état de conformité documentaire*

Déroulement procédural étape par étape :

1. **Pièces exigées :** déterminer $\mathscr{R}$ selon la catégorie de l'institution (par exemple agrément et arrêté pour une banque ; agrément de l'autorité compétente et attestation pour un établissement de paiement) et la convention d'adhésion, exigée pour toute catégorie.

2. **Délai résiduel par type :** pour chaque type $r \in \mathscr{R}$, retenir la pièce valide la plus récente et calculer son délai résiduel ; une pièce absente ou dont l'empreinte n'est pas confirmée par `MS-DOCUMENT` vaut un délai $-\infty$:

$$\Delta_r = \max_{p \in \mathscr{P},\ p.\text{type}=r,\ p.\text{sealed}} \big(p.\text{expiresOn} - d\big), \qquad \Delta_{\text{conv}} = \max_{c \in \mathscr{C}} \big(c.\text{expiresOn} - d\big) \tag{6.29}$$

3. **Agrégation :** l'état est dicté par le délai le plus court :

$$\Delta^* = \min\Big(\Delta_{\text{conv}},\ \min_{r \in \mathscr{R}} \Delta_r\Big), \qquad c = \begin{cases} \texttt{NON_CONFORME} & \text{si } \Delta^* \le 0 \\ \texttt{A_REGULARISER} & \text{si } 0 < \Delta^* \le 30 \\ \texttt{CONFORME} & \text{sinon} \end{cases} \tag{6.30}$$

4. **Effet sur le statut :** si $c = \texttt{A_REGULARISER}$ et $I.\text{status} = \texttt{ACTIF}$, proposer la transition vers `A_REGULARISER` ; si $c = \texttt{CONFORME}$ et $I.\text{status} = \texttt{A_REGULARISER}$, proposer le retour à `ACTIF` ; si $c = \texttt{NON_CONFORME}$, déclencher le signalement (algorithme 6.29). Dans tous les cas, la transition reste soumise au maker-checker.

5. **Persistance et notification :** si $c \neq I.\text{complianceState}$, mettre à jour l'institution, consigner une interaction « état de conformité recalculé » et insérer `participant.compliance-changed.v1` portant l'ancien état, le nouvel état, la pièce déterminante et Δ^* ; `MS-NOTIFICATION` informe le responsable conformité et le correspondant direction du membre ; `MS-REPORTING` met à jour l'indicateur de conformité du parc.

Algorithme 6.28 : Transactional Outbox et publication des événements participant.*.v1
Cet algorithme assure la cohérence à terme entre la base relationnelle du service et ses consommateurs sans double écriture. Le scellement probant n'est pas réalisé ici : `MS-AUDIT` consomme chaque événement à effet et l'inscrit comme feuille de son arbre de Merkle.

Spécification formelle de l'algorithme 6.28 : outbox et publication	
Entrées	Mutation métier (fiche, convention, service souscrit, correspondant, pièce, échéance, interaction, contact, transition).
Sorties	État persisté ; événement publié sur le bus et acquitté ; entrée d'outbox marquée `PROCESSED`.
Garantie	Livraison au moins une fois ; ordre par institution ; consommateurs idempotents ; enveloppe CloudEvents.

TABLE 6.31: *Fiche de spécification : outbox et publication des événements participant*

Déroulement procédural étape par étape :

1. **Transaction locale :** ouvrir une transaction ; appliquer la mutation ; construire l'événement (identifiant, sujet `participant.<agrégat>-<événement>.v1`, identifiant de l'institution comme identifiant d'agrégat, horodatage, charge utile sans donnée de carte ni secret) ; l'insérer dans la table d'outbox à l'état `PENDING` ; valider. Toute erreur annule l'ensemble.

2. **Sélection d'un lot :** un processus d'arrière-plan verrouille jusqu'à 100 entrées en attente par ordre de création, sans bloquer les autres instances du service (`SELECT ... FOR UPDATE SKIP LOCKED`).

3. **Publication :** envoyer chaque entrée avec l'identifiant de l'institution comme clé de partition, ce qui conserve l'ordre des événements d'un même membre (une transition n'est jamais reçue avant la proposition qui la précède), et attendre l'acquittement du bus.

4. **Acquittement et réessais :** marquer `PROCESSED` ; en cas d'échec, incrémenter le compteur de tentatives avec délai exponentiel ; au-delà de cinq tentatives, marquer `FAILED` et lever une alerte vers `MS-MONITORING`.

5. **Consommation :** `MS-AUDIT` (toutes les entrées à effet), `MS-HOMOLOGATION` (statuts, services souscrits), `MS-NOTIFICATION` (demandes de notification, échéances), `MS-REPORTING` (tous les sujets) mémorisent les identifiants déjà traités et ignorent les doublons.

Algorithme 6.29 : Signalement d'une non-conformité à la production monétique Cet algorithme formalise ce que fait la plateforme lorsqu'une institution devient non conforme : elle bascule l'état de conformité, notifie la production monétique et la Direction par `MS-NOTIFICATION`, trace la décision et attend l'attestation de la suspension décidée hors

de la plateforme. Elle ne suspend rien techniquement et n'émet aucune commande vers le commutateur.

Spécification formelle de l'algorithme 6.29 : signalement d'une non-conformité	
Entrées	Institution I ; cause (échéance J-0, pièce invalidée, décision du responsable conformité) ; pièce déterminante ; t_{now}.
Sorties	I.complianceState = `NON_CONFORME` ; signalement remis et acquitté ; interaction consignée ; transition vers `SUSPENDU` en attente d'attestation.
Délai	Remise du signalement en moins de cinq minutes ; escalade vers les suppléants après le délai d'acquittement S1.
Contrôles	Aucune action sur la production ; attestation de la suspension soumise au maker-checker ; traçabilité par `MS-AUDIT`.

TABLE 6.32: *Fiche de spécification : signalement d'une non-conformité*

Déroulement procédural étape par étape :

1. **Bascule de l'état de conformité :** dans une transaction, passer I.complianceState ← `NON_CONFORME`, consigner une interaction « signalement de non-conformité » portant la cause et la pièce déterminante, et insérer `participant.compliance-changed.v1` dans l'outbox.

2. **Destinataires :** résoudre les destinataires internes (responsable conformité, chef du DES, Direction Générale, production monétique du groupement) par leurs rôles dans `MS-IAM`, et les destinataires externes par l'annuaire d'escalade de l'institution au niveau S1 (titulaire puis suppléant).

3. **Signalement :** appeler de façon synchrone le port de `MS-NOTIFICATION` (`notifyUrgent`) avec l'objet « non-conformité documentaire, suspension à décider », la référence de la pièce et le délai d'acquittement ; `MS-NOTIFICATION` remet dans la plateforme, sur le canal poussé et par la messagerie électronique, puis escalade vers les suppléants en l'absence d'acquittement. L'identifiant de remise est conservé dans l'interaction.

4. **Décision hors plateforme :** la suspension effective est décidée par la Direction et exécutée par la production monétique dans le commutateur, hors de la plateforme. La plateforme n'en a connaissance que par le dépôt, dans `MS-DOCUMENT`, du procès-verbal ou du courrier de décision.

5. **Attestation par transition :** à la réception de ce dépôt, le responsable conformité propose la transition vers `SUSPENDU` en référençant la pièce ; un approbateur de niveau

2 distinct l'approuve (algorithme 6.25) ; `participant.status-changed.v1` est publié et scellé par `MS-AUDIT`. Tant que l'attestation n'est pas reçue, l'institution reste `A_REGULARISER` ou `ACTIF` avec un état `NON_CONFORME`, ce que `MS-REPORTING` fait apparaître dans le cockpit du DES.

6. **Régularisation :** le dépôt d'une pièce valide relance le calcul de conformité (algorithme 6.27) ; le retour à `ACTIF` suit le même circuit d'attestation, la levée de suspension étant elle aussi exécutée hors de la plateforme.

6.1.7 Homologation des participants (MS-HOMOLOGATION)

Le service `MS-HOMOLOGATION` suit le parcours de raccordement d'une institution au réseau GIMACPAY pour un type de projet donné (carte interbancaire, paiement mobile, délégataire). Il porte les liaisons, le référentiel d'opérations versionné (tronc commun et branches métier, organisé en graphe orienté acyclique), le périmètre contractualisé de chaque liaison, les opérations instanciées et leur clôture selon la règle des quatre éléments, la reprise en lecture seule des résultats des campagnes d'essais depuis le simulateur de certification, le calcul des couvertures de certification et de mise en service service par service et la vérification du code QR marchand. Il se situe entre `MS-PARTICIPANT`, dont il reçoit les services souscrits, et `MS-CERTIFICATION`, à qui il signale qu'une liaison est apte à la certification. Le service ne décode aucun message ISO 8583 ni ISO 20022, ne génère aucun jeu d'essai, ne calcule aucun verdict de scénario et ne détient aucune clé : le simulateur de certification est une application tierce dont la plateforme lit l'avancement et les résultats, les référence et les trace, sans jamais les recalculer ni les modifier. Les quitus, la fiche de changement et le dossier de mise en service appartiennent à `MS-CERTIFICATION`.

6.1.7.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : COBAC, ISO/IEC 17065, PCI-DSS v4.0.1 et RFC 3161

- **Règlement COBAC R-2024/01 :** le raccordement d'un membre à un système de paiement suppose une homologation documentée dont chaque étape est attribuée, prouvée, datée et validée ; le service en tient le registre et publie chaque clôture vers `MS-AUDIT` (feuille de l'arbre de Merkle, RFC 9162).
- **ISO/IEC 17065 :** l'évaluation (campagne d'essais dans le simulateur) est séparée de la décision (quatre quitus dans `MS-CERTIFICATION`) ; le service formalise cette séparation en ne portant que le suivi du parcours et la reprise des résultats, jamais leur production ni la décision de certifier.

- **PCI-DSS v4.0.1 :** le service reste hors de l'environnement des données de titulaires de cartes ; les preuves déposées passent par le contrôle de masquage de `MS-DOCUMENT` et les traces d'essais ne sont référencées que par leur identifiant dans le simulateur, jamais copiées.
- **RFC 3161 :** l'élément d'horodatage de la règle des quatre éléments est un jeton délivré par l'autorité d'horodatage sur l'empreinte SHA-256 de la preuve scellée, ce qui rend la date de clôture opposable indépendamment de l'horloge de la plateforme.

Liaison, référentiel d'opérations et périmètre contractualisé Une liaison est ouverte pour une institution (référencée par son identifiant, la fiche restant dans `MS-PARTICIPANT`) et un type de projet ; elle fige la version du référentiel d'opérations en vigueur à son ouverture. Le référentiel d'un type de projet est un graphe orienté acyclique dont chaque nœud, l'opération de référence, porte un code, un libellé, une branche (tronc commun ou branche métier), une phase (paramétrage, échange de certificats, essais, recette, mise en service), ses prédécesseurs, la partie à qui elle incombe (groupement, participant, les deux), la preuve attendue et, pour les opérations d'essai, l'identifiant du scénario correspondant dans le simulateur et le service auquel elle contribue. Le périmètre contractualisé de la liaison est dérivé des services souscrits publiés par `MS-PARTICIPANT` (`participant.service-subscribed.v1`) : chaque service est inclus ou hors périmètre et porte un état d'avancement (non démarré, en essai, certifié, en service). Une opération de branche dont le service est hors périmètre est instanciée à l'état « hors périmètre » et n'entre dans aucune couverture.

Opérations et règle des quatre éléments Les opérations d'une liaison sont instanciées à partir du référentiel par tri topologique de Kahn (algorithme 6.30) ; une opération n'est éligible que lorsque tous ses prédécesseurs sont clos. La clôture d'une opération exige la réunion de quatre éléments (règle BF-11 du cahier des charges) : un responsable désigné, une preuve déposée dans `MS-DOCUMENT` et retenue en mode conformité dans le dépôt objet WORM, un horodatage RFC 3161 sur l'empreinte de cette preuve, et une validation par un validateur habilité distinct du responsable (algorithme 6.31). Une opération dont la validation est refusée passe en arbitrage, avec motif, sans être rouverte. Cette règle ne doit pas être confondue avec les quatre quitus de la mise en service, qui relèvent de `MS-CERTIFICATION`.

Reprise en lecture seule des résultats du simulateur Le simulateur de certification exécute les campagnes d'essais ; la plateforme n'en reprend, par un adaptateur de lecture, que quatre éléments (tableau des éléments repris du cahier des charges) : l'identifiant du scénario, son résultat, l'horodatage et la référence de trace, et l'avancement de la campagne. Chaque scénario est rapproché de l'opération de référence par identifiant ; le résultat est positionné sur l'opération

sans recalcul, la référence de trace tient lieu de référence de preuve et l'horodatage restitué est conservé. La reprise est déclenchée périodiquement et sur notification d'achèvement ; elle est idempotente et tolère les indisponibilités du simulateur (algorithme 6.32). Un scénario inconnu du référentiel est rangé en attente de rapprochement et signalé au chef de section ; un résultat d'échec bloque les opérations descendantes jusqu'à une nouvelle exécution favorable.

Couvertures, aptitude à la certification et code QR marchand Pour chaque service du périmètre, la couverture de certification est la proportion des opérations closes parmi celles que le service requiert (opérations de sa branche et ancêtres du tronc commun) ; la couverture de mise en service porte sur les opérations de phase « mise en service », déverrouillées après l'attestation émise par `MS-CERTIFICATION`. Lorsque tous les services inclus atteignent une couverture de certification totale, la liaison devient apte à la certification et l'événement `homologation.liaison-ready-for-certification.v1` est publié (algorithme 6.33). Pour un acquéreur de paiement marchand, la vérification du code QR (forme statique, forme dynamique) est une opération de la branche paiement mobile : le service en enregistre la forme, le résultat constaté par l'ingénieur d'homologation, la date et la pièce probante, sans générer ni décoder lui-même de code.

Non-intrusion et cohérence événementielle

- **Ce que le service ne fait pas :** aucun décodage de message, aucun verdict, aucun jeu d'essai, aucune clé, aucune écriture dans le simulateur ni dans le commutateur. Le port de lecture du simulateur est le seul lien avec cette application tierce ; il est unidirectionnel.
- **Transactional Outbox :** toute mutation (liaison, périmètre, opération, scénario repris, couverture, vérification du code QR, version du référentiel) écrit dans la même transaction l'état et l'événement correspondant ; un processus d'arrière-plan publie sur le bus d'événements (enveloppe CloudEvents, livraison au moins une fois, ordre par liaison).
- **Sujets publiés :** cinq sujets sont émis :
  - `homologation.operation-closed.v1` (clôture selon la règle des quatre éléments) ;
  - `homologation.coverage-updated.v1` (couvertures recalculées) ;
  - `homologation.liaison-ready-for-certification.v1` (aptitude à la certification) ;
  - `homologation.catalog-published.v1` (nouvelle version du référentiel) ;
  - `homologation.notification-requested.v1` (demande de notification).

`MS-AUDIT` consomme tous les événements à effet ; `MS-CERTIFICATION` et `MS-REPORTING` consomment les clôtures, les couvertures et l'aptitude.

6.1.7.2 Diagramme de composants internes de MS-HOMOLOGATION

La Figure 6.19 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les commandes de l'application web du DES, du portail des participants et de la console d'administration (via `MS-GATEWAY`), le réveil de l'ordonnanceur de reprise et les événements du bus ; le cœur porte les huit entités du domaine 3 relevant de l'homologation ; les adaptateurs pilotés dialoguent avec la base relationnelle du service, le simulateur de certification (lecture seule), `MS-DOCUMENT`, l'autorité d'horodatage, `MS-PARTICIPANT` et le bus d'événements.

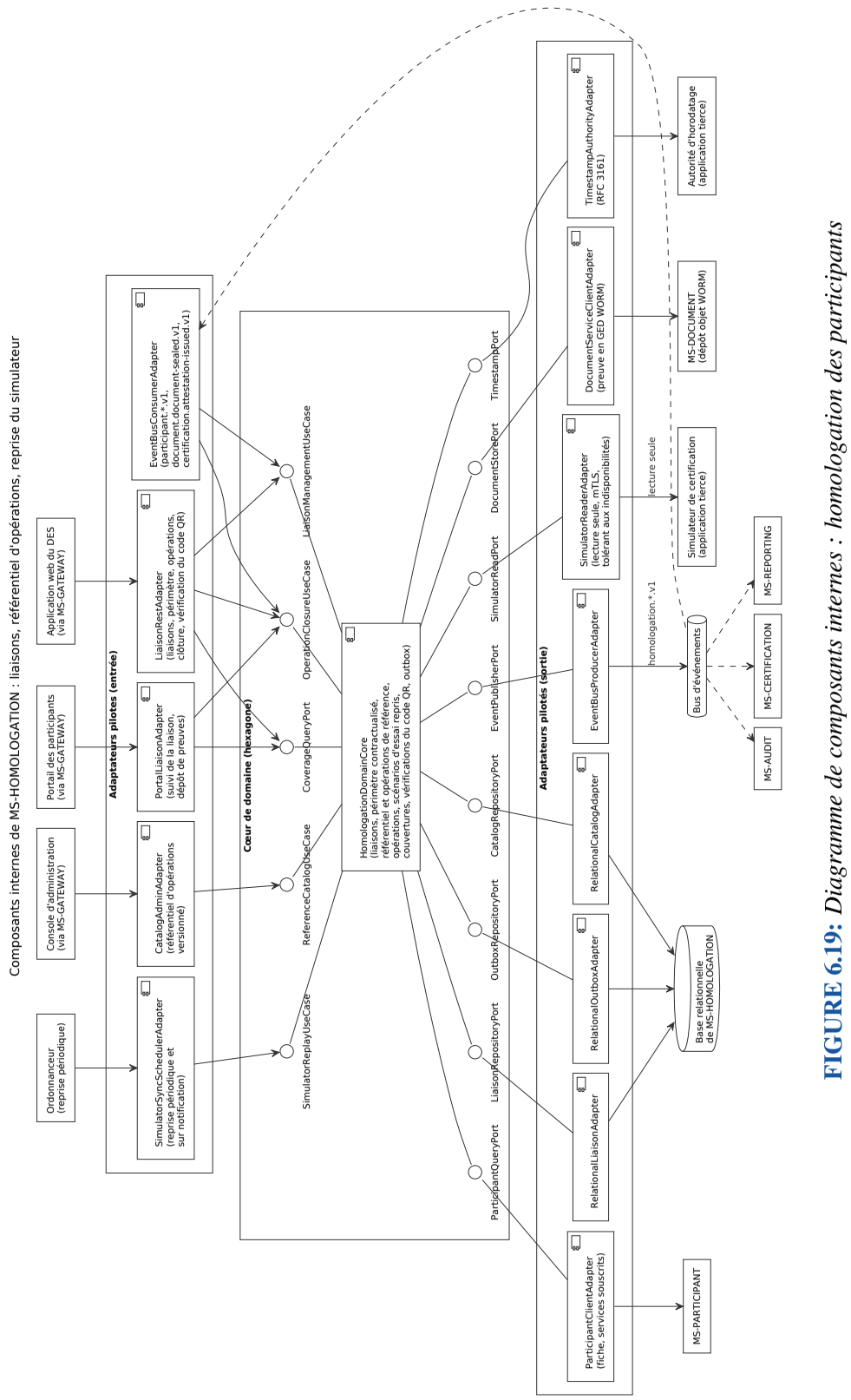


FIGURE 6.19: *Diagramme de composants internes : homologation des participants*

- **Adaptateurs pilotes (entrée) :** `LiaisonRestAdapter` (liaisons, périmètre, opérations, clôture, vérification du code QR) ; `PortalLiaisonAdapter` (suivi de sa liaison par le représentant du participant, dépôt des preuves qui lui incombent) ; `CatalogAdminAdapter` (publication d'une version du référentiel d'opérations) ; `SimulatorSyncSchedulerAdapter` (reprise périodique et sur notification d'achèvement) ; `EventBusConsumerAdapter` (`participant.service-subscribed.v1` et `participant.status-changed.v1` pour le périmètre et le gel de la liaison, `document.document-sealed.v1` pour la confirmation de scellement d'une preuve, `certification.quitus-signed.v1` pour replacer la liaison en homologation avec le motif lorsqu'un quitus est refusé, `certification.attestation-issued.v1` pour déverrouiller la phase de mise en service).
- **Cœur de domaine :** `HomologationDomainCore` expose `LiaisonManagementUseCase`, `ReferenceCatalogUseCase`, `OperationClosureUseCase`, `SimulatorReplayUseCase` et `CoverageQueryPort`, et requiert huit ports secondaires.
- **Adaptateurs pilotés (sortie) :** `RelationalLiaisonAdapter`, `RelationalCatalogAdapter` et `RelationalOutboxAdapter` (base relationnelle du service, politiques de lignes par institution) ; `SimulatorReaderAdapter` (lecture seule en mTLS, délai borné, disjoncteur) ; `DocumentServiceClientAdapter` (état de scellement d'une preuve) ; `TimestampAuthorityAdapter` (jeton RFC 3161) ; `ParticipantClientAdapter` (fiche et services souscrits) ; `EventBusProducerAdapter`.
- **Interactions :** `MS-PARTICIPANT` en lecture synchrone et par événement ; `MS-DOCUMENT` et l'autorité d'horodatage en appel synchrone lors des clôtures ; le simulateur en lecture seule ; `MS-AUDIT`, `MS-CERTIFICATION` et `MS-REPORTING` en consommateurs des événements `homologation.*.v1`.

6.1.7.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.20 détaille les classes du domaine, les ports et les adaptateurs. Les huit entités du domaine 3 relevant de l'homologation y sont reprises avec leurs types et leurs signatures ; le quitus et le dossier de mise en service y figurent comme références vers `MS-CERTIFICATION`.

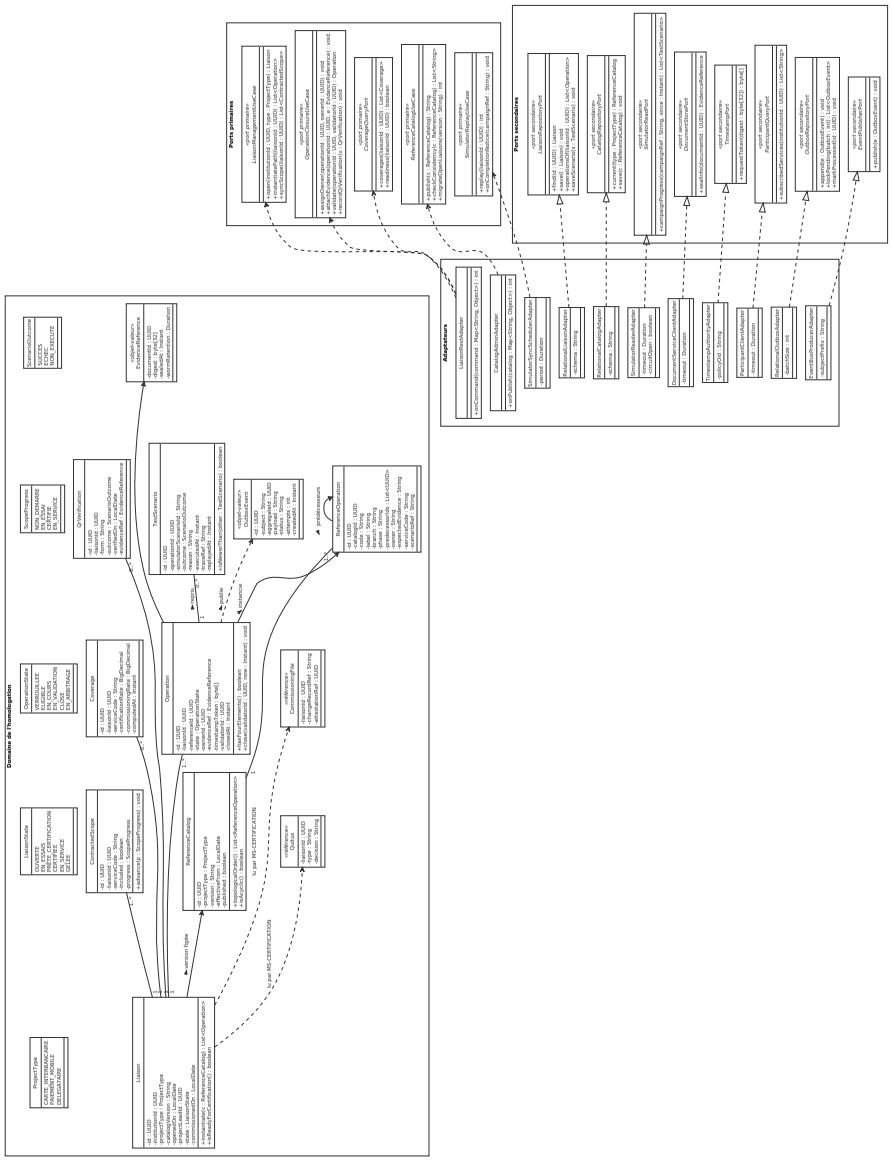


FIGURE 6.20: *Diagramme de classes de conception : service MS-HOMOLOGATION*

- **Entités :** `Liaison` (`institutionId : UUID`, `projectType : ProjectType`, `catalogVersion : String`, `openedOn`, `commissionedOn : LocalDate`, `projectLeadId : UUID`, `state : LiaisonState`, méthodes `instantiate`, `isReadyForCertification`) ; `ContractedScope` (`serviceCode`, `included : boolean`, `progress : ScopeProgress`) ; `ReferenceCatalog` (`projectType`, `version`, `effectiveFrom`, `published`, méthodes `topologicalOrder`, `isAcyclic`) ; `ReferenceOperation` (`code`, `label`, `branch`, `phase`, `predecessorIds : List<UUID>`, `owner`, `expectedEvidence`, `serviceCode`, `scenarioRef`) ; `Operation` (`state : OperationState`, `ownerId`, `validatorId : UUID`, `evidenceRef : EvidenceReference`, `timestampToken : byte[]`, `closedAt : Instant`, méthodes `hasFourElements`, `close`) ; `TestScenario` (`simulatorScenarioId`, `outcome : ScenarioOutcome`, `reason`, `executedAt`, `traceRef`, `replayedAt`) ; `Coverage` (`serviceCode`, `certificationRate`, `commissioningRate : BigDecimal`, `computedAt`) ; `QrVerification` (`form`, `outcome`, `verifiedOn`, `evidenceRef`).
- **Énumérations, objets-valeurs et références :** `ProjectType`, `LiaisonState` (`OUVERTE`, `EN_ESSAIS`, `PRETE_CERTIFICATION`, `CERTIFIEE`, `EN_SERVICE`, `GELEE`), `OperationState` (`VERROUILLEE`, `ELIGIBLE`, `EN_COURS`, `EN_VALIDATION`, `CLOSE`, `EN_ARBITRAGE`), `ScopeProgress`, `ScenarioOutcome` ; `EvidenceReference` (`documentId`, `digest : byte[32]`, `sealedAt`, `wormRetention : Duration`) ; `OutboxEvent` ; `Quitus` et `CommissioningFile` stéréotypés « référence ».
- **Ports primaires :** `LiaisonManagementUseCase` (`open`, `instantiatePath`, `syncScope`) ; `ReferenceCatalogUseCase` (`publish`, `checkConsistency`, `migrateOpenLiaisons`) ; `OperationClosureUseCase` (`assignOwner`, `attachEvidence`, `validate`, `recordQrVerification`) ; `SimulatorReplayUseCase` (`replay`, `onCompletionNotice`) ; `CoverageQueryPort` (`coverages`, `readiness`).
- **Ports secondaires :** `LiaisonRepositoryPort` (`find`, `save`, `operationsOf`, `saveScenario`), `CatalogRepositoryPort` (`current`, `save`), `SimulatorReadPort` (`campaignProgress`), `DocumentStorePort` (`sealInfo`), `TimestampPort` (`requestToken`), `ParticipantQueryPort` (`subscribedServices`), `OutboxRepositoryPort`, `EventPublisherPort`.
- **Adaptateurs :** `LiaisonRestAdapter`, `CatalogAdminAdapter` et `SimulatorSyncSchedulerAdapter` pilotent les ports primaires

; `RelationalLiaisonAdapter`, `RelationalCatalogAdapter`, `SimulatorReaderAdapter`, `DocumentServiceClientAdapter`, `TimestampAuthorityAdapter`, `ParticipantClientAdapter`, `RelationalOutboxAdapter` et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.7.4 Diagramme d'objets du service MS-HOMOLOGATION

La Figure 6.21 capture une liaison de paiement mobile de l'Établissement de paiement A en phase d'essais : l'opération d'échange des certificats du tronc commun a été close douze jours plus tôt selon la règle des quatre éléments ; l'opération d'essai de transfert de compte à compte est en cours et vient de recevoir, par reprise, un résultat favorable du simulateur ; la couverture de certification du service de transfert est à moitié atteinte ; la vérification du code QR statique a été consignée ; l'événement de mise à jour de couverture attend sa publication.

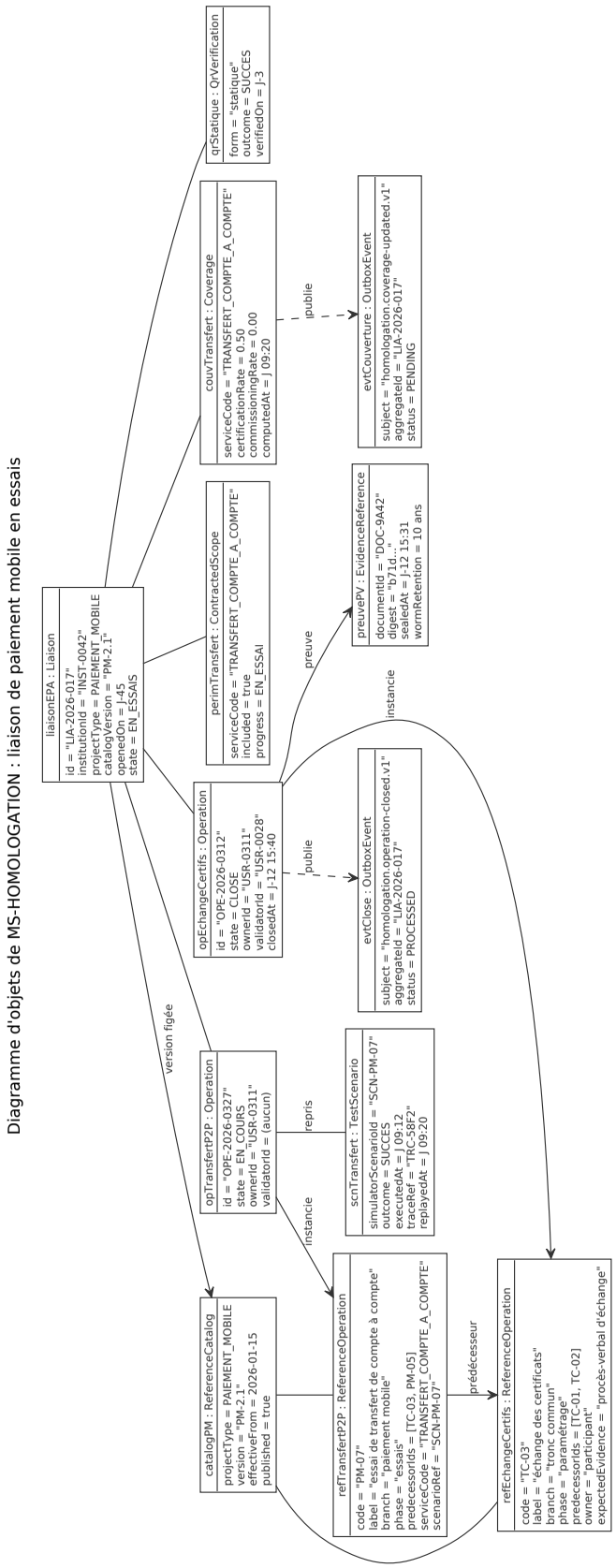


FIGURE 6.21: *Diagramme d'objets : liaison de paiement mobile en essais*

- `liaisonEPA : Liaison`, identifiant `LIA-2026-017`, institution `INST-0042`, type paiement mobile, version de référentiel `PM-2.1` figée, ouverte à J-45, état `EN_ESSAIS` ;
- `catalogPM : ReferenceCatalog`, version `PM-2.1`, publiée, en vigueur depuis janvier 2026 ;
- `refEchangeCertifs : ReferenceOperation`, code `TC-03`, tronc commun, phase paramétrage, prédécesseurs `TC-01` et `TC-02`, incombant au participant, preuve attendue « procès-verbal d'échange » ; `refTransfertP2P : ReferenceOperation`, code `PM-07`, branche paiement mobile, phase essais, prédécesseurs `TC-03` et `PM-05`, service de transfert, scénario `SCN-PM-07` ;
- `opEchangeCertifs : Operation`, identifiant `OPE-2026-0312`, close, responsable `USR-0311`, validateur `USR-0028`, liée à `preuvePV : EvidenceReference` (pièce `DOC-9A42`, empreinte connue, scellée à J-12, rétention de dix ans) ;
- `opTransfertP2P : Operation`, identifiant `OPE-2026-0327`, en cours, responsable `USR-0311`, sans validateur ; `scnTransfert : TestScenario`, scénario `SCN-PM-07`, résultat `SUCCES` restitué par le simulateur, exécuté à 09h12, trace `TRC-58F2`, repris à 09h20 ;
- `perimTransfert : ContractedScope`, service de transfert inclus, en essai ; `couvTransfert : Coverage`, couverture de certification 0,50, couverture de mise en service 0,00, calculée à 09h20 ;
- `qrStatique : QrVerification`, forme statique, résultat favorable, vérifiée à J-3 ;
- `evtClose : OutboxEvent`, événement de clôture déjà publié (sujet `homologation.operation-closed.v1`) ; `evtCouverture : OutboxEvent`, événement de couverture en attente (sujet `homologation.coverage-updated.v1`).

6.1.7.5 Algorithmes fondamentaux de MS-HOMOLOGATION

Cette section formalise les cinq algorithmes qui régissent l'instanciation du parcours par tri topologique, la clôture d'une opération par la règle des quatre éléments, la reprise idempotente des résultats du simulateur, le calcul des couvertures avec détection de l'aptitude à la certification, et le contrôle de cohérence lors de la publication d'une nouvelle version du référentiel.

Algorithme 6.30 : Instanciation du parcours d'une liaison par tri topologique de Kahn
Cet algorithme vérifie que le référentiel d'opérations est un graphe orienté acyclique, en dérive un ordre d'exécution déterministe et instancie les opérations de la liaison avec leur état initial (éligible, verrouillée ou hors périmètre). Il est exécuté à l'ouverture d'une liaison et lors d'une migration de version.

Spécification formelle de l'algorithme 6.30 : tri topologique et instanciation	
Entrées	Référentiel $G = (V, E)$ (V : opérations de référence, E : arcs prédécesseur vers successeur) ; liaison L ; périmètre $\mathscr{S}_L$ (services inclus).
Sorties	Ordre topologique Λ ; opérations instanciées $\mathscr{O}_L$ avec état initial ; ou rejet si G contient un cycle.
Complexité	Temps $\mathscr{O}(\lvert V\rvert + \lvert E\rvert)$; espace $\mathscr{O}(\lvert V\rvert)$ (file et vecteur des degrés entrants).
Contrôles	Acyclicité ; unicité des codes ; tout nœud de branche rattaché à un service ; version du référentiel figée sur la liaison.

TABLE 6.33: *Fiche de spécification : tri topologique de Kahn et instanciation du parcours*

Déroulement procédural étape par étape :

1. **Degrés entrants :** pour chaque $v \in V$, initialiser $\deg^-(v) \leftarrow 0$; pour chaque arc $(u, v) \in E$, incrémenter $\deg^-(v)$. Les arcs sont construits à partir des listes de prédécesseurs des nœuds ; un prédécesseur inconnu du référentiel est une erreur de cohérence qui interrompt l'instanciation.

2. **Sources :** enfiler dans une file $\mathscr{Q}$, par ordre croissant de code (ce qui rend l'ordre déterministe), tous les nœuds tels que $\deg^-(v) = 0$.

3. **Parcours :** tant que $\mathscr{Q}$ n'est pas vide, défiler u, l'ajouter à Λ, et pour chaque successeur w de u décrémenter $\deg^-(w)$; si $\deg^-(w)$ atteint 0, enfiler w.

4. **Détection de cycle :** si $\lvert\Lambda\rvert \neq \lvert V\rvert$, le référentiel contient un cycle : rejeter, publier `homologation.notification-requested.v1` à destination du chef du DES avec les nœuds restants, et ne créer aucune opération.

5. **Instanciation :** parcourir Λ et créer, pour chaque v, une opération o_v rattachée à L dont l'état initial est :

$$o_v.\text{state} = \begin{cases} \texttt{HORS_PERIMETRE} & \text{si } v.\text{serviceCode} \neq \varnothing \text{ et } v.\text{serviceCode} \notin \mathscr{S}_L \\ \texttt{ELIGIBLE} & \text{si } \deg^-_{\text{init}}(v) = 0 \\ \texttt{VERROUILLEE} & \text{sinon} \end{cases} \tag{6.31}$$

Les opérations de phase « mise en service » restent verrouillées en outre par l'attente de `certification.attestation-issued.v1`.

6. **Persistance :** enregistrer $\mathcal{O}_L$, la version figée du référentiel et l'état `OUVERTE` de la liaison dans une même transaction avec l'événement `homologation.coverage-updated.v1` initial (toutes couvertures à zéro).

Algorithme 6.31 : Clôture d'une opération par la règle des quatre éléments Cet algorithme garantit qu'aucune opération n'est réputée close sans la réunion de ses quatre éléments, que le validateur est distinct du responsable, que la preuve est bien scellée en WORM par `MS-DOCUMENT`, et que la clôture déverrouille les opérations descendantes et recalcule les couvertures.

Spécification formelle de l'algorithme 6.31 : règle des quatre éléments	
Entrées	Opération o à l'état `EN_COURS` ou `EN_VALIDATION` ; responsable r ; référence de preuve p ; validateur v ; t_{now}.
Sorties	o close avec ses quatre éléments, successeurs déverrouillés, `homologation.operation-closed.v1` ; ou o en arbitrage.
Complexité	$\mathcal{O}(1)$ par clôture, plus $\mathcal{O}(d^+(o))$ pour le déverrouillage des successeurs.
Standard	RFC 3161 (horodatage), RFC 9162 (scellement par `MS-AUDIT`), règle BF-11 du cahier des charges.

TABLE 6.34: *Fiche de spécification : clôture par la règle des quatre éléments*

Déroulement procédural étape par étape :

1. **Éligibilité :** vérifier que tous les prédécesseurs de o sont à l'état `CLOSE` et que o n'est pas hors périmètre ; sinon rejeter avec la liste des prédécesseurs manquants.

2. **Élément 1, responsable :** enregistrer o.ownerId $\leftarrow r$; le responsable est un ingénieur d'homologation (niveau 4) ou, pour une opération incombant au participant, le représentant de l'institution, identifié par le jeton interne réduit.

3. **Élément 2, preuve :** interroger `DocumentStorePort.sealInfo`(p) et exiger que la pièce soit scellée en mode conformité avec une rétention d'au moins dix ans et une empreinte h_p connue ; pour une opération d'essai, la référence de trace restituée par le simulateur tient lieu de preuve, sans copie de la trace.

4. **Élément 3, horodatage :** demander à l'autorité d'horodatage un jeton τ sur l'empreinte

de la preuve et de l'opération :

$$\tau = \mathrm{TSA}\big(\mathrm{SHA256}(o.\mathrm{id} \parallel h_p \parallel r)\big) \tag{6.32}$$

et conserver τ dans o.timestampToken ; passer o à `EN_VALIDATION` et insérer `homologation.notification-requested.v1` à destination du validateur habilité.

5. **Élément 4, validation :** à la réception de la décision, vérifier que $v \neq r$ et que v possède le niveau 2 ou 4 avec le périmètre de la liaison ; en cas de refus ou de contestation, passer o à `EN_ARBITRAGE` avec le motif et notifier le chef du DES ; sinon appliquer $o.\mathrm{close}(v, t_{\mathrm{now}})$.

6. **Déverrouillage et publication :** dans la même transaction, passer à `ELIGIBLE` tout successeur dont tous les prédécesseurs sont désormais clos, recalculer les couvertures (algorithme 6.33) et insérer `homologation.operation-closed.v1` portant les identifiants des quatre éléments ; `MS-AUDIT` l'inscrit comme feuille de son arbre, ce qui rend la clôture vérifiable par un auditeur sans confiance dans le seul service d'homologation.

Algorithme 6.32 : Reprise idempotente des résultats du simulateur Cet algorithme lit l'avancement d'une campagne dans le simulateur de certification, rapproche chaque scénario de l'opération correspondante et positionne le résultat sans le recalculer. Il est tolérant aux pannes : une lecture interrompue est reprise depuis le dernier instant traité et une lecture répétée ne produit aucun doublon.

Spécification formelle de l'algorithme 6.32 : reprise des résultats du simulateur	
Entrées	Liaison L et référence de campagne κ_L ; curseur t_{last} (dernier horodatage repris) ; déclencheur (période ou notification).
Sorties	Scénarios repris $\mathscr{R}$; opérations mises à jour ; curseur avancé ; couvertures recalculées ; ou report en cas d'indisponibilité.
Complexité	$\mathscr{O}(\lvert\mathscr{R}\rvert)$ par reprise ; lectures paginées ; aucune donnée d'essai copiée.
Garantie	Lecture seule ; idempotence par (scénario, horodatage d'exécution) ; résultat jamais recalculé ni modifiable à la main.

TABLE 6.35: *Fiche de spécification : reprise des résultats du simulateur*

Déroulement procédural étape par étape :

1. **Déclenchement :** la reprise est lancée par l'ordonnanceur à période fixe (quinze minutes en phase d'essais) ou par une notification d'achèvement de scénario reçue par la passerelle ; la notification ne porte aucun résultat, elle ne fait que déclencher une lecture.

2. **Lecture tolérante :** appeler `SimulatorReadPort.campaignProgress`$(\kappa_L, t_{\text{last}})$ en mTLS avec un délai borné ; en cas d'indisponibilité, ouvrir le disjoncteur pendant un délai croissant (une, deux, quatre minutes, plafonné à trente), consigner l'incident dans le journal du service et, au-delà de trois échecs consécutifs, lever une alerte vers `MS-MONITORING`. Aucune donnée n'est modifiée en cas d'échec.

3. **Rapprochement :** pour chaque scénario lu s, chercher l'opération o de L dont l'opération de référence porte scenarioRef $= s$.id ; si aucune ne correspond, ranger s en attente de rapprochement et notifier le chef de section ; si o est hors périmètre, ignorer s.

4. **Idempotence :** si un `TestScenario` existe déjà pour $(s.\text{id}, s.\text{executedAt})$, ignorer s ; sinon l'enregistrer avec le résultat, le motif, l'horodatage et la référence de trace tels que restitués, et la date de reprise.

5. **Positionnement du résultat :** en cas de `SUCCES`, passer o à `EN_VALIDATION` avec la référence de trace comme preuve et l'horodatage restitué comme troisième élément, le responsable et le validateur restant à fournir selon l'algorithme 6.31 ; en cas d'`ECHEC`, conserver o à `EN_COURS`, consigner le motif restitué et verrouiller les successeurs déjà éligibles. Le résultat n'est jamais recalculé ni saisi manuellement.

6. **Curseur et publication :** avancer t_{last} au plus grand horodatage lu, dans la même transaction que le dernier scénario traité ; recalculer les couvertures ; insérer `homologation.coverage-updated.v1` et `homologation.notification-requested.v1` (avancement à l'ingénieur d'homologation) ; `MS-AUDIT` consigne la reprise.

Algorithme 6.33 : Calcul des couvertures et détection de l'aptitude à la certification Cet algorithme mesure, service par service, l'avancement de la liaison et détecte l'instant où tous les services inclus au périmètre sont couverts, ce qui rend la liaison apte à la certification. Il est invoqué après chaque clôture, chaque reprise et chaque changement de périmètre.

Spécification formelle de l'algorithme 6.33 : couvertures et aptitude	
Entrées	Liaison L ; opérations $\mathscr{O}_L$ et leur graphe ; périmètre $\mathscr{S}_L$; présence de l'attestation de certification.
Sorties	Couvertures (γ_s, μ_s) pour chaque service s ; état de la liaison ; événements de couverture et d'aptitude.
Complexité	$\mathscr{O}(\lvert\mathscr{S}_L\rvert \cdot (\lvert V\rvert + \lvert E\rvert))$ par parcours des ancêtres ; ancêtres mis en cache par version de référentiel.
Contrôles	Seules les opérations closes selon la règle des quatre éléments comptent ; aucune pondération manuelle.

TABLE 6.36: *Fiche de spécification : couvertures et aptitude à la certification*

Déroulement procédural étape par étape :

1. **Opérations requises par service :** pour chaque service inclus $s \in \mathscr{S}_L$, déterminer l'ensemble $\mathscr{B}_s$ des opérations de branche contribuant à s et sa fermeture par les prédécesseurs (ancêtres du tronc commun compris) :

$$\mathscr{R}_s = \mathscr{B}_s \cup \bigcup_{o \in \mathscr{B}_s} \mathrm{Anc}(o) \tag{6.33}$$

   en excluant les opérations de phase « mise en service », comptées séparément dans $\mathscr{M}_s$.

2. **Couverture de certification :** calculer la proportion des opérations requises closes :

$$\gamma_s = \frac{\lvert\{\, o \in \mathscr{R}_s \mid o.\mathrm{state} = \texttt{CLOSE} \,\}\rvert}{\lvert\mathscr{R}_s\rvert} \tag{6.34}$$

3. **Couverture de mise en service :** si l'événement `certification.attestation-issued.v1` a été reçu pour L, calculer de même μ_s sur $\mathscr{M}_s$; sinon $\mu_s = 0$ et les opérations de $\mathscr{M}_s$ restent verrouillées.

4. **Avancement du périmètre :** positionner `progress` de chaque service : `NON_DEMARRE` si aucune opération de $\mathscr{B}_s$ n'est commencée, `EN_ESSAI` si $0 < \gamma_s < 1$, `CERTIFIE` si $\gamma_s = 1$ et l'attestation est reçue, `EN_SERVICE` si $\mu_s = 1$.

5. **Aptitude :** si $\gamma_s = 1$ pour tout service inclus et si toutes les opérations du tronc commun hors mise en service sont closes, passer L à `PRETE_CERTIFICATION` et insérer `homologation.liaison-ready-for-certification.v1`, consommé par `MS-CERTIFICATION` qui ouvre alors la collecte des quatre quitus ; si un résultat d'échec repris fait redescendre une couverture, l'aptitude est retirée par un événement symétrique.

6. **Persistance :** enregistrer les couvertures avec leur date de calcul et insérer `homologation.coverage-updated.v1`, consommé par `MS-REPORTING` pour les indicateurs d'avancement des liaisons et par le portail des participants pour l'affichage au représentant de l'institution.

Algorithme 6.34 : Contrôle de cohérence à la publication d'une version du référentiel Cet algorithme vérifie une nouvelle version du référentiel d'opérations avant sa publication, puis migre les liaisons en cours qui le demandent sans perdre les opérations déjà closes. Les liaisons aptes à la certification ou au-delà conservent leur version figée.

Spécification formelle de l'algorithme 6.34 : cohérence et migration du référentiel	
Entrées	Version candidate $G' = (V', E')$; version en vigueur G ; liaisons ouvertes $\mathscr{L}$ du même type de projet ; approbateur.
Sorties	Version publiée ou liste des anomalies ; liaisons migrées avec opérations conservées, ajoutées ou archivées ; événements.
Complexité	$\mathcal{O}(\lvert V'\rvert + \lvert E'\rvert)$ pour le contrôle ; $\mathcal{O}(\lvert\mathscr{L}\rvert \cdot (\lvert V'\rvert + \lvert E'\rvert))$ pour la migration.
Contrôles	Acyclicité ; complétude des nœuds ; unicité des codes et des scénarios ; migration approuvée en maker-checker.

TABLE 6.37: *Fiche de spécification : cohérence et migration du référentiel*

Déroulement procédural étape par étape :

1. **Contrôles structurels :** appliquer le tri de Kahn à G' (algorithme 6.30) et rejeter tout cycle ; vérifier que chaque nœud porte un code unique, une branche, une phase, une partie responsable et une preuve attendue ; que tout nœud de branche porte un service connu de `MS-PARTICIPANT` (liste des services par `ParticipantQueryPort`) ; que tout nœud d'essai porte un identifiant de scénario unique dans la version ; qu'aucun nœud de branche n'est prédécesseur d'un nœud du tronc commun.

2. **Différentiel :** calculer par code $V^{=} = V \cap V'$ (nœuds conservés), $V^{+} = V' \setminus V$ (ajoutés) et $V^{-} = V \setminus V'$ (retirés), et relever les nœuds conservés dont les prédécesseurs, la preuve attendue ou le scénario changent.

3. **Publication :** enregistrer G' avec sa date d'entrée en vigueur à l'état publié, après approbation d'un responsable distinct de l'auteur ; insérer `homologation.catalog-published.v1` portant le différentiel. Les liaisons ouvertes après cette date figent G'.

4. **Sélection des liaisons à migrer :** retenir dans $\mathscr{L}$ les liaisons aux états `OUVERTE` ou `EN_ESSAIS` pour lesquelles l'ingénieur d'homologation demande la migration ; les liaisons `PRETE_CERTIFICATION`, `CERTIFIEE` et `EN_SERVICE` restent sur leur version.

5. **Migration d'une liaison :** pour chaque liaison retenue, dans une transaction : conserver les opérations de $V^{=}$ avec leur état et leurs éléments de clôture ; instancier celles de V^{+} ; archiver celles de V^{-} (état `ARCHIVEE`, hors couverture, historique conservé) ; pour un nœud conservé dont la preuve attendue ou le scénario change, repasser l'opération close à `EN_VALIDATION` avec le motif « référentiel modifié » ; recalculer les états d'éligibilité par un nouveau parcours de Kahn ; mettre à jour `catalogVersion`.

6. **Recalcul et notification :** recalculer les couvertures (algorithme 6.33), insérer `homologation.coverage-updated.v1` et notifier le chef de projet de la liaison et le représentant de l'institution des opérations ajoutées ou réouvertes ; `MS-AUDIT` consigne la migration avec l'identifiant de l'approbateur.

6.1.8 Certification et mise en service des participants (MS-CERTIFICATION)

Le service `MS-CERTIFICATION` porte la décision de certification et l'autorisation de mise en service d'une liaison, une fois que `MS-HOMOLOGATION` (section 6.1.7) a signalé qu'elle est apte à la certification. Il constitue le dossier de mise en service, conduit le circuit des quatre quitus (technique, sécurité, conformité, direction générale), émet l'attestation de certification au format PDF/A-3 signée en PAdES et horodatée selon la RFC 3161, lit dans le dispositif de gestion des changements la fiche de changement approuvée par le comité des changements du groupement, contrôle la complétude du dossier puis le scelle. Il se situe en aval de `MS-HOMOLOGATION`, dont il reçoit par événement les couvertures et les opérations closes, et en amont de `MS-PARTICIPANT`, qui inscrit l'institution à l'état `ACTIF` lorsque la mise en service est actée. Le service ne suit aucune opération d'homologation, ne calcule aucune couverture, ne reprend aucun résultat du simulateur de certification et ne tient aucun graphe d'opérations : ces responsabilités relèvent de `MS-HOMOLOGATION`. Il ne crée, ne modifie ni n'approuve aucune fiche de changement, et n'agit jamais sur le commutateur : l'ouverture effective des flux d'un participant est réalisée par la production monétique, qui en atteste par un procès-verbal que la plateforme référence.

6.1.8.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : ISO/IEC 17065, COBAC, PCI-DSS v4.0.1 et normes de preuve

- **ISO/IEC 17065 (clauses 7.5 et 7.6) :** la revue et la décision de certification sont confiées à des personnes qui n'ont pas conduit l'évaluation. La plateforme traduit cette exigence par une dissociation de services : le suivi de l'évaluation (opérations, reprise des résultats, couvertures) est porté par `MS-HOMOLOGATION`, la décision (quitus et attestation) par `MS-CERTIFICATION`, avec des bases, des identités de service et des clés distinctes. Un signataire de quitus ne peut être ni le chef de projet de la liaison ni le responsable d'une de ses opérations.
- **Règlements COBAC R-2016/04 et R-2024/01 :** la décision d'admettre un membre dans un système de paiement relève du contrôle interne ; elle doit être prise par des fonctions séparées, documentée, motivée et conservée de manière probante. Chaque quitus et chaque dossier scellé sont publiés vers `MS-AUDIT`, qui les inscrit comme feuilles de son arbre de Merkle (RFC 9162).
- **PCI-DSS v4.0.1 :** le service reste hors de l'environnement des données de titulaires de cartes ; il ne manipule que des références et des empreintes, et toute pièce qu'il dépose (attestation, dossier de preuves) passe par le contrôle de masquage de `MS-DOCUMENT`.
- **RFC 3161, ISO 19005-3 et ETSI EN 319 142 :** les décisions et le dossier sont horodatés par un jeton de l'autorité d'horodatage ; l'attestation est un document PDF/A-3 embarquant le dossier de preuves en pièces jointes et portant une signature PAdES de niveau B-LTA, vérifiable à long terme indépendamment de la plateforme.

Les quatre quitus : rôles, ordre imposé et forme de la décision La mise en service est conditionnée par quatre quitus, chacun délivré par un rôle distinct (règle RG-73) :

- **Quitus technique (chef du DES) :** constate la couverture de certification totale de chaque service du périmètre contractualisé et la clôture, selon la règle des quatre éléments, de toutes les opérations requises ;
- **Quitus de sécurité (RSSI) :** se prononce sur les pièces de sécurité du dossier (certificats échangés, résultats des essais de sécurité restitués par le simulateur, déclarations de conformité du participant) ;
- **Quitus de conformité (responsable conformité) :** vérifie, par lecture de la fiche tenue par `MS-PARTICIPANT`, l'agrément en cours, la convention de raccordement et l'état de conformité documentaire ;
- **Quitus de direction générale :** sanctionne la décision d'admission au regard des trois quitus précédents.

L'ordre est imposé : technique d'abord, puis sécurité et conformité en parallèle, puis direction générale lorsque les deux précédents sont favorables. Chaque quitus est une décision signée, horodatée, motivée et scellée : le signataire saisit sa décision et son motif, se réauthentifie par sa clé de sécurité matérielle FIDO2 (W3C WebAuthn) sur un défi lié à l'empreinte de la décision, puis la signature est calculée dans le coffre de clés avec sa clé personnelle non exportable, certifiée par l'autorité de certification interne ; le jeton RFC 3161 et la publication vers `MS-AUDIT` achèvent le scellement (algorithme 6.35). Les quatre quitus ne doivent pas être confondus avec la règle des quatre éléments, qui régit la clôture d'une opération d'homologation.

Refus d'un quitus et retour en homologation Tout quitus défavorable fait passer le dossier à l'état `EN_CORRECTION` et renvoie la liaison en homologation avec le motif du refus : l'événement `certification.quitus-signed.v1`, porteur de la décision et du motif, est consommé par `MS-HOMOLOGATION`, qui retire l'aptitude et rouvre les opérations visées. Lorsque la liaison redevient apte, le circuit reprend au quitus refusé ; les quitus favorables antérieurs sont conservés si le socle d'évaluation qu'ils ont signé est inchangé (même empreinte), et deviennent caducs dans le cas contraire, ce qui impose leur nouvelle signature.

Dossier de mise en service, fiche de changement et procès-verbal Le dossier de mise en service est ouvert à la réception de `homologation.liaison-ready-for-certification.v1`. Il réunit le socle d'évaluation (couvertures par service et opérations closes avec les empreintes de leurs preuves, projetés depuis les événements de `MS-HOMOLOGATION`), les quatre quitus, l'attestation de certification, la référence de la fiche de changement, le procès-verbal de mise en service et les empreintes de chaque pièce. La fiche de changement est créée et approuvée dans le dispositif de gestion des changements, qui détient seul l'autorité sur la mise en production (règle RG-34) ; l'ingénieur d'homologation en saisit la référence, et l'adaptateur `ChangeManagementReaderAdapter` en lit, en mTLS et en lecture seule, l'état d'approbation, la fenêtre de changement et la date d'approbation. Le procès-verbal de mise en service, établi par la production monétique à l'issue de la fenêtre et contresigné par le chef du DES et le représentant du participant, est déposé dans `MS-DOCUMENT`. Lorsque le contrôle de complétude est satisfait (algorithme 6.36), le dossier est scellé et la mise en service est actée.

Automate du dossier de mise en service Le cycle de vie du dossier est régi par un automate à cinq états, dont chaque transition est écrite avec son événement dans la même transaction :

- `OUVERT` : dossier créé à la réception de l'aptitude ; le socle d'évaluation est figé et en cours de scellement ;

- `QUITUS_EN_COURS` : socle scellé, circuit des quatre quitus engagé ; aucune pièce du socle ne peut plus être modifiée sans rendre caducs les quitus qui la couvrent ;
- `EN_CORRECTION` : un quitus a été refusé, ou le participant a changé d'état dans `MS-PARTICIPANT` (suspension, retrait) pendant le circuit ; la liaison est renvoyée en homologation et le dossier attend une nouvelle aptitude ;
- `CERTIFIE` : quatre quitus favorables, attestation émise et scellée en WORM ; la phase de mise en service est déverrouillée dans `MS-HOMOLOGATION` ;
- `MISE_EN_SERVICE_AUTORISEE` (état terminal) : dossier complet, manifeste scellé et horodaté, mise en service actée ; toute évolution ultérieure du périmètre donne lieu à une nouvelle liaison et à un nouveau dossier.

Les transitions autorisées sont : `OUVERT` vers `QUITUS_EN_COURS` ; `QUITUS_EN_COURS` vers `EN_CORRECTION` ou `CERTIFIE` ; `EN_CORRECTION` vers `QUITUS_EN_COURS` ; `CERTIFIE` vers `MISE_EN_SERVICE_AUTORISEE`. Toute autre transition est rejetée par le domaine.

Non-intrusion et cohérence événementielle

- **Ce que le service ne fait pas :** aucun calcul de couverture ni tri topologique (algorithme 6.30 de `MS-HOMOLOGATION`), aucune lecture du simulateur, aucune écriture dans le dispositif de gestion des changements, aucune action sur le commutateur, aucune clé monétique. Les seules clés utilisées sont les clés de signature des responsables et la clé de cachet de la plateforme, toutes deux conservées dans le coffre de clés.
- **Transactional Outbox :** toute mutation (ouverture du dossier, quitus, attestation, fiche lue, scellement) écrit dans la même transaction l'état et l'événement ; un processus d'arrière-plan publie sur le bus d'événements (enveloppe CloudEvents, livraison au moins une fois, ordre par liaison). Le consommateur d'entrée est idempotent (table de déduplication par identifiant d'événement, règle RG-35).
- **Sujets publiés :** quatre sujets sont émis :
  - `certification.quitus-signed.v1` (décision signée, favorable ou défavorable, avec son motif ; consommée par `MS-HOMOLOGATION` en cas de refus) ;
  - `certification.attestation-issued.v1` (attestation déposée en WORM ; consommée par `MS-HOMOLOGATION` pour déverrouiller la phase de mise en service et par `MS-PARTICIPANT` comme prérequis de l'état `ACTIF`) ;

- `certification.go-live-authorized.v1` (dossier complet et scellé ; déclencheur de la transition vers `ACTIF` dans `MS-PARTICIPANT`) ;
- `certification.notification-requested.v1` (demande de notification des signataires et des parties prenantes).

`MS-AUDIT`, `MS-REPORTING` et `MS-NOTIFICATION` consomment les trois premiers sujets.

6.1.8.2 Diagramme de composants internes de MS-CERTIFICATION

La Figure 6.22 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les commandes de l'application web du DES (signataires et ingénieur d'homologation) et de la console d'administration et d'audit (via `MS-GATEWAY`), le réveil de l'ordonnanceur et les événements du bus ; le cœur porte les trois entités du domaine 3 relevant de la certification et l'attestation ; les adaptateurs pilotés dialoguent avec la base relationnelle du service, le dispositif de gestion des changements (lecture seule), `MS-IAM`, le coffre de clés, l'autorité d'horodatage, `MS-DOCUMENT`, `MS-PARTICIPANT` et le bus d'événements.

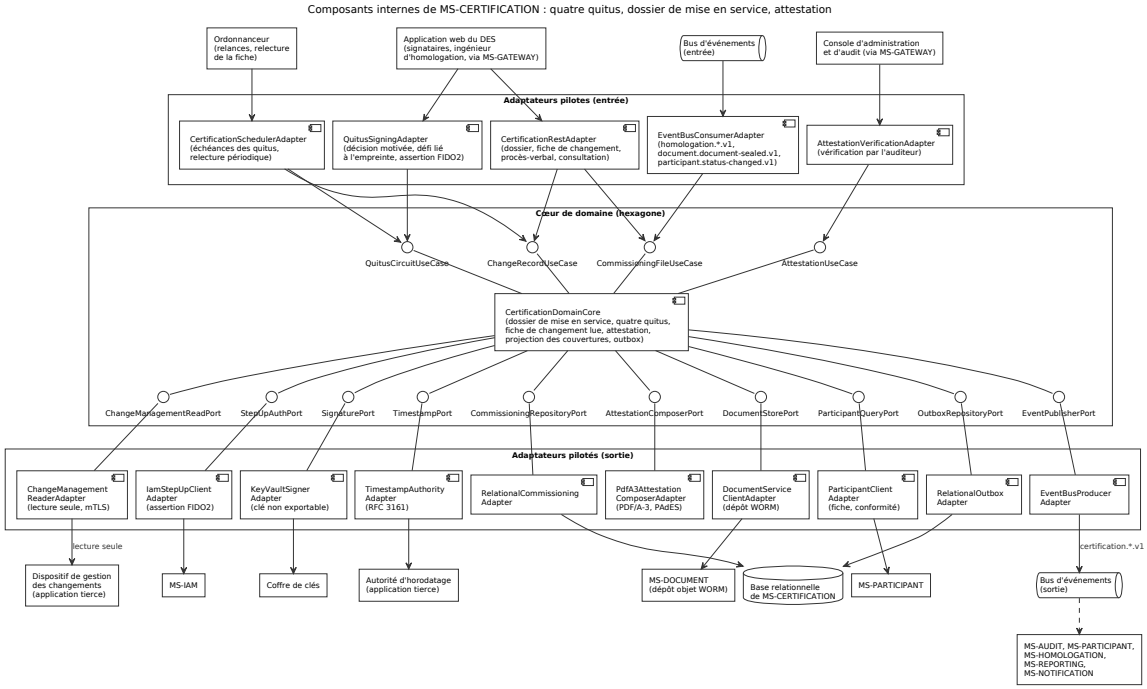


FIGURE 6.22: *Diagramme de composants internes : certification et mise en service*

- **Adaptateurs pilotes (entrée) :** `CertificationRestAdapter` (consultation du dossier, saisie de la référence de la fiche de changement, rattachement du procès-verbal) ; `QuitusSigningAdapter` (émission du défi lié à l'empreinte de la décision, réception de la décision motivée et de l'assertion FIDO2) ;

`AttestationVerificationAdapter` (vérification d'une attestation par l'auditeur) ; `CertificationSchedulerAdapter` (échéances et relances des quitus, relecture périodique de la fiche) ; `EventBusConsumerAdapter` (`homologation.liaison-ready-for-certification.v1`, `homologation.coverage-updated.v1`, `homologation.operation-closed.v1`, `document.document-sealed.v1`, `participant.status-changed.v1`).

- **Cœur de domaine :** `CertificationDomainCore` expose `CommissioningFileUseCase`, `QuitusCircuitUseCase`, `ChangeRecordUseCase` et `AttestationUseCase`, et requiert dix ports secondaires.
- **Adaptateurs pilotés (sortie) :** `RelationalCommissioningAdapter` et `RelationalOutboxAdapter` (base relationnelle du service) ; `ChangeManagementReaderAdapter` (lecture seule en mTLS, délai borné, disjoncteur) ; `IamStepUpClientAdapter` (vérification de l'assertion FIDO2 par `MS-IAM`) ; `KeyVaultSignerAdapter` (signature dans le coffre de clés, clé non exportable) ; `TimestampAuthorityAdapter` (jeton RFC 3161) ; `PdfA3AttestationComposerAdapter` (composition PDF/A-3 et signature PAdES) ; `DocumentServiceClientAdapter` (dépôt WORM et état de scellement) ; `ParticipantClientAdapter` (fiche et état de conformité) ; `EventBusProducerAdapter`.
- **Interactions :** `MS-HOMOLOGATION` par événement uniquement (aucun appel synchrone) ; `MS-IAM`, le coffre de clés et l'autorité d'horodatage à chaque quitus ; `MS-DOCUMENT` au dépôt de l'attestation et au contrôle des pièces ; le dispositif de gestion des changements en lecture seule ; `MS-AUDIT`, `MS-PARTICIPANT`, `MS-HOMOLOGATION`, `MS-REPORTING` et `MS-NOTIFICATION` en consommateurs des événements `certification.*.v1`.

6.1.8.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.23 détaille les classes du domaine, les ports et les adaptateurs. Les entités d'analyse Quitus, Fiche de changement et Dossier de mise en service y sont reprises avec leurs types et leurs signatures ; la liaison et la couverture y figurent comme références vers `MS-HOMOLOGATION`, dont le service ne détient qu'une projection locale.

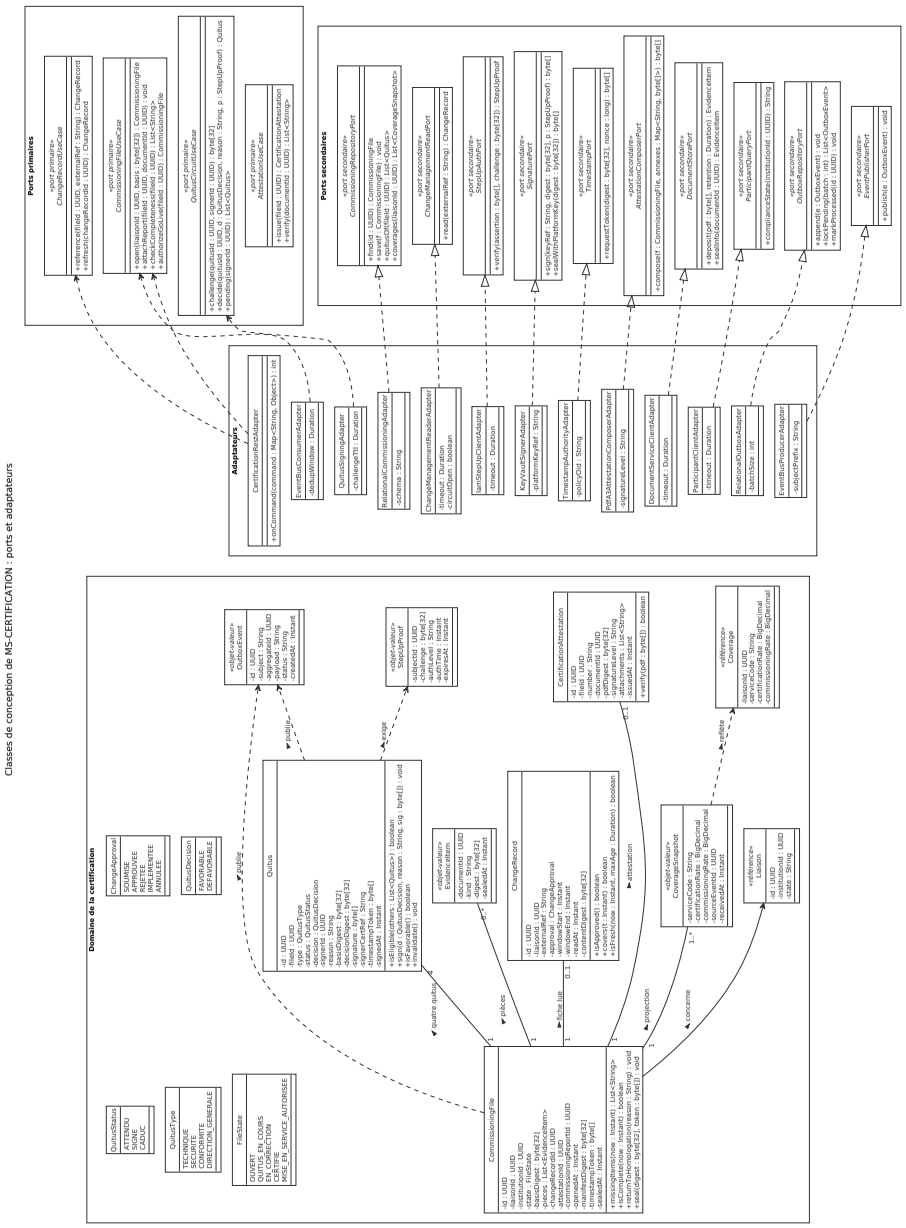


FIGURE 6.23: *Diagramme de classes de conception : service MS-CERTIFICATION*

- **Entités :** `CommissioningFile`, le dossier de mise en service (`liaisonId`, `institutionId : UUID`, `state : FileState`, `basisDigest : byte[32]`, `pieces : List<EvidenceItem>`, `changeRecordId`, `attestationId`, `commissioningReportId : UUID`, `manifestDigest : byte[32]`, `timestampToken : byte[]`, `openedAt`, `sealedAt : Instant`, méthodes `missingItems`, `isComplete`, `returnToHomologation`, `seal`) ; `Quitus` (`type : QuitusType`, `status : QuitusStatus`, `decision : QuitusDecision`, `signerId`, `reason`, `basisDigest` et `decisionDigest : byte[32]`, `signature`, `timestampToken : byte[]`, `signerCertRef`, `signedAt`, méthodes `isEligible`, `sign`, `isFavorable`, `invalidate`) ; `ChangeRecord`, la fiche de changement lue (`externalRef`, `approval : ChangeApproval`, `windowStart`, `windowEnd`, `readAt : Instant`, `contentDigest`, méthodes `isApproved`, `covers`, `isFresh`) ; `CertificationAttestation` (`number`, `documentId`, `pdfDigest : byte[32]`, `signatureLevel`, `attachments : List<String>`, `issuedAt`, méthode `verify`).
- **Énumérations, objets-valeurs et références :** `FileState` (`OUVERT`, `QUITUS_EN_COURS`, `EN_CORRECTION`, `CERTIFIE`, `MISE_EN_SERVICE_AUTORISEE`), `QuitusType`, `QuitusStatus` (`ATTENDU`, `SIGNE`, `CADUC`), `QuitusDecision`, `ChangeApproval` (`SOUMISE`, `APPROUVEE`, `REJETEE`, `IMPLEMENTEE`, `ANNULEE`) ; `CoverageSnapshot` (projection des couvertures, `certificationRate` et `commissioningRate : BigDecimal`, `sourceEventId`) ; `EvidenceItem` (`documentId`, `kind`, `digest : byte[32]`, `sealedAt`) ; `StepUpProof` (preuve de réauthentification à usage unique : `challenge : byte[32]`, `authLevel`, `authTime`, `expiresAt`) ; `OutboxEvent` ; `Liaison` et `Coverage` stéréotypées « référence ».
- **Ports primaires :** `CommissioningFileUseCase` (`open`, `attachReport`, `checkCompleteness`, `authorizeGoLive`) ; `QuitusCircuitUseCase` (`challenge`, `decide`, `pending`) ; `ChangeRecordUseCase` (`reference`, `refresh`) ; `AttestationUseCase` (`issue`, `verify`).
- **Ports secondaires :** `CommissioningRepositoryPort`, `ChangeManagementReadPort` (`read`), `StepUpAuthPort` (`verify`), `SignaturePort` (`sign`, `sealWithPlatformKey`), `TimestampPort` (`requestToken`), `AttestationComposerPort` (`compose`), `DocumentStorePort` (`deposit`, `sealInfo`), `ParticipantQueryPort` (`complianceState`), `OutboxRepositoryPort`, `EventPublisherPort`.

- **Adaptateurs :** `CertificationRestAdapter`, `QuitusSigningAdapter` et `EventBusConsumerAdapter` pilotent les ports primaires ; les dix adaptateurs pilotés réalisent chacun un port secondaire.

6.1.8.4 Diagramme d'objets du service MS-CERTIFICATION

La Figure 6.24 capture la liaison de paiement mobile de l'Établissement de paiement A, déjà suivie dans `MS-HOMOLOGATION`, à l'instant où son dossier de mise en service vient d'être scellé : les quatre quitus ont été signés favorablement dans l'ordre imposé sur le même socle d'évaluation, l'attestation de certification a été émise neuf jours plus tôt, la fiche de changement lue est implémentée, le procès-verbal de mise en service est scellé en WORM, les couvertures de certification et de mise en service sont totales, et l'événement d'autorisation de mise en service attend sa publication.

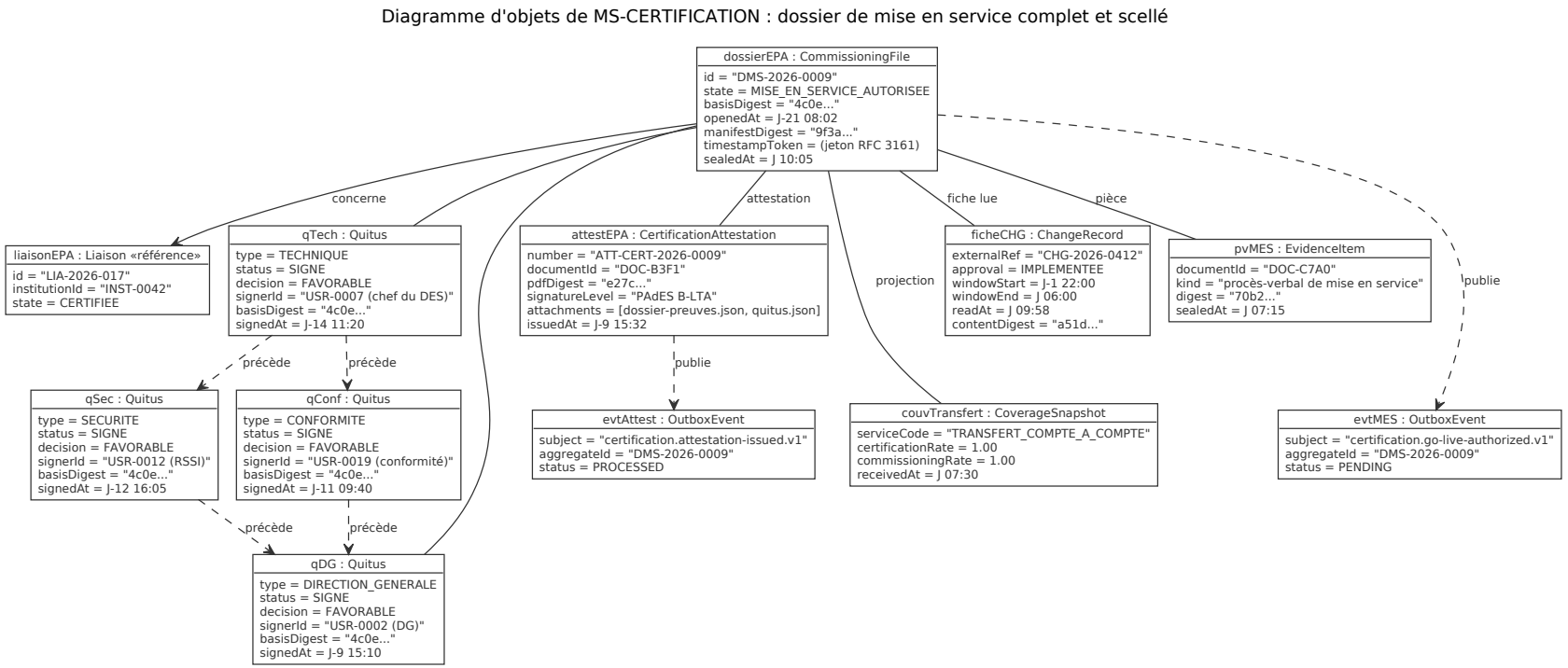


FIGURE 6.24: *Diagramme d'objets : dossier de mise en service complet et scellé*

- `liaisonEPA : Liaison` (référence), identifiant `LIA-2026-017`, institution `INST-0042`, état `CERTIFIEE` ;
- `dossierEPA : CommissioningFile`, identifiant `DMS-2026-0009`, ouvert à J-21, empreinte de socle `4c0e...`, empreinte de manifeste `9f3a...` horodatée par jeton RFC 3161, scellé à J 10h05, état `MISE_EN_SERVICE_AUTORISEE` ;
- `qTech`, `qSec`, `qConf` et `qDG : Quitus`, signés favorablement respectivement par le chef du DES (J-14), le RSSI (J-12), le responsable conformité (J-11) et la Direction Générale (J-9), tous sur l'empreinte de socle `4c0e...` ; les liens « précède » matérialisent l'ordre imposé ;
- `attestEPA : CertificationAttestation`, numéro `ATT-CERT-2026-0009`, pièce `DOC-B3F1`, niveau PAdES B-LTA, pièces jointes (dossier de preuves et quitus au format JSON), émise à J-9 15h32 ;
- `ficheCHG : ChangeRecord`, référence `CHG-2026-0412`, état `IMPLEMENTEE`, fenêtre de J-1 22h00 à J 06h00, lue à J 09h58 ;
- `pvMES : EvidenceItem`, procès-verbal de mise en service, pièce `DOC-C7A0`, scellé à J 07h15 ; `couvTransfert : CoverageSnapshot`, service de transfert de compte à compte, couvertures de certification et de mise en service égales à 1,00 ;
- `evtAttest : OutboxEvent`, sujet `certification.attestation-issued.v1`, publié ; `evtMES : OutboxEvent`, sujet `certification.go-live-authorized.v1`, en attente de publication.

6.1.8.5 Algorithmes fondamentaux de MS-CERTIFICATION

Cette section formalise les quatre algorithmes qui régissent le circuit des quatre quitus, le contrôle de complétude du dossier de mise en service, le scellement avec horodatage RFC 3161 des décisions et du dossier, et la génération de l'attestation de certification au format PDF/A-3 signée en PAdES.

Algorithme 6.35 : Circuit des quatre quitus Cet algorithme ouvre le circuit sur un socle d'évaluation figé, n'accepte une décision que du rôle attendu et dans l'ordre imposé, lie la réauthentification forte et la signature à l'empreinte exacte de la décision, et oriente le dossier vers l'attestation ou vers le retour en homologation.

Spécification formelle de l'algorithme 6.35 : circuit des quatre quitus	
Entrées	Dossier F ; socle d'évaluation B (couvertures, opérations closes, empreintes des preuves) ; décision (q, d, m) du signataire u ; assertion FIDO2 a.
Sorties	Quitus signé $(\delta_q, \sigma_q, \tau_q)$; quitus devenus éligibles ; dossier `CERTIFIE` ou `EN_CORRECTION` ; événements.
Complexité	$\mathcal{O}(1)$ par décision (quatre types fixes) ; trois appels synchrones bornés (`MS-IAM`, coffre de clés, autorité d'horodatage).
Contrôles	Rôle attendu ; quatre signataires distincts ; signataire étranger à l'évaluation ; motif obligatoire ; défi à usage unique.

TABLE 6.38: *Fiche de spécification : circuit des quatre quitus*

Déroulement procédural étape par étape :

1. **Ouverture du circuit :** à la réception de `homologation.liaison-ready-for-certification.v1`, calculer l'empreinte du socle $\beta = \mathrm{SHA256}(\mathrm{JCS}(B))$ (canonicalisation RFC 8785), la sceller (algorithme 6.37), créer les quatre quitus à l'état `ATTENDU` portant β et passer F à `QUITUS_EN_COURS`. En reprise après correction, conserver un quitus favorable si son β est égal au nouveau socle, le passer à `CADUC` et en recréer un sinon.

2. **Éligibilité dans l'ordre imposé :** avec la relation de précédence $\prec$ définie par $T \prec S$, $T \prec C$, $S \prec D$ et $C \prec D$ (technique, sécurité, conformité, direction générale), un quitus q est éligible si :

$$\mathrm{elig}(q) \iff q.\mathrm{status} = \texttt{ATTENDU} \wedge \forall p \prec q,\ p \text{ signé et favorable} \tag{6.35}$$

   À chaque quitus devenu éligible, insérer `certification.notification-requested.v1` à destination du rôle attendu, avec échéance et relance par l'ordonnanceur.

3. **Habilitation du signataire :** exiger que u détienne le rôle attendu pour le type de q (niveau 2, ou délégation temporaire active consignée par `MS-IAM`), qu'il n'ait signé aucun autre quitus de F, qu'il ne soit ni chef de projet de la liaison ni responsable d'une de ses opérations ; pour un quitus de conformité favorable, exiger en outre l'état `CONFORME` lu par `ParticipantQueryPort`.

4. **Défi et réauthentification forte :** construire la décision canonique et son empreinte :

$$\delta_q = \mathrm{SHA256}\big(\mathrm{JCS}(F.\mathrm{id}, q.\mathrm{type}, d, m, \beta, u, t)\big) \tag{6.36}$$

et la présenter comme défi WebAuthn ; `StepUpAuthPort.verify` contrôle l'assertion a (défi égal à δ_q, présence et vérification de l'utilisateur, compteur de signature croissant) et délivre une preuve à usage unique valable deux minutes.

5. **Signature et scellement :** `SignaturePort.sign` fait calculer σ_q sur δ_q par le coffre de clés avec la clé personnelle de u, sur présentation de la preuve ; vérifier σ_q avec le certificat du signataire avant toute écriture, puis obtenir τ_q sur $\mathrm{SHA256}(\delta_q \parallel \sigma_q)$; enregistrer le quitus `SIGNE` et insérer `certification.quitus-signed.v1` dans la même transaction.

6. **Orientation du dossier :** si d est défavorable, passer F à `EN_CORRECTION`, suspendre les quitus encore attendus et notifier le chef du DES et le chef de projet ; `MS-HOMOLOGATION` renvoie la liaison en homologation avec le motif m. Si les quatre quitus sont signés et favorables, déclencher la génération de l'attestation (algorithme 6.38).

Algorithme 6.36 : Constitution et contrôle de complétude du dossier de mise en service
Cet algorithme vérifie, avant toute autorisation, que le dossier réunit toutes les conditions de la mise en service, chacune étayée par une pièce dont l'empreinte est contrôlée, puis déclenche son scellement. Il est invoqué à chaque événement pertinent et à la demande de l'ingénieur d'homologation ; il est déterministe et sans effet tant qu'une condition manque.

Spécification formelle de l'algorithme 6.36 : complétude du dossier	
Entrées	Dossier F à l'état `CERTIFIE` ; projection des couvertures $\{(\gamma_s, \mu_s)\}_{s \in \mathscr{S}_L}$; quitus ; attestation ; fiche K ; procès-verbal P ; t_{now}.
Sorties	Liste des éléments manquants ; ou dossier scellé, état `MISE_EN_SERVICE_AUTORISEE` et événement d'autorisation.
Complexité	$\mathscr{O}(\lvert\mathscr{S}_L\rvert + \lvert\mathscr{P}_F\rvert)$, $\mathscr{P}_F$ désignant les pièces du dossier ; une lecture de la fiche.
Garantie	Aucune autorisation sur une lecture périmée ; fiche jamais modifiée ; règle RG-34 respectée.

TABLE 6.39: *Fiche de spécification : constitution et contrôle de complétude du dossier*

Déroulement procédural étape par étape :

1. **Projection des couvertures :** maintenir, à partir de `homologation.liaison-ready-for-certification.v1` et de `homologation.coverage-updated.v1`, la dernière couverture reçue par service (identifiant d'événement retenu, événement plus ancien ignoré). La couverture de mise en service ne progresse qu'après `certification.attestation-issued.v1`, qui déverrouille les opérations correspondantes dans `MS-HOMOLOGATION` (algorithme 6.33).

2. **Relecture de la fiche :** si $t_{\text{now}} - K.\text{readAt}$ dépasse quinze minutes, appeler `ChangeManagementReadPort.read` ; en cas d'indisponibilité, différer le contrôle sans conclure, sans jamais retenir un état antérieur.

3. **Évaluation des conditions :** le dossier est complet si et seulement si

$$\text{Complet}(F) \iff \bigwedge_{k=1}^{6} C_k(F) \tag{6.37}$$

avec C_1 : $\gamma_s = 1$ pour tout service inclus ; C_2 : quatre quitus signés, favorables, non caducs et portant le β courant ; C_3 : attestation déposée, scellement confirmé par `document.document-sealed.v1` ; C_4 : $K.\text{approval} \in \{\texttt{APPROUVEE}, \texttt{IMPLEMENTEE}\}$; C_5 : $\mu_s = 1$ pour tout service inclus ; C_6 : P scellé en WORM, date d'ouverture des flux comprise dans la fenêtre de K.

4. **Contrôle des empreintes :** pour chaque pièce $p \in \mathscr{P}_F$, comparer l'empreinte enregistrée à celle que restitue `DocumentStorePort.sealInfo` ; toute divergence rend le dossier incomplet et lève une alerte vers le RSSI.

5. **Issue :** si une condition manque, retourner la liste $\{k \mid \neg C_k(F)\}$ avec libellés, affichée à l'ingénieur d'homologation. Sinon, construire le manifeste M_F (identifiants, β, $(\delta_q, \sigma_q, \tau_q)$ des quatre quitus, empreintes de l'attestation, de la fiche lue et du procès-verbal) et le sceller (algorithme 6.37).

6. **Autorisation :** dans la même transaction que le scellement, passer F à `MISE_EN_SERVICE_AUTORISEE` et insérer `certification.go-live-authorized.v1`, consommé par `MS-PARTICIPANT` (transition vers `ACTIF`), `MS-REPORTING`, `MS-NOTIFICATION` et `MS-AUDIT`.

Algorithme 6.37 : Scellement et horodatage RFC 3161 Cet algorithme est commun au socle d'évaluation, à chaque quitus et au manifeste du dossier : il canonicalise l'objet, en calcule l'empreinte, obtient un jeton de l'autorité d'horodatage, le vérifie et en confie l'inscription à `MS-AUDIT`. La date du jeton est opposable indépendamment de l'horloge de la plateforme.

Spécification formelle de l'algorithme 6.37 : scellement et horodatage	
Entrées	Objet à sceller X (socle, décision signée ou manifeste) ; politique d'horodatage attendue ; ancre de confiance de l'autorité.
Sorties	Empreinte h_X ; jeton vérifié τ_X ; événement porteur de h_X et de τ_X inscrit par `MS-AUDIT`.
Complexité	$\mathcal{O}(\lvert X\rvert)$ pour la canonicalisation et l'empreinte ; un aller-retour avec l'autorité.
Standard	RFC 3161 et RFC 5816 (horodatage), RFC 8785 (canonicalisation), RFC 9162 (inscription par `MS-AUDIT`).

TABLE 6.40: *Fiche de spécification : scellement et horodatage RFC 3161*

Déroulement procédural étape par étape :

1. **Canonicalisation et empreinte :** sérialiser X selon la RFC 8785 (clés triées, nombres et chaînes normalisés), ce qui rend l'empreinte reproductible par un vérificateur tiers, puis calculer $h_X = \mathrm{SHA256}(\mathrm{JCS}(X))$.

2. **Requête :** construire une requête `TimeStampReq` contenant l'empreinte de message $(\text{SHA-256}, h_X)$, un nonce aléatoire n de 64 bits, la politique attendue et l'indicateur de demande du certificat de l'autorité ; l'envoyer par `TimestampPort.requestToken`.

3. **Vérification du jeton :** exiger un statut `granted` ou `grantedWithMods`, puis vérifier dans `TSTInfo` que l'empreinte de message est égale à h_X, que le nonce est égal à n et que la politique est l'attendue ; vérifier la signature du jeton et l'identifiant du certificat signataire (RFC 5816), et la chaîne de ce certificat jusqu'à l'ancre de confiance, usage étendu d'horodatage compris.

4. **Contrôle de cohérence temporelle :** rejeter le jeton si sa date t_τ s'écarte de l'horloge locale synchronisée au-delà de la tolérance configurée, ce qui signale une dérive de l'une des deux horloges ; consigner l'anomalie dans le journal du service.

5. **Indisponibilité :** en cas d'échec, réessayer avec retard exponentiel ; l'objet reste à l'état non scellé et aucune transition qui en dépend (circuit, autorisation) n'est franchie ; au-delà de trois échecs, lever une alerte vers `MS-MONITORING`.

6. **Inscription :** enregistrer (h_X, τ_X) et insérer l'événement correspondant dans l'outbox ; `MS-AUDIT` en fait une feuille $\ell = \mathrm{SHA256}(\texttt{0x00} \parallel e)$ de son arbre, e désignant l'événement canonique, ce qui permet à l'auditeur de prouver l'inclusion de la décision sans faire confiance au seul service.

Algorithme 6.38 : Génération de l'attestation PDF/A-3 signée PAdES Cet algorithme compose l'attestation de certification lorsque les quatre quitus sont favorables, y embarque le dossier de preuves, la signe avec la clé de cachet de la plateforme au niveau PAdES B-LTA, la dépose en WORM et publie son émission. L'attestation reste vérifiable hors de la plateforme pendant toute la durée de conservation.

Spécification formelle de l'algorithme 6.38 : attestation PDF/A-3 signée PAdES	
Entrées	Dossier F ; quatre quitus scellés ; socle B ; gabarit de l'attestation ; référence de la clé de cachet ; informations de révocation.
Sorties	Attestation PDF/A-3 de niveau PAdES B-LTA ; pièce WORM ; `certification.attestation-issued.v1`.
Complexité	$\mathcal{O}(\lvert D\rvert + \sum \lvert a_i\rvert)$ en octets du document et des pièces jointes ; une signature, deux jetons d'horodatage.
Standard	ISO 19005-3 (PDF/A-3), ETSI EN 319 142 (PAdES), RFC 5652 (CMS), RFC 3161, RFC 5280 et RFC 6960.

TABLE 6.41: *Fiche de spécification : génération de l'attestation PDF/A-3 signée PAdES*

Déroulement procédural étape par étape :

1. **Composition :** produire le document à partir du gabarit (institution, liaison, services certifiés, dates et signataires des quatre quitus, numéro d'attestation), polices incorporées, profil de couleur déclaré et métadonnées XMP d'identification PDF/A-3 (niveau de conformité « u ») ; aucune donnée de carte n'y figure.

2. **Pièces jointes :** embarquer le dossier de preuves (socle B en JSON canonique, ou en XML pour les destinataires qui le demandent) et les quatre décisions signées avec leurs jetons, chacune déclarée dans le tableau des fichiers associés avec son type de média et une relation `Source` ou `Data` ; enregistrer leurs empreintes h_{a_i}.

3. **Signature PAdES :** réserver le champ de signature, calculer l'empreinte des plages d'octets couvertes et faire signer par `SignaturePort.sealWithPlatformKey` :

$$h_D = \mathrm{SHA256}\big(D[\mathrm{ByteRange}]\big), \qquad \sigma_D = \mathrm{Sign}_{k_{\mathrm{cachet}}}(h_D) \tag{6.38}$$

   puis encapsuler σ_D dans une structure CMS (RFC 5652) avec l'attribut de certificat signataire, et y ajouter un jeton RFC 3161 sur la valeur de signature (niveau B-T).

4. **Validation à long terme :** rassembler la chaîne de certificats jusqu'à l'autorité de certification interne, les réponses OCSP (RFC 6960) et les listes de révocation (RFC

5280), et les inscrire dans le magasin de sécurité du document par mise à jour incrémentale (niveau B-LT) ; ajouter un horodatage de document couvrant l'ensemble (niveau B-LTA).

5. **Contrôles avant dépôt :** valider la conformité PDF/A-3 et la signature (intégrité, chaîne, révocation, jetons) par un vérificateur indépendant de l'outil de composition ; tout échec interrompt l'émission et lève une alerte vers le RSSI.

6. **Dépôt et publication :** déposer le document par `DocumentStorePort.deposit` (analyse antivirale, contrôle de masquage, empreinte, rétention en mode conformité d'au moins dix ans : algorithme 6.17) ; enregistrer l'attestation, passer F à `CERTIFIE` et insérer `certification.attestation-issued.v1` portant le numéro, l'identifiant de pièce et SHA256(D), que `MS-AUDIT` référence.

6.1.9 Tickets, incidents et cellule de crise (MS-INCIDENT)

Le service `MS-INCIDENT` tient le cycle de vie de toute sollicitation adressée au Département Exploitation et Supervision (DES) : demande, incident, intervention, accès d'astreinte, anomalie. Il porte l'automate d'états des tickets et la chronologie immuable de leurs transitions, qualifie les incidents par la matrice impact × urgence et leur attribue une sévérité de S1 à S4 et, le cas échéant, le marqueur réglementaire, décompte le délai imputable au département en gelant les périodes d'attente de tiers, déroule la matrice d'escalade, contrôle les critères de clôture d'un incident, génère le rapport circonstancié et conduit la cellule de crise, de sa convocation à l'archivage du rapport post-incident. Il reçoit ses tickets des utilisateurs (application web du département et portail des participants, par `MS-GATEWAY`) et des autres services par le bus d'événements : alerte acquittée de `MS-MONITORING`, escalade épuisée de `MS-NOTIFICATION`, suspens contesté de `MS-RAPPROCHEMENT`, divergence d'intégrité de `MS-AUDIT` ou de `MS-DOCUMENT`. Le service ne supervise rien (c'est le rôle de `MS-MONITORING`), ne remet aucun message (il le demande à `MS-NOTIFICATION`), n'héberge ni salon ni conférence (il les demande à `MS-COLLABORATION`) et ne gère pas les tâches (les actions de remédiation deviennent des tâches de `MS-PILOTAGE`). Surtout, il n'agit jamais sur la production monétique : les mesures de rétablissement sont exécutées dans les systèmes de production par leurs exploitants ; la plateforme les trace, les date et en conserve les preuves.

6.1.9.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : COBAC, PCI-DSS v4.0.1 et ISO/IEC 27001

- **Règlements COBAC R-2016/04 et R-2024/01 :** le dispositif de contrôle interne et de gestion des risques opérationnels et de sécurité des systèmes d'information attend que

les incidents soient détectés, qualifiés, suivis jusqu'à leur résolution, documentés et, pour les plus significatifs, portés à la connaissance de l'autorité de supervision. Le service en tient la matière : chronologie opposable, sévérité et marqueur réglementaire, rapport circonstancié. La déclaration elle-même relève du responsable conformité ; la plateforme la prépare et la trace, sans se substituer à lui.

- **PCI-DSS v4.0.1, exigence 12.10 :** un plan de réponse aux incidents existe et peut être activé immédiatement ; il désigne les rôles, les modalités d'escalade et de communication, et il est amélioré à partir des retours d'expérience. Le service outille chacun de ces points : matrice d'escalade, cellule de crise, critère de capitalisation.
- **ISO/IEC 27001, mesures de l'annexe A relatives aux incidents :** planification et préparation, appréciation des événements et décision, réponse, apprentissage à partir des incidents et collecte de preuves. La qualification horodatée, la chaîne des transitions et le dépôt des pièces dans `MS-DOCUMENT` répondent à la dernière exigence.
- **Journalisation :** toute mutation est un événement à effet, publié sous `incident.<agrégat>-<événement>.v1` par la table d'outbox et consommé par `MS-AUDIT` ; `MS-REPORTING` en tire les indicateurs (délais de prise en compte et de rétablissement, respect des engagements, nombre d'incidents par sévérité).

Tickets de toute nature et automate d'états

- **Types :** `DEMANDE` (sollicitation d'un participant ou d'un collaborateur), `INCIDENT` (dégradation ou interruption d'un service, ou événement de sécurité), `INTERVENTION` (opération planifiée consignée), `ACCES_ASTREINTE` (demande d'accès exceptionnel pendant l'astreinte, dont l'octroi reste une délégation temporaire de `MS-IAM` bornée dans le temps) et `ANOMALIE` (dysfonctionnement de la plateforme elle-même, escalade épuisée, litige de rapprochement).
- **États :** `OUVERT`, `QUALIFIE`, `EN_COURS`, `EN_ATTENTE_TIERS`, `RESOLU`, `CLOS`, `REOUVERT`. Seules les transitions de la table de l'automate (algorithme 6.39) sont admises ; chacune exige un acteur authentifié et, pour la mise en attente, la résolution sans suite et la réouverture, un justificatif.
- **Chronologie :** chaque transition est une ligne en ajout seul qui porte l'empreinte de la précédente ; la chronologie d'un ticket forme ainsi une chaîne vérifiable localement, doublée par l'arbre de Merkle de `MS-AUDIT`.
- **Origine et liens :** un ticket référence son origine (alerte de `MS-MONITORING`, suspens de `MS-RAPPROCHEMENT`, notification de `MS-NOTIFICATION`), l'institution concernée et

la liaison, par leurs seuls identifiants. Un représentant de participant ne crée et ne consulte que les tickets de sa propre institution, filtrage imposé par le contrôle d'accès par attributs.

Qualification, engagements de service et gel d'attente de tiers

- **Matrice impact × urgence :** l'impact (étendue : d'un utilisateur à l'ensemble du réseau) et l'urgence (sensibilité au temps) sont cotés de 1 à 5 ; la matrice 5×5 versionnée donne la sévérité S1 (critique) à S4 (mineure). La version de matrice appliquée est enregistrée avec la qualification, de sorte qu'un changement de paramétrage ne modifie jamais rétroactivement une sévérité déjà attribuée.
- **Marqueur réglementaire :** un incident est marqué « à déclarer » lorsqu'il est de sévérité S1, lorsqu'il s'agit d'un incident de sécurité avec suspicion de compromission de données, ou lorsqu'une indisponibilité de service dépasse le seuil fixé par la procédure interne de déclaration ; le marqueur impose le rapport circonstancié et le visa du responsable conformité à la clôture.
- **Engagements :** à chaque sévérité correspond un délai de prise en compte, un délai de rétablissement et des paliers d'escalade (tableau 6.42). Le décompte court en temps calendaire, l'exploitation étant continue.
- **Gel :** la mise en attente de tiers (opérateur de télécommunications, participant, fournisseur) ouvre un gel d'engagement motivé et appuyé d'une pièce ; la sortie de l'état le referme. Le temps gelé est déduit du délai imputable, jamais de la durée brute, qui reste publiée ; un gel ne suspend pas l'information hiérarchique d'un incident S1.

Sévérité	Prise en compte	Rétablissement	Paliers d'escalade	Cellule de crise
S1	15 min	2 h	N1 à N3 immédiatement, rappel à 30 min, N4 à 1 h	automatique
S2	30 min	4 h	N2 à 50 %, N3 à 75 %, N4 à 100 % du délai	sur décision
S3	2 h	8 h	N2 à 75 %, N3 à 100 % du délai	non
S4	8 h	3 jours	N2 à l'échéance	non

TABLE 6.42: *Engagements de service et paliers d'escalade par sévérité (valeurs paramétrables)*

Escalade selon la matrice d'escalade

- **Niveaux internes :** N1 opérateur de supervision ou agent assigné ; N2 chef de quart ; N3 chef du DES, et le RSSI pour un incident de sécurité ; N4 Direction Générale.

Les titulaires et leurs délégués sont lus à l'instant de l'escalade dans `MS-IAM` (matrice d'escalade interne et délégations actives).

- **Niveaux externes :** lorsqu'un incident touche une institution, son contact d'escalade de la sévérité considérée est lu dans l'annuaire d'escalade de `MS-PARTICIPANT` et informé en parallèle.
- **Remise :** le service ne remet rien lui-même : il publie `incident.incident-escalated.v1` et `incident.notification-requested.v1`, ou appelle le port synchrone de `MS-NOTIFICATION` pour un incident S1 ; l'acquittement et la suppléance des destinataires relèvent de ce service (algorithme 6.23). Une escalade épuisée (`notification.escalation-exhausted.v1`) revient à `MS-INCIDENT`, qui ouvre un ticket d'anomalie.

Critères de clôture d'un incident et rapport circonstancié

- **Critères :** un incident n'est clos que si quatre critères sont satisfaits : cause racine établie, remédiation (plan et actions correctives achevées, actions préventives portées par des tâches nominatives de `MS-PILOTAGE`), test de résolution prouvé, capitalisation (retour d'expérience référencé). Ces critères de clôture d'un incident sont propres à ce service et ne se confondent pas avec la règle des quatre éléments de la clôture d'une opération d'homologation (algorithme 6.31).
- **Rapport circonstancié :** obligatoire pour S1, S2 et tout incident marqué ; généré au passage à `RESOLU` à partir de la chronologie, de la qualification, des gels, des escalades et des critères, complété par le gestionnaire, converti en PDF/A-3, horodaté selon la RFC 3161 et déposé dans `MS-DOCUMENT`, qui en rend la référence et l'empreinte.
- **Liens avec les autres services :** l'ouverture d'un ticket depuis une alerte est publiée et consommée par `MS-MONITORING`, qui renseigne le ticket lié de l'alerte ; les actions de remédiation sont demandées à `MS-PILOTAGE` (`incident.remediation-requested.v1`), dont les événements de tâche mettent à jour leur état.

Cellule de crise, main courante de crise et rapport post-incident

- **Ouverture :** automatique à la qualification S1, ou sur décision motivée du chef du DES pour un incident S2 ou un événement grave. L'ouverture (`incident.crisis-opened.v1`) convoque les membres de droit par

MS-NOTIFICATION (niveau critique) et demande à MS-COLLABORATION le salon chiffré de bout en bout et la conférence de crise (algorithme 6.62) ; MS-COLLABORATION ne fait qu'ouvrir, sur cette demande, ce que MS-INCIDENT a décidé.

- **Quorum et suppléance :** la cellule est constituée lorsque le quorum pondéré est atteint et que le chef du DES ou son délégué est présent ; un membre absent au délai de quorum est remplacé par son suppléant, et l'anomalie est consignée.
- **Conduite :** la main courante de crise consigne en ajout seul, avec chaînage des empreintes, présences, hypothèses, directives et décisions ; une décision portant une action devient une tâche de MS-PILOTAGE.
- **Clôture et archivage :** la clôture (incident.crisis-closed.v1) conduit MS-COLLABORATION à fermer le salon et à sceller l'archive des échanges en GED ; MS-INCIDENT en conserve la référence et produit, sous cinq jours ouvrés, le rapport post-incident, scellé à son tour. La cellule est archivée lorsque les deux références sont présentes.

6.1.9.2 Diagramme de composants internes de MS-INCIDENT

La Figure 6.25 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les actions des utilisateurs par MS-GATEWAY, les événements des autres services et les impulsions de l'ordonnanceur ; le cœur porte les six entités d'analyse du domaine 4 qui lui reviennent (ticket, incident, transition, gel d'engagement, cellule de crise, entrée de main courante de crise) ; les adaptateurs pilotés dialoguent avec la base relationnelle du service, MS-IAM, MS-PARTICIPANT, MS-NOTIFICATION, MS-DOCUMENT, l'autorité d'horodatage et le bus d'événements.

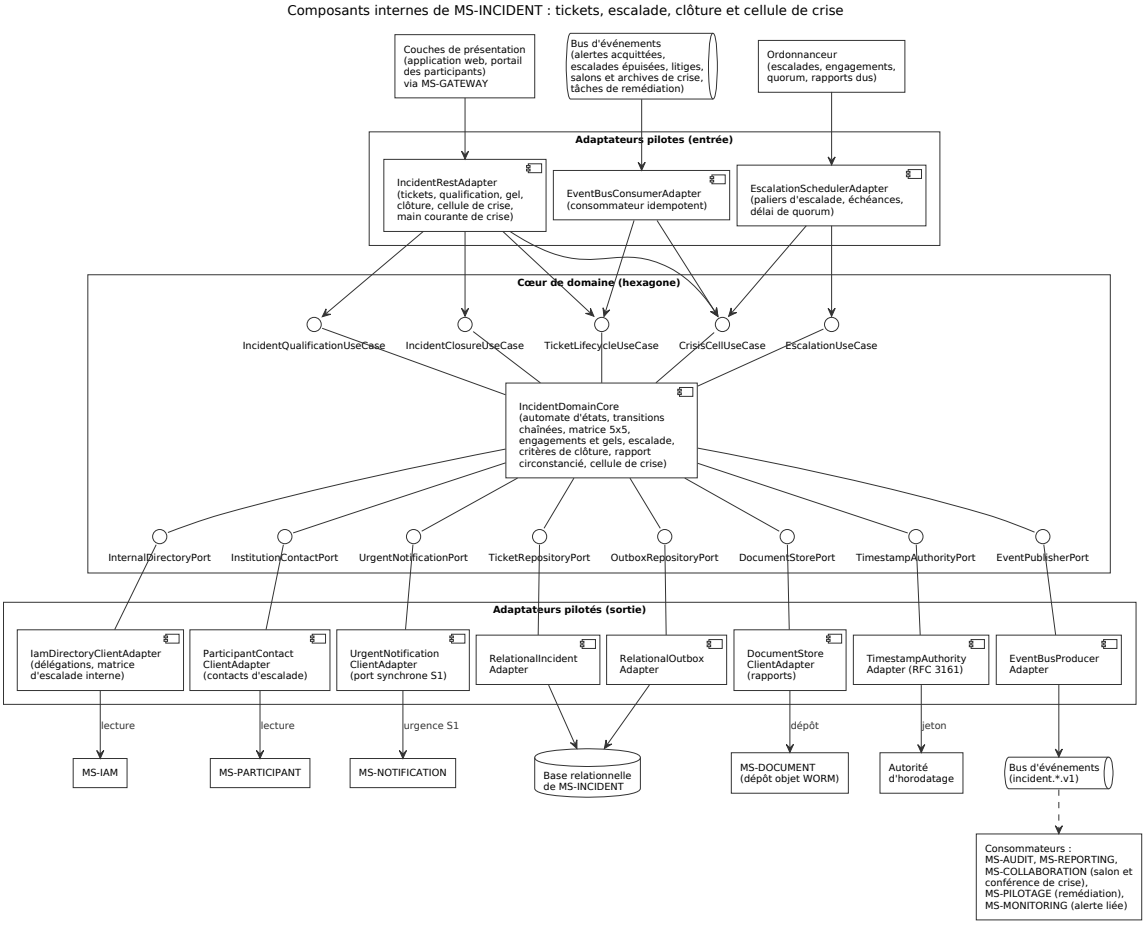


FIGURE 6.25: *Diagramme de composants internes : tickets, qualification, escalade, clôture et cellule de crise*

- **Adaptateurs pilotes (entrée) :** `EventBusConsumerAdapter` (consommateur idempotent de `monitoring.alert-acknowledged.v1`, `monitoring.alert-raised.v1`, `notification.escalation-exhausted.v1`, `notification.acknowledged.v1`, `rapprochement.suspens-contested.v1`, des événements de salon et d'archive de crise de `MS-COLLABORATION` et des événements de tâche de `MS-PILOTAGE`) ; `IncidentRestAdapter` (tickets, qualification, mise en attente, clôture, cellule de crise et main courante) ; `EscalationSchedulerAdapter` (paliers d'escalade, échéances d'engagement, délai de quorum, rapports post-incident dus).

- **Cœur de domaine :** `IncidentDomainCore` expose `TicketLifecycleUseCase`, `IncidentQualificationUseCase`, `EscalationUseCase`, `IncidentClosureUseCase` et `CrisisCellUseCase`, et requiert huit ports secondaires.

- **Adaptateurs pilotés (sortie) :** `RelationalIncidentAdapter` (tickets, incidents, transitions, gels, escalades, cellules, main courante) ;

`IamDirectoryClientAdapter` (matrice d'escalade interne, délégations, en lecture) ; `ParticipantContactClientAdapter` (fiche et contacts d'escalade par sévérité, en lecture) ; `UrgentNotificationClientAdapter` (port synchrone de `MS-NOTIFICATION` pour S1) ; `DocumentStoreClientAdapter` (dépôt des rapports) ; `TimestampAuthorityAdapter` (RFC 3161) ; `RelationalOutboxAdapter` et `EventBusProducerAdapter`.

- **Interactions :** `MS-AUDIT` et `MS-REPORTING` consomment tous les événements `incident.*` ; `MS-COLLABORATION` consomme l'ouverture et la clôture de crise ; `MS-PILOTAGE` consomme les demandes de remédiation ; `MS-MONITORING` consomme l'ouverture et la clôture des tickets issus d'une alerte ; `MS-NOTIFICATION` consomme `incident.notification-requested.v1`.

6.1.9.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.26 détaille les classes du domaine, les ports et les adaptateurs. Les entités d'analyse *Ticket*, *Incident*, *Transition*, *Gel d'engagement*, *Cellule de crise* et *Entrée de main courante* (ici restreinte aux entrées de crise, les entrées de quart appartenant à `MS-MONITORING`) y sont reprises avec leurs types et leurs signatures ; la matrice de qualification, l'engagement de service, l'escalade, le membre et la décision de crise les complètent.

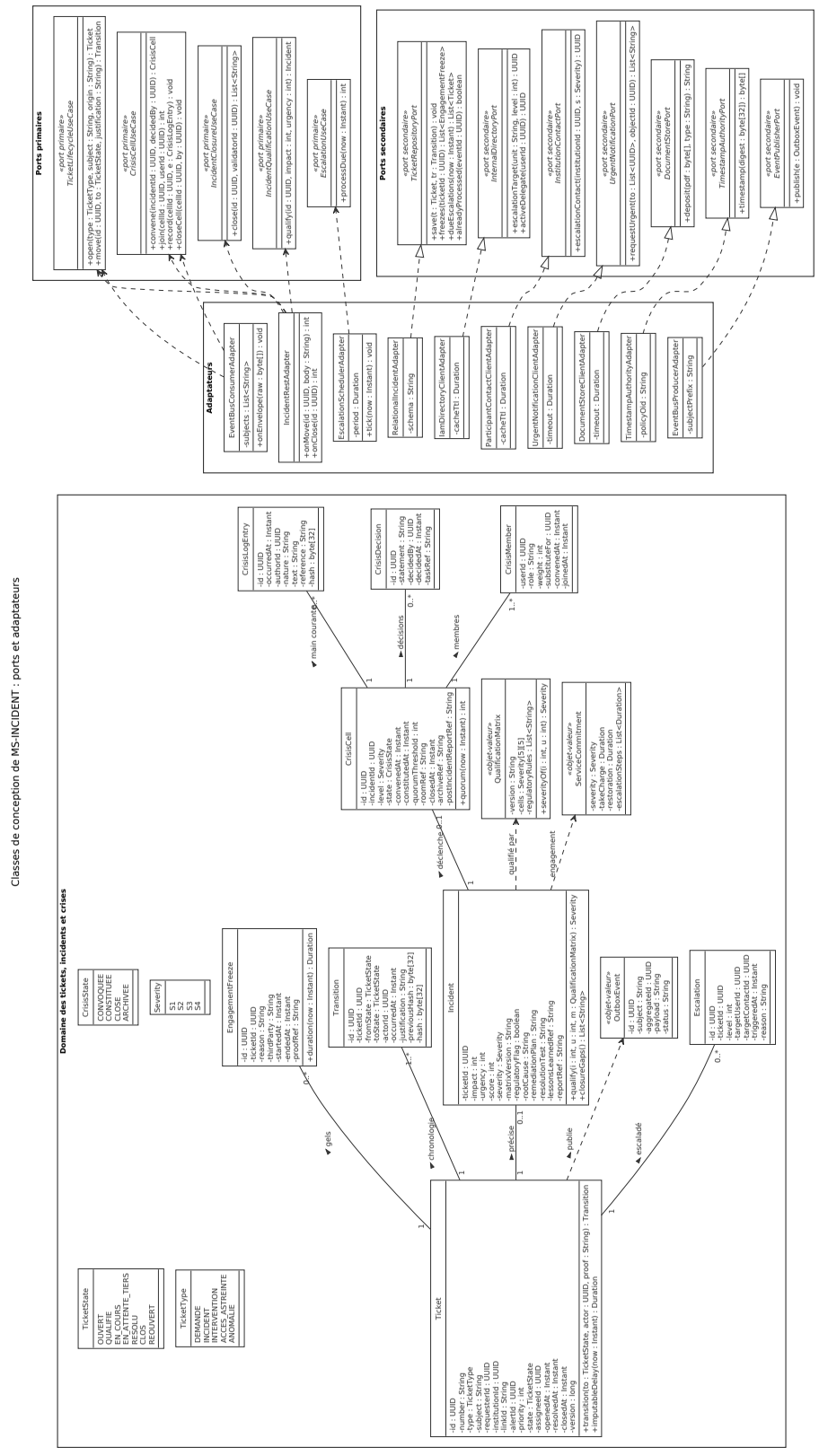


FIGURE 6.26: *Diagramme de classes de conception : service MS-INCIDENT*

- **Entités :** `Ticket` (`number : String`, `type : TicketType`, `requesterId`, `institutionId`, `alertId`, `assigneeId : UUID`, `linkId : String`, `priority : int`, `state : TicketState`, `openedAt`, `resolvedAt`, `closedAt : Instant`, `version : long`, méthodes `transition`, `imputableDelay`) ; `Incident` (`impact`, `urgency`, `score : int`, `severity : Severity`, `matrixVersion : String`, `regulatoryFlag : boolean`, `rootCause`, `remediationPlan`, `resolutionTest`, `lessonsLearnedRef`, `reportRef : String`, méthodes `qualify`, `closureGaps`) ; `Transition` (`fromState`, `toState`, `actorId`, `occurredAt`, `justification`, `previousHash`, `hash : byte[32]`) ; `EngagementFreeze` (`reason`, `thirdParty`, `startedAt`, `endedAt`, `proofRef`, méthode `duration`) ; `Escalation` (`level : int`, `targetUserId`, `targetContactId : UUID`, `triggeredAt`, `reason`) ; `CrisisCell` (`incidentId`, `level`, `state : CrisisState`, `convenedAt`, `constitutedAt`, `closedAt : Instant`, `quorumThreshold : int`, `roomRef`, `archiveRef`, `postIncidentReportRef : String`, méthode `quorum`) ; `CrisisMember` (`userId`, `role`, `weight : int`, `substituteFor : UUID`, `convenedAt`, `joinedAt`) ; `CrisisDecision` (`statement`, `decidedBy`, `decidedAt`, `taskRef`) ; `CrisisLogEntry` (`occurredAt`, `authorId`, `nature`, `text`, `reference`, `hash : byte[32]`).

- **Objets-valeurs :** `QualificationMatrix` (`version`, `cells : Severity[5][5]`, `regulatoryRules`, méthode `severityOf`) ; `ServiceCommitment` (`takeCharge`, `restoration : Duration`, `escalationSteps : List<Duration>`) ; `OutboxEvent`.

- **Énumérations :** `TicketType` (`DEMANDE`, `INCIDENT`, `INTERVENTION`, `ACCES_ASTREINTE`, `ANOMALIE`) ; `TicketState` (sept états) ; `Severity` (`S1` à `S4`) ; `CrisisState` (`CONVOQUEE`, `CONSTITUEE`, `CLOSE`, `ARCHIVEE`).

- **Ports primaires :** `TicketLifecycleUseCase` (`open`, `move`) ; `IncidentQualificationUseCase` (`qualify`) ; `EscalationUseCase` (`processDue`) ; `IncidentClosureUseCase` (`close`, qui retourne la liste des critères manquants) ; `CrisisCellUseCase` (`convene`, `join`, `record`, `closeCell`).

- **Ports secondaires :** `TicketRepositoryPort` (`save`, `freezes`, `dueEscalations`, `alreadyProcessed`) ; `InternalDirectoryPort` (`escalationTarget`, `activeDelegate`) ; `InstitutionContactPort` (`escalationContact`) ; `UrgentNotificationPort` (`requestUrgent`) ; `DocumentStorePort` (`deposit`) ; `TimestampAuthorityPort` (`timestamp`)

; `OutboxRepositoryPort` ; `EventPublisherPort`.

- **Adaptateurs :** `EventBusConsumerAdapter`, `IncidentRestAdapter` et `EscalationSchedulerAdapter` pilotent les ports primaires ; `RelationalIncidentAdapter`, `IamDirectoryClientAdapter`, `ParticipantContactClientAdapter`, `UrgentNotificationClientAdapter`, `DocumentStoreClientAdapter`, `TimestampAuthorityAdapter` et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.9.4 Diagramme d'objets du service MS-INCIDENT

La Figure 6.27 capture l'état du service à 03h40, au cours de la nuit déjà décrite pour `MS-NOTIFICATION` : l'alerte critique de la liaison `LIA-2026-017`, acquittée à 02h10 avec demande de ticket, a ouvert le ticket `TCK-000318` ; qualifié S1 à 02h13 (impact 5, urgence 4), il a été escaladé au chef du DES et au contact d'escalade S1 de l'institution, et a convoqué la cellule de crise, constituée à 02h31 grâce au suppléant de la Direction Générale. Depuis 03h05, le ticket est en attente de tiers : la rupture est localisée chez l'opérateur de télécommunications, et un gel d'engagement est ouvert. Le délai imputable est alors de 56 minutes (de 02h10 à 03h05), pour un engagement de rétablissement de deux heures.

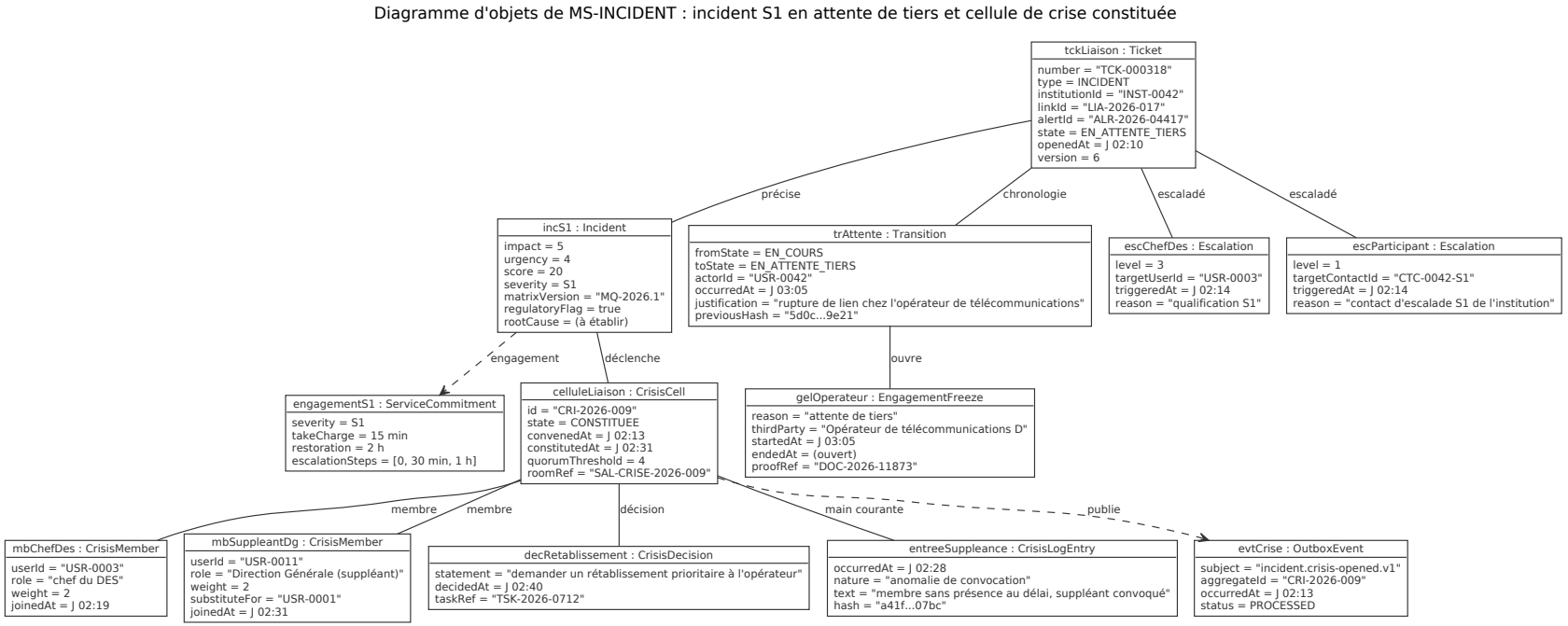


FIGURE 6.27: *Diagramme d'objets : incident S1 en attente de tiers et cellule de crise constituée*

- `tckLiaison : Ticket`, numéro `TCK-000318`, type `INCIDENT`, institution `INST-0042`, liaison `LIA-2026-017`, alerte d'origine `ALR-2026-04417`, état `EN_ATTENTE_TIERS`, version 6 ;
- `incS1 : Incident`, impact 5, urgence 4, score 20, sévérité `S1` selon la matrice `MQ-2026.1`, marqueur réglementaire positionné, cause racine à établir ; `engagementS1 : ServiceCommitment`, prise en compte 15 minutes, rétablissement 2 heures, paliers à 0, 30 minutes et 1 heure ;
- `trAttente : Transition`, de `EN_COURS` vers `EN_ATTENTE_TIERS` à 03h05, justifiée, chaînée à la transition précédente ; elle ouvre `gelOperateur : EngagementFreeze`, motif attente de tiers, tiers « Opérateur de télécommunications D », pièce `DOC-2026-11873`, non refermé ;
- `escChefDes : Escalation`, niveau 3, vers `USR-0003`, et `escParticipant : Escalation`, contact `CTC-0042-S1` de l'institution, déclenchées à 02h14 ;
- `celluleLiaison : CrisisCell`, `CRI-2026-009`, convoquée à 02h13, constituée à 02h31, seuil de quorum 4, salon `SAL-CRISE-2026-009` ouvert par `MS-COLLABORATION` ;
- `mbChefDes : CrisisMember` (poids 2, présent à 02h19) et `mbSuppleantDg : CrisisMember` (poids 2, suppléant de `USR-0001`, présent à 02h31) ;
- `decRetablissement : CrisisDecision`, demande de rétablissement prioritaire à l'opérateur, convertie en tâche `TSK-2026-0712` ; `entreeSuppleance : CrisisLogEntry`, anomalie de convocation consignée à 02h28 ;
- `evtCrise : OutboxEvent`, sujet `incident.crisis-opened.v1`, publié à 02h13 et traité.

6.1.9.5 Algorithmes fondamentaux de MS-INCIDENT

Cette section formalise les cinq algorithmes qui régissent l'automate d'états des tickets, la qualification et le calcul du délai imputable, l'escalade temporisée, l'activation et la conduite de la cellule de crise, et le contrôle des critères de clôture d'un incident.

Algorithme 6.39 : Automate d'états des tickets et transitions autorisées Cet algorithme valide toute demande de changement d'état d'un ticket contre la table de l'automate, applique les gardes propres à chaque transition, maintient la chronologie chaînée et publie l'événement correspondant. Il est l'unique chemin de mutation de l'état d'un ticket.

Spécification formelle de l'algorithme 6.39 : automate d'états des tickets	
Entrées	Ticket k (état e, version v) ; état cible e' ; acteur a et ses attributs ; justificatif j ; t_{now}.
Sorties	`Transition` chaînée et nouvel état, ou refus motivé ; gel ouvert ou fermé ; événement `incident.*`.
Complexité	$\mathcal{O}(1)$ par transition ; vérification d'une chronologie de m transitions en $\mathcal{O}(m)$.
Garantie	Aucun état hors de la table ; concurrence arbitrée par la version ; chronologie infalsifiable sans rupture de chaîne.

TABLE 6.43: *Fiche de spécification : automate d'états des tickets*

Déroulement procédural étape par étape :

1. **Table de l'automate :** la relation de transition admise est

$$\begin{aligned}\Delta = \{\,&(\mathrm{O},\mathrm{Q}),(\mathrm{O},\mathrm{C}),(\mathrm{Q},\mathrm{E}),(\mathrm{E},\mathrm{A}),(\mathrm{A},\mathrm{E}),(\mathrm{E},\mathrm{R}),(\mathrm{A},\mathrm{R}),\\ &(\mathrm{R},\mathrm{C}),(\mathrm{R},\mathrm{X}),(\mathrm{C},\mathrm{X}),(\mathrm{X},\mathrm{Q}),(\mathrm{X},\mathrm{E})\,\}\end{aligned} \tag{6.39}$$

   avec O ouvert, Q qualifié, E en cours, A en attente de tiers, R résolu, C clos, X réouvert. Si $(e,e') \notin \Delta$, refuser.

2. **Gardes :** (O,Q) exige, pour un incident, une qualification (algorithme 6.40) et, pour les autres types, une priorité et un assigné ; (O,C) (doublon, sans objet) exige un justificatif et un acteur de niveau responsable ou chef de quart ; (E,A) exige le tiers et une pièce ; (R,C) est déléguée au contrôle des critères de clôture (algorithme 6.43) ; (C,X) n'est admise que dans les trente jours suivant la clôture et par un responsable, au-delà un nouveau ticket lié est ouvert. Un représentant de participant ne peut demander que (R,C) ou (R,X) sur les tickets de son institution.

3. **Effets sur le gel :** l'entrée en A crée `EngagementFreeze`$(k,\text{tiers},t_{\text{now}},j)$; la sortie de A renseigne sa fin à t_{now} ; un seul gel ouvert par ticket à un instant donné.

4. **Chaînage :** construire la transition $\tau_n = (k,e,e',a,t_{\text{now}},j)$ et calculer

$$h_0 = \text{SHA-256}(k.\text{id}), \qquad h_n = \text{SHA-256}\big(h_{n-1} \parallel \text{JCS}(\tau_n)\big) \tag{6.40}$$

   où JCS est la sérialisation canonique de la RFC 8785 ; τ_n conserve h_{n-1} et h_n.

5. **Persistance atomique :** dans une transaction, mettre à jour le ticket sous la condition version $= v$ (sinon refuser pour conflit et recharger), insérer τ_n, le gel éventuel et l'événement d'outbox : `incident.ticket-opened.v1` à la création, `incident.`

`incident-resolved.v1` à l'entrée en R, `incident.ticket-closed.v1` à l'entrée en C, `incident.ticket-transitioned.v1` pour les autres.

6. **Vérification :** un auditeur recalcule la chaîne $h_0, \ldots, h_m$ et la compare aux empreintes stockées ; toute rupture désigne la transition altérée, que l'arbre de `MS-AUDIT` permet de confirmer.

Algorithme 6.40 : Qualification 5×5 et calcul du délai imputable avec gel Cet algorithme attribue à un incident sa sévérité et son marqueur réglementaire à partir de la matrice impact × urgence en vigueur, puis calcule à tout instant le délai imputable au département, gels d'attente de tiers déduits, et le respect des engagements.

Spécification formelle de l'algorithme 6.40 : qualification et délai imputable	
Entrées	Impact $I \in \{1..5\}$; urgence $U \in \{1..5\}$; matrice M versionnée ; attributs de l'incident ; gels $G_k = [d_k, f_k]$; engagements (P_S, R_S).
Sorties	Sévérité S, marqueur ρ, version de M ; délai imputable T_{imp} ; indicateurs de dépassement.
Complexité	$\mathcal{O}(1)$ pour la qualification ; $\mathcal{O}(g)$ pour g gels.
Contrôles	Matrice figée à la qualification ; baisse de sévérité validée par un responsable ; durée brute toujours conservée.

TABLE 6.44: *Fiche de spécification : qualification et délai imputable*

Déroulement procédural étape par étape :

1. **Sévérité :** lire $S = M[I][U]$; la matrice par défaut dérive du score $s = I \times U$:

$$S = \begin{cases} \text{S1} & s \geq 20 \\ \text{S2} & 12 \leq s \leq 19 \text{ ou } I = 5 \\ \text{S3} & 6 \leq s \leq 11 \\ \text{S4} & s \leq 5 \end{cases} \tag{6.41}$$

   la règle $I = 5$ garantissant qu'une atteinte à l'ensemble du réseau n'est jamais qualifiée au-dessous de S2. Enregistrer I, U, s, S et la version de M.

2. **Marqueur réglementaire :**

$$\rho = (S = \text{S1}) \vee (\text{sécurité} \wedge \text{compromission suspectée}) \vee (D_{\text{indispo}} \geq D_{\text{reg}}) \tag{6.42}$$

   où D_{reg} est le seuil de la procédure interne de déclaration ; ρ peut être positionné manuellement par le responsable conformité, jamais retiré sans son visa.

3. **Requalification :** une hausse de sévérité s'applique immédiatement et l'engagement le plus strict atteint est retenu depuis l'ouverture ; une baisse exige un responsable et un justificatif. Chaque qualification publie `incident.incident-qualified.v1` ; une qualification S1 déclenche l'escalade (algorithme 6.41) et la cellule de crise (algorithme 6.42).

4. **Délai imputable :** pour t_o l'ouverture, t_r la résolution (ou $+\infty$) et $\bar{t} = \min(t_{\text{now}}, t_r)$,

$$T_{\text{imp}}(t_{\text{now}}) = (\bar{t} - t_o) - \sum_k \left| \, [d_k,\ \min(f_k, \bar{t})] \cap [t_o, \bar{t}] \, \right| \tag{6.43}$$

   un gel non refermé étant borné par $\bar{t}$.

5. **Engagements :** la prise en compte est respectée si $t_{\text{E}} - t_o \le P_S$, où t_{E} est la première entrée en cours (aucun gel n'est possible avant) ; le rétablissement est respecté si $T_{\text{imp}}(t_r) \le R_S$. Les deux indicateurs, la durée brute et la somme des gels sont portés par `incident.incident-resolved.v1`.

Algorithme 6.41 : Escalade temporisée selon la matrice d'escalade Cet algorithme décide, pour chaque incident actif, du palier d'escalade atteint en fonction de sa sévérité et de la fraction consommée de son engagement, résout les destinataires internes et externes et demande leur information. L'ordonnanceur l'exécute chaque minute ; la qualification et la requalification l'appellent directement.

Spécification formelle de l'algorithme 6.41 : escalade temporisée	
Entrées	Incident x (sévérité S, institution, niveau atteint ℓ) ; paliers $\theta_{S,1..L}$; T_{imp} ; t_{now}.
Sorties	Escalades nouvelles ; `incident.incident-escalated.v1` ; demandes de notification (événement ou port synchrone S1).
Complexité	$\mathcal{O}(n)$ par passage pour n incidents actifs ; une lecture d'annuaire par palier franchi.
Contrôles	Un palier n'est franchi qu'une fois ; destinataires lus à l'instant ; remise et suppléance déléguées à `MS-NOTIFICATION`.

TABLE 6.45: *Fiche de spécification : escalade temporisée*

Déroulement procédural étape par étape :

1. **Sélection :** `dueEscalations`(t_{now}) retourne les incidents non résolus dont la prochaine échéance de palier est dépassée ; pour chacun, calculer T_{imp} (algorithme 6.40).

2. **Palier atteint :** le niveau cible est

$$\ell^* = \max\{\, \ell \in \{1..L\} \ :\ T_{\text{imp}} \ge \theta_{S,\ell} \,\} \tag{6.44}$$

avec $\theta_{S,\ell}$ exprimé en fraction du délai R_S pour S2 à S4 (tableau 6.42) et en durée absolue pour S1 ($\theta = 0$ pour N1 à N3). Pour un incident S1, l'information hiérarchique utilise la durée brute : le gel ne retarde pas l'information de la Direction Générale.

3. **Résolution des destinataires :** pour chaque niveau $\ell \in]\ell, \ell^*]$, lire le titulaire `escalationTarget`(unité, ℓ) dans `MS-IAM`, lui substituer `activeDelegate` s'il a délégué, et ajouter le RSSI au niveau 3 pour un incident de sécurité ; si l'incident touche une institution, lire `escalationContact`(inst, S) dans `MS-PARTICIPANT`.

4. **Idempotence :** insérer une `Escalation` par couple (incident, niveau) sous contrainte d'unicité ; un second passage concurrent échoue sans effet.

5. **Demande de remise :** pour S1, appeler la méthode `requestUrgent` du port `UrgentNotificationPort` et vérifier le retour des traces initiales ; sinon insérer `incident.notification-requested.v1` (niveau urgent pour S2, avertissement pour S3 et S4). Insérer `incident.incident-escalated.v1` (niveau, destinataires, T_{imp}) et programmer l'échéance du palier suivant.

6. **Épuisement :** à la réception de `notification.escalation-exhausted.v1` pour un destinataire d'escalade, ouvrir un ticket `ANOMALIE` lié et le consigner dans la chronologie de l'incident.

Algorithme 6.42 : Activation et conduite de la cellule de crise Cet algorithme convoque la cellule de crise, établit son quorum pondéré, substitue les suppléants aux membres absents, consigne la conduite de la crise et en organise la clôture et l'archivage. Il raffine le diagramme de séquence système « activer une cellule de crise » (UC-COL-01) du cahier d'analyse, en répartissant les rôles entre `MS-INCIDENT`, qui décide, `MS-NOTIFICATION`, qui remet les convocations, et `MS-COLLABORATION`, qui ouvre le salon et la conférence.

Spécification formelle de l'algorithme 6.42 : cellule de crise	
Entrées	Incident x qualifié S1, ou décision du chef du DES ; membres de droit $\mathscr{M}$ et poids w_i ; seuil $\Theta = 4$; délai de quorum $T_q = 15$ min.
Sorties	`CrisisCell` constituée, close puis archivée ; main courante chaînée ; décisions et tâches ; rapport post-incident.
Complexité	$\mathscr{O}(\lvert\mathscr{M}\rvert)$ par évaluation du quorum ; $\mathscr{O}(1)$ par entrée de main courante.
Contrôles	Une cellule active par incident ; présence du chef du DES ou de son délégué ; clôture par un responsable.

TABLE 6.46: *Fiche de spécification : activation et conduite de la cellule de crise*

Déroulement procédural étape par étape :

1. **Convocation :** si aucune cellule n'est active pour x, créer `CrisisCell` à l'état `CONVOQUEE` ; composer $\mathscr{M}$ à partir des rôles de droit lus dans `MS-IAM` : Direction Générale ($w = 2$), chef du DES ($w = 2$), RSSI, responsable conformité et chef de quart en vacation ($w = 1$). Insérer `incident.crisis-opened.v1`, consommé par `MS-COLLABORATION` qui ouvre le salon et la conférence et publie leur référence ; appeler le port synchrone de `MS-NOTIFICATION` pour une convocation critique de $\mathscr{M}$.

2. **Présences :** une présence est enregistrée par `join` lorsque le membre, authentifié, rejoint la cellule dans la plateforme ou dans le salon ; l'acquittement de la convocation (`notification.acknowledged.v1`) ne vaut pas présence.

3. **Quorum :** à chaque présence, évaluer

$$Q(t) = \sum_{i \in \mathscr{M}} w_i \, \delta_i(t), \qquad \text{constituée} \iff Q(t) \geq \Theta \ \wedge \ \delta_{\mathrm{DES}}(t) = 1 \tag{6.45}$$

   où $\delta_i(t) = 1$ si le membre i, ou le suppléant qui le remplace, est présent, un même siège n'étant compté qu'une fois ; lorsque la condition est vraie, passer à `CONSTITUEE`, renseigner l'instant et publier `incident.crisis-constituted.v1`.

4. **Suppléance :** à $t_{\mathrm{conv}} + T_q$, pour chaque membre absent, lire son délégué actif (`activeDelegate`) ou, à défaut, le niveau suivant de la matrice d'escalade interne ; ajouter ce suppléant avec le poids du titulaire et `substituteFor` renseigné, le convoquer, et consigner une entrée « anomalie de convocation ». Avant la constitution, le chef du DES peut prendre des mesures conservatoires, consignées comme telles.

5. **Conduite :** chaque entrée de main courante c_n (présence, hypothèse, directive, décision) est chaînée par $h_n = \mathrm{SHA\text{-}256}(h_{n-1} \,\|\, \mathrm{JCS}(c_n))$; une décision portant une action publie `incident.remediation-requested.v1`, et la référence de tâche renvoyée par `MS-PILOTAGE` est reportée dans la décision.

6. **Clôture :** sur `closeCell` par le chef du DES ou la Direction Générale, exiger que l'incident soit résolu ou qu'une décision motivée de retour en gestion courante soit consignée ; passer à `CLOSE` et publier `incident.crisis-closed.v1`. `MS-COLLABORATION` ferme le salon, scelle l'archive des échanges et en publie la référence, reportée dans `archiveRef`.

7. **Rapport post-incident et archivage :** générer le rapport post-incident (chronologie, membres et suppléances, main courante et sa chaîne, décisions et tâches, référence de l'archive) ; après validation par le chef du DES, le convertir en PDF/A-3, obtenir le

jeton RFC 3161 sur son empreinte et le déposer dans `MS-DOCUMENT`. L'ordonnanceur relance le chef du DES si le rapport n'est pas validé cinq jours ouvrés après la clôture ; la cellule passe à `ARCHIVEE` lorsque `archiveRef` et `postIncidentReportRef` sont renseignées.

Algorithme 6.43 : Contrôle des critères de clôture d'un incident Cet algorithme décide si un incident résolu peut être clos. Il vérifie les quatre critères de clôture d'un incident, la présence et la validation du rapport circonstancié lorsqu'il est exigé, et la séparation entre celui qui a résolu et celui qui valide ; à défaut, il retourne la liste exacte des manques.

Spécification formelle de l'algorithme 6.43 : critères de clôture	
Entrées	Incident x à l'état `RESOLU` ; valideur v ; actions de remédiation et état des tâches ; alertes reçues sur l'objet ; période d'observation ω_S.
Sorties	Liste des manques $\mathscr{G}$, ou transition vers `CLOS` et `incident.ticket-closed.v1`.
Complexité	$\mathcal{O}(a+p)$ pour a actions et p pièces.
Contrôles	Pièces vérifiées dans `MS-DOCUMENT` ; valideur distinct du résolveur ; visa conformité si marqueur.

TABLE 6.47: *Fiche de spécification : contrôle des critères de clôture d'un incident*

Déroulement procédural étape par étape :

1. **Cause racine :** exiger une cause renseignée et rattachée à une catégorie de la taxonomie ; une cause externe (tiers) n'est acceptée qu'avec la pièce du tiers. Sinon ajouter « cause racine » à $\mathscr{G}$.

2. **Remédiation :** exiger un plan ; toutes les actions correctives doivent être achevées (`pilotage.task-completed.v1` reçu) ; les actions préventives peuvent rester ouvertes si chacune est portée par une tâche nominative à échéance. Sinon ajouter « remédiation ».

3. **Test de résolution :** exiger la description du test, son résultat positif, son auteur, sa date postérieure à la résolution et une preuve déposée dans `MS-DOCUMENT` ; pour S1 et S2, exiger en outre l'absence de nouvelle alerte sur le même objet pendant la période d'observation ($\omega_{S1} = \omega_{S2} = 24$ h), établie à partir des `monitoring.alert-raised.v1` reçus. Sinon ajouter « test de résolution ».

4. **Capitalisation :** exiger la référence d'un retour d'expérience pour S1 et S2 ; pour S3 et S4, la mention « sans objet » justifiée est admise. Sinon ajouter « capitalisation ».

5. **Rapport et validation :** si $S \in \{\mathrm{S1}, \mathrm{S2}\}$ ou si ρ, exiger le rapport circonstancié déposé (`reportRef`) et, si ρ, le visa du responsable conformité ; exiger

$$v \neq \text{résolveur}(x) \ \wedge \ \big(S \in \{\mathrm{S1}, \mathrm{S2}\} \Rightarrow \text{niveau}(v) = \text{responsable}\big) \tag{6.46}$$

6. **Décision :** si $\mathscr{G} = \emptyset$, déclencher la transition (R, C) de l'algorithme 6.39 et publier `incident.ticket-closed.v1` (sévérité, délais, respect des engagements, références du rapport et du retour d'expérience) ; sinon retourner $\mathscr{G}$ sans changer l'état. Ces critères ne s'appliquent qu'aux incidents : une demande ou une intervention résolue est close sur confirmation du demandeur, ou tacitement cinq jours après sa résolution.

6.1.10 Monitoring, astreintes et quarts (MS-MONITORING)

Le service `MS-MONITORING` est l'outil de la salle de supervision du Département Exploitation et Supervision (DES), en service continu. Il décrit les liaisons et les plateformes supervisées (institution ou plateforme, type, seuils, état courant, dernière mesure), reçoit les alertes et les mesures agrégées émises par la pile d'observabilité et par les systèmes de production vers un point d'entrée en réception seule, corrèle et déduplique ces alertes, en obtient l'acquittement par l'opérateur de quart dans un délai fixé par la gravité et demande à `MS-INCIDENT` l'ouverture d'un ticket lorsque l'alerte le justifie. Il génère la grille d'astreinte 24/7 par programmation linéaire en nombres entiers, encadre les vacations (matin, après-midi, nuit) et leur chef de quart, tient la main courante de quart et produit, en fin de vacation, le rapport de quart signé par l'opérateur sortant, contresigné par l'entrant, visé par le chef de quart, horodaté selon la RFC 3161, déposé dans `MS-DOCUMENT` et référencé dans `MS-AUDIT`. Le service est non intrusif : il ne pilote rien, n'interroge ni ne commande aucun système de production, et ne conserve aucune donnée de transaction, seulement des mesures agrégées et des alertes. Il ne qualifie pas les incidents (`MS-INCIDENT`), ne remet pas les messages (`MS-NOTIFICATION`), ne calcule pas les indicateurs consolidés (`MS-REPORTING`) et ne rapproche aucun état (`MS-RAPPROCHEMENT`).

6.1.10.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : COBAC, PCI-DSS v4.0.1 et ISO/IEC 27001

- **Règlements COBAC R-2016/04 et R-2024/01 :** la surveillance continue des systèmes, la détection des anomalies opérationnelles et la traçabilité des opérations d'exploitation sont des attendus du dispositif de contrôle interne et de sécurité des systèmes d'information. La main courante en ajout seul et le rapport de quart scellé en constituent la preuve, conservée dix ans dans le dépôt objet WORM.

- **PCI-DSS v4.0.1, exigences 10 et 12.10 :** les défaillances des systèmes de contrôle de sécurité critiques doivent être détectées, alertées et traitées rapidement, et le plan de réponse aux incidents doit couvrir la surveillance et le traitement des alertes. Le délai d'acquittement par gravité, la demande de ticket et la synchronisation des horloges sur une source de temps de référence répondent à ces exigences.
- **ISO/IEC 27001, mesure de surveillance des activités (annexe A) :** réseaux, systèmes et applications sont surveillés pour détecter les comportements anormaux, et les résultats sont conservés ; le service en conserve les alertes et les mesures agrégées, jamais les transactions.
- **Journalisation :** toute mutation est un événement à effet, publié sous `monitoring.<agrégat>-<événement>.v1` par la table d'outbox et consommé par `MS-AUDIT` ; `MS-REPORTING` en tire les délais d'acquittement, la disponibilité des liaisons et la couverture des vacations.

Liaisons supervisées et réception non intrusive

- **Liaisons et plateformes :** une liaison supervisée désigne soit la liaison d'une institution (identifiant d'institution lu dans `MS-PARTICIPANT`), soit une plateforme du groupement (commutateur, simulateur de certification, infrastructure) ; elle porte son type, ses seuils par indicateur, son état courant, l'instant de la dernière mesure et la période de mesure attendue. Une liaison peut dépendre d'une plateforme, relation utilisée par la corrélation.
- **Point d'entrée en réception seule :** la pile d'observabilité et les systèmes de production émettent vers l'adaptateur de réception, joint par `MS-GATEWAY` en mTLS ; la plateforme ne s'y connecte jamais en sens inverse et ne transmet aucune commande. Chaque source est enregistrée avec son certificat et son schéma de message.
- **Aucune donnée de transaction :** seuls les champs du schéma déclaré en liste blanche sont acceptés (indicateur, fenêtre, valeur agrégée, règle, gravité proposée) ; tout autre champ entraîne le rejet du message entier. Le contrôle de masquage de `MS-GATEWAY` s'applique en amont ; le service n'accepte ni identifiant de transaction, ni numéro de carte, ni montant unitaire.

Alertes : corrélation, déduplication, acquittement et ticket

- **Corrélation et déduplication :** une alerte est identifiée par son empreinte (source, liaison, règle) ; les répétitions dans la fenêtre de déduplication sont absorbées dans l'alerte ouverte, et les alertes d'une liaison dont la plateforme parente est déjà en alerte lui sont rattachées comme symptômes (algorithme 6.44).

- **Acquittement :** l'acquittement est réservé aux opérateurs de la vacation en cours et au chef de quart, dans un délai qui dépend de la gravité (tableau 6.48) ; il porte la décision d'ouvrir ou non un ticket et un commentaire.
- **Ticket :** l'acquittement avec demande de ticket est publié (`monitoring.alert-acknowledged.v1`) ; `MS-INCIDENT` ouvre le ticket et publie son identifiant, reporté dans l'alerte comme ticket lié. Une alerte critique ne peut être acquittée sans ticket que si elle est rattachée à une alerte racine déjà pourvue d'un ticket.

Gravité	Acquittement	Demande de notification	Ticket
Critique	5 min	port synchrone de `MS-NOTIFICATION`, niveau critique, vacation en cours	obligatoire
Majeure	15 min	`monitoring.notification-requested.v1`, niveau urgent	à l'appréciation
Mineure	60 min	`monitoring.notification-requested.v1`, niveau avertissement	facultatif

TABLE 6.48: *Gravités d'alerte, délais d'acquittement, notification et ticket (valeurs paramétrables)*

Grille d'astreinte 24/7 par programmation linéaire en nombres entiers

- **Objet :** la grille affecte, pour chaque jour et chaque plage de la semaine, les opérateurs de niveau 1 (présents en salle, dont le chef de quart) et de niveau 2 (astreinte joignable), en respectant la couverture, les compétences, le repos réglementaire, les plafonds horaires et les disponibilités, et en équilibrant la charge (algorithme 6.45).
- **Disponibilités et compétences :** les congés et absences validés sont reçus de `MS-IAM` par `iam.availability-validated.v1` ; les compétences (habilitation de chef de quart, niveau d'astreinte) sont lues dans `MS-IAM` à la génération. Les règles de repos et les plafonds sont des paramètres, fixés conformément à la réglementation du travail applicable et au règlement intérieur.
- **Publication et révision :** la grille générée est validée par le chef du DES puis publiée (`monitoring.oncall-published.v1`), consommée par `MS-NOTIFICATION` (restriction des destinataires à la vacation) et par `MS-IAM` (attribut de vacation du contrôle d'accès). Une disponibilité validée après publication déclenche une révision qui fige le passé et minimise les changements.

Vacations, main courante et rapport de quart

- **Vacations :** matin (06h à 14h), après-midi (14h à 22h), nuit (22h à 06h) ; chaque vacation est instanciée depuis la grille publiée, avec ses opérateurs et son chef de quart.
- **Main courante :** chaque entrée (horodatage, auteur, nature, texte, référence d'alerte, de ticket ou de liaison) est ajoutée sans possibilité de modification ; une correction est une nouvelle entrée qui cite la précédente. Les entrées sont chaînées par empreinte, la tête de chaîne étant reprise dans le rapport.
- **Rapport de quart :** généré en fin de vacation (alertes par gravité, alertes non acquittées ou ouvertes, tickets ouverts et clos, suspens non régularisés en nombre, état des liaisons, main courante, consignes), annoté par l'opérateur sortant puis soumis au double scellement (algorithme 6.46). La responsabilité de la salle n'est transférée qu'à la contresignature de l'entrant.

6.1.10.2 Diagramme de composants internes de MS-MONITORING

La Figure 6.28 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les alertes des sources supervisées, les événements des autres services, les actions de la console de quart et les impulsions de l'ordonnanceur ; le cœur porte les six entités d'analyse du domaine 4 qui lui reviennent (liaison supervisée, alerte, grille d'astreinte, vacation, rapport de quart, entrée de main courante) ; les adaptateurs pilotés dialoguent avec la base relationnelle, le solveur en nombres entiers embarqué, `MS-IAM`, `MS-NOTIFICATION`, `MS-DOCUMENT`, l'autorité d'horodatage et le bus d'événements.

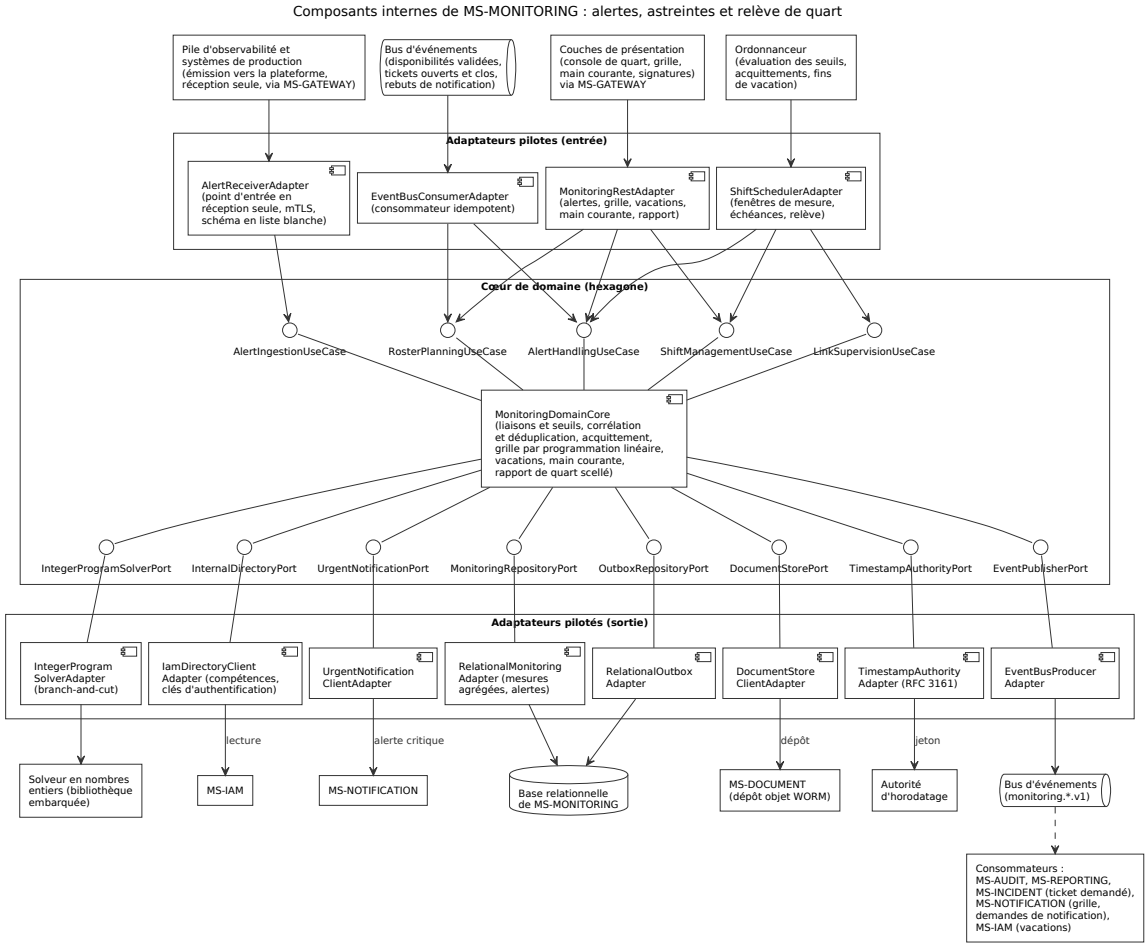


FIGURE 6.28: *Diagramme de composants internes : alertes, astreintes et relève de quart*

- **Adaptateurs pilotes (entrée) :** `AlertReceiverAdapter` (point d'entrée en réception seule, mTLS, schémas en liste blanche) ; `EventBusConsumerAdapter` (consommateur idempotent de `iam.availability-validated.v1`, `incident.ticket-opened.v1`, `incident.ticket-closed.v1`, `notification.delivery-failed.v1`, `notification.unresolved.v1`, des événements de suspens de `MS-RAPPROCHEMENT` et des alertes internes des services) ; `MonitoringRestAdapter` (console de quart : alertes, acquittements, grille, vacations, main courante, signatures) ; `ShiftSchedulerAdapter` (fenêtres de mesure, échéances d'acquittement, fins de vacation).

- **Cœur de domaine :** `MonitoringDomainCore` expose `AlertIngestionUseCase`, `AlertHandlingUseCase`, `LinkSupervisionUseCase`, `RosterPlanningUseCase` et `ShiftManagementUseCase`, et requiert huit ports secondaires.

- **Adaptateurs pilotés (sortie) :** `RelationalMonitoringAdapter` (liaisons, mesures agrégées, alertes, grilles, vacations, main courante, rapports) ;

`IntegerProgramSolverAdapter` (solveur en nombres entiers embarqué, méthode par séparation et coupes) ; `IamDirectoryClientAdapter` (compétences et clés publiques d'authentification des signataires, en lecture) ; `UrgentNotificationClientAdapter` (alertes critiques) ; `DocumentStoreClientAdapter` ; `TimestampAuthorityAdapter` (RFC 3161) ; `RelationalOutboxAdapter` et `EventBusProducerAdapter`.

- **Interactions :** `MS-AUDIT` et `MS-REPORTING` consomment tous les événements `monitoring.*` ; `MS-INCIDENT` consomme les acquittements avec demande de ticket ; `MS-NOTIFICATION` consomme les demandes de notification et la grille publiée ; `MS-IAM` consomme la grille pour l'attribut de vacation.

6.1.10.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.29 détaille les classes du domaine, les ports et les adaptateurs. Les entités d'analyse *Liaison supervisée*, *Alerte*, *Grille d'astreinte*, *Vacation*, *Rapport de quart* et *Entrée de main courante* (ici les entrées de quart, les entrées de crise appartenant à `MS-INCIDENT`) y sont reprises avec leurs types et leurs signatures ; le seuil, la fenêtre de mesure, l'affectation et la signature les complètent.

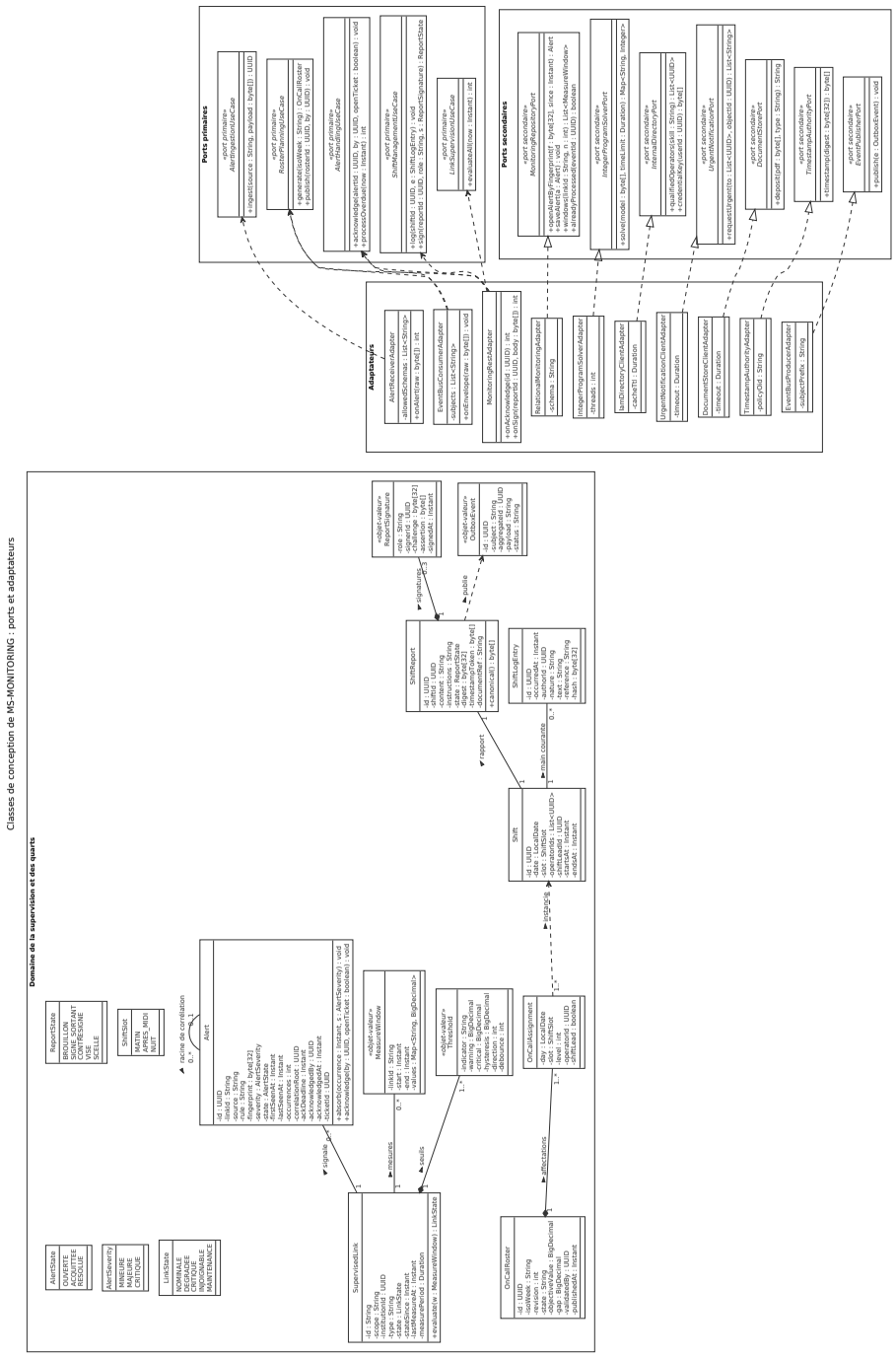


FIGURE 6.29: *Diagramme de classes de conception : service MS-MONITORING*

- **Entités :** `SupervisedLink` (`id`, `scope`, `type : String`, `institutionId : UUID`, `state : LinkState`, `stateSince`, `lastMeasureAt : Instant`, `measurePeriod : Duration`, méthode `evaluate`) ; `Alert` (`linkId`, `source`, `rule : String`, `fingerprint : byte[32]`, `severity : AlertSeverity`, `state : AlertState`, `firstSeenAt`, `lastSeenAt`, `ackDeadline`, `acknowledgedAt : Instant`, `occurrences : int`, `correlationRoot`, `acknowledgedBy`, `ticketId : UUID`, méthodes `absorb`, `acknowledge`) ; `OnCallRoster` (`isoWeek`, `revision : int`, `state`, `objectiveValue`, `gap : BigDecimal`, `validatedBy`, `publishedAt`) ; `OnCallAssignment` (`day : LocalDate`, `slot : ShiftSlot`, `level : int`, `operatorId : UUID`, `shiftLead : boolean`) ; `Shift` (`date`, `slot`, `operatorIds : List<UUID>`, `shiftLeadId`, `startsAt`, `endsAt`) ; `ShiftLogEntry` (`occurredAt`, `authorId`, `nature`, `text`, `reference`, `hash : byte[32]`) ; `ShiftReport` (`content`, `instructions : String`, `state : ReportState`, `digest : byte[32]`, `timestampToken : byte[]`, `documentRef : String`, méthode `canonical`).

- **Objets-valeurs :** `Threshold` (`indicator`, `warning`, `critical`, `hysteresis : BigDecimal`, `direction`, `debounce : int`) ; `MeasureWindow` (`start`, `end : Instant`, `values : Map<String, BigDecimal>`) ; `ReportSignature` (`role`, `signerId`, `challenge : byte[32]`, `assertion : byte[]`, `signedAt`) ; `OutboxEvent`.

- **Énumérations :** `LinkState` (`NOMINALE`, `DEGRADEE`, `CRITIQUE`, `INJOIGNABLE`, `MAINTENANCE`) ; `AlertSeverity` (`MINEURE`, `MAJEURE`, `CRITIQUE`) ; `AlertState` (`OUVERTE`, `ACQUITTEE`, `RESOLUE`) ; `ShiftSlot` (`MATIN`, `APRES_MIDI`, `NUIT`) ; `ReportState` (`BROUILLON`, `SIGNE_SORTANT`, `CONTRESIGNE`, `VISE`, `SCELLE`).

- **Ports primaires :** `AlertIngestionUseCase` (`ingest`) ; `AlertHandlingUseCase` (`acknowledge`, `processOverdue`) ; `LinkSupervisionUseCase` (`evaluateAll`) ; `RosterPlanningUseCase` (`generate`, `publish`) ; `ShiftManagementUseCase` (`log`, `sign`).

- **Ports secondaires :** `MonitoringRepositoryPort` (`openAlertByFingerprint`, `saveAlert`, `windows`, `alreadyProcessed`) ; `IntegerProgramSolverPort` (`solve`) ; `InternalDirectoryPort` (`qualifiedOperators`, `credentialKey`) ; `UrgentNotificationPort` ; `DocumentStorePort` ; `TimestampAuthorityPort` ; `OutboxRepositoryPort` ; `EventPublisherPort`.

- **Adaptateurs :** `AlertReceiverAdapter`, `EventBusConsumerAdapter` et `MonitoringRestAdapter` pilotent les ports primaires ; `RelationalMonitoringAdapter`, `IntegerProgramSolverAdapter`, `IamDirectoryClientAdapter`, `UrgentNotificationClientAdapter`, `DocumentStoreClientAdapter`, `TimestampAuthorityAdapter` et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.10.4 Diagramme d'objets du service MS-MONITORING

La Figure 6.30 capture la relève de 06h00 qui suit la nuit décrite pour `MS-INCIDENT` : la liaison `LIA-2026-017`, en rupture depuis 02h06, est revenue à l'état nominal à 05h08 ; son alerte critique, acquittée à 02h10 avec demande de ticket, est résolue et porte le ticket `TCK-000318`. La vacation de nuit, instanciée depuis la révision 2 de la grille de la semaine 39, s'achève : le rapport de quart a été signé par l'opérateur sortant à 06h02, contresigné par l'entrant à 06h09, visé par le chef de quart à 06h11, puis horodaté, déposé et scellé.

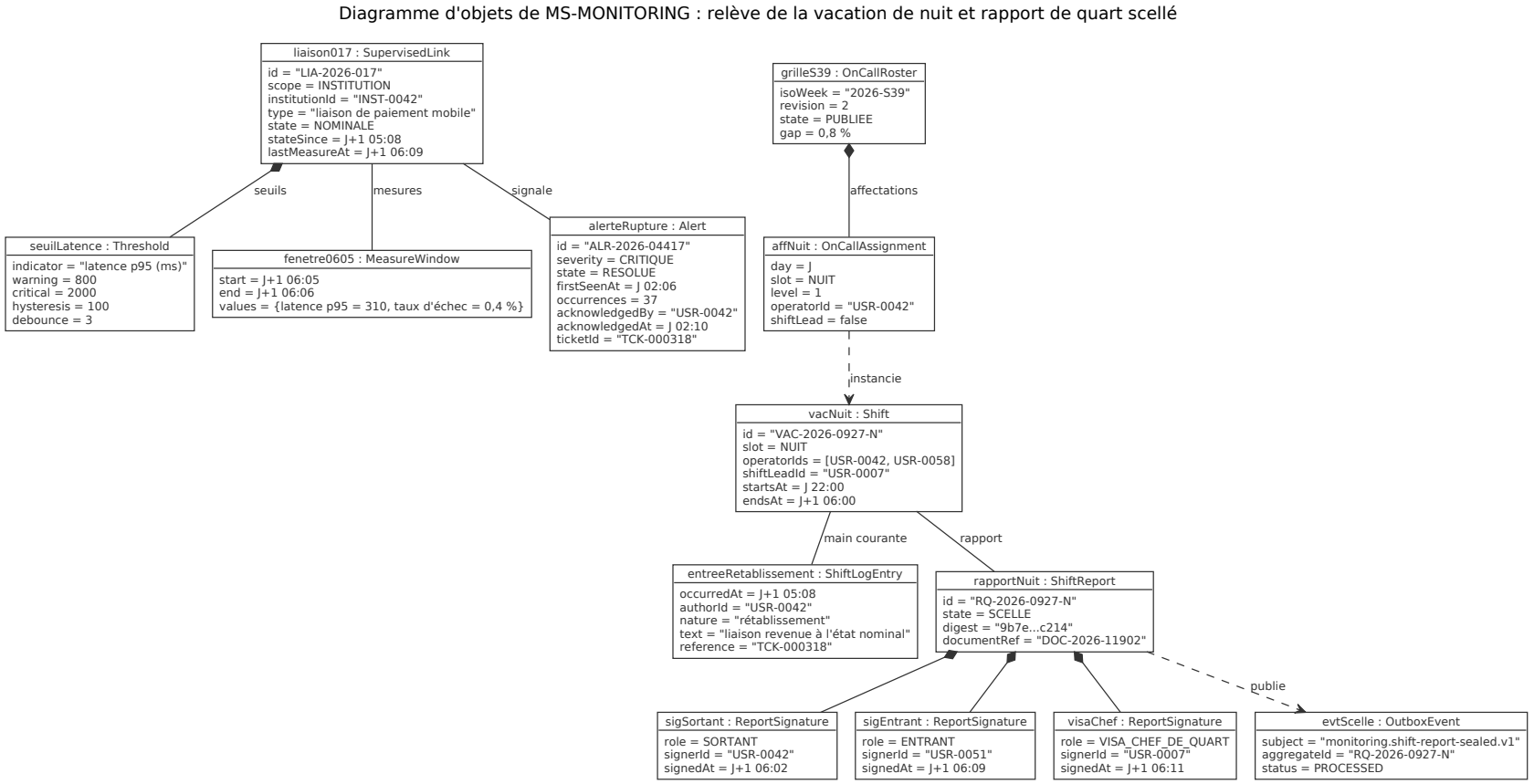


FIGURE 6.30: *Diagramme d'objets : relève de la vacation de nuit et rapport de quart scellé*

- `liaison017 : SupervisedLink`, liaison de paiement mobile de l'institution `INST-0042`, état `NOMINALE` depuis 05h08, dernière mesure à 06h09 ; `seuilLatence : Threshold`, latence au 95e centile, avertissement à 800 ms, critique à 2000 ms, hystérésis de 100 ms, trois fenêtres de confirmation ; `fenetre0605 : MeasureWindow`, valeurs agrégées de la minute de 06h05 ;
- `alerteRupture : Alert`, `ALR-2026-04417`, gravité `CRITIQUE`, 37 occurrences absorbées, acquittée par `USR-0042` à 02h10, ticket lié `TCK-000318`, état `RESOLUE` ;
- `grilleS39 : OnCallRoster`, semaine `2026-S39`, révision 2 publiée, écart d'optimalité de 0,8 % ; `affNuit : OnCallAssignment`, nuit du jour J, niveau 1, opérateur `USR-0042` ;
- `vacNuit : Shift`, `VAC-2026-0927-N`, de 22h00 à 06h00, opérateurs `USR-0042` et `USR-0058`, chef de quart `USR-0007` ; `entreeRetablissement : ShiftLogEntry`, retour à l'état nominal consigné à 05h08 avec la référence du ticket ;
- `rapportNuit : ShiftReport`, `RQ-2026-0927-N`, état `SCELLE`, empreinte finale, référence `DOC-2026-11902` dans `MS-DOCUMENT` ; `sigSortant`, `sigEntrant` et `visaChef : ReportSignature`, signatures de `USR-0042`, `USR-0051` et `USR-0007` ;
- `evtScelle : OutboxEvent`, sujet `monitoring.shift-report-sealed.v1`, publié et traité.

6.1.10.5 Algorithmes fondamentaux de MS-MONITORING

Cette section formalise les quatre algorithmes qui régissent la corrélation et la déduplication des alertes avec acquittement temporisé, la génération de la grille d'astreinte par programmation linéaire en nombres entiers, la relève de quart avec double scellement du rapport, et l'évaluation des seuils et de l'état d'une liaison supervisée.

Algorithme 6.44 : Corrélation et déduplication des alertes avec acquittement temporisé
Cet algorithme transforme le flux brut des alertes reçues en un ensemble réduit d'alertes actionnables : il absorbe les répétitions, rattache les symptômes à leur cause probable, fixe l'échéance d'acquittement, demande les notifications et traite l'acquittement et la demande de ticket.

Spécification formelle de l'algorithme 6.44 : corrélation et déduplication	
Entrées	Message a (source, liaison l, règle, gravité g, instant) ; fenêtre de déduplication $w_d = 30$ min ; fenêtre de corrélation $w_c = 10$ min ; délais δ_g.
Sorties	Alerte créée ou mise à jour ; `monitoring.alert-raised.v1` ; demandes de notification ; `monitoring.alert-acknowledged.v1`.
Complexité	$\mathcal{O}(1)$ par message (recherche indexée par empreinte) ; $\mathcal{O}(p)$ pour p plateformes parentes de l.
Contrôles	Schéma en liste blanche ; acquittement réservé à la vacation en cours ; ticket obligatoire pour une alerte critique racine.

TABLE 6.49: *Fiche de spécification : corrélation, déduplication et acquittement des alertes*

Déroulement procédural étape par étape :

1. **Admission :** vérifier que la source est enregistrée, que le message respecte son schéma et ne porte aucun champ hors liste blanche ; sinon rejeter et consigner le rejet.

2. **Empreinte et déduplication :** calculer

$$f = \text{SHA-256}\big(\text{source} \parallel l \parallel \text{règle}\big) \tag{6.47}$$

   la gravité n'entrant pas dans l'empreinte ; si `openAlertByFingerprint`$(f, t - w_d)$ retourne une alerte A non résolue, appeler `absorb` : incrémenter les occurrences, mettre à jour `lastSeenAt` et poser $A.g \leftarrow \max(A.g, g)$; seule une hausse de gravité republie `monitoring.alert-raised.v1` et recalcule l'échéance d'acquittement.

3. **Corrélation :** sinon créer A ; si une plateforme p dont dépend l porte une alerte ouverte R avec $A.t - R.t_{\text{first}} \leq w_c$, poser A.correlationRoot $= R$: A est un symptôme, visible dans la console sous R, sans notification propre.

4. **Échéance et notification :** pour une alerte racine, poser A.ackDeadline $= A.t_{\text{first}} + \delta_g$ (δ = 5, 15 ou 60 min) ; publier `monitoring.alert-raised.v1` et, selon le tableau 6.48, appeler le port synchrone de `MS-NOTIFICATION` (critique) ou insérer `monitoring.notification-requested.v1`.

5. **Acquittement :** `acknowledge`(A, u, ticket) exige que u figure dans la vacation en cours ou en soit le chef de quart ; si A est critique et racine, ticket doit être vrai. Renseigner l'acquittement, passer à `ACQUITTEE`, étendre l'acquittement aux symptômes rattachés et publier `monitoring.alert-acknowledged.v1` (liaison, institution, gravité, demande de ticket, délai écoulé). À réception de `incident.ticket-opened.v1` portant l'identifiant de A, renseigner `ticketId`.

6. **Retard :** `processOverdue`(t_{now}) marque hors délai toute alerte racine non acquittée à son échéance, consigne le fait dans la main courante et demande une notification au chef de quart ; l'escalade ultérieure des destinataires relève de `MS-NOTIFICATION` (algorithme 6.23).

7. **Résolution :** un message de résolution de la source, ou le retour de la liaison à l'état nominal (algorithme 6.47), passe A et ses symptômes à `RESOLUE` et publie `monitoring.alert-resolved.v1`.

Algorithme 6.45 : Génération de la grille d'astreinte par programmation linéaire en nombres entiers Cet algorithme construit la grille hebdomadaire d'astreinte comme la solution d'un programme linéaire en nombres entiers : il couvre chaque plage par les effectifs et les compétences requis, respecte le repos réglementaire, les plafonds horaires et les disponibilités validées, et répartit équitablement la charge. Il sert aussi à la révision d'une grille publiée.

Spécification formelle de l'algorithme 6.45 : grille d'astreinte	
Entrées	Opérateurs I ; jours T ; plages $S = \{\text{M},\text{A},\text{N}\}$; niveaux $L = \{1,2\}$; besoins $D_{t,s,\ell}$; compétences K_ℓ, Q ; indisponibilités $\mathscr{U}$; paramètres $H_{\max}$, γ, α, β, Λ.
Sorties	Affectations $x_{i,t,s,\ell}$ et chefs de quart $z_{i,t,s}$; valeur de l'objectif et écart d'optimalité ; plages non couvertes éventuelles.
Complexité	Problème NP-difficile ; $\lvert I\rvert \cdot \lvert T\rvert \cdot \lvert S\rvert \cdot (\lvert L\rvert + 1)$ variables binaires, soit environ 3 000 pour vingt opérateurs ; résolution par séparation et coupes bornée à 300 s.
Garantie	Contraintes dures toujours satisfaites ; un défaut de couverture est rendu explicite, jamais masqué.

TABLE 6.50: *Fiche de spécification : grille d'astreinte par programmation linéaire*

Déroulement procédural étape par étape :

1. **Variables :** $x_{i,t,s,\ell} \in \{0,1\}$ vaut 1 si l'opérateur i tient la plage s du jour t au niveau ℓ (1 en salle, 2 en astreinte joignable) ; $z_{i,t,s} \in \{0,1\}$ désigne le chef de quart ; $u_{t,s,\ell} \geq 0$ mesure un défaut de couverture ; $E \geq 0$ est l'écart maximal de charge. La charge horaire de i est

$$h_i = 8 \sum_{t \in T} \sum_{s \in S} \left(x_{i,t,s,1} + \gamma x_{i,t,s,2} \right), \qquad \gamma = 0{,}25 \tag{6.48}$$

2. **Couverture et compétences :**

$$\sum_{i \in K_\ell} x_{i,t,s,\ell} + u_{t,s,\ell} \geq D_{t,s,\ell}, \qquad x_{i,t,s,\ell} = 0 \ \ \forall i \notin K_\ell \tag{6.49}$$

avec $D_{t,s,1} \geq 2$ (binôme en salle) ; un chef de quart habilité par plage :

$$\sum_{i \in Q} z_{i,t,s} = 1, \qquad z_{i,t,s} \leq x_{i,t,s,1}, \qquad z_{i,t,s} = 0 \;\; \forall i \notin Q \tag{6.50}$$

3. **Repos, plafonds et disponibilités :** une affectation par jour, $\sum_{s,\ell} x_{i,t,s,\ell} \leq 1$; pour tout couple de plages consécutives séparées par moins que le repos minimal $R_{\min} = 11$ h, soit $P = \{(\mathrm{N},\mathrm{M}), (\mathrm{N},\mathrm{A}), (\mathrm{A},\mathrm{M})\}$,

$$x_{i,t,s,1} + x_{i,t+1,s',1} \leq 1 \qquad \forall (s,s') \in P \tag{6.51}$$

au plus trois nuits consécutives, $\sum_{k=0}^{3} x_{i,t+k,\mathrm{N},1} \leq 3$; le plafond hebdomadaire $h_i \leq H_{\max}$ (48 h par défaut) ; et $x_{i,t,s,\ell} = 0$ pour tout $(i,t,s) \in \mathscr{U}$, ensemble tenu à jour par `iam.availability-validated.v1`. Le dernier jour de la semaine précédente est repris, figé, pour que les contraintes de repos franchissent la frontière de semaine.

4. **Équité et objectif :** avec μ la charge moyenne cible, imposer $h_i - \mu \leq E$ et $\mu - h_i \leq E$ pour tout i, puis minimiser

$$\min \sum_{i,t,s,\ell} C_{i,t,s,\ell}\, x_{i,t,s,\ell} + \alpha E + \Lambda \sum_{t,s,\ell} u_{t,s,\ell} + \beta \sum_{i,t,s,\ell} (1 - 2\bar{x}_{i,t,s,\ell})\, x_{i,t,s,\ell} \tag{6.52}$$

où C porte les préférences et la pénibilité (nuits, fins de semaine), Λ est une pénalité dominante qui ne laisse un défaut de couverture que s'il est inévitable, et le dernier terme, nul en génération initiale, vaut à une constante près la distance de Hamming à la grille publiée $\bar{x}$ lors d'une révision.

5. **Résolution :** transmettre le modèle au port `IntegerProgramSolverPort` avec une limite de 300 s ; retenir la meilleure solution réalisable et son écart d'optimalité. Tout $u_{t,s,\ell} > 0$ est présenté au chef du DES comme plage non couverte, avec les contraintes saturées qui l'expliquent.

6. **Validation et publication :** la grille (`OnCallRoster`, révision n) est validée par le chef du DES, puis publiée (`monitoring.oncall-published.v1`) ; les vacations sont instanciées. En révision, les jours écoulés et la vacation en cours sont figés ($x = \bar{x}$), seul le reste de l'horizon est réoptimisé, et la révision $n+1$ publiée n'énumère que les affectations modifiées.

Algorithme 6.46 : Relève de quart et double scellement du rapport Cet algorithme conduit la passation de responsabilité entre deux vacations : il génère le rapport de quart, recueille successivement la signature de l'opérateur sortant, la contresignature de l'entrant et le visa du

chef de quart, chacune liée aux précédentes, puis horodate, dépose et scelle le rapport. Il raffine le diagramme de séquence système « opérer la relève de quart » (UC-EXP-02) du cahier d'analyse.

Spécification formelle de l'algorithme 6.46 : relève de quart	
Entrées	Vacation V ; main courante de V ; alertes, tickets et suspens de la période ; signataires sortant, entrant et chef de quart ; clés publiques d'authentification lues dans `MS-IAM`.
Sorties	`ShiftReport` scellé (empreinte, jeton RFC 3161, référence de document) ; `monitoring.shift-report-sealed.v1`.
Complexité	$\mathcal{O}(n)$ pour n entrées et alertes agrégées ; trois vérifications de signature.
Standard	RFC 8785 (sérialisation canonique), W3C WebAuthn, SHA-256, ISO 19005-3 (PDF/A-3), RFC 3161.

TABLE 6.51: *Fiche de spécification : relève de quart et double scellement*

Déroulement procédural étape par étape :

1. **Génération :** à la fin de V, agréger les alertes par gravité, les alertes ouvertes ou hors délai, les tickets ouverts et clos (projection locale des événements `incident.*`), le nombre de suspens non régularisés, l'état des liaisons et la tête de chaîne de la main courante ; l'opérateur sortant annote les consignes. Figer le contenu et calculer $J = \mathrm{JCS}(R)$ (RFC 8785), puis $H_1 = \text{SHA-256}(J)$.

2. **Signature sortante :** l'opérateur sortant produit une assertion WebAuthn avec sa clé de sécurité matérielle FIDO2, le défi étant H_1 ; le service vérifie l'assertion avec la clé publique enregistrée (`credentialKey`), le défi, l'origine et la vérification de l'utilisateur, conserve σ_s et passe à `SIGNE_SORTANT` ; l'entrant et le chef de quart sont notifiés.

3. **Contresignature entrante :** après examen contradictoire, l'entrant signe le défi lié à la première signature ; il peut joindre des réserves, consignées en entrée de main courante et citées dans le rapport sans altérer J :

$$H_2 = \text{SHA-256}(J \parallel \sigma_s), \qquad \sigma_e = \mathrm{WebAuthn}_{\text{entrant}}(H_2) \tag{6.53}$$

   L'état passe à `CONTRESIGNE` : la responsabilité de la salle est transférée à cet instant. Sans contresignature trente minutes après la fin de V, le chef de quart est notifié, et le sortant demeure responsable.

4. **Visa du chef de quart :** $H_3 = \text{SHA-256}(J \parallel \sigma_s \parallel \sigma_e)$ et $\sigma_c = \mathrm{WebAuthn}_{\text{chef}}(H_3)$; le chef de quart ne peut viser un rapport qu'il a lui-même signé comme sortant ou entrant, son délégué désigné dans `MS-IAM` visant alors ; l'état passe à `VISE`.

5. **Empreinte finale et document :**

$$H_f = \text{SHA-256}(J \parallel \sigma_s \parallel \sigma_e \parallel \sigma_c) \tag{6.54}$$

produire le rapport en PDF/A-3, avec J et les trois assertions en pièces jointes, calculer son empreinte D et obtenir le jeton RFC 3161 sur D par `TimestampAuthorityPort`.

6. **Dépôt et scellement :** déposer le document dans `MS-DOCUMENT` (rétention de dix ans en mode conformité), qui en contrôle le masquage et l'empreinte et rend la référence ; renseigner `digest`, `timestampToken` et `documentRef`, passer à `SCELLE` et insérer `monitoring.shift-report-sealed.v1` (H_f, D, référence, numéro de série du jeton), dont `MS-AUDIT` fait une feuille de son arbre. Un rapport scellé n'est jamais modifié : une correction produit une nouvelle version visée par le chef de quart.

Algorithme 6.47 : Évaluation des seuils et de l'état d'une liaison supervisée Cet algorithme calcule, à chaque fin de fenêtre de mesure, l'état d'une liaison supervisée à partir de ses mesures agrégées et de ses seuils, avec hystérésis et confirmation sur plusieurs fenêtres pour éviter les oscillations, détecte l'absence de mesures et produit les alertes internes correspondantes.

Spécification formelle de l'algorithme 6.47 : état d'une liaison supervisée	
Entrées	Liaison l (état e, période π, dernière mesure t_m) ; seuils $(W_j, C_j, \eta_j, d_j, k_j)$ par indicateur j ; dernières fenêtres de mesure ; t_{now}.
Sorties	Nouvel état de l et instant de changement ; alertes internes transmises à l'algorithme 6.44 ; résolutions.
Complexité	$\mathcal{O}(\lvert J_l \rvert \cdot k)$ par liaison et par fenêtre, pour $\lvert J_l \rvert$ indicateurs et k fenêtres de confirmation.
Performance	Évaluation de l'ensemble des liaisons en moins d'une seconde par minute ; aucune lecture de transaction.

TABLE 6.52: *Fiche de spécification : évaluation des seuils et de l'état d'une liaison*

Déroulement procédural étape par étape :

1. **Maintenance et fraîcheur :** si l est en fenêtre de maintenance déclarée par le chef de quart, conserver `MAINTENANCE`, consigner les mesures et ne produire aucune alerte ; sinon, si $t_{\text{now}} - t_m > 3\pi$, l'état brut est `INJOIGNABLE`, retenu sans confirmation.

2. **Niveau par indicateur :** pour chaque indicateur j de valeur agrégée m_j, orienter la mesure par $d_j \in \{+1, -1\}$ (+1 lorsque la hausse est défavorable, comme une latence ; -1 pour un

taux de succès) et poser $v_j = d_j m_j$, $\tilde{W}_j = d_j W_j$, $\tilde{C}_j = d_j C_j$:

$$n_j = \begin{cases} 2 & v_j \geq \tilde{C}_j \ \text{ ou } \ (n_j^{\text{préc}} = 2 \wedge v_j > \tilde{C}_j - \eta_j) \\ 1 & v_j \geq \tilde{W}_j \ \text{ ou } \ (n_j^{\text{préc}} \geq 1 \wedge v_j > \tilde{W}_j - \eta_j) \\ 0 & \text{sinon} \end{cases} \tag{6.55}$$

la bande d'hystérésis η_j empêchant une mesure oscillant autour d'un seuil de faire alterner les états.

3. **État brut :** $n = \max_j n_j$, puis $e_{\text{brut}} = \texttt{NOMINALE}, \texttt{DEGRADEE}$ ou `CRITIQUE` pour $n = 0, 1, 2$.

4. **Confirmation :** une aggravation n'est adoptée que si e_{brut} est au moins aussi grave sur les k_j dernières fenêtres ; un retour à un état moins grave exige k_j fenêtres consécutives ; `INJOIGNABLE` est adopté immédiatement.

5. **Effets :** sur changement d'état, mettre à jour `state` et `stateSince` ; une aggravation produit une alerte interne (source « évaluation des seuils », règle $j^* = \arg\max_j n_j$, gravité majeure pour `DEGRADEE`, critique pour `CRITIQUE` et `INJOIGNABLE`) remise à l'algorithme 6.44 ; un retour à `NOMINALE` résout les alertes de cette source pour l et est consigné dans la main courante de la vacation en cours.

6.1.11 Rapprochement des états et suivi des suspens (MS-RAPPROCHEMENT)

Le service `MS-RAPPROCHEMENT` porte, pour le domaine 4, la confrontation des états de fin de journée du commutateur et des participants, l'isolement des écarts en dossiers de suspens et le suivi de chaque suspens jusqu'à sa régularisation attestée. Il reçoit ses données exclusivement par des fichiers déposés (état du commutateur et état du participant pour une journée, éventuellement état du système de règlement en extension), soumis au contrôle de masquage des données de carte et scellés par empreinte avant toute exploitation. Il rapproche les lignes par identifiants pivots sans interpréter le contenu des opérations, classe les écarts, ouvre les dossiers, les affecte à un responsable de régularisation avec échéance, consigne la conciliation et ne clôt un suspens que sur une attestation de régularisation déposée dans `MS-DOCUMENT` et validée par un second acteur. Il n'apure rien, ne réinjecte aucune contre-passation, n'émet aucun message vers le commutateur ni vers le système de règlement : les corrections sont réalisées dans les systèmes de production, et la plateforme n'en conserve que la preuve. Il expose au portail des participants les seuls suspens de l'institution connectée et publie ses indicateurs vers `MS-REPORTING`, ses échéances vers `MS-NOTIFICATION` et chaque décision à effet vers `MS-AUDIT`.

6.1.11.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : contrôle interne, protection des données de carte et traçabilité

- **Règlement COBAC R-2016/04 :** le dispositif de contrôle interne impose la justification des comptes et le suivi des suspens jusqu'à leur dénouement. `MS-RAPPROCHEMENT` outille ce suivi pour le groupement : détection exhaustive et horodatée des écarts (règle RG-43 du cahier d'analyse), impossibilité de modifier le montant ou l'état d'un suspens sans trace (RG-44), clôture uniquement sur attestation (RG-45). L'apurement comptable lui-même demeure du ressort des systèmes de production du commutateur et des participants.
- **PCI-DSS v4.0.1, exigence 3 :** les états déposés ne doivent contenir aucun numéro de carte en clair. Chaque fichier est soumis au contrôle de masquage avant enregistrement ; un fichier qui échoue est rejeté sans être persisté, le rejet est tracé et notifié au déposant. Les lignes conservées ne portent que des références d'opération, jamais de données de compte.
- **PCI-DSS v4.0.1, exigence 10 et ISO/IEC 27001 :** chaque import, chaque rapprochement, chaque transition d'un suspens et chaque attestation sont publiés vers `MS-AUDIT`, qui les inscrit comme feuilles de l'arbre de Merkle (RFC 9162). Un auditeur peut établir, pour toute journée, que les états confrontés sont bien ceux dont les empreintes ont été scellées.

Périmètre et principe de non-intrusion Le rapprochement porté par la plateforme est un rapprochement de suivi, non un rapprochement comptable exécutoire. Le service ne se connecte à aucun système de production : l'état du commutateur est un fichier déposé par l'opérateur du DES, l'état du participant est un fichier déposé par le représentant de l'institution sur le portail ou par l'opérateur pour son compte, et l'état du système de règlement, admis comme extension pour un rapprochement à trois voies, est lui aussi un fichier déposé et jamais une connexion. Aucune ligne d'état n'est modifiée, aucune contre-passation n'est forgée, aucun ordre de rappel de fonds n'est émis. Lorsqu'une régularisation est décidée en conciliation, elle est exécutée dans les systèmes de production par l'acteur compétent ; la plateforme enregistre la décision (à qui elle incombe, par quel moyen, à quelle échéance), attend la pièce justificative et ne clôt le dossier qu'après validation de cette pièce par un second acteur.

États importés : contrat de dépôt et portage local de l'entité Un état importé est décrit par sa source (commutateur, participant, système de règlement), l'institution concernée, la journée, la date d'import, l'identité du déposant, l'empreinte SHA-256 du fichier, le résultat du contrôle de masquage et la référence du fichier original déposé dans `MS-DOCUMENT`. Le format attendu est un format à colonnes (RFC 4180) ou structuré (RFC 8259), fixé par le contrat de dépôt de chaque source et vérifié à l'import. L'entité « État importé » du cahier d'analyse est partagée

avec MS-REPORTING ; elle est ici portée localement, sous la classe ImportedStatement, et non référencée, pour trois raisons : le rapprochement a besoin du détail des lignes, qui ne doit pas transiter sur le bus d'événements ni faire l'objet d'un appel synchrone à chaque journée ; les états du rapprochement (unitaires, quotidiens) et ceux du reporting (agrégés, périodiques) n'ont ni la même granularité ni la même rétention ; enfin les deux services sont livrés dans des vagues différentes et doivent rester déployables indépendamment. Les deux services partagent le même contrat de contrôle (masquage, empreinte, idempotence par empreinte) et les mêmes objets-valeurs. Les lignes d'un état sont conservées dans la base relationnelle du service pour une durée bornée (rétention de 400 jours), le fichier original restant disponible dans le dépôt objet WORM.

Identifiants pivots et typologie des écarts Le rapprochement n'interprète pas le contenu des opérations ; il aligne des lignes par un objet-valeur PivotKey composé de la référence de transaction, de la référence d'autorisation, de l'horodatage, du montant et du code participant. Deux lignes sont appariées lorsque leurs références et leur code participant coïncident et que leurs horodatages diffèrent d'au plus une tolérance τ (120 secondes par défaut, paramétrable par source), les horloges du commutateur et des participants n'étant pas synchronisées à la seconde. Les écarts sont classés en six typologies : ABSENT_COMMUTATEUR (ligne présente uniquement chez le participant), ABSENT_PARTICIPANT (ligne présente uniquement dans l'état du commutateur), ABSENT_REGLEMENT (extension à trois voies), MONTANT_DIFFERENT, STATUT_DIFFERENT (par exemple approuvée d'un côté, annulée de l'autre) et DOUBLON (même clé pivot répétée du même côté). Chaque écart devient un dossier de suspens individuel, rattaché à l'institution et à la journée.

Dossiers de suspens, conciliation, attestation et vieillissement

- **Automate d'états :** OUVERT, AFFECTE, EN_CONCILIATION, CONTESTE, REGULARISATION_DECLAREE, CLOS. Chaque transition porte l'acteur, l'horodatage et un justificatif ; aucune transition ne modifie le montant ni la typologie, figés à l'ouverture.
- **Affectation et échéance :** tout suspens est affecté à un responsable de régularisation (interlocuteur règlement du participant, lu dans MS-PARTICIPANT, ou responsable compensation du groupement) avec une échéance, J+5 par défaut.
- **Conciliation :** les échanges entre le groupement et le participant sont consignés en entrées de conciliation (auteur, horodatage, texte, pièce éventuelle déposée dans MS-DOCUMENT). Un désaccord persistant bascule le dossier en CONTESTE et ouvre un ticket de litige dans MS-INCIDENT, sans bloquer la clôture du rapprochement de la journée.

- **Attestation à deux acteurs :** la régularisation exécutée en production est attestée par une pièce déposée dans `MS-DOCUMENT` (empreinte SHA-256, rétention WORM) puis validée par un second acteur distinct du déposant ; seule cette validation clôt le suspens.
- **Vieillissement :** une tâche quotidienne calcule l'ancienneté de chaque suspens non clos et applique les règles J+1 (rappel au responsable), J+5 (échéance dépassée : responsable compensation et relance du participant), J+30 (escalade au chef du DES) par l'événement `rapprochement.notification-requested.v1`, consommé par `MS-NOTIFICATION` avec escalade vers les suppléants en l'absence d'acquittement.

Événements publiés et consultation par le portail Les mutations passent par la table d'outbox (Transactional Outbox) et sont publiées sous les sujets suivants, tous préfixés par `rapprochement.` : `statement-imported.v1`, `completed.v1` (nombre de lignes appariées et d'écarts), `suspens-opened.v1`, `suspens-assigned.v1`, `suspens-closed.v1` et `notification-requested.v1`. `MS-REPORTING` en dérive le nombre de suspens ouverts par ancienneté et le délai moyen de régularisation ; `MS-AUDIT` consomme chaque événement à effet. Le portail des participants n'accède qu'au port `ParticipantSuspensQueryPort`, dont chaque requête est filtrée par l'identifiant d'institution porté dans le jeton interne réduit forgé par `MS-GATEWAY` (algorithme 6.2) ; le filtre est rejoué par une politique de lignes dans la base relationnelle, de sorte qu'aucune requête ne peut restituer les suspens d'une autre institution.

6.1.11.2 Diagramme de composants internes de MS-RAPPROCHEMENT

La Figure 6.31 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les dépôts d'états et les commandes de suivi de l'application web du DES, les consultations du portail des participants et le réveil quotidien de la tâche de vieillissement ; le cœur porte les entités du rapprochement ; les adaptateurs pilotés dialoguent avec la base relationnelle du service, le contrôle de masquage, `MS-DOCUMENT`, `MS-PARTICIPANT` et le bus d'événements.

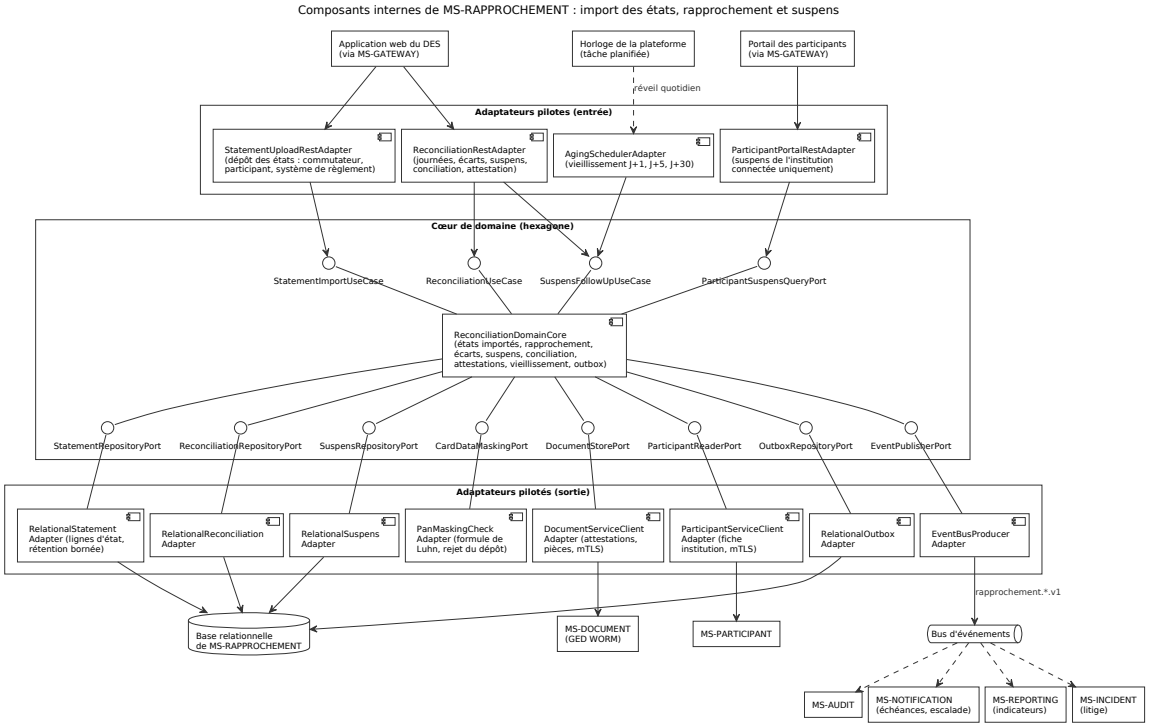


FIGURE 6.31: *Diagramme de composants internes : import des états, rapprochement et suspens*

- **Adaptateurs pilotes (entrée) :** `StatementUploadRestAdapter` (dépôt des états du commutateur, du participant et, en extension, du système de règlement, avec limite de taille) ; `ReconciliationRestAdapter` (lancement et consultation des rapprochements, écarts, affectation, conciliation, attestation) ; `ParticipantPortalRestAdapter` (suspens de l'institution connectée uniquement) ; `AgingSchedulerAdapter` (tâche quotidienne de vieillissement).

- **Cœur de domaine :** `ReconciliationDomainCore` expose `StatementImportUseCase`, `ReconciliationUseCase`, `SuspensFollowUpUseCase` et `ParticipantSuspensQueryPort`, et requiert huit ports secondaires.

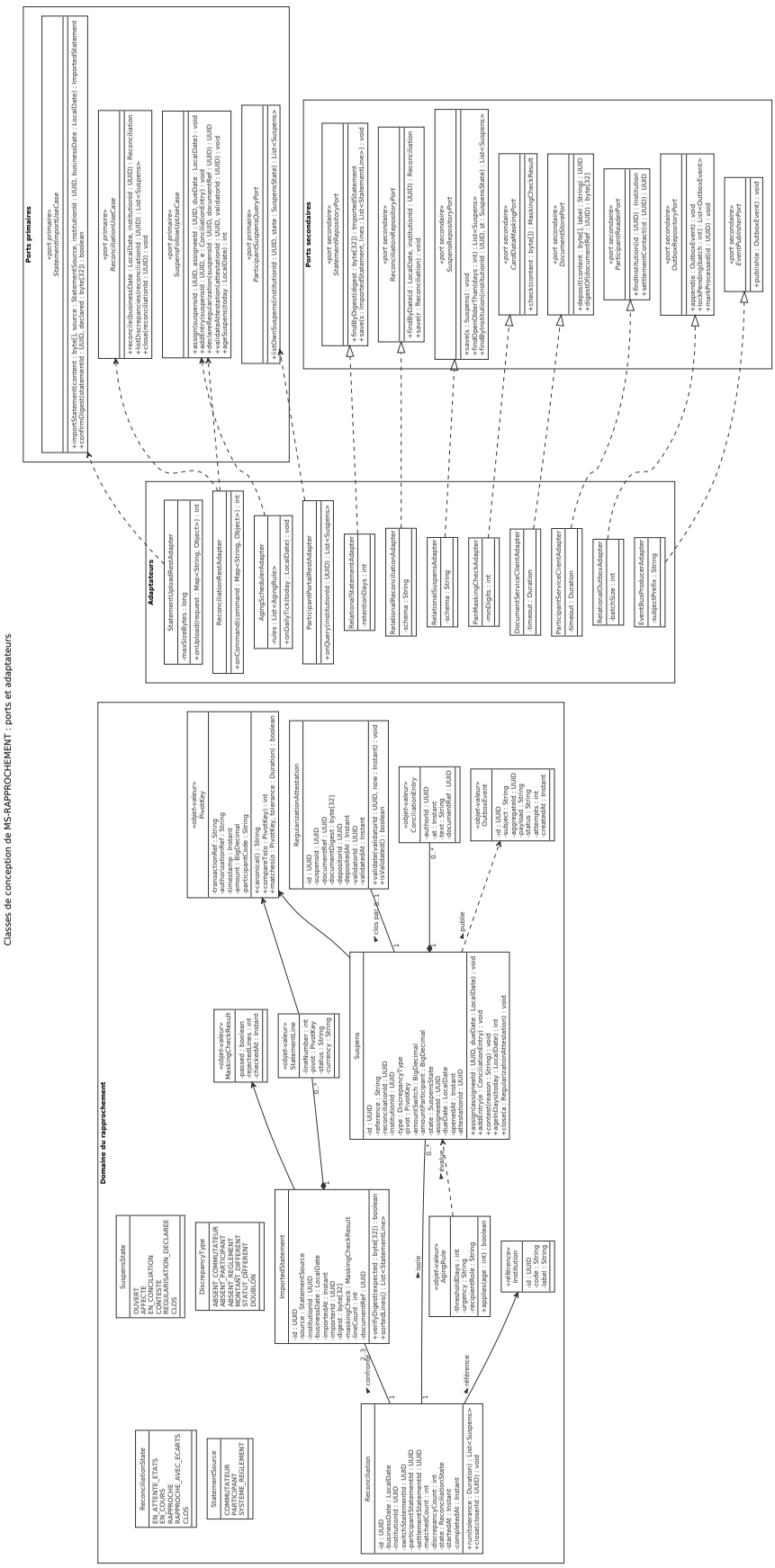
- **Adaptateurs pilotés (sortie) :** `RelationalStatementAdapter` (lignes d'état, rétention bornée), `RelationalReconciliationAdapter`, `RelationalSuspensAdapter` et `RelationalOutboxAdapter` (base relationnelle du service) ; `PanMaskingCheckAdapter` (formule de Luhn, rejet du dépôt) ; `DocumentServiceClientAdapter` (dépôt des fichiers originaux, des pièces et des attestations, mTLS) ; `ParticipantServiceClientAdapter` (lecture de la fiche institution et de l'interlocuteur règlement, mTLS) ; `EventBusProducerAdapter`.

- **Interactions :** appels synchrones vers `MS-DOCUMENT` et `MS-PARTICIPANT` unique-

ment ; `MS-AUDIT`, `MS-NOTIFICATION`, `MS-REPORTING` et `MS-INCIDENT` (ouverture d'un ticket de litige) en consommateurs des événements `rapprochement.*.v1`.

6.1.11.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.32 détaille les classes du domaine, les ports et les adaptateurs. Les deux entités du domaine 4 relevant du rapprochement (`Rapprochement`, `Suspens`) y sont reprises avec leurs types et leurs signatures, complétées par l'état importé porté localement et par les objets-valeurs de clé pivot, de ligne, de contrôle de masquage, de conciliation et de règle de vieillissement.


Classes de conception de MS-RAPPROCHEMENT : ports et adaptateurs
Ports primaires
«port primaire»
StatementImportUseCase
+importStatement(content : byte[], source : StatementSource, institutionId : UUID, businessDate : LocalDate) : ImportedStatement
+confirmDigest(statementId : UUID, received : byte[32]) : boolean
«port primaire»
ReconciliationUseCase
+reconcile(businessDate : LocalDate, institutionId : UUID) : Reconciliation
+listDiscrepancies(reconciliationId : UUID) : List<Suspens>
+close(reconciliationId : UUID) : void
«port primaire»
SuspensFollowUpUseCase
+assign(suspensId : UUID, assigneeId : UUID, dueDate : LocalDate) : void
+addEntry(suspensId : UUID, e : ConciliationEntry) : void
+escalate(suspensId : UUID, newSeverity : Severity) : void
+validateAttestation(attestationId : UUID, validatorId : UUID) : void
+ageSuspens(today : LocalDate) : int
«port primaire»
ParticipantPortailUseCase
+getOwnSuspens(institutionId : UUID, state : SuspensState) : List<Suspens>
Ports secondaires
«port secondaire»
StatementRepositoryPort
+findByDigest(digest : byte[32]) : ImportedStatement
+save(s : ImportedStatement, lines : List<StatementLine>) : void
«port secondaire»
ReconciliationRepositoryPort
+findBy(id : LocalDate, institutionId : UUID) : Reconciliation
+save(r : Reconciliation) : void
«port secondaire»
SuspensRepositoryPort
+save(s : Suspens) : void
+findById(id : UUID) : Optional<Suspens>
+findBy(institutionId : UUID, st : SuspensState) : List<Suspens>
«port secondaire»
CardDetailMaskingPort
+check(content : byte[]) : MaskingCheckResult
«port secondaire»
DocumentStorePort
+deposit(content : byte[], label : String) : UUID
+digest(documentRef : UUID) : byte[32]
«port secondaire»
ParticipantReaderPort
+findInstitution(id : UUID) : Institution
+settlementContact(id : UUID) : UUID
«port secondaire»
OutboxRepositoryPort
+append(e : OutboxEvent) : void
+fetchPending(limit : int) : List<OutboxEvent>
+markProcessed(id : UUID) : void
«port secondaire»
EventBusPort
+publish(e : OutboxEvent) : void
Adaptateurs
StatementUploadRestAdapter
-maxSizeBytes : long
+onUpload(request : Map<String, Object>) : int
ReconciliationRestAdapter
+onCommand(command : Map<String, Object>) : int
AgingScheduleAdapter
-rules : List<AgingRule>
+onDailyTick(today : LocalDate) : void
ParticipantPortailRestAdapter
+onQuery(institutionId : UUID) : List<Suspens>
RelationalStatementAdapter
-retentionDays : int
RelationalReconciliationAdapter
-schema : String
RelationalSuspensAdapter
-schema : String
PanMaskingCheckAdapter
-minDigits : int
DocumentServiceClientAdapter
-timeout : Duration
ParticipantServiceClientAdapter
-timeout : Duration
RelationalOutboxAdapter
-batchSize : int
EventBusProducerAdapter
-subjectPrefix : String
Domaine du rapprochement
ReconciliationState
EN_ATTENTE_ETATS
EN_COURS
RAPPROCHE
RAPPROCHE_AVEC_ECARTS
CLOS
StatementSource
COMMUTATEUR
AUTOMATE_CPTA
SYSTEME_REGLEMENT
SuspensState
OUVERT
ASSIGNE
EN_CONCILIATION
CONTESTE
REGULARISATION_DECLAREE
CLOS
DiscrepancyType
ABSENT_COMMUTATEUR
ABSENT_AUTOMATE_CPTA
ABSENT_REGLEMENT
MONTANT_DIFFERENT
DATE_DECALEE
DOUBLON
«objet-valeur»
PivotKey
-transactionRef : String
-counterpartyId : String
-timestamp : Instant
-amount : BigDecimal
-currency : String
+canonical() : String
+compareTo(o : PivotKey) : int
+matches(o : PivotKey, tolerance : Duration) : boolean
RegularisationAttestation
-id : UUID
-suspensId : UUID
-documentRef : UUID
-documentHash : byte[32]
-depositedAt : Instant
-validatorId : UUID
-validatedAt : Instant
+validate(validatorId : UUID, now : Instant) : void
+isValidated() : boolean
«objet-valeur»
ConciliationEntry
-authorId : UUID
-at : Instant
-text : String
-documentRef : UUID
«objet-valeur»
MaskingCheckResult
-passed : boolean
-rejectedRules : int
-checkedBytes : int
«objet-valeur»
StatementLine
-lineNumber : int
-pivot : PivotKey
-label : String
-currency : String
Suspens
-id : UUID
-reference : String
-reconciliationId : UUID
-institutionId : UUID
-type : DiscrepancyType
-pivot : PivotKey
-amountSwitch : BigDecimal
-amountStatement : BigDecimal
-state : SuspensState
-assigneeId : UUID
-dueDate : LocalDate
-openedAt : Instant
-attestationId : UUID
+assign(assigneeId : UUID, dueDate : LocalDate) : void
+addEntry(e : ConciliationEntry) : void
+escalate(reason : String) : void
+attachAttestation(id : UUID) : int
+close(a : RegularisationAttestation) : void
«objet-valeur»
OutboxEvent
-id : UUID
-subject : String
-aggregateId : UUID
-payload : String
-status : String
-attempts : int
-createdAt : Instant
ImportedStatement
-id : UUID
-source : StatementSource
-institutionId : UUID
-businessDate : LocalDate
-importedAt : Instant
-lineCount : int
-digest : byte[32]
-maskingCheck : MaskingCheckResult
-lineCount : int
-documentRef : UUID
+verifyDigest(expected : byte[32]) : boolean
+markMasked() : List<StatementLine>
«objet-valeur»
AgingRule
-thresholdDays : int
-urgency : String
+appliesTo(type : String) : boolean
«référence»
Institution
-id : UUID
-code : String
-label : String
Reconciliation
-id : UUID
-businessDate : LocalDate
-institutionId : UUID
-switchStatementId : UUID
-participantStatementId : UUID
-settlementStatementId : UUID
-matchedCount : int
-discrepancyCount : int
-state : ReconciliationState
-startedAt : Instant
-completedAt : Instant
+run(tolerance : Duration) : List<Suspens>
+close(closerId : UUID) : void
1..*
0..*
1
1
1
1
1
1
0..*
1
1
1
1
1
1

- **Entités :** `Reconciliation` (`businessDate : LocalDate`, `institutionId`, `switchStatementId`, `participantStatementId`, `settlementStatementId : UUID`, `matchedCount`, `discrepancyCount : int`, `state : ReconciliationState`, `startedAt`, `completedAt : Instant`) ; `Suspens` (`reference : String`, `type : DiscrepancyType`, `pivot : PivotKey`, `amountSwitch`, `amountParticipant : BigDecimal`, `state : SuspensState`, `assigneeId : UUID`, `dueDate : LocalDate`, `attestationId : UUID`) ; `ImportedStatement` (`source : StatementSource`, `businessDate`, `importedAt`, `importerId`, `digest : byte[32]`, `maskingCheck`, `lineCount`, `documentRef`) ; `RegularizationAttestation` (`documentRef`, `documentDigest : byte[32]`, `depositorId`, `depositedAt`, `validatorId`, `validatedAt`) ; `Institution` en « référence » (portée par `MS-PARTICIPANT`).

- **Objets-valeurs :** `PivotKey` (`transactionRef`, `authorizationRef : String`, `timestamp : Instant`, `amount : BigDecimal`, `participantCode : String`, méthodes `canonical`, `compareTo`, `matches(o, tolerance : Duration)`) ; `StatementLine` (`lineNumber`, `pivot`, `status`, `currency`) ; `MaskingCheckResult` (`passed : boolean`, `rejectedLines : int`, `checkedAt`) ; `ConciliationEntry` (`authorId`, `at`, `text`, `documentRef`) ; `AgingRule` (`thresholdDays : int`, `urgency`, `recipientRole`) ; `OutboxEvent`.

- **Énumérations :** `StatementSource`, `ReconciliationState`, `DiscrepancyType`, `SuspensState`.

- **Ports primaires :** `StatementImportUseCase` (`importStatement`, `confirmDigest`) ; `ReconciliationUseCase` (`reconcile`, `listDiscrepancies`, `close`) ; `SuspensFollowUpUseCase` (`assign`, `addEntry`, `declareRegularization`, `validateAttestation`, `ageSuspens`) ; `ParticipantSuspensQueryPort` (`listOwnSuspens`).

- **Ports secondaires :** `StatementRepositoryPort` (`findByDigest`, `save`), `ReconciliationRepositoryPort`, `SuspensRepositoryPort` (`findOpenOlderThan`, `findByInstitution`), `CardDataMaskingPort` (`check`), `DocumentStorePort` (`deposit`, `digestOf`), `ParticipantReaderPort` (`findInstitution`, `settlementContact`), `OutboxRepositoryPort`, `EventPublisherPort`.

- **Adaptateurs :** les ports primaires sont pilotés par `StatementUploadRestAdapter`, `ReconciliationRestAdapter`, `ParticipantPortalRestAdapter`

et `AgingSchedulerAdapter` ; `RelationalStatementAdapter`, `RelationalReconciliationAdapter`, `RelationalSuspensAdapter`, `PanMaskingCheckAdapter`, `DocumentServiceClientAdapter`, `ParticipantServiceClientAdapter`, `RelationalOutboxAdapter` et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.11.4 Diagramme d'objets du service MS-RAPPROCHEMENT

La Figure 6.33 capture la matinée de J+1 pour la Banque B : les deux états de la journée J ont été déposés et contrôlés, le rapprochement s'est achevé avec trois écarts, un suspens de montant est affecté avec échéance à J+5 et un suspens d'absence côté participant, régularisé en production dans la matinée, vient d'être clos par une attestation validée par un second acteur ; l'événement de clôture attend sa publication.

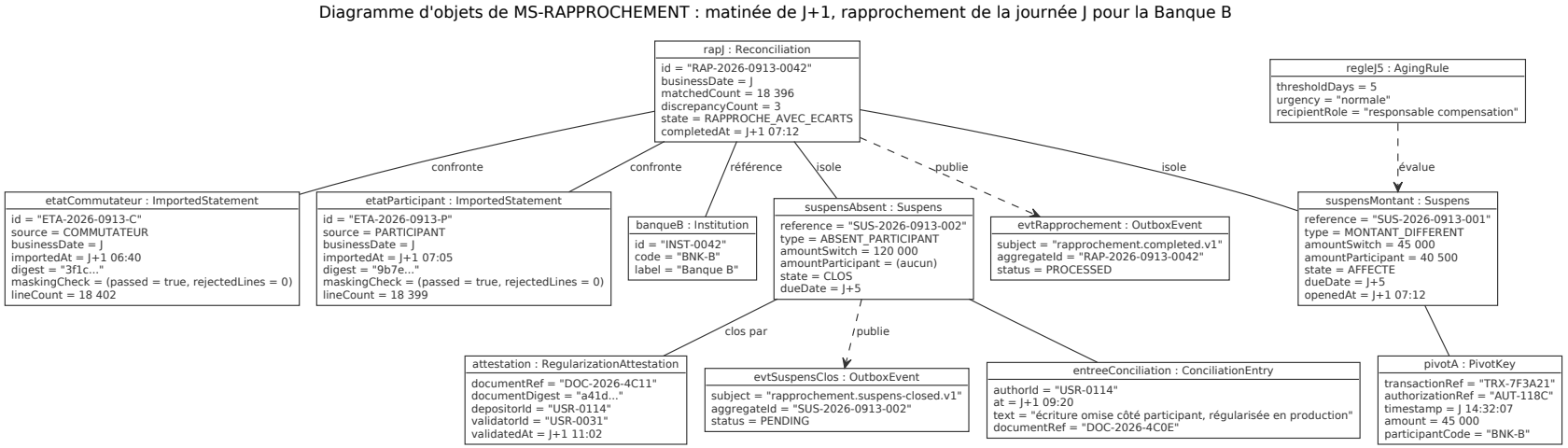


FIGURE 6.33: *Diagramme d'objets : rapprochement de la journée J et premiers suspens de la Banque B*

- `banqueB : Institution`, référence `INST-0042`, code `BNK-B` ;
- `etatCommutateur : ImportedStatement`, source `COMMUTATEUR`, journée J, importé à J+1 06h40, empreinte `3f1c...`, contrôle de masquage réussi, 18 402 lignes ; `etatParticipant : ImportedStatement`, source `PARTICIPANT`, importé à J+1 07h05, empreinte `9b7e...`, 18 399 lignes ;
- `rapJ : Reconciliation`, identifiant `RAP-2026-0913-0042`, 18 396 lignes appariées, 3 écarts, état `RAPPROCHE_AVEC_ECARTS`, achevé à J+1 07h12 ;
- `suspensMontant : Suspens`, référence `SUS-2026-0913-001`, typologie `MONTANT_DIFFERENT`, 45 000 côté commutateur contre 40 500 côté participant, état `AFFECTE`, échéance J+5, porté par `pivotA : PivotKey` (références `TRX-7F3A21` et `AUT-118C`, horodatage J 14h32) ;
- `suspensAbsent : Suspens`, référence `SUS-2026-0913-002`, typologie `ABSENT_PARTICIPANT`, 120 000, état `CLOS`, avec `entreeConciliation : ConciliationEntry` (écriture omise côté participant, régularisée en production, pièce `DOC-2026-4C0E`) et `attestation : RegularizationAttestation` (pièce `DOC-2026-4C11`, déposée par `USR-0114`, validée par `USR-0031` à J+1 11h02) ;
- `regleJ5 : AgingRule`, seuil 5 jours, urgence normale, destinataire responsable compensation ;
- `evtRapprochement : OutboxEvent`, sujet `rapprochement.completed.v1`, déjà publié ;
- `evtSuspensClos : OutboxEvent`, sujet `rapprochement.suspens-closed.v1`, en attente de publication.

6.1.11.5 Algorithmes fondamentaux de MS-RAPPROCHEMENT

Cette section formalise les quatre algorithmes qui régissent l'import et le contrôle d'un état, le rapprochement par identifiants pivots, la typologie des écarts et l'ouverture des suspens, puis le cycle de vie d'un suspens jusqu'à son attestation et son vieillissement.

Algorithme 6.48 : Import et contrôle d'un état déposé (format, masquage, empreinte, idempotence) Cet algorithme transforme un fichier déposé en état importé exploitable, ou le rejette. Il est le seul point d'entrée des données du service et garantit qu'aucune donnée de carte n'est persistée et qu'un même fichier déposé deux fois ne produit qu'un seul état.

Spécification formelle de l'algorithme 6.48 : import et contrôle d'un état	
Entrées	Fichier F ; source s ; institution i ; journée d ; empreinte déclarée h_{decl} (facultative) ; déposant u.
Sorties	`ImportedStatement` persisté avec ses lignes, ou rejet motivé ; événement `rapprochement.statement-imported.v1`.
Complexité	$\mathcal{O}(L)$ en temps, L étant le nombre de lignes ; lecture en flux, mémoire bornée par la taille d'un lot.
Contrôles	Format RFC 4180 ou RFC 8259 selon le contrat de dépôt ; masquage (formule de Luhn) ; SHA-256 ; idempotence par empreinte.

TABLE 6.53: *Fiche de spécification : import et contrôle d'un état*

Déroulement procédural étape par étape :

1. **Contrôle de recevabilité :** vérifier la taille maximale, le type déclaré et la conformité au contrat de dépôt de la source s (colonnes obligatoires, encodage, séparateur). Vérifier que le déposant u est habilité pour la source et l'institution : un représentant d'un participant ne peut déposer qu'un état de source `PARTICIPANT` pour sa propre institution.

2. **Contrôle de masquage :** soumettre le fichier au port `CardDataMaskingPort`, qui applique aux suites de 13 à 19 chiffres la formule de Luhn selon l'algorithme 6.3 ; si une suite valide non masquée est détectée, rejeter le dépôt sans rien persister, insérer `rapprochement.import-rejected.v1` dans l'outbox et notifier le déposant. Le résultat est conservé dans `MaskingCheckResult`.

3. **Empreinte et idempotence :** calculer, en une seule passe de lecture,

$$h = \mathrm{SHA256}(F) \tag{6.56}$$

   et interroger `StatementRepositoryPort.findByDigest`(h). Si un état existe déjà avec cette empreinte, retourner cet état sans nouvel enregistrement (dépôt idempotent). Si h_{decl} est fournie et diffère de h, rejeter avec le motif « empreinte déclarée non concordante ».

4. **Dépôt du fichier original :** déposer F dans `MS-DOCUMENT` par `DocumentStorePort.deposit`, qui l'analyse, le scelle et le conserve en WORM ; mémoriser la référence `documentRef`.

5. **Normalisation des lignes :** pour chaque enregistrement de F, construire `StatementLine` avec sa `PivotKey` (références canonisées : suppression des espaces

et des zéros non significatifs, casse fixée, montant en unité monétaire entière, horodatage converti en instant universel). Les lignes sont insérées par lots dans la base relationnelle du service, dans une transaction unique avec l'en-tête `ImportedStatement`.

6. **Publication :** insérer `rapprochement.statement-imported.v1` (source, institution, journée, empreinte, nombre de lignes) dans l'outbox ; `MS-AUDIT` scelle l'empreinte, `MS-REPORTING` en dérive le taux de dépôt des états dans le délai. Lorsque l'état du commutateur et celui du participant sont tous deux présents pour (i, d), le rapprochement est lancé (algorithme 6.49).

Algorithme 6.49 : Rapprochement par identifiants pivots (tri-fusion et tolérance d'horodatage) Cet algorithme confronte deux états (ou trois en extension) sans interpréter les opérations. Il repose sur un tri des lignes par clé pivot canonique suivi d'une fusion à deux index, ce qui borne le coût par $\mathcal{O}(n \log n)$ et évite toute table de hachage proportionnelle à la volumétrie.

Spécification formelle de l'algorithme 6.49 : rapprochement par identifiants pivots	
Entrées	Lignes A (commutateur, n_A) et B (participant, n_B) de la journée d pour l'institution i ; tolérance τ ; lignes C (règlement) en extension.
Sorties	Nombre de lignes appariées ; liste des écarts typés $\mathscr{E}$ transmise à l'algorithme 6.50 ; `Reconciliation` mise à jour.
Complexité	$\mathcal{O}(n_A \log n_A + n_B \log n_B)$ pour le tri, $\mathcal{O}(n_A + n_B)$ pour la fusion ; mémoire supplémentaire constante en lecture ordonnée.
Garantie	Déterminisme : deux exécutions sur les mêmes états produisent les mêmes écarts ; aucune ligne n'est modifiée.

TABLE 6.54: *Fiche de spécification : rapprochement par identifiants pivots*

Déroulement procédural étape par étape :

1. **Ordre canonique :** définir sur `PivotKey` l'ordre lexicographique $\prec$ sur le tuple (participantCode, transactionRef, authorizationRef, timestamp) ; obtenir A et B triés selon $\prec$ par l'index de la base relationnelle (tri externe si la volumétrie dépasse la mémoire allouée).

2. **Initialisation :** $a \leftarrow 0$, $b \leftarrow 0$, apparies $\leftarrow 0$, $\mathscr{E} \leftarrow \emptyset$; créer `Reconciliation`(d, i) à l'état `EN_COURS`.

3. **Détection des doublons :** avant la fusion, toute suite de lignes consécutives d'un même côté partageant (transactionRef, authorizationRef, participantCode) avec des horodatages

distants d'au plus τ engendre un écart `DOUBLON` pour chaque ligne excédentaire, qui est retirée de la fusion.

4. **Fusion à deux index :** tant que $a < n_A$ et $b < n_B$, comparer $k_A = A[a]$.pivot et $k_B = B[b]$.pivot sur les trois références :

   - si les références coïncident et si

   $$|\,k_A.\text{timestamp} - k_B.\text{timestamp}\,| \leq \tau \tag{6.57}$$

   alors comparer montant et statut : égalité stricte, apparies $\leftarrow$ apparies $+ 1$; montants différents, ajouter $(A[a], B[b], \texttt{MONTANT_DIFFERENT})$ à $\mathscr{E}$; statuts différents, ajouter $(A[a], B[b], \texttt{STATUT_DIFFERENT})$; avancer a et b ;
   - si $k_A \prec k_B$ (ou références égales mais horodatage de A antérieur de plus de τ), ajouter $(A[a], \emptyset, \texttt{ABSENT_PARTICIPANT})$ et avancer a ;
   - sinon ajouter $(\emptyset, B[b], \texttt{ABSENT_COMMUTATEUR})$ et avancer b.

5. **Épuisement :** les lignes restantes de A deviennent des écarts `ABSENT_PARTICIPANT`, celles de B des écarts `ABSENT_COMMUTATEUR`.

6. **Extension à trois voies :** si un état C du système de règlement est déposé, appliquer une seconde fusion entre les lignes appariées de (A, B) et C sur la référence de transaction et le montant ; toute ligne appariée absente de C, ou de montant différent dans C, engendre un écart `ABSENT_REGLEMENT`. Aucune connexion au système de règlement n'est établie : C est un fichier importé selon l'algorithme 6.48.

7. **Clôture du calcul :** renseigner `matchedCount` $=$ apparies et `discrepancyCount` $= |\mathscr{E}|$; passer l'état à `RAPPROCHE` si $\mathscr{E} = \emptyset$, sinon à `RAPPROCHE_AVEC_ECARTS` ; transmettre $\mathscr{E}$ à l'algorithme 6.50.

Algorithme 6.50 : Typologie des écarts et ouverture des dossiers de suspens Cet algorithme transforme chaque écart détecté en dossier de suspens individuel, qualifié, rattaché à l'institution, affecté à un responsable de régularisation avec échéance, et publie le résultat du rapprochement.

Spécification formelle de l'algorithme 6.50 : typologie et ouverture des suspens	
Entrées	Écarts $\mathscr{E}$; `Reconciliation` r ; délai de régularisation par défaut $\Delta = 5$ jours ; interlocuteur règlement de l'institution.
Sorties	Un `Suspens` par écart, à l'état `AFFECTE` ; événements `rapprochement.suspens-opened.v1` et `rapprochement.completed.v1`.
Complexité	$\mathscr{O}(\lvert\mathscr{E}\rvert)$; une lecture de `MS-PARTICIPANT` par rapprochement, mise en cache pour la journée.
Garantie	Montant et typologie figés à l'ouverture (RG-44) ; réouverture d'un rapprochement interdite après clôture ; idempotence par $(r, \text{pivot}, \text{type})$.

TABLE 6.55: *Fiche de spécification : typologie et ouverture des suspens*

Déroulement procédural étape par étape :

1. **Responsable par défaut :** lire l'interlocuteur règlement de l'institution i par le port `ParticipantReaderPort` (méthode `settlementContact`). Les typologies `ABSENT_COMMUTATEUR`, `MONTANT_DIFFERENT` et `STATUT_DIFFERENT` sont affectées par défaut au responsable compensation du groupement, qui arbitre ; `ABSENT_PARTICIPANT` et `DOUBLON` côté participant sont affectés à l'interlocuteur règlement de l'institution ; `ABSENT_REGLEMENT` est affecté au responsable compensation. L'affectation par défaut est modifiable par l'opérateur, avec trace.

2. **Création du dossier :** pour chaque écart $(l_A, l_B, t) \in \mathscr{E}$, construire `Suspens` avec une référence lisible `SUS-<année>-<jjjj>-<séquence>`, la typologie t, la clé pivot de la ligne présente, `amountSwitch` $= l_A$.amount (ou vide), `amountParticipant` $= l_B$.amount (ou vide), l'état `OUVERT` et l'horodatage d'ouverture. Si un suspens existe déjà pour (r, pivot, t), ne rien créer.

3. **Affectation et échéance :** appliquer `assign`(assigneeId, d_{ech}) avec

$$d_{\text{ech}} = \text{jourOuvre}(d+1) + \Delta \tag{6.58}$$

   où jourOuvre décale au premier jour ouvré ; l'état passe à `AFFECTE`.

4. **Publication unitaire :** insérer `rapprochement.suspens-opened.v1` (référence, institution, typologie, montants, responsable, échéance) et `rapprochement.suspens-assigned.v1` dans l'outbox ; `MS-NOTIFICATION` avise le responsable, `MS-REPORTING` incrémente le nombre de suspens ouverts.

5. **Publication du rapprochement :** insérer `rapprochement.completed.v1` (journée, institution, lignes appariées, nombre d'écarts par typologie, empreintes des états confrontés) ; cet événement, scellé par `MS-AUDIT`, constitue l'état contradictoire opposable au participant, consultable sur le portail pour ses seules lignes.

6. **Clôture du rapprochement :** un rapprochement peut être clos par l'opérateur dès que ses écarts sont tous en dossiers de suspens ; la clôture n'attend pas la régularisation des suspens, qui suivent leur propre cycle (algorithme 6.51).

Algorithme 6.51 : Cycle de vie d'un suspens jusqu'à l'attestation et vieillissement Cet algorithme gouverne les transitions d'un dossier de suspens, impose la double intervention pour la clôture et fait vieillir quotidiennement les dossiers non clos, avec notification et escalade graduées.

Spécification formelle de l'algorithme 6.51 : cycle de vie et vieillissement d'un suspens	
Entrées	`Suspens` s ; commande (entrée de conciliation, contestation, déclaration, validation) ; règles de vieillissement $\{1, 5, 30\}$ jours ; date du jour t.
Sorties	Transition appliquée avec trace ; `rapprochement.suspens-closed.v1` à la clôture ; `rapprochement.notification-requested.v1` au vieillissement.
Complexité	$\mathcal{O}(1)$ par commande ; $\mathcal{O}(S)$ par passage quotidien, S étant le nombre de suspens non clos.
Contrôles	Validateur distinct du déposant ; pièce présente et scellée dans `MS-DOCUMENT` ; montant et typologie immuables ; aucune écriture vers la production.

TABLE 6.56: *Fiche de spécification : cycle de vie et vieillissement d'un suspens*

Déroulement procédural étape par étape :

1. **Conciliation :** toute entrée de conciliation (`addEntry`) porte l'auteur, l'horodatage, le texte et, le cas échéant, une pièce déposée dans `MS-DOCUMENT` ; la première entrée fait passer s de `AFFECTE` à `EN_CONCILIATION`. Une contestation (`contest`) place s en `CONTESTE` et insère `rapprochement.suspens-contested.v1`, consommé par `MS-INCIDENT` qui ouvre un ticket de litige référençant s ; la levée de la contestation ramène s en `EN_CONCILIATION`.

2. **Déclaration de régularisation :** lorsque la correction a été exécutée dans les systèmes de production, le responsable (ou le participant sur le portail) appelle `declareRegularization`$(s, \text{documentRef})$; le service vérifie par `DocumentStorePort.digestOf` que la pièce existe et est scellée, crée

`RegularizationAttestation` (déposant, horodatage, empreinte de la pièce) et passe s en `REGULARISATION_DECLAREE`.

3. **Validation par un second acteur :** `validateAttestation` n'est acceptée que si validatorId $\neq$ depositorId et si le validateur est de niveau responsable ou opérateur habilité au rapprochement ; la validation renseigne `validatedAt`, passe s en `CLOS` et insère `rapprochement.suspens-closed.v1` (référence, typologie, délai de régularisation, empreinte de l'attestation). Aucune autre transition ne conduit à `CLOS`.

4. **Immuabilité :** toute tentative de modification de `amountSwitch`, `amountParticipant`, `type` ou `pivot` est refusée ; une erreur d'ouverture se traite par clôture motivée (attestation de non-écart validée par un second acteur), jamais par édition.

5. **Vieillissement quotidien :** la tâche `ageSuspens`(t) parcourt les suspens non clos et calcule
$$\text{age}(s,t) = t - \text{date}(s.\text{openedAt}) \quad \text{en jours calendaires} \tag{6.59}$$
puis applique la première règle non encore appliquée dont le seuil est atteint : à J+1, rappel au responsable (urgence normale) ; à J+5, ou dès le dépassement de `dueDate`, avis au responsable compensation et relance du participant (urgence élevée) ; à J+30, escalade au chef du DES (urgence élevée, acquittement requis). Chaque règle appliquée est mémorisée pour ne l'être qu'une fois.

6. **Publication et escalade :** chaque règle insère `rapprochement.notification-requested.v1` (destinataires par rôle, urgence, référence du suspens) dans l'outbox ; `MS-NOTIFICATION` assure la remise et l'escalade vers les suppléants en l'absence d'acquittement ; `MS-REPORTING` tient le nombre de suspens ouverts par tranche d'ancienneté (moins de 5 jours, de 5 à 30 jours, plus de 30 jours) et `MS-AUDIT` scelle chaque transition.

6.1.12 Pilotage de l'activité : tableaux, tâches, projets, risques et instances de décision (MS-PILOTAGE)

Le service `MS-PILOTAGE` porte, pour le domaine 5, l'organisation du travail et le cycle décisionnel du Département Exploitation et Supervision (DES). Il tient les tableaux Kanban de chaque service ou pôle, avec leurs colonnes et leurs limites d'en-cours ; les tâches nominatives, à responsable unique, dont il conserve l'origine (ticket de `MS-INCIDENT`, opération de `MS-HOMOLOGATION`, décision de réunion, fiche d'action) et les critères d'acceptation ; les projets structurants et leurs jalons, ordonnancés par la méthode PERT/CPM ; la cartographie des risques sur une matrice 5×5 (risque brut, coefficient de maîtrise, risque résiduel) et les fiches

d'action conduites selon le cycle PDCA ; enfin les réunions de gouvernance, leurs présences, leurs comptes rendus déposés dans `MS-DOCUMENT` et la conversion de chaque décision en tâche suivie. Le service ne calcule aucun indicateur et ne compose aucun cockpit : il publie ses faits (tâches affectées, achevées ou en retard, jalons, risques, décisions) sur le bus d'événements, et `MS-REPORTING` les compte. Il ne duplique pas davantage l'état d'un ticket ou d'une opération : une tâche référence son origine et en consomme les événements de clôture, sans jamais agir sur le service qui la porte. Il n'accède à aucun système de production et ne manipule aucune donnée de carte.

6.1.12.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : contrôle interne, gestion des risques et traçabilité des décisions

- **Règlement COBAC R-2016/04 :** le dispositif de contrôle interne suppose que les dysfonctionnements relevés donnent lieu à des actions correctrices dotées d'un responsable et d'une échéance, et que leur mise en œuvre soit suivie. Les fiches d'action, les tâches qui en découlent et leurs relances en constituent l'instrument, chaque étape étant tracée par `MS-AUDIT`.
- **Règlement COBAC R-2024/01 :** la gouvernance du système d'information et la maîtrise des risques qui s'y rattachent appellent une cartographie tenue à jour, des propriétaires de risque désignés et des plans de traitement suivis par les instances de gouvernance ; la cartographie 5×5 et les comités du DES y répondent.
- **ISO/IEC 27001, ISO/IEC 27005 et ISO 31000 :** appréciation (clause 6.1.2) et traitement (clause 6.1.3) des risques, amélioration continue (clause 10) ; la distinction entre risque brut et risque résiduel et le cycle planifier, réaliser, vérifier, agir en sont la transposition directe.
- **PCI-DSS v4.0.1, exigences 12.3 et 12.4 :** les analyses de risques ciblées et la responsabilité de la direction dans la protection des données de compte trouvent ici leur support de suivi : fiches d'action nominatives, échéances et comptes rendus de comité conservés en GED WORM.
- **RFC 9162 et RFC 8259 :** chaque mutation (affectation, déplacement, dérogation, décision, réévaluation de risque, transition de phase) est publiée en événement structuré et inscrite par `MS-AUDIT` comme feuille de l'arbre de Merkle.

Tableaux Kanban et limites d'en-cours Chaque service ou pôle du DES (exploitation, supervision, homologation, conformité) dispose d'au moins un tableau, défini par une suite

ordonnée de colonnes (par exemple `A_FAIRE`, `EN_COURS`, `EN_REVUE`, `TERMINE`) ; chaque colonne non terminale porte une limite d'en-cours L_c, nombre maximal de tâches qu'elle peut contenir. La limite n'est pas un réglage d'affichage : elle est contrôlée à chaque déplacement (algorithme 6.54) et tout déplacement qui la dépasserait est refusé, sauf dérogation motivée, accordée par un responsable distinct du demandeur et bornée dans le temps. Le fondement en est la loi de Little, qui relie l'en-cours moyen N, le débit d'achèvement λ et le délai moyen de traversée W :

$$N = \lambda W \qquad \Longrightarrow \qquad W = \frac{N}{\lambda} \tag{6.60}$$

à débit constant, limiter l'en-cours raccourcit mécaniquement le délai de traitement de chaque tâche.

Tâches nominatives, origine et critères d'acceptation Une tâche a un seul responsable (`assigneeId`), une échéance, une origine typée et au moins un critère d'acceptation. L'origine est l'une de quatre sources : un ticket de `MS-INCIDENT`, une opération d'homologation de `MS-HOMOLOGATION`, une décision de réunion ou une fiche d'action ; une tâche interne au pôle est admise sous le type `INTERNE`. Le service ne conserve de l'origine que sa référence et en consomme les événements : `homologation.operation-closed.v1` satisfait le critère « opération close selon la règle des quatre éléments » d'une tâche d'origine opération, `incident.incident-resolved.v1` celui d'une tâche d'origine ticket ; la tâche est alors proposée à la clôture de son responsable, jamais déplacée d'office. Le responsable doit être actif dans l'annuaire et disponible à l'échéance : ces informations sont lues dans une projection locale alimentée par `iam.user-changed.v1` et `iam.availability-validated.v1`, sans appel synchrone à `MS-IAM`. Le passage dans une colonne terminale exige que tous les critères soient satisfaits, avec pièce justificative en GED lorsque le critère l'impose.

Projets, jalons et ordonnancement PERT/CPM Un projet structurant du groupement (raccordement d'une vague de participants, renouvellement des certificats d'échange, révision du plan de continuité) porte une portée, un responsable, un budget, des dépendances envers d'autres projets et un ensemble de jalons. Chaque jalon est estimé par trois durées (optimiste, probable, pessimiste) et relié à ses prédécesseurs ; l'ordonnancement (algorithme 6.52) en déduit la durée espérée, les dates au plus tôt et au plus tard, les marges totale et libre, le chemin critique et la probabilité de tenir la date cible. L'avancement du projet est la part pondérée par les durées espérées des jalons atteints ; il est publié et `MS-REPORTING` en fait l'indicateur `PIL-PROJECT-PROGRESS`.

Cartographie des risques et fiches d'action PDCA Un risque, rattaché à un projet ou à un actif du département, est coté en probabilité P et en impact I sur l'échelle 1 à 5 ; son risque brut

vaut $P \times I$, son risque résiduel tient compte du coefficient de maîtrise des contrôles en place (algorithme 6.53). Tout risque résiduel de zone élevée ou critique impose une fiche d'action, dont le propriétaire du risque est responsable. Une fiche d'action peut aussi naître d'un incident clos (action issue du rapport post-incident), d'une décision de comité ou d'un indicateur dégradé : à la réception de `reporting.threshold-crossed.v1` en état critique, le service propose l'ouverture d'une fiche que le responsable confirme depuis le cockpit (cas d'utilisation UC-PIL-01 et diagramme de séquence système du cockpit décisionnel du cahier d'analyse). La fiche parcourt les phases planifier, réaliser, vérifier et agir ; ses actions concrètes sont des tâches nominatives du tableau du pôle concerné.

Réunions, décisions et cohérence événementielle Une réunion appartient à une instance (comité de pilotage hebdomadaire du DES, revue mensuelle des risques, comité de mise en service, revue post-incident) ; elle porte un ordre du jour, la liste des participants convoqués, les présences et, une fois tenue, un compte rendu déposé dans `MS-DOCUMENT` sous le type procès-verbal (rétention de dix ans en mode conformité), dont l'empreinte SHA-256 est conservée. Chaque décision a un texte, un responsable et une échéance, et engendre exactement une tâche (algorithme 6.55) ; l'ordre du jour de la séance suivante de la même instance reprend automatiquement le point « suivi des décisions ». Toute mutation passe par la table d'outbox (Transactional Outbox) et est publiée sur le bus d'événements :

Sujet	Déclencheur	Consommateurs
`pilotage.task-assigned.v1`	création ou réaffectation d'une tâche	AUDIT, REPORTING
`pilotage.task-moved.v1`	déplacement, avec dérogation éventuelle	AUDIT, REPORTING
`pilotage.task-completed.v1`	passage en colonne terminale	AUDIT, REPORTING
`pilotage.task-overdue.v1`	échéance dépassée	AUDIT, REPORTING
`pilotage.decision-recorded.v1`	décision consignée et convertie	AUDIT, REPORTING
`pilotage.risk-updated.v1`	cotation ou changement de zone	AUDIT, REPORTING
`pilotage.action-sheet-changed.v1`	transition de phase PDCA	AUDIT, REPORTING
`pilotage.project-scheduled.v1`	nouvel ordonnancement d'un projet	AUDIT, REPORTING
`pilotage.notification-requested.v1`	affectation, relance, escalade	NOTIFICATION

TABLE 6.57: *Événements publiés par MS-PILOTAGE*

6.1.12.2 Diagramme de composants internes de MS-PILOTAGE

La Figure 6.34 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les commandes de l'application web du DES (tableaux et tâches, projets, risques et fiches d'action, réunions), les événements d'origine consommés sur le bus et le réveil quotidien de la veille des échéances ; le cœur porte les huit entités du domaine 5 relevant du pilotage ; les adaptateurs pilotés dialoguent avec la base relationnelle du service, la projection locale de l'annuaire, `MS-DOCUMENT` et le bus d'événements.

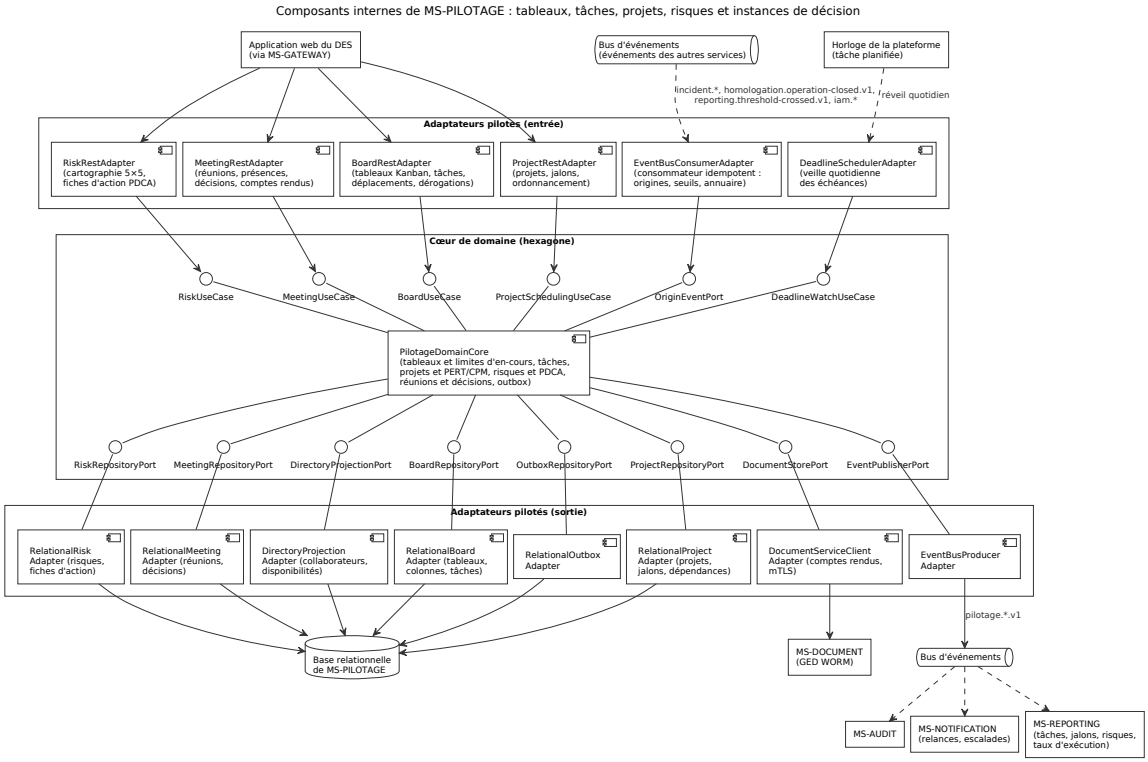


FIGURE 6.34: *Diagramme de composants internes : tableaux, tâches, projets, risques et instances de décision*

- **Adaptateurs pilotes (entrée) :** `BoardRestAdapter` (tableaux Kanban, tâches, déplacements, demandes et accords de dérogation) ; `ProjectRestAdapter` (projets, jalons, ordonnancement) ; `RiskRestAdapter` (cartographie 5×5, fiches d'action PDCA) ; `MeetingRestAdapter` (réunions, présences, décisions, dépôt du compte rendu) ; `EventBusConsumerAdapter` (consommateur idempotent de `incident.*`, `homologation.operation-closed.v1`, `reporting.threshold-crossed.v1`, `iam.user-changed.v1` et `iam.availability-validated.v1`) ; `DeadlineSchedulerAdapter` (veille quotidienne des échéances et des dérogations expirées).

- **Cœur de domaine :** `PilotageDomainCore` expose `BoardUseCase`, `ProjectSchedulingUseCase`, `RiskUseCase`, `MeetingUseCase`, `OriginEventPort` et `DeadlineWatchUseCase`, et requiert huit ports secondaires.

- **Adaptateurs pilotés (sortie) :** `RelationalBoardAdapter` (tableaux, colonnes, tâches, verrou de colonne), `RelationalProjectAdapter` (projets, jalons, dépendances), `RelationalRiskAdapter` (risques, fiches d'action) et `RelationalMeetingAdapter` (réunions, décisions) sur la base relationnelle du service ; `DirectoryProjectionAdapter` (collaborateurs actifs et disponibilités) ; `DocumentServiceClientAdapter` (comptes rendus, mTLS) ;

`RelationalOutboxAdapter` ; `EventBusProducerAdapter`.

- **Interactions :** consommation des événements de `MS-INCIDENT`, `MS-HOMOLOGATION`, `MS-REPORTING` et `MS-IAM` ; un seul appel synchrone, vers `MS-DOCUMENT` ; `MS-AUDIT`, `MS-NOTIFICATION` et `MS-REPORTING` en consommateurs des événements `pilotage.*.v1`.

6.1.12.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.35 détaille les classes du domaine, les ports et les adaptateurs. Les huit entités du domaine 5 portées par ce service (`Tableau`, `Tâche`, `Projet`, `Jalon`, `Risque`, `Réunion`, `Décision`, `Fiche d'action`) y sont reprises avec leurs types et leurs signatures ; `Indicateur`, `État importé` et `Rapport périodique` apparaissent en «`référence`», car ils sont portés par `MS-REPORTING`.

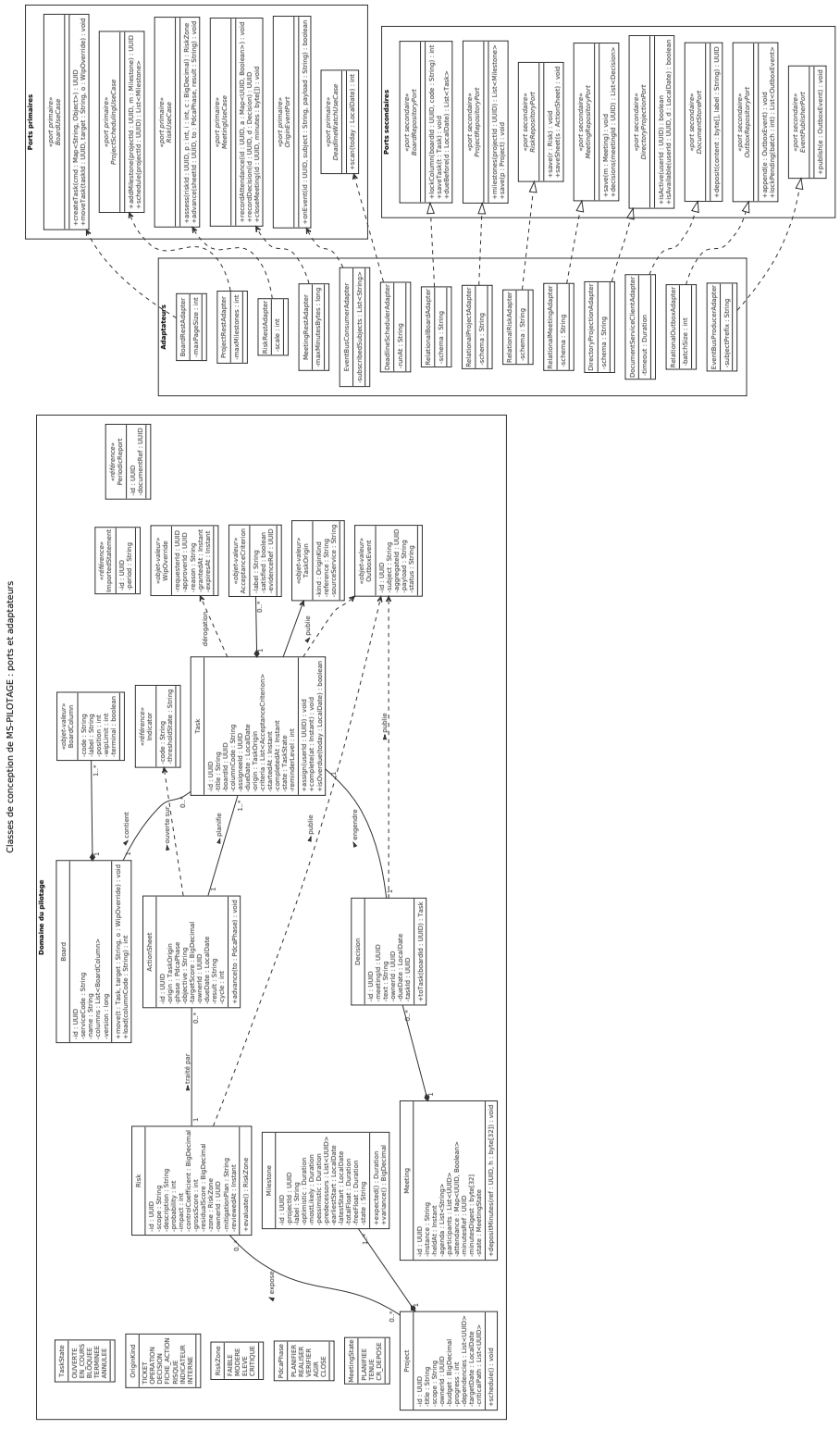


FIGURE 6.35: *Diagramme de classes de conception : service MS-PILOTAGE*

- **Entités :** `Board` (`serviceCode`, `name : String`, `columns : List<BoardColumn>`, `version : long`, méthodes `move`, `load`) ; `Task` (`title`, `boardId`, `columnCode`, `assigneeId : UUID`, `dueDate : LocalDate`, `origin : TaskOrigin`, `criteria : List<AcceptanceCriterion>`, `startedAt`, `completedAt : Instant`, `state : TaskState`, `reminderLevel : int`) ; `Project` (`scope`, `ownerId`, `budget : BigDecimal`, `progress : int`, `dependencies`, `targetDate`, `criticalPath : List<UUID>`) ; `Milestone` (`optimistic`, `mostLikely`, `pessimistic : Duration`, `predecessors`, `earliestStart`, `latestStart : LocalDate`, `totalFloat`, `freeFloat : Duration`) ; `Risk` (`probability`, `impact`, `grossScore : int`, `controlCoefficient`, `residualScore : BigDecimal`, `zone : RiskZone`, `ownerId`, `mitigationPlan`) ; `ActionSheet` (`origin`, `phase : PdcaPhase`, `objective`, `targetScore : BigDecimal`, `dueDate`, `result`, `cycle : int`) ; `Meeting` (`instance`, `heldAt : Instant`, `agenda`, `participants`, `attendance : Map<UUID, Boolean>`, `minutesRef : UUID`, `minutesDigest : byte[32]`, `state : MeetingState`) ; `Decision` (`meetingId`, `text`, `ownerId`, `dueDate`, `taskId`, méthode `toTask`).

- **Objets-valeurs :** `BoardColumn` (`code`, `position`, `wipLimit : int`, `terminal : boolean`) ; `WipOverride` (`requesterId`, `approverId : UUID`, `reason : String`, `grantedAt`, `expiresAt : Instant`) ; `TaskOrigin` (`kind : OriginKind`, `reference`, `sourceService`) ; `AcceptanceCriterion` (`label`, `satisfied : boolean`, `evidenceRef : UUID`) ; `OutboxEvent`.

- **Énumérations :** `OriginKind` (ticket, opération, décision, fiche d'action, risque, indicateur, interne), `TaskState`, `PdcaPhase`, `RiskZone`, `MeetingState`.

- **Ports primaires :** `BoardUseCase` (`createTask`, `moveTask`) ; `ProjectSchedulingUseCase` (`addMilestone`, `schedule`) ; `RiskUseCase` (`assess`, `advance`) ; `MeetingUseCase` (`recordAttendance`, `recordDecision`, `closeMeeting`) ; `OriginEventPort` (`onEvent`) ; `DeadlineWatchUseCase` (`scan`).

- **Ports secondaires :** `BoardRepositoryPort` (`lockColumn`, `saveTask`, `dueBefore`), `ProjectRepositoryPort`, `RiskRepositoryPort`, `MeetingRepositoryPort`, `DirectoryProjectionPort` (`isActive`, `isAvailable`), `DocumentStorePort`, `OutboxRepositoryPort`, `EventPublisherPort`.

- **Adaptateurs :** les ports primaires sont pilotés par `BoardRestAdapter`, `ProjectRestAdapter`, `RiskRestAdapter`, `MeetingRestAdapter`,

`EventBusConsumerAdapter` et `DeadlineSchedulerAdapter` ; `RelationalBoardAdapter`, `RelationalProjectAdapter`, `RelationalRiskAdapter`, `RelationalMeetingAdapter`, `DirectoryProjectionAdapter`, `DocumentServiceClientAdapter`, `RelationalOutboxAdapter` et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.12.4 Diagramme d'objets du service MS-PILOTAGE

La Figure 6.36 capture la sortie du comité de pilotage hebdomadaire du DES : le compte rendu vient d'être déposé et scellé ; la troisième décision, confiée à un ingénieur d'homologation, a été convertie en tâche du tableau du pôle homologation, et l'événement d'affectation attend sa publication. Dans le même tableau, une tâche d'origine ticket occupe la colonne « en cours » au-delà de sa limite grâce à une dérogation motivée accordée par le chef du DES. Le risque d'expiration des certificats des liaisons en homologation, réévalué en zone élevée, est traité par une fiche d'action en phase « réaliser », dont la décision du comité constitue l'action concrète ; le projet de renouvellement qui l'expose a son jalon de bascule sur le chemin critique.

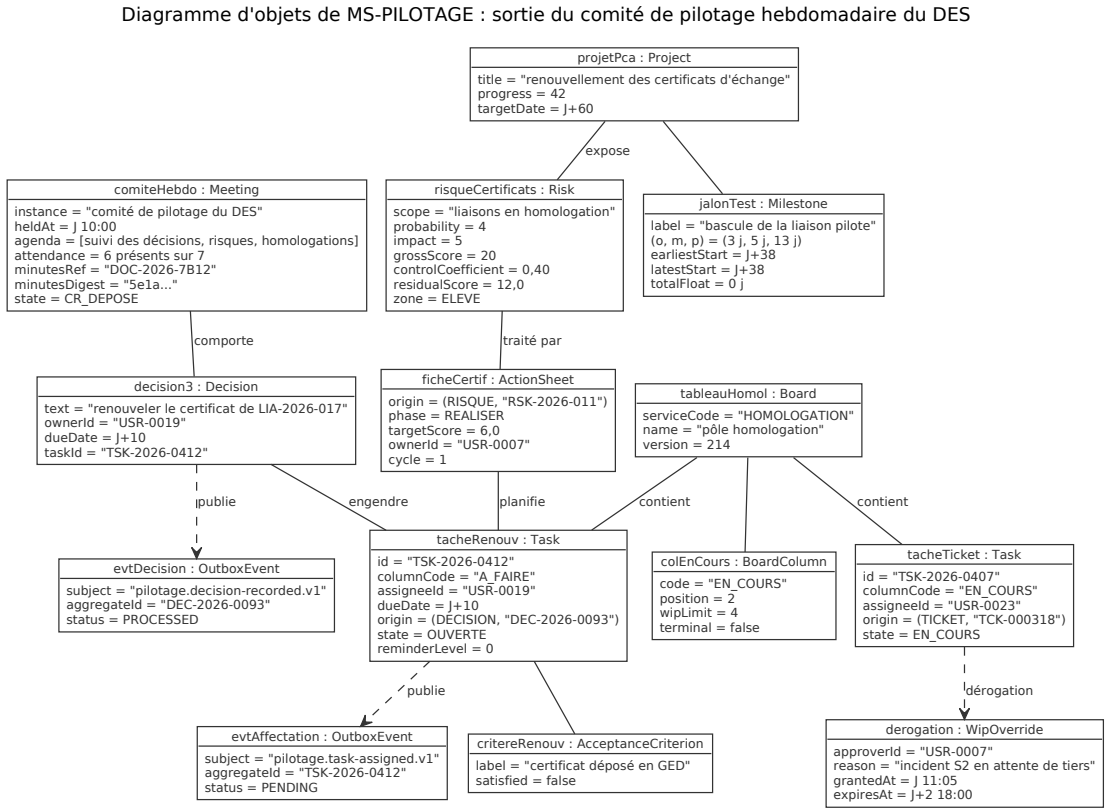


FIGURE 6.36: *Diagramme d'objets : sortie du comité de pilotage hebdomadaire du DES*

- `comiteHebdo : Meeting`, instance « comité de pilotage du DES », tenue à 10h00,

six présents sur sept, compte rendu `DOC-2026-7B12` d'empreinte `5e1a...`, état `CR_DEPOSE` ;

- `decision3 : Decision`, « renouveler le certificat de `LIA-2026-017` », responsable `USR-0019`, échéance J+10, tâche engendrée `TSK-2026-0412` ;
- `tacheRenouv : Task`, colonne `A_FAIRE`, origine `(DECISION, DEC-2026-0093)`, état `OUVERTE`, niveau de relance 0, avec le critère `critereRenouv : AcceptanceCriterion` « certificat déposé en GED », non encore satisfait ;
- `tableauHomol : Board`, pôle homologation, version 214, avec `colEnCours : BoardColumn` (code `EN_COURS`, limite d'en-cours 4) ;
- `tacheTicket : Task`, `TSK-2026-0407`, origine `(TICKET, TCK-000318)`, cinquième tâche de la colonne `EN_COURS`, admise par `derogation : WipOverride` (approbateur `USR-0007`, motif « incident S2 en attente de tiers », expiration à J+2, 18h00) ;
- `risqueCertificats : Risk`, $P = 4$, $I = 5$, risque brut 20, coefficient de maîtrise 0,40, risque résiduel 12,0, zone `ELEVE`, traité par `ficheCertif : ActionSheet` (origine risque `RSK-2026-011`, phase `REALISER`, cible 6,0, premier cycle) qui planifie `tacheRenouv` ;
- `projetPca : Project`, « renouvellement des certificats d'échange », avancement 42 %, date cible J+60, et `jalonTest : Milestone` « bascule de la liaison pilote », durées (3, 5, 13) jours, début au plus tôt et au plus tard J+38, marge totale nulle : il est critique ;
- `evtDecision : OutboxEvent`, sujet `pilotage.decision-recorded.v1`, publié ; `evtAffectation : OutboxEvent`, sujet `pilotage.task-assigned.v1`, en attente de publication.

6.1.12.5 Algorithmes fondamentaux de MS-PILOTAGE

Cette section formalise les quatre algorithmes qui régissent l'ordonnancement PERT/CPM des projets et le calcul du chemin critique, la cotation des risques sur la matrice 5×5 et la conduite des fiches d'action selon le cycle PDCA, le contrôle des limites d'en-cours lors d'un déplacement Kanban, et la conversion des décisions de réunion en tâches suivies jusqu'à leur échéance. Le calcul des indicateurs et des cockpits, qui figurait dans la première conception de ce service, relève désormais de `MS-REPORTING` (algorithme 6.58).

Algorithme 6.52 : Ordonnancement PERT/CPM et calcul du chemin critique Cet algorithme ordonnance les jalons d'un projet à partir de leurs trois estimations de durée et de leurs dépendances, calcule les dates au plus tôt et au plus tard, les marges, le chemin critique et la probabilité de tenir la date cible. Il est exécuté à chaque ajout ou modification d'un jalon et à chaque atteinte d'un jalon, dont la durée réelle remplace alors l'estimation.

Spécification formelle de l'algorithme 6.52 : ordonnancement PERT/CPM	
Entrées	Graphe $G=(V,E)$ des jalons d'un projet (potentiels-tâches) ; pour chaque jalon j, durées (o_j, m_j, p_j) avec $o_j \le m_j \le p_j$; date de début D_0 ; date cible D_c ; calendrier des jours ouvrés.
Sorties	Pour chaque jalon : t_j, σ_j^2, dates au plus tôt et au plus tard, marges totale et libre ; chemin critique $\mathscr{C}$; durée T ; probabilité $\Pr(T \le D_c)$.
Complexité	$\mathcal{O}(\lvert V\rvert + \lvert E\rvert)$ pour le tri topologique et les deux passes.
Précondition	G acyclique, vérifié par le tri topologique de Kahn (algorithme 6.30).

TABLE 6.58: *Fiche de spécification : ordonnancement PERT/CPM et chemin critique*

Déroulement procédural étape par étape :

1. **Durées espérées et variances :** pour chaque jalon non atteint, calculer selon la loi bêta de la méthode PERT

$$t_j = \frac{o_j + 4m_j + p_j}{6}, \qquad \sigma_j^2 = \left(\frac{p_j - o_j}{6}\right)^2 \tag{6.61}$$

   un jalon atteint prenant sa durée réelle et une variance nulle.

2. **Tri topologique :** appliquer l'algorithme de Kahn à G ; si le nombre de sommets ordonnés est inférieur à $|V|$, rejeter la modification qui a introduit la dépendance circulaire, avec la liste des jalons en cause, et conserver l'ordonnancement précédent.

3. **Passe avant :** dans l'ordre topologique, calculer le début au plus tôt $ES_j = \max_{i \in \mathrm{Pred}(j)} (ES_i + t_i)$, avec $ES_j = 0$ pour un jalon sans prédécesseur, puis $EF_j = ES_j + t_j$ et la durée du projet $T = \max_j EF_j$.

4. **Passe arrière :** dans l'ordre topologique inverse, calculer la fin au plus tard $LF_j = \min_{k \in \mathrm{Succ}(j)} LS_k$, avec $LF_j = T$ pour un jalon sans successeur, puis $LS_j = LF_j - t_j$.

5. **Marges et chemin critique :** pour chaque jalon,

$$MT_j = LS_j - ES_j, \qquad ML_j = \min_{k \in \mathrm{Succ}(j)} ES_k - EF_j \tag{6.62}$$

($ML_j = T - EF_j$ en l'absence de successeur) ; le chemin critique $\mathscr{C}$ est la suite des jalons de marge totale nulle, à une tolérance d'une demi-journée près.

6. **Probabilité de respect de la date cible :** par approximation normale sur le chemin critique (le plus dispersé s'il en existe plusieurs),

$$Z = \frac{D_c - D_0 - T}{\sqrt{\sum_{j \in \mathscr{C}} \sigma_j^2}}, \qquad \Pr(T \le D_c) \approx \Phi(Z) \tag{6.63}$$

Φ étant la fonction de répartition de la loi normale centrée réduite.

7. **Projection calendaire et publication :** convertir ES_j et LS_j en dates par le calendrier des jours ouvrés ; enregistrer les jalons et le chemin critique ; insérer `pilotage.project-scheduled.v1` dans l'outbox et, si $\Pr(T \le D_c) < 0{,}8$ ou si le chemin critique a changé, `pilotage.notification-requested.v1` à destination du responsable du projet.

Algorithme 6.53 : Cotation des risques sur la matrice 5×5 et conduite du cycle PDCA
Cet algorithme cote un risque en risque brut et en risque résiduel, le classe dans une zone de la matrice, décide de l'ouverture d'une fiche d'action et fait progresser celle-ci dans les phases planifier, réaliser, vérifier et agir, jusqu'à ce que le risque résiduel atteigne son objectif.

Spécification formelle de l'algorithme 6.53 : matrice des risques et PDCA	
Entrées	Risque r ; probabilité $P \in \{1,\dots,5\}$; impact $I \in \{1,\dots,5\}$; efficacité $e_k \in [0,1]$ et poids w_k des contrôles en place ; fiche d'action ouverte éventuelle.
Sorties	R_b, R_r, zone ; fiche d'action créée ou transitée ; `pilotage.risk-updated.v1`, `pilotage.action-sheet-changed.v1`.
Complexité	$\mathcal{O}(k)$ pour k contrôles ; $\mathcal{O}(n)$ pour vérifier les n tâches d'une fiche.
Standard	ISO/IEC 27005 et ISO 31000 (appréciation et traitement) ; ISO/IEC 27001, clause 10.

TABLE 6.59: *Fiche de spécification : matrice des risques et cycle PDCA*

Déroulement procédural étape par étape :

1. **Risque brut et coefficient de maîtrise :** calculer

$$R_b = P \times I \in [1,25], \qquad c = \min\left(0{,}9,\ \frac{\sum_k w_k e_k}{\sum_k w_k}\right) \tag{6.64}$$

le plafond de 0,9 traduisant qu'aucun dispositif de contrôle n'annule entièrement un risque.

2. **Risque résiduel et zone :** $R_r = R_b \times (1 - c)$, puis

$$\text{zone}(R_r) = \begin{cases} \texttt{FAIBLE} & \text{si } R_r < 5 \\ \texttt{MODERE} & \text{si } 5 \leq R_r < 10 \\ \texttt{ELEVE} & \text{si } 10 \leq R_r < 15 \\ \texttt{CRITIQUE} & \text{si } R_r \geq 15 \end{cases} \tag{6.65}$$

   enregistrer la cotation datée et insérer `pilotage.risk-updated.v1` (risque, P, I, R_b, c, R_r, ancienne et nouvelle zone).

3. **Décision d'ouverture :** si la zone est `ELEVE` ou `CRITIQUE` et qu'aucune fiche n'est ouverte pour r, créer une fiche d'action en phase `PLANIFIER`, confiée au propriétaire du risque, avec une échéance de 15 jours ouvrés (5 pour une zone critique) ; en zone critique, insérer `pilotage.notification-requested.v1` à destination du chef du DES et de la Direction Générale. Une fiche d'origine indicateur, incident ou décision entre dans la même phase.

4. **Planifier :** le responsable consigne l'analyse des causes, l'objectif R_{cible} (par défaut la borne haute de la zone modérée, soit $R_{\text{cible}} < 10$) et les actions ; chaque action devient une tâche nominative d'origine `FICHE_ACTION`. Le passage à `REALISER` exige au moins une tâche et un objectif chiffré.

5. **Réaliser :** la fiche reste dans cette phase tant que ses tâches ne sont pas toutes terminées ; l'achèvement de la dernière (événement interne `pilotage.task-completed.v1`) fait passer la fiche à `VERIFIER` et ouvre une période d'observation, de 30 jours par défaut.

6. **Vérifier :** à l'issue de la période, le propriétaire recote P, I et les contrôles ; le nouveau R'_r est calculé par les étapes 1 et 2. Pour une fiche d'origine indicateur, l'état de seuil lu dans l'événement le plus récent de `MS-REPORTING` doit en outre être revenu à `NORMAL`.

7. **Agir :** si $R'_r \leq R_{\text{cible}}$, la mesure est pérennisée (procédure mise à jour, déposée dans `MS-DOCUMENT`) et la fiche passe à `CLOSE` ; sinon, un nouveau cycle commence en `PLANIFIER` avec cycle $\leftarrow$ cycle $+ 1$, et le troisième cycle infructueux inscrit la fiche à l'ordre du jour de la revue mensuelle des risques. Chaque transition insère `pilotage.action-sheet-changed.v1` dans l'outbox.

Algorithme 6.54 : Contrôle des limites d'en-cours lors d'un déplacement Kanban Cet algorithme décide, de manière atomique, si une tâche peut entrer dans une colonne sans en dépasser la limite d'en-cours, et encadre la dérogation motivée qui permet exceptionnellement

de la franchir. Il garantit que deux déplacements concurrents ne peuvent pas, ensemble, dépasser la limite.

Spécification formelle de l'algorithme 6.54 : limites d'en-cours	
Entrées	Tâche t ; colonne cible c de limite L_c ; auteur u ; dérogation facultative o (demandeur, approbateur, motif, expiration).
Sorties	Déplacement appliqué ou refus motivé (liste des tâches occupant c) ; `pilotage.task-moved.v1`.
Complexité	$\mathcal{O}(1)$: un verrou de ligne sur la colonne et un comptage indexé.
Garantie	Sérialisation des déplacements vers une même colonne ; au plus une tâche en dépassement par colonne.

TABLE 6.60: *Fiche de spécification : contrôle des limites d'en-cours*

Déroulement procédural étape par étape :

1. **Habilitation et transition :** vérifier que u est le responsable de t ou un responsable du pôle propriétaire du tableau, et que la transition de la colonne courante vers c est admise par la politique du tableau. Si c est terminale, vérifier que tous les critères d'acceptation de t sont satisfaits, avec pièce justificative lorsque le critère l'exige ; sinon refuser.

2. **Verrouillage et comptage :** ouvrir une transaction, poser un verrou de ligne sur la colonne c (`lockColumn`) puis compter les tâches non annulées qu'elle contient :

$$n_c = \left|\{\, x \in \text{Board} : x.\text{columnCode} = c,\ x.\text{state} \neq \texttt{ANNULEE},\ x \neq t \,\}\right| \tag{6.66}$$

   Le verrou sérialise les déplacements concurrents vers c ; il est relâché à la validation.

3. **Test de la limite :** si c est terminale, si $L_c = 0$ (colonne non bornée) ou si $n_c + 1 \leq L_c$, accepter. Sinon, en l'absence de dérogation, refuser en renvoyant la liste des tâches de c et l'invitation à en achever une avant d'en commencer une autre.

4. **Examen de la dérogation :** l'accepter seulement si l'approbateur est un responsable (niveau 2) ou le chef du pôle, distinct du demandeur ; si le motif est renseigné ; si l'expiration n'excède pas 72 heures ; et si aucune autre dérogation active n'existe sur c, de sorte que $n_c + 1 \leq L_c + 1$. Sinon refuser.

5. **Application :** mettre à jour la colonne et l'état de t (`EN_COURS` à l'entrée d'une colonne active, avec `startedAt` s'il est vide ; `TERMINEE` et `completedAt` en colonne terminale), incrémenter la version du tableau et insérer dans l'outbox `pilotage.task-moved.v1` (tâche, colonnes source et cible, n_c, L_c, dérogation éventuelle

avec motif et approbateur), ainsi que `pilotage.task-completed.v1` en colonne terminale ; valider la transaction.

6. **Expiration des dérogations :** la veille quotidienne (`DeadlineSchedulerAdapter`) relève les dérogations expirées dont la colonne excède encore sa limite et insère `pilotage.notification-requested.v1` à destination de l'approbateur et du responsable de la tâche. Le service ne déplace jamais une tâche de lui-même : le retour sous la limite relève du pôle.

Algorithme 6.55 : Conversion d'une décision en tâche et suivi des échéances Cet algorithme clôt une réunion par le dépôt de son compte rendu, convertit chacune de ses décisions en une tâche nominative, puis en suit l'échéance par des relances graduées jusqu'à l'escalade ; il tient pour chaque instance le taux d'exécution de ses décisions, publié vers `MS-REPORTING`.

Spécification formelle de l'algorithme 6.55 : décisions et échéances	
Entrées	Réunion m tenue ; décisions D_m (texte, responsable, échéance) ; compte rendu F ; date du jour d.
Sorties	Compte rendu scellé ; une tâche par décision ; relances et escalades ; taux d'exécution $\tau(m)$; `pilotage.decision-recorded.v1`, `pilotage.task-assigned.v1`, `pilotage.task-overdue.v1`.
Complexité	$\mathcal{O}(\lvert D_m \rvert)$ à la clôture ; $\mathcal{O}(n)$ par veille pour n tâches ouvertes (index sur l'échéance).
Garantie	Conversion idempotente (une décision engendre une et une seule tâche) ; une relance par niveau.

TABLE 6.61: *Fiche de spécification : conversion des décisions et suivi des échéances*

Déroulement procédural étape par étape :

1. **Dépôt du compte rendu :** vérifier que m est à l'état `TENUE` et que les présences sont consignées ; déposer F (PDF/A-3) dans `MS-DOCUMENT` sous le type procès-verbal (algorithme 6.17), conserver la référence et $h = \mathrm{SHA256}(F)$ dans `minutesRef` et `minutesDigest`, et passer à `CR_DEPOSE`. Les décisions ne sont plus modifiables : une correction passe par une décision rectificative lors d'une séance ultérieure.

2. **Validation des décisions :** pour chaque $\delta \in D_m$, vérifier par la projection de l'annuaire que le responsable est actif et disponible à l'échéance (aucune absence validée qui la couvre) et que l'échéance est postérieure à la séance ; en cas d'échec, la décision est renvoyée au secrétaire de séance pour désignation d'un autre responsable ou d'une autre échéance.

3. **Conversion idempotente :** si δ.taskId est déjà renseigné, ne rien faire ; sinon créer, dans la même transaction, la tâche $t = \delta.\text{toTask}(b)$ sur le tableau b du pôle du responsable (colonne initiale, origine `(DECISION, δ.id)`, critères d'acceptation issus de la décision, au moins un), renseigner δ.taskId, et insérer `pilotage.decision-recorded.v1`, `pilotage.task-assigned.v1` et `pilotage.notification-requested.v1` (avis au responsable) dans l'outbox.

4. **Veille des échéances :** chaque jour ouvré à 06h30, pour chaque tâche ouverte, calculer l'écart en jours ouvrés $r = d - \text{dueDate}$ et le niveau de relance attendu

$$\ell(r) = \begin{cases} 1 & \text{si } r = -2 \text{ (rappel au responsable)} \\ 2 & \text{si } r = 0 \text{ (échéance du jour)} \\ 3 & \text{si } 1 \leq r < 5 \text{ (retard : responsable et chef de pôle)} \\ 4 & \text{si } r \geq 5 \text{ (escalade au chef du DES)} \end{cases} \tag{6.67}$$

   et, si $\ell(r) > t$.reminderLevel, insérer `pilotage.notification-requested.v1` pour les destinataires du niveau, puis poser t.reminderLevel $\leftarrow \ell(r)$; au premier passage au niveau 3, insérer aussi `pilotage.task-overdue.v1`. `MS-NOTIFICATION` assure la remise et l'escalade vers les suppléants en l'absence d'acquittement.

5. **Achèvement :** la tâche est achevée par son passage en colonne terminale (algorithme 6.54), critères satisfaits ; la décision est alors réputée exécutée, dans les délais si completedAt $\leq$ dueDate.

6. **Taux d'exécution et suivi en séance :** à chaque achèvement ou retard, recalculer pour la réunion m

$$\tau(m) = \frac{|\{\, \delta \in D_m : \delta \text{ exécutée dans les délais} \,\}|}{|D_m|} \tag{6.68}$$

   et le porter dans la charge utile de `pilotage.task-completed.v1` ou `pilotage.task-overdue.v1`, d'où `MS-REPORTING` dérive l'indicateur d'exécution des décisions par instance. La séance suivante de la même instance reçoit automatiquement à son ordre du jour la liste des décisions non exécutées, avec leur retard.

6.1.13 Magasin décisionnel, indicateurs, cockpits et rapports périodiques (MS-REPORTING)

Le service `MS-REPORTING` porte, pour le domaine 5, l'instrument de mesure de la plateforme : il tient un magasin décisionnel propre, organisé en schéma en étoile, alimenté de deux façons seulement. D'une part, il consomme de manière idempotente les événements publiés par les autres services (tickets et incidents, alertes et acquittements, opérations d'homologation, quitus et

attestations, suspens, tâches et jalons) et les projette en faits mesurables. D'autre part, il intègre les états déclarés par fichier (volumes, taux d'acceptation et disponibilité déclarée, par période et par participant), déposés avec contrôle de masquage et empreinte. Il en dérive des indicateurs à code, source, période, seuil et tendance, calculés en flux par fenêtres glissantes, compose le cockpit de la Direction Générale, le cockpit du DES et les vues par service, engendre à date fixe les rapports hebdomadaires et mensuels, les signe, les dépose dans `MS-DOCUMENT` et en notifie les destinataires. Il ne capte aucune transaction du commutateur, ne se connecte à aucun système de production et n'héberge ni donnée de carte ni opération monétique unitaire : son magasin ne contient que des agrégats et des mesures d'activité de la plateforme. Les indicateurs et les cockpits relèvent de ce service et non de `MS-PILOTAGE`, qui lui fournit par événement les tâches, projets et risques qu'il compte.

6.1.13.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : reporting prudentiel, protection des données et intégrité

- **Règlement COBAC R-2016/04 :** le contrôle interne permanent exige une remontée régulière et inaltérable de l'activité et des incidents opérationnels vers l'organe exécutif. Les rapports périodiques du DES en sont l'instrument : générés à date fixe à partir d'indicateurs figés, signés, déposés en GED WORM et scellés par `MS-AUDIT`, ils sont opposables et reproductibles.
- **Règlement COBAC R-2024/01 :** la gouvernance du système d'information appelle des tableaux de bord auditables sur la résilience opérationnelle ; le cockpit de la Direction Générale et les rapports mensuels en tiennent lieu, avec une traçabilité complète de la provenance de chaque valeur (événement source ou état importé, empreinte, période).
- **PCI-DSS v4.0.1, exigences 3 et 7 :** le magasin ne stocke aucune donnée de compte ; les états déposés passent le contrôle de masquage avant toute intégration et les charges utiles des événements ne portent par construction que des références. L'accès aux cockpits et à l'exportation est restreint par rôle et par périmètre de visibilité (niveaux 2 et 5, et niveau 3 ou 4 pour les vues de leur service).
- **ISO/IEC 27001 et RFC 9162 :** chaque import, chaque franchissement de seuil, chaque rapport publié et chaque exportation sont publiés vers `MS-AUDIT`, qui les inscrit comme feuilles de l'arbre de Merkle ; un auditeur peut vérifier qu'un rapport présenté correspond au rapport scellé.

Deux sources d'alimentation, aucune captation Le principe de non-intrusion s'applique intégralement : la plateforme n'observe pas le trafic du commutateur et ne reçoit aucun

flux transactionnel. Les indicateurs d'activité de la plateforme (délais, taux, volumes de tickets, d'alertes, d'opérations, de suspens, de tâches) sont dérivés des événements des autres services, consommés sur le bus d'événements avec une table des événements traités qui garantit l'idempotence ; les indicateurs d'activité du réseau (volumes échangés, taux d'acceptation, disponibilité déclarée) proviennent d'états agrégés déclarés par le commutateur et par les participants, déposés par fichier pour une période et une institution. Ces états sont des déclarations, jamais des mesures de la plateforme : les indicateurs qui en dérivent portent explicitement la source `ETAT_IMPORTE` et sont présentés comme « déclarés » dans les cockpits et les rapports. L'entité « État importé » est ici portée localement (agrégats périodiques, rétention longue), distinctement de son homologue de `MS-RAPPROCHEMENT` (lignes unitaires, journée), les deux services partageant le même contrat de contrôle (masquage, empreinte, idempotence par empreinte, dépôt de l'original en GED).

Magasin décisionnel en étoile et absence de données unitaires Le magasin est structuré en schéma en étoile : une table de faits par domaine (incidents et tickets, alertes, opérations d'homologation, quitus, suspens, tâches et jalons, états déclarés), chacune rattachée à quatre dimensions conformes : le temps (jour, semaine ISO, mois, trimestre), l'institution (participant, pays, catégorie), le service du DES (exploitation, supervision, homologation, conformité) et la sévérité ou l'urgence. Un fait porte des mesures numériques (compte, durée, montant agrégé, taux) et l'identifiant de l'événement ou de l'état qui l'a produit, ce qui rend chaque valeur traçable. Au-delà de 90 jours, les faits événementiels sont compactés en agrégats quotidiens par clé de dimension ; les états déclarés sont conservés cinq ans. Aucune table ne contient de transaction monétique, de numéro de carte, de référence d'autorisation ni de texte libre : le magasin n'est qu'un espace d'agrégats.

Indicateurs, seuils, tendances et fenêtres glissantes Un indicateur est défini par un code, un libellé, une source (`EVENEMENT`, `ETAT_IMPORTE` ou `DERIVE` lorsqu'il combine les deux), une unité, une fenêtre, une clé de dimension, un seuil à deux niveaux (alerte, critique, avec sens de lecture) et une tendance. Les indicateurs événementiels sont tenus en flux par des fenêtres glissantes à tampon circulaire (par exemple 30 segments d'un jour) : l'ajout d'une mesure et l'éviction du segment le plus ancien sont en temps constant, le recalcul en temps proportionnel au nombre de segments. Le référentiel initial comprend notamment : le délai moyen de résolution des incidents par sévérité (`EXP-MTTR-S1` à `EXP-MTTR-S4`) ; le taux de respect des engagements de service (`EXP-SLA-RATE`) ; le taux d'acquittement des alertes dans le délai (`MON-ACK-RATE`) ; la couverture des vacations par la grille d'astreinte (`MON-ONCALL-COVER`) ; le taux de couverture des liaisons certifiées sur les liaisons contractualisées (`HOM-LINK-COVER`) ; les opérations d'homologation en retard (`HOM-OPS-LATE`) ; les quitus en attente (`CERT-QUITUS-PENDING`) ; le nombre de

suspens ouverts par ancienneté (RAP-SUSPENS-J5, RAP-SUSPENS-J30) et le délai moyen de régularisation (RAP-REG-DELAY) ; les tâches en retard par service (PIL-TASK-LATE), l'avancement des projets structurants (PIL-PROJECT-PROGRESS) et les risques résiduels majeurs (PIL-RISK-MAJOR), comptés sur les références de MS-PILOTAGE ; la disponibilité déclarée du réseau (RES-DISPO-DECL), les volumes déclarés (RES-VOL-DECL) et le taux d'acceptation déclaré (RES-ACCEPT-DECL) par période et par participant. Tout changement d'état de seuil publie reporting.threshold-crossed.v1, consommé par MS-NOTIFICATION (avis au responsable du service concerné, à la Direction pour un état critique) et par MS-PILOTAGE, qui propose l'ouverture d'une fiche d'action.

Cockpits, vues par service et exportation contrôlée

- **Cockpit de la Direction Générale :** disponibilité déclarée du réseau et volumes déclarés par pays et par participant ; incidents S1 et S2 du mois avec délai de résolution ; taux de respect des engagements ; avancement des homologations et des mises en service (liaisons, quitus) ; suspens ouverts depuis plus de 30 jours ; risques résiduels majeurs ; avancement des projets structurants. Chaque tuile porte la valeur, la tendance, l'état de seuil et la date de la dernière donnée intégrée.
- **Cockpit du DES :** alertes en cours et taux d'acquittement ; tickets par état et par sévérité ; délai moyen de résolution par sévérité ; couverture des astreintes de la semaine ; opérations d'homologation en retard ; suspens par tranche d'ancienneté ; tâches en retard par service ; rapports périodiques en attente de visa.
- **Vues par service :** chaque service du DES accède au sous-ensemble d'indicateurs de sa dimension, avec exploration par axe (pays, institution, période, sévérité) et historique ; le périmètre de visibilité du jeton interne réduit borne les dimensions accessibles.
- **Rafraîchissement :** les cockpits lisent les valeurs matérialisées des indicateurs (rafraîchissement de 60 secondes) ; un franchissement de seuil est poussé sans délai par le canal poussé de MS-GATEWAY.
- **Exportation contrôlée :** un responsable ou un auditeur peut exporter des agrégats (indicateurs, périodes, dimensions) dans un format à colonnes ; l'export est plafonné en lignes, filigrané par l'identité du demandeur et l'horodatage, déposé dans MS-DOCUMENT avec journal de consultation et publié par reporting.export-requested.v1. Aucune exportation ne peut atteindre une donnée unitaire, le magasin n'en contenant pas.

Rapports périodiques et cohérence événementielle Les rapports hebdomadaires (le lundi à 06h00, semaine ISO écoulée) et mensuels (premier jour ouvré, mois écoulé) sont engendrés par

service à partir des indicateurs figés de la période, rendus en PDF/A-3 (ISO 19005-3), signés par la clé de signature non exportable du service dans le coffre de clés (signature PAdES, ETSI EN 319 142) puis déposés dans `MS-DOCUMENT` ; le responsable du service est notifié pour visa, et la Direction Générale reçoit le rapport mensuel consolidé. Toute mutation du service (fait projeté, état importé, indicateur recalculé, seuil franchi, rapport publié, exportation) passe par la table d'outbox et est publiée sous les sujets `reporting.statement-imported.v1`, `reporting.threshold-crossed.v1`, `reporting.report-published.v1` et `reporting.export-requested.v1`, tous consommés par `MS-AUDIT`.

6.1.13.2 Diagramme de composants internes de MS-REPORTING

La Figure 6.37 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les événements du bus, les dépôts d'états déclarés, les consultations des cockpits, les réveils planifiés des rapports et les demandes d'exportation ; le cœur porte le magasin, les indicateurs et les rapports ; les adaptateurs pilotés dialoguent avec le magasin décisionnel, le contrôle de masquage, `MS-DOCUMENT`, le coffre de clés, `MS-PARTICIPANT` et le bus d'événements.

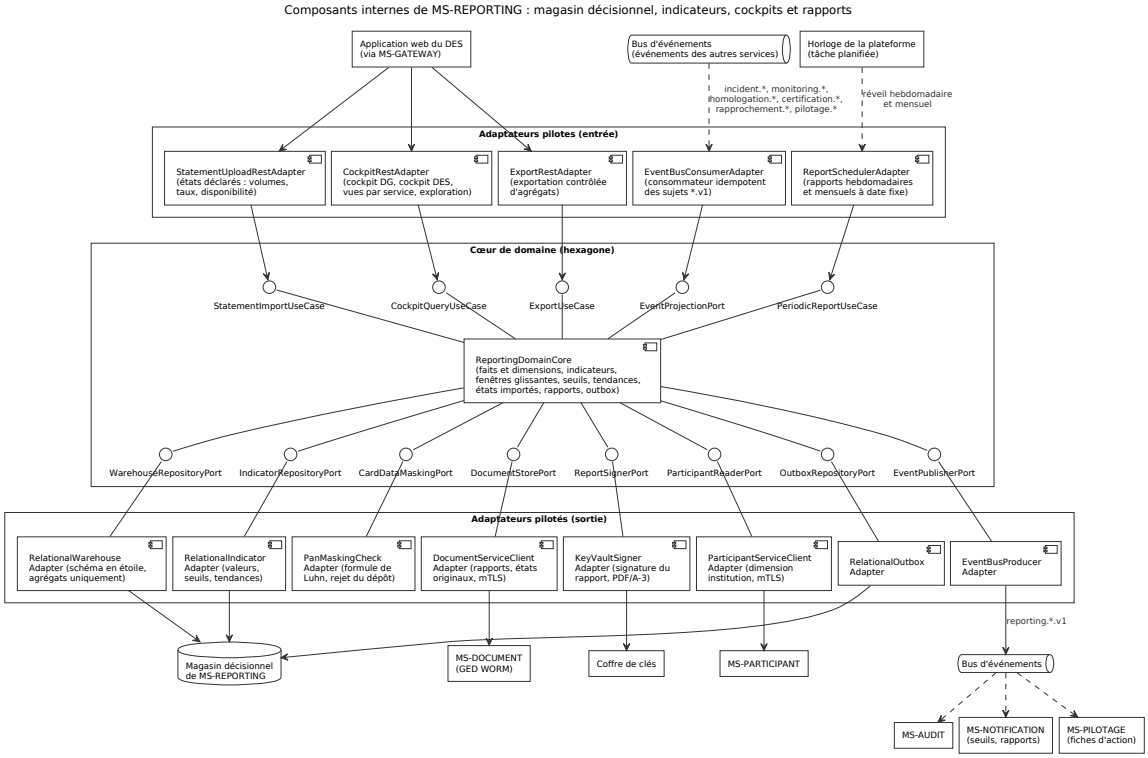


FIGURE 6.37: *Diagramme de composants internes : magasin décisionnel, indicateurs, cockpits et rapports*

- **Adaptateurs pilotes (entrée) :** `EventBusConsumerAdapter` (consommateur idempotent des sujets `incident.*`, `monitoring.*`, `homologation.*`, `certification.*`, `rapprochement.*`, `pilotage.*`) ;

`StatementUploadRestAdapter` (états déclarés : volumes, taux, disponibilité) ; `CockpitRestAdapter` (cockpit de la Direction Générale, cockpit du DES, vues par service, exploration, historique) ; `ReportSchedulerAdapter` (rapports hebdomadaires et mensuels à date fixe) ; `ExportRestAdapter` (exportation contrôlée d'agrégats).

- **Cœur de domaine :** `ReportingDomainCore` expose `EventProjectionPort`, `StatementImportUseCase`, `CockpitQueryUseCase`, `PeriodicReportUseCase` et `ExportUseCase`, et requiert huit ports secondaires.
- **Adaptateurs pilotés (sortie) :** `RelationalWarehouseAdapter` (schéma en étoile, agrégats uniquement) et `RelationalIndicatorAdapter` (valeurs, seuils, tendances) sur le magasin décisionnel ; `PanMaskingCheckAdapter` (formule de Luhn, rejet du dépôt) ; `DocumentServiceClientAdapter` (rapports, exports, états originaux, mTLS) ; `KeyVaultSignerAdapter` (signature PAdES du rapport) ; `ParticipantServiceClientAdapter` (dimension institution, mTLS) ; `RelationalOutboxAdapter` ; `EventBusProducerAdapter`.
- **Interactions :** consommation des événements de six services ; appels synchrones vers `MS-DOCUMENT`, le coffre de clés et `MS-PARTICIPANT` ; `MS-AUDIT`, `MS-NOTIFICATION` et `MS-PILOTAGE` en consommateurs des événements `reporting.*.v1`.

6.1.13.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.38 détaille les classes du domaine, les ports et les adaptateurs. Les trois entités du domaine 5 portées par ce service (`Indicateur`, `État importé`, `Rapport périodique`) y sont reprises avec leurs types et leurs signatures ; `Tâche`, `Projet` et `Risque` apparaissent en «`référence`», car ils sont portés par `MS-PILOTAGE` et seulement comptés ici.

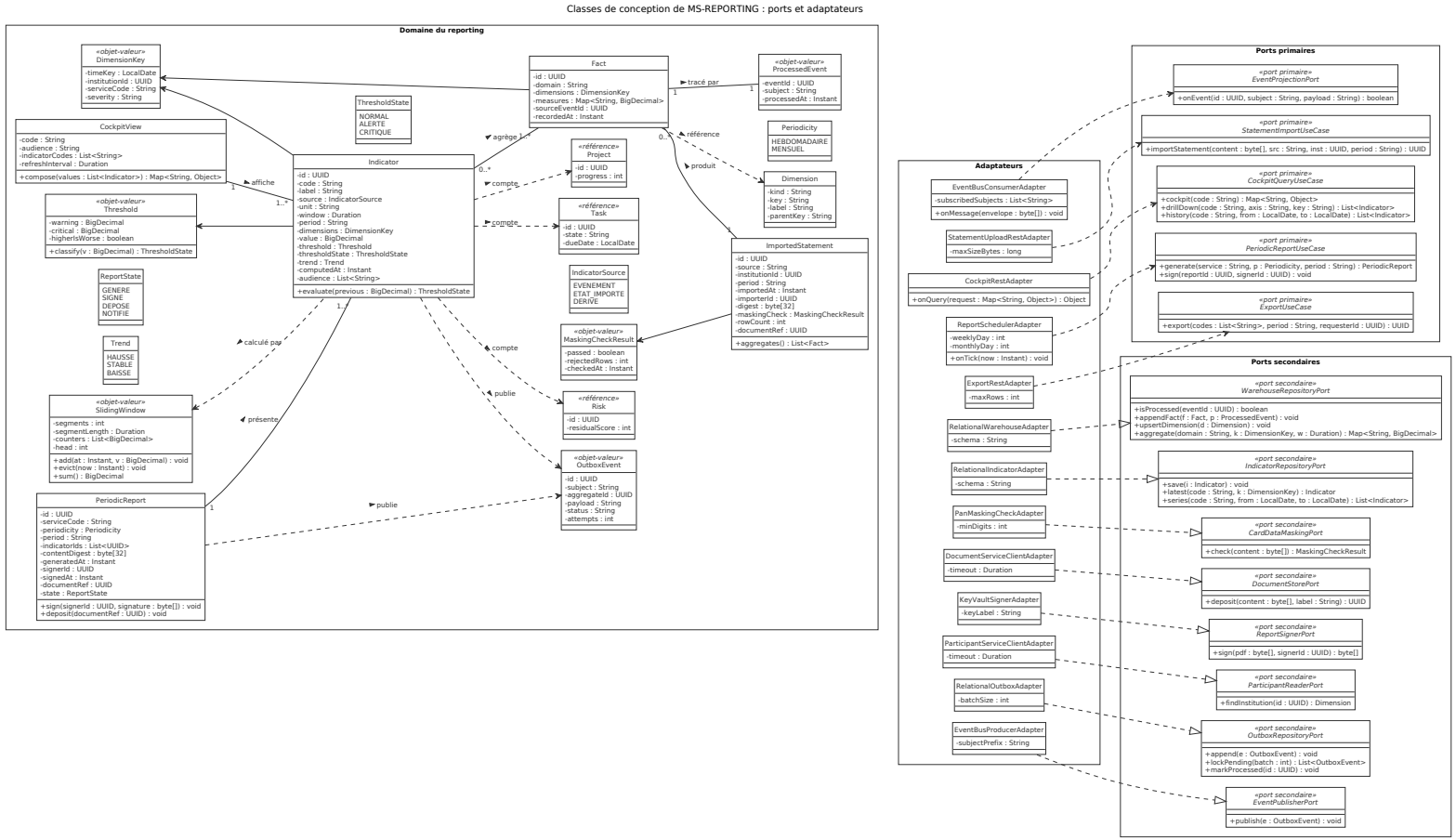


FIGURE 6.38: *Diagramme de classes de conception : service MS-REPORTING*

- **Entités :** `Indicator` (`code`, `label : String`, `source : IndicatorSource`, `unit`, `window : Duration`, `period : String`, `dimensions : DimensionKey`, `value : BigDecimal`, `threshold : Threshold`, `thresholdState : ThresholdState`, `trend : Trend`, `computedAt : Instant`, `audience : List<String>`) ; `ImportedStatement` (`source`, `institutionId`, `period`, `importedAt`, `importerId`, `digest : byte[32]`, `maskingCheck`, `rowCount`, `documentRef`) ; `PeriodicReport` (`serviceCode`, `periodicity : Periodicity`, `period`, `indicatorIds : List<UUID>`, `contentDigest : byte[32]`, `generatedAt`, `signerId`, `signedAt`, `documentRef`, `state : ReportState`) ; `Fact` (`domain`, `dimensions`, `measures : Map<String, BigDecimal>`, `sourceEventId`, `recordedAt`) ; `Dimension` (`kind`, `key`, `label`, `parentKey`) ; `CockpitView` (`code`, `audience`, `indicatorCodes`, `refreshInterval`) ; `Task`, `Project`, `Risk` en « référence ».
- **Objets-valeurs :** `DimensionKey` (`timeKey : LocalDate`, `institutionId : UUID`, `serviceCode`, `severity`) ; `Threshold` (`warning`, `critical : BigDecimal`, `higherIsWorse : boolean`, `classify`) ; `SlidingWindow` (`segments : int`, `segmentLength : Duration`, `counters`, `head`, méthodes `add`, `evict`, `sum`) ; `ProcessedEvent` (`eventId`, `subject`, `processedAt`) ; `MaskingCheckResult` ; `OutboxEvent`.
- **Énumérations :** `IndicatorSource`, `ThresholdState`, `Trend`, `Periodicity`, `ReportState`.
- **Ports primaires :** `EventProjectionPort` (`onEvent`) ; `StatementImportUseCase` (`importStatement`) ; `CockpitQueryUseCase` (`cockpit`, `drillDown`, `history`) ; `PeriodicReportUseCase` (`generate`, `sign`) ; `ExportUseCase` (`export`).
- **Ports secondaires :** `WarehouseRepositoryPort` (`isProcessed`, `appendFact`, `upsertDimension`, `aggregate`), `IndicatorRepositoryPort` (`save`, `latest`, `series`), `CardDataMaskingPort`, `DocumentStorePort`, `ReportSignerPort`, `ParticipantReaderPort`, `OutboxRepositoryPort`, `EventPublisherPort`.
- **Adaptateurs :** les ports primaires sont pilotés par `EventBusConsumerAdapter`, `StatementUploadRestAdapter`, `CockpitRestAdapter`, `ReportSchedulerAdapter` et `ExportRestAdapter` ; `RelationalWarehouseAdapter`, `RelationalIndicatorAdapter`, `PanMaskingCheckAdapter`, `DocumentServiceClientAdapter`,

`KeyVaultSignerAdapter`, `ParticipantServiceClientAdapter`, `RelationalOutboxAdapter` et `EventBusProducerAdapter` réalisent les ports secondaires.

6.1.13.4 Diagramme d'objets du service MS-REPORTING

La Figure 6.39 capture le premier lundi du mois : le rapport mensuel du pôle exploitation a été engendré à 06h00, signé et déposé, et attend sa notification ; dans la matinée, une escalade d'incident S2 concernant la Banque B vient d'être projetée en fait, ce qui a fait passer le délai moyen de résolution S2 en état d'alerte et déclenché un événement de seuil ; la disponibilité déclarée du réseau pour le mois écoulé provient d'un état importé trois jours plus tôt.

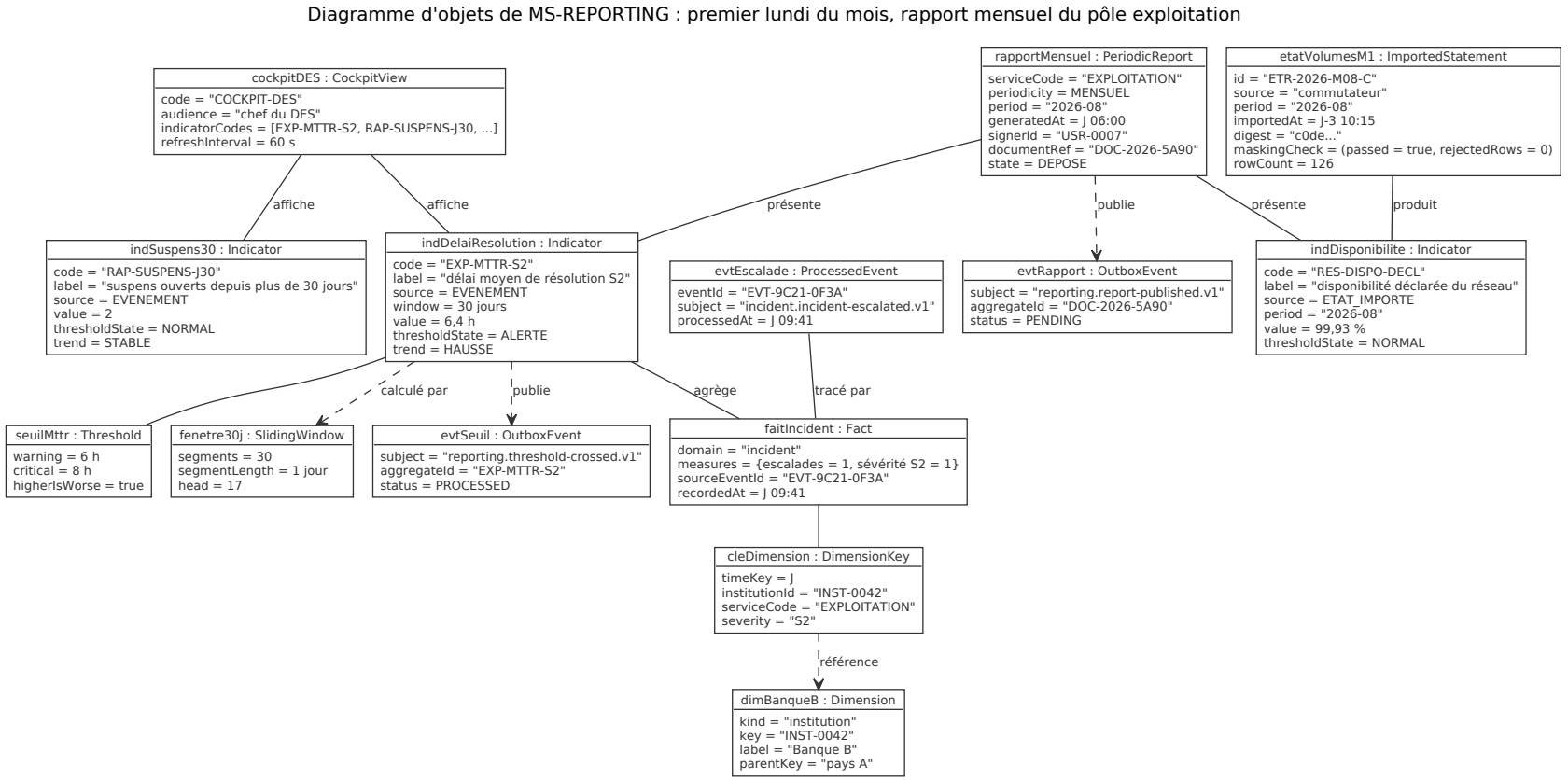


FIGURE 6.39: *Diagramme d'objets : rapport mensuel du pôle exploitation et franchissement de seuil*

- `evtEscalade : ProcessedEvent`, identifiant `EVT-9C21-0F3A`, sujet `incident.incident-escalated.v1`, traité à 09h41 ; `faitIncident : Fact`, domaine incident, mesures (une escalade, sévérité S2), tracé par cet événement ;
- `cleDimension : DimensionKey`, journée J, institution `INST-0042`, service exploitation, sévérité S2, référençant `dimBanqueB : Dimension` (institution, libellé Banque B, rattachée au pays A) ;
- `indDelaiResolution : Indicator`, code `EXP-MTTR-S2`, source `EVENEMENT`, fenêtre de 30 jours, valeur 6,4 heures, état `ALERTE`, tendance `HAUSSE`, calculé par `fenetre30j : SlidingWindow` (30 segments d'un jour) contre `seuilMttr : Threshold` (alerte à 6 heures, critique à 8 heures) ;
- `indSuspens30 : Indicator`, code `RAP-SUSPENS-J30`, valeur 2, état `NORMAL`, tendance `STABLE` ;
- `etatVolumesM1 : ImportedStatement`, source commutateur, période du mois écoulé, importé à J-3, empreinte `c0de...`, contrôle de masquage réussi, 126 lignes agrégées, produisant `indDisponibilite : Indicator` (code `RES-DISPO-DECL`, source `ETAT_IMPORTE`, 99,93 %, état `NORMAL`) ;
- `cockpitDES : CockpitView`, audience chef du DES, rafraîchissement de 60 secondes, affichant les deux indicateurs événementiels ;
- `rapportMensuel : PeriodicReport`, pôle exploitation, périodicité mensuelle, engendré à 06h00, signé par `USR-0007`, pièce `DOC-2026-5A90`, état `DEPOSE` ;
- `evtSeuil : OutboxEvent`, sujet `reporting.threshold-crossed.v1`, publié ; `evtRapport : OutboxEvent`, sujet `reporting.report-published.v1`, en attente de publication.

6.1.13.5 Algorithmes fondamentaux de MS-REPORTING

Cette section formalise les quatre algorithmes qui régissent la projection idempotente des événements dans le magasin, l'import et l'intégration d'un état déclaré, le calcul incrémental des indicateurs à fenêtre glissante avec détection de seuil et de tendance, et la génération, la signature et le dépôt du rapport périodique.

Algorithme 6.56 : Projection idempotente des événements dans le magasin décisionnel
Cet algorithme transforme chaque événement reçu du bus en un fait du magasin, exactement une

fois, quel que soit le nombre de livraisons. Il est le seul chemin d'alimentation événementielle du magasin et ne conserve des charges utiles que les mesures et les clés de dimension.

Spécification formelle de l'algorithme 6.56 : projection idempotente	
Entrées	Enveloppe CloudEvents e (identifiant e.id, sujet, instant e.time, charge utile) ; table des règles de projection $\mathscr{R}$.
Sorties	`Fact` et `ProcessedEvent` persistés en une transaction, ou acquittement silencieux d'un doublon ; fenêtres mises à jour.
Complexité	$\mathscr{O}(1)$ par événement (une lecture indexée, une insertion, mise à jour de fenêtres en temps constant).
Garantie	Traitement exactement une fois par contrainte d'unicité sur e.id ; ordre d'arrivée indifférent (faits datés par e.time).

TABLE 6.62: *Fiche de spécification : projection idempotente des événements*

Déroulement procédural étape par étape :

1. **Filtrage par sujet :** rechercher dans $\mathscr{R}$ la règle associée au sujet de e ; en l'absence de règle (sujet non mesuré), acquitter sans traitement. Une règle précise le domaine de faits cible, les mesures à extraire (compteur unitaire, durée entre deux instants portés par la charge utile, montant agrégé) et les champs qui alimentent les dimensions.

2. **Contrôle d'idempotence :** interroger le port `WarehouseRepositoryPort` (méthode `isProcessed`) avec e.id ; si l'événement est connu, acquitter immédiatement. Ce contrôle préalable évite une transaction inutile ; il est doublé, à l'étape 5, par la contrainte d'unicité de la table des événements traités, qui reste la garantie de référence.

3. **Résolution des dimensions :** construire `DimensionKey` : `timeKey` $=$ date(e.time) (jamais la date de réception), `institutionId` lu dans la charge utile, `serviceCode` déduit de la règle et de la charge utile, `severity` le cas échéant. Si l'institution est inconnue de la dimension, lire son libellé et son pays par `ParticipantReaderPort` (réponse mise en cache) et appeler `upsertDimension`.

4. **Extraction des mesures :** appliquer la règle pour produire le vecteur de mesures m ; par exemple, pour `incident.incident-resolved.v1`,

$$m = \{\ \text{resolus} = 1,\ \ \text{dureeResolution} = t_{\text{resolu}} - t_{\text{ouvert}} - \textstyle\sum \text{gels}\ \} \tag{6.69}$$

   les gels d'engagement en attente de tiers étant déduits. Aucun texte libre ni identifiant de carte n'est extrait ; les rares champs textuels retenus (codes) sont soumis au contrôle de masquage.

5. **Transaction d'insertion :** ouvrir une transaction ; insérer `Fact`(domaine, k, m, e.id, t_{now}) et `ProcessedEvent`(e.id, sujet, t_{now}) ; si l'insertion viole la contrainte d'unicité sur e.id, annuler et acquitter (livraison redondante). Valider.

6. **Mise à jour des fenêtres :** pour chaque indicateur événementiel dont la règle déclare que e contribue, appeler `SlidingWindow.add`(e.time, m) selon l'algorithme 6.58 ; un événement dont la date est antérieure à la fenêtre courante ne modifie que les agrégats historiques.

7. **Acquittement :** acquitter le message auprès du bus après validation de la transaction, jamais avant ; en cas de panne entre les deux, la relivraison est absorbée par l'étape 2.

Algorithme 6.57 : Import et intégration d'un état déclaré Cet algorithme intègre au magasin un état déclaré par fichier (volumes, taux d'acceptation, disponibilité déclarée, par période et par participant), avec les mêmes contrôles de recevabilité, de masquage, d'empreinte et d'idempotence que l'import d'un état de rapprochement (algorithme 6.48), puis en dérive les faits déclarés et recalcule les indicateurs de la période.

Spécification formelle de l'algorithme 6.57 : import d'un état déclaré	
Entrées	Fichier F ; source s (commutateur, participant) ; institution i ; période P ; déposant u.
Sorties	`ImportedStatement` et faits déclarés persistés ; indicateurs `ETAT_IMPORTE` de P recalculés ; `reporting.statement-imported.v1`.
Complexité	$\mathcal{O}(L)$ en temps, L étant le nombre de lignes agrégées (quelques centaines par état).
Contrôles	Format RFC 4180 ou RFC 8259 ; masquage (formule de Luhn) ; SHA-256 ; plausibilité des valeurs ; versionnage sans écrasement.

TABLE 6.63: *Fiche de spécification : import et intégration d'un état déclaré*

Déroulement procédural étape par étape :

1. **Recevabilité et habilitation :** vérifier la taille, le format et le contrat de dépôt de la source (colonnes : période, code institution, code de mesure, valeur, unité) ; un représentant d'un participant ne peut déposer qu'un état de source participant pour sa propre institution ; l'état du commutateur est déposé par un opérateur ou un responsable du DES.

2. **Masquage, empreinte et idempotence :** appliquer `CardDataMaskingPort.check`(F) et rejeter tout fichier contenant une suite de chiffres vérifiant la formule de Luhn (algorithme 6.3) ; calculer $h = \text{SHA256}(F)$; si un état porte déjà h, retourner cet état sans nouvel enregistrement.

3. **Dépôt de l'original :** déposer F dans `MS-DOCUMENT` et mémoriser `documentRef` ; l'original scellé demeure la preuve de ce qui a été déclaré.

4. **Validation sémantique :** pour chaque ligne, vérifier que la période est incluse dans P, que le code institution existe dans la dimension institution, que le code de mesure appartient au référentiel (`volume`, `tauxAcceptation`, `disponibilite`, `nombreOperations`) et que la valeur est plausible : un taux $\in [0,100]$, un volume ≥ 0, une disponibilité $\in [0,100]$. Une ligne invalide rejette l'état entier avec la liste des lignes en cause ; aucune intégration partielle.

5. **Versionnage sans écrasement :** si un état antérieur existe pour (s,i,P), ses faits sont marqués « remplacés » (référence vers le nouvel état) et non supprimés, de sorte que toute valeur publiée antérieurement reste reconstituable ; le nouvel état devient la version courante.

6. **Projection en faits :** pour chaque ligne, insérer `Fact`(`etat_declare`, $k, m,$ id de l′tat) avec k construit sur la période, l'institution et le service concerné, et m la mesure déclarée, dans une transaction unique avec l'en-tête `ImportedStatement`.

7. **Recalcul et publication :** recalculer les indicateurs de source `ETAT_IMPORTE` ou `DERIVE` de la période P (par exemple la disponibilité déclarée du réseau, moyenne des disponibilités déclarées pondérée par les volumes) et appliquer la détection de seuil de l'algorithme 6.58 ; insérer `reporting.statement-imported.v1` (source, institution, période, empreinte, nombre de lignes) dans l'outbox.

Algorithme 6.58 : Calcul incrémental des indicateurs à fenêtre glissante, seuil et tendance
Cet algorithme tient à jour, en flux, la valeur de chaque indicateur événementiel par un tampon circulaire à mémoire constante, la compare à ses seuils, en déduit la tendance et publie tout changement d'état. La technique du tampon circulaire, héritée de la première conception, est conservée ; elle s'applique désormais aux mesures d'activité de la plateforme et non à un flux de transactions que celle-ci ne reçoit pas.

Spécification formelle de l'algorithme 6.58 : fenêtre glissante, seuil et tendance	
Entrées	Indicateur I (règle de calcul f, fenêtre W, pas S, seuil θ) ; mesures datées (t,m) ; instant courant t_{now}.
Sorties	Valeur v, état de seuil, tendance ; `reporting.threshold-crossed.v1` à tout changement d'état.
Structure	Tampon circulaire de $K = W/S$ segments (par exemple $K = 30$ segments d'un jour, ou $K = 24$ segments d'une heure).
Complexité	Ajout et éviction en $\mathcal{O}(1)$; recalcul en $\mathcal{O}(K)$; mémoire $\mathcal{O}(K \cdot D)$ pour D clés de dimension suivies.

TABLE 6.64: *Fiche de spécification : fenêtre glissante, seuil et tendance*

Déroulement procédural étape par étape :

1. **Initialisation :** pour chaque couple (indicateur, clé de dimension), allouer K segments portant les compteurs requis par f (par exemple $N_{\text{resolus}}[k]$ et $\Sigma_{\text{duree}}[k]$ pour un délai moyen, $N_{\text{dansDelai}}[k]$ et $N_{\text{total}}[k]$ pour un taux) ; le segment de tête est celui de t_{now}.

2. **Ajout d'une mesure :** à la réception de (t,m) issue de l'algorithme 6.56, si $t \geq t_{\text{now}} - W$, calculer l'indice
$$idx = \left\lfloor \frac{t \bmod W}{S} \right\rfloor \in [0, K-1] \tag{6.70}$$
et incrémenter les compteurs du segment idx ; sinon, ne mettre à jour que les agrégats historiques du magasin (la fenêtre courante n'est pas affectée).

3. **Éviction :** lorsque t_{now} franchit un pas S, avancer la tête et remettre à zéro le segment le plus ancien, qui a préalablement été persisté dans les agrégats historiques.

4. **Recalcul :** agréger les K segments et appliquer f ; par exemple, pour le délai moyen de résolution et pour le taux de respect des engagements,
$$v_{\text{MTTR}} = \frac{\sum_k \Sigma_{\text{duree}}[k]}{\sum_k N_{\text{resolus}}[k]}, \qquad v_{\text{SLA}} = 100 \times \frac{\sum_k N_{\text{dansDelai}}[k]}{\sum_k N_{\text{total}}[k]} \tag{6.71}$$
un dénominateur nul laissant la valeur précédente avec le marqueur « sans donnée ».

5. **Classification par seuil :** évaluer $\theta.\text{classify}(v)$: `CRITIQUE` si v dépasse le seuil critique dans le sens défavorable, `ALERTE` si elle dépasse le seuil d'alerte, `NORMAL` sinon ; une hystérésis de 5 % du seuil évite les oscillations autour de la limite.

6. **Tendance :** comparer v à la valeur v_{prev} de la fenêtre précédente de même longueur :

$$\text{tendance} = \begin{cases} \texttt{HAUSSE} & \text{si } v > v_{\text{prev}}\,(1+\varepsilon) \\ \texttt{BAISSE} & \text{si } v < v_{\text{prev}}\,(1-\varepsilon) \\ \texttt{STABLE} & \text{sinon} \end{cases} \qquad \varepsilon = 0{,}05 \tag{6.72}$$

7. **Persistance et publication :** sauvegarder `Indicator` (valeur, état, tendance, `computedAt`) par `IndicatorRepositoryPort` ; si l'état de seuil a changé, insérer `reporting.threshold-crossed.v1` (code, dimension, ancien et nouvel état, valeur, seuil) dans l'outbox, consommé par `MS-NOTIFICATION`, par `MS-PILOTAGE` et par `MS-AUDIT`, et pousser la nouvelle valeur aux cockpits ouverts par le canal poussé.

Algorithme 6.59 : Génération, signature et dépôt du rapport périodique Cet algorithme engendre, à date fixe, le rapport hebdomadaire ou mensuel d'un service à partir d'indicateurs figés, le rend en PDF/A-3, le signe, le dépose dans `MS-DOCUMENT` et en notifie les destinataires ; il rend chaque rapport reproductible et opposable.

Spécification formelle de l'algorithme 6.59 : rapport périodique	
Entrées	Service sv ; périodicité (hebdomadaire, mensuelle) ; période P ; gabarit du rapport ; clé de signature du service dans le coffre.
Sorties	`PeriodicReport` à l'état `NOTIFIE` ; document signé déposé en WORM ; `reporting.report-published.v1`.
Complexité	$\mathcal{O}(n_I \cdot K)$ pour figer n_I indicateurs ; rendu et signature bornés par la taille du document.
Standard	ISO 19005-3 (PDF/A-3) ; ETSI EN 319 142 (PAdES) ; SHA-256 ; RFC 9162 par `MS-AUDIT`.

TABLE 6.65: *Fiche de spécification : génération, signature et dépôt du rapport périodique*

Déroulement procédural étape par étape :

1. **Déclenchement et idempotence :** `ReportSchedulerAdapter` réveille `generate`$(sv, \text{periodicite}, P)$ le lundi à 06h00 (semaine ISO écoulée) ou le premier jour ouvré du mois (mois écoulé) ; si un rapport existe déjà pour $(sv, \text{periodicite}, P)$, ne rien engendrer. Une génération manuelle par un responsable produit une version supplémentaire, jamais un remplacement.

2. **Figement des indicateurs :** sélectionner les indicateurs de l'audience du service pour P, lire leur valeur, leur état et leur tendance à la clôture de P (séries de

`IndicatorRepositoryPort`) et les copier dans le rapport ; les indicateurs déclarés sont accompagnés de l'empreinte et de la date d'import de l'état dont ils proviennent, et un indicateur sans donnée est présenté comme tel.

3. **Rendu :** composer le document selon le gabarit (synthèse, indicateurs par rubrique, comparaison avec la période précédente, franchissements de seuil de la période, suspens et incidents majeurs en nombre) au format PDF/A-3, y joindre en pièce interne le jeu d'indicateurs figés dans un format structuré (RFC 8259) et calculer `contentDigest` $=$ SHA256(document).

4. **Signature :** obtenir par `ReportSignerPort.sign` une signature PAdES apposée avec la clé de signature non exportable du service, détenue dans le coffre de clés ; l'identité du signataire désigné (responsable du service) et l'instant sont portés par la signature ; passer à `SIGNE`.

5. **Dépôt :** déposer le document signé dans `MS-DOCUMENT`, qui vérifie l'empreinte, l'analyse, le versionne et le conserve en WORM ; mémoriser `documentRef` ; passer à `DEPOSE`.

6. **Publication et notification :** insérer `reporting.report-published.v1` (service, périodicité, période, empreinte, référence de document) dans l'outbox ; `MS-AUDIT` l'inscrit dans l'arbre de Merkle, ce qui horodate de façon probante la publication ; `MS-NOTIFICATION` avise le responsable du service pour visa et, pour le rapport mensuel consolidé, la Direction Générale ; passer à `NOTIFIE`. Le visa du responsable est enregistré comme événement distinct et n'altère pas le document signé.

6.1.14 Collaboration chiffrée : salons, terminaux vérifiés, conférences locales et archives de crise (MS-COLLABORATION)

Le service `MS-COLLABORATION` porte, pour le domaine 6, les échanges internes du Département Exploitation et Supervision (DES) : salons de discussion chiffrés de bout en bout, rattachés à une vacation, à un thème, à un ticket ou à une cellule de crise ; vérification des terminaux des collaborateurs, qui conditionne la distribution des clés de session ; conférences audio et vidéo tenues sur un serveur de conférence (SFU) hébergé sur site, avec sur-chiffrement des trames médias ; salons de crise ouverts à la demande de `MS-INCIDENT` et archives de crise scellées en GED. Il s'appuie sur un serveur de messagerie fédérée, bâti sur un protocole fédéré ouvert, installé dans l'enclave et fermé à toute fédération extérieure aux deux sites de la plateforme : ce serveur ne détient que des messages chiffrés et des clés publiques, et ne peut lire aucun contenu. Le service ne porte pas la logique de crise (qualification, quorum, escalade, main courante), qui appartient à `MS-INCIDENT`, ni la remise multicanale des alertes, qui appartient

à `MS-NOTIFICATION` ; il n'utilise aucun relais externe, n'échange aucune donnée avec le commutateur et n'est pas un canal de transmission de données de carte.

6.1.14.1 Responsabilités métier, cadrage réglementaire et principes directeurs

Cadrage réglementaire : confidentialité des échanges, continuité et preuve

- **Règlement COBAC R-2024/01 :** la sécurité du système d'information et la continuité d'activité exigent des canaux de coordination sûrs, maîtrisés par l'établissement et disponibles en situation dégradée. Les salons et les conférences sont hébergés sur site, répliqués sur le site de secours, sans dépendance envers un service de communication extérieur.
- **Règlement COBAC R-2016/04 :** les décisions prises en situation de crise doivent pouvoir être reconstituées ; l'archive de crise, compilée, horodatée et conservée en WORM, en est la trace opposable.
- **PCI-DSS v4.0.1, exigence 12.10 :** le plan de réponse aux incidents suppose des procédures de communication et de coordination définies ; le salon de crise, ouvert automatiquement avec son quorum, en est le support. Aucun échange ne doit contenir de numéro de carte en clair : le terminal applique le contrôle de masquage avant chiffrement, et l'archive y est de nouveau soumise avant dépôt.
- **ISO/IEC 27001, annexe A :** transfert de l'information (mesure 5.14), préparation et réponse aux incidents (mesures 5.24 et 5.26), sécurité pendant une perturbation (mesure 5.29), usage de la cryptographie (mesure 8.24).
- **Standards cryptographiques :** X25519 (RFC 7748), Ed25519 (RFC 8032), HKDF (RFC 5869), architecture de sécurité WebRTC (RFC 8827), SFrame (RFC 9605), horodatage (RFC 3161), certificats (RFC 5280).

Salons, rattachements et rétention Un salon a un type, un rattachement et une politique de chiffrement de bout en bout obligatoire. Les membres sont tirés des rattachements eux-mêmes et non d'une liste libre : les membres d'un salon de quart sont les collaborateurs de la vacation publiée par `MS-MONITORING`, ceux d'un salon d'incident les intervenants du ticket, ceux d'un salon de crise le quorum transmis par `MS-INCIDENT`. Toute révocation de session ou désactivation d'un collaborateur (`iam.session-revoked.v1`, `iam.user-changed.v1`) retire ses terminaux des salons et déclenche la rotation des clés de groupe.

Type	Rattachement	Membres	Rétention
Quart	vacation (`MS-MONITORING`)	équipe de la vacation, chef de quart	180 jours
Thème	pôle ou sujet permanent	membres désignés par un responsable	1 an
Incident	ticket (`MS-INCIDENT`)	intervenants du ticket	1 an après clôture
Crise	cellule de crise (`MS-INCIDENT`)	quorum, terminal d'archivage	90 jours après scellement ; archive 10 ans

TABLE 6.66: *Types de salons de MS-COLLABORATION*

Chiffrement de bout en bout : double cliquet et clé de session de groupe Chaque terminal (navigateur de l'application web du DES, identifié et enrôlé) engendre localement une clé d'identité Ed25519, une clé d'accord X25519, une pré-clé signée et un lot de pré-clés à usage unique ; seules les parties publiques sont déposées dans le service, les parties privées ne quittent jamais le terminal. Deux terminaux établissent une session à double cliquet (algorithme 6.60) : un accord initial de type Diffie-Hellman sur pré-clés, puis un cliquet Diffie-Hellman à chaque changement de locuteur et un cliquet symétrique à chaque message, qui assurent la confidentialité persistante et le rétablissement après compromission. Ces sessions deux à deux servent à transporter la clé de session de groupe de chaque émetteur d'un salon : une chaîne de clés à cliquet de hachage, renouvelée à toute sortie d'un membre, après 100 messages ou après 7 jours. Un membre entrant ne reçoit que l'état courant de la chaîne et ne peut donc pas lire l'historique antérieur à son admission.

Vérification des terminaux et distribution des clés Un terminal n'est `VERIFIE` que si sa clé d'identité est signée par la clé maîtresse de son utilisateur (signature croisée) et si cette clé maîtresse a elle-même été confirmée, lors de l'enrôlement, par comparaison d'un code court entre un terminal déjà vérifié et le nouveau, sous authentification forte de l'utilisateur. La règle est double : le module cryptographique du terminal émetteur ne partage une clé de session qu'avec des terminaux vérifiés, et le service refuse de relayer un message de partage de clé destiné à un terminal non vérifié ou révoqué. Un terminal nouvellement ajouté reste donc muet et aveugle jusqu'à sa vérification ; le salon en affiche l'état à tous les membres. La révocation d'un terminal (perte, départ, session révoquée) est publiée et provoque la rotation des clés de groupe de tous les salons où il figurait.

Conférences locales et sur-chiffrement des trames Les conférences audio et vidéo passent par le serveur de conférence (SFU) et par un relais de traversée (RFC 8656), tous deux hébergés sur site, dans la zone média de l'enclave ; aucun relais externe n'est utilisé et aucun flux ne quitte les deux sites. La protection de saut en saut de WebRTC (RFC 8827) est complétée par un sur-chiffrement de bout en bout des trames encodées selon SFrame (RFC 9605) : le serveur de conférence ne voit que les en-têtes nécessaires à l'acheminement sélectif et ne peut déchiffrer ni l'audio, ni la vidéo, ni le partage d'écran. Les clés médias sont renouvelées à chaque entrée ou sortie d'un participant (algorithme 6.61). L'accès à une salle exige un jeton de salle à courte durée, délivré au seul membre du salon dont le terminal est vérifié. L'enregistrement n'est possible qu'avec le consentement de chaque participant présent : un nouvel entrant qui refuse suspend l'enregistrement, et chaque segment enregistré porte la liste des consentements qui l'autorisent.

Salons de crise et archives de crise À l'ouverture d'une cellule de crise, `MS-INCIDENT` demande l'ouverture d'un salon de crise (algorithme 6.62) par le port synchrone du service, sous mTLS, car il lui faut l'identifiant du salon pour l'inscrire au ticket et à la main courante ; l'événement de cellule ouverte, consommé de manière idempotente, sert de chemin de reprise. Le salon de crise admet, outre le quorum, un membre technique déclaré, le terminal d'archivage du service, dont les clés privées sont détenues dans le coffre de clés : il reçoit les clés de session comme tout membre, sa présence est affichée et annoncée dans le salon, et il n'est admis que dans les salons de crise. À la clôture de la cellule, il permet de constituer l'archive de crise (algorithme 6.63) : messages et chronologie de la conférence, empreinte, jeton d'horodatage RFC 3161, dépôt dans `MS-DOCUMENT` en WORM pour dix ans, référence inscrite dans le registre de `MS-AUDIT`. La qualification, le quorum et l'escalade de crise restent décrits dans la conception de `MS-INCIDENT` (sous-section 6.1.9, algorithme 6.42).

Accusés de réception et cohérence événementielle Les accusés de réception (remis, lu) sont des métadonnées visibles du serveur, enregistrées par message et par membre ; ils permettent à l'animateur d'un salon de crise de savoir qui a pris connaissance d'une consigne, sans que le contenu soit jamais lisible par le service. Toute mutation passe par la table d'outbox et est publiée sous les sujets `collaboration.room-opened.v1`, `collaboration.crisis-room-opened.v1`, `collaboration.conference-ended.v1`, `collaboration.crisis-archive-sealed.v1`, `collaboration.terminal-verified.v1` et `collaboration.notification-requested.v1` (invitations), tous consommés par `MS-AUDIT` ; `MS-INCIDENT` consomme l'ouverture du salon de crise et le scellement de l'archive, `MS-NOTIFICATION` les demandes d'invitation. Aucune charge utile ne contient de contenu de message.

6.1.14.2 Diagramme de composants internes de MS-COLLABORATION

La Figure 6.40 présente l'organisation hexagonale du service : les adaptateurs pilotes reçoivent les commandes du module cryptographique des terminaux (via `MS-GATEWAY`), la demande synchrone de `MS-INCIDENT`, les événements du bus et le réveil de la tâche de rétention ; le cœur porte les six entités du domaine 6 ; les adaptateurs pilotés dialoguent avec la base relationnelle du service, le serveur de messagerie fédérée, le serveur de conférence, le terminal d'archivage et le coffre de clés, `MS-DOCUMENT`, l'autorité d'horodatage et le bus d'événements.

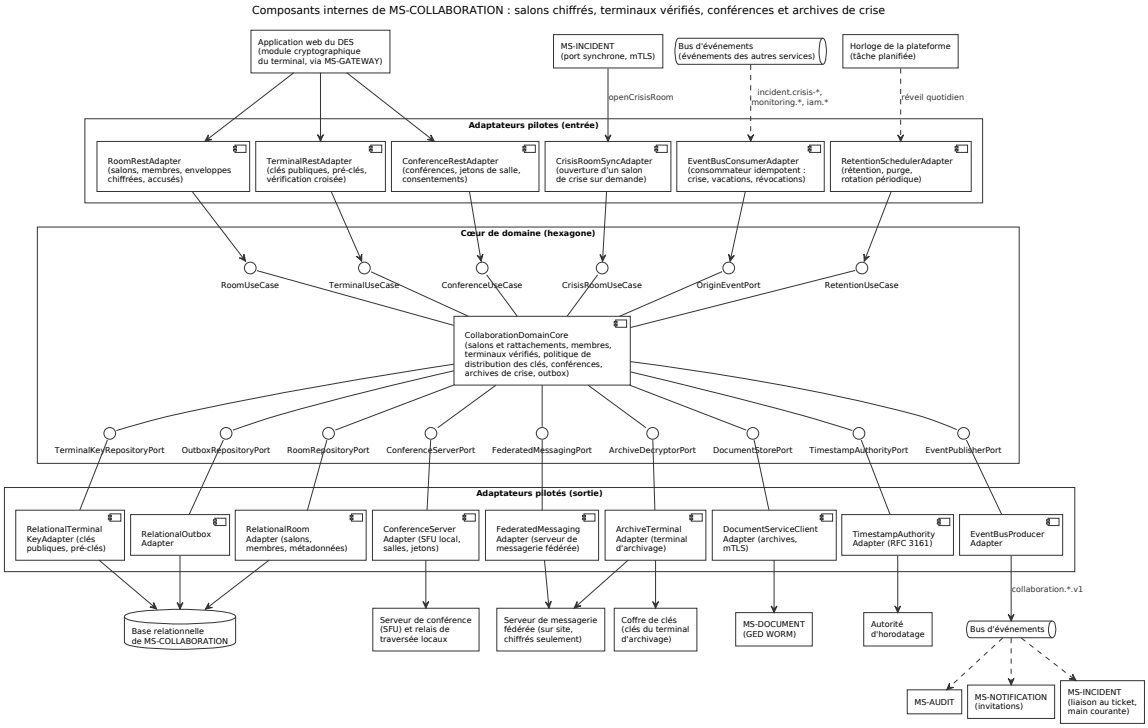


FIGURE 6.40: *Diagramme de composants internes : salons chiffrés, terminaux vérifiés, conférences et archives de crise*

- **Adaptateurs pilotes (entrée) :** `RoomRestAdapter` (salons, membres, enveloppes chiffrées, accusés) ; `TerminalRestAdapter` (dépôt des clés publiques et des pré-clés, lot de pré-clés d'un terminal, vérification croisée) ; `ConferenceRestAdapter` (conférences, jetons de salle, consentements) ; `CrisisRoomSyncAdapter` (port synchrone réservé à `MS-INCIDENT`) ; `EventBusConsumerAdapter` (sujets de cellule de crise de `MS-INCIDENT`, vacations de `MS-MONITORING`, `iam.session-revoked.v1`, `iam.user-changed.v1`) ; `RetentionSchedulerAdapter` (rétention, purge, rotation périodique des clés de groupe).
- **Cœur de domaine :** `CollaborationDomainCore` expose `RoomUseCase`, `TerminalUseCase`, `ConferenceUseCase`, `CrisisRoomUseCase`, `OriginEventPort` et `RetentionUseCase`, et requiert neuf ports secondaires.

- **Adaptateurs pilotés (sortie) :** `RelationalRoomAdapter` (salons, membres, métadonnées) et `RelationalTerminalKeyAdapter` (clés publiques, pré-clés, états de vérification) sur la base relationnelle du service ; `FederatedMessagingAdapter` (serveur de messagerie fédérée : création de salons, adhésions, export des messages chiffrés) ; `ConferenceServerAdapter` (salles du SFU, jetons, politique SFrame obligatoire) ; `ArchiveTerminalAdapter` (terminal d'archivage, clés dans le coffre de clés) ; `DocumentServiceClientAdapter` (archives, mTLS) ; `TimestampAuthorityAdapter` (RFC 3161) ; `RelationalOutboxAdapter` ; `EventBusProducerAdapter`.
- **Interactions :** un appel synchrone entrant (`MS-INCIDENT`) ; deux appels synchrones sortants (`MS-DOCUMENT`, autorité d'horodatage) ; consommation des événements de `MS-INCIDENT`, `MS-MONITORING` et `MS-IAM` ; `MS-AUDIT`, `MS-NOTIFICATION` et `MS-INCIDENT` en consommateurs des événements `collaboration.*.v1`.

6.1.14.3 Diagramme de classes de conception (ports et adaptateurs)

La Figure 6.41 détaille les classes du domaine, les ports et les adaptateurs. Les six entités du domaine 6 (`Salon`, `Membre de salon`, `Terminal vérifié`, `Message`, `Conférence`, `Archive de crise`) y sont reprises avec leurs types et leurs signatures ; la cellule de crise et la vacation apparaissent en «`référence`», car elles sont portées par `MS-INCIDENT` et `MS-MONITORING`.

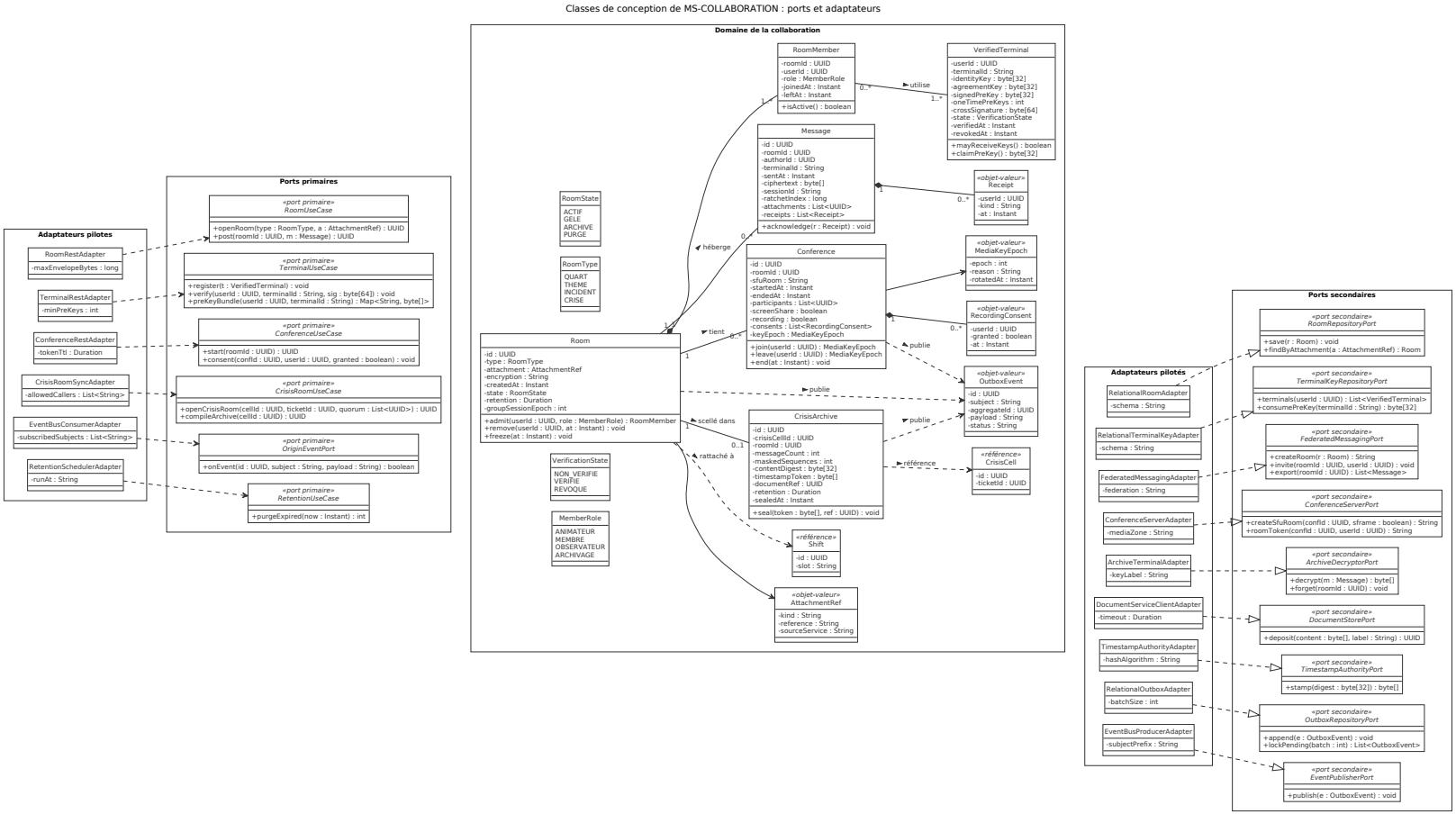


FIGURE 6.41: *Diagramme de classes de conception : service MS-COLLABORATION*

- **Entités :** `Room` (`type : RoomType`, `attachment : AttachmentRef`, `encryption : String`, `createdAt : Instant`, `state : RoomState`, `retention : Duration`, `groupSessionEpoch : int`, méthodes `admit`, `remove`, `freeze`) ; `RoomMember` (`roomId`, `userId : UUID`, `role : MemberRole`, `joinedAt`, `leftAt : Instant`) ; `VerifiedTerminal` (`terminalId`, `identityKey`, `agreementKey`, `signedPreKey : byte[32]`, `oneTimePreKeys : int`, `crossSignature : byte[64]`, `state : VerificationState`, `verifiedAt`, `revokedAt`, méthodes `mayReceiveKeys`, `claimPreKey`) ; `Message` (`authorId`, `terminalId`, `sentAt`, `ciphertext : byte[]`, `sessionId`, `ratchetIndex : long`, `attachments`, `receipts : List<Receipt>`) ; `Conference` (`sfuRoom`, `startedAt`, `endedAt`, `participants`, `screenShare`, `recording : boolean`, `consents`, `keyEpoch`, méthodes `join`, `leave`, `end`) ; `CrisisArchive` (`crisisCellId`, `messageCount`, `maskedSequences : int`, `contentDigest : byte[32]`, `timestampToken : byte[]`, `documentRef : UUID`, `retention`, `sealedAt`, méthode `seal`).
- **Objets-valeurs :** `AttachmentRef` (`kind`, `reference`, `sourceService`) ; `Receipt` (`userId`, `kind`, `at`) ; `RecordingConsent` (`userId`, `granted : boolean`, `at`) ; `MediaKeyEpoch` (`epoch : int`, `reason`, `rotatedAt`) ; `OutboxEvent`.
- **Énumérations :** `RoomType` (quart, thème, incident, crise), `RoomState` (actif, gelé, archivé, purgé), `MemberRole` (animateur, membre, observateur, archivage), `VerificationState`.
- **Ports primaires :** `RoomUseCase` (`openRoom`, `post`) ; `TerminalUseCase` (`register`, `verify`, `preKeyBundle`) ; `ConferenceUseCase` (`start`, `consent`) ; `CrisisRoomUseCase` (`openCrisisRoom`, `compileArchive`) ; `OriginEventPort` (`onEvent`) ; `RetentionUseCase` (`purgeExpired`).
- **Ports secondaires :** `RoomRepositoryPort`, `TerminalKeyRepositoryPort` (`terminals`, `consumePreKey`), `FederatedMessagingPort` (`createRoom`, `invite`, `export`), `ConferenceServerPort` (`createSfuRoom`, `roomToken`), `ArchiveDecryptorPort` (`decrypt`, `forget`), `DocumentStorePort`, `TimestampAuthorityPort`, `OutboxRepositoryPort`, `EventPublisherPort`.
- **Adaptateurs :** les ports primaires sont pilotés par `RoomRestAdapter`, `TerminalRestAdapter`, `ConferenceRestAdapter`, `CrisisRoomSyncAdapter`, `EventBusConsumerAdapter` et

`RetentionSchedulerAdapter` ; les ports secondaires sont réalisés par `RelationalRoomAdapter`, `RelationalTerminalKeyAdapter`, `FederatedMessagingAdapter`, `ConferenceServerAdapter`, `ArchiveTerminalAdapter`, `DocumentServiceClientAdapter`, `TimestampAuthorityAdapter`, `RelationalOutboxAdapter` et `EventBusProducerAdapter`.

6.1.14.4 Diagramme d'objets du service MS-COLLABORATION

La Figure 6.42 capture un salon de crise six minutes après son ouverture (T_0) à la demande de `MS-INCIDENT`, pour la cellule de crise liée au ticket `TCK-000318`. Le chef du DES anime le salon depuis un terminal vérifié ; le RSSI vient de rejoindre la conférence depuis son terminal vérifié, tandis qu'un second terminal qu'il a ajouté le matin même reste non vérifié et ne reçoit aucune clé ; son entrée a provoqué la quatrième rotation des clés médias et son consentement à l'enregistrement a été recueilli. Le terminal d'archivage est membre depuis l'ouverture.

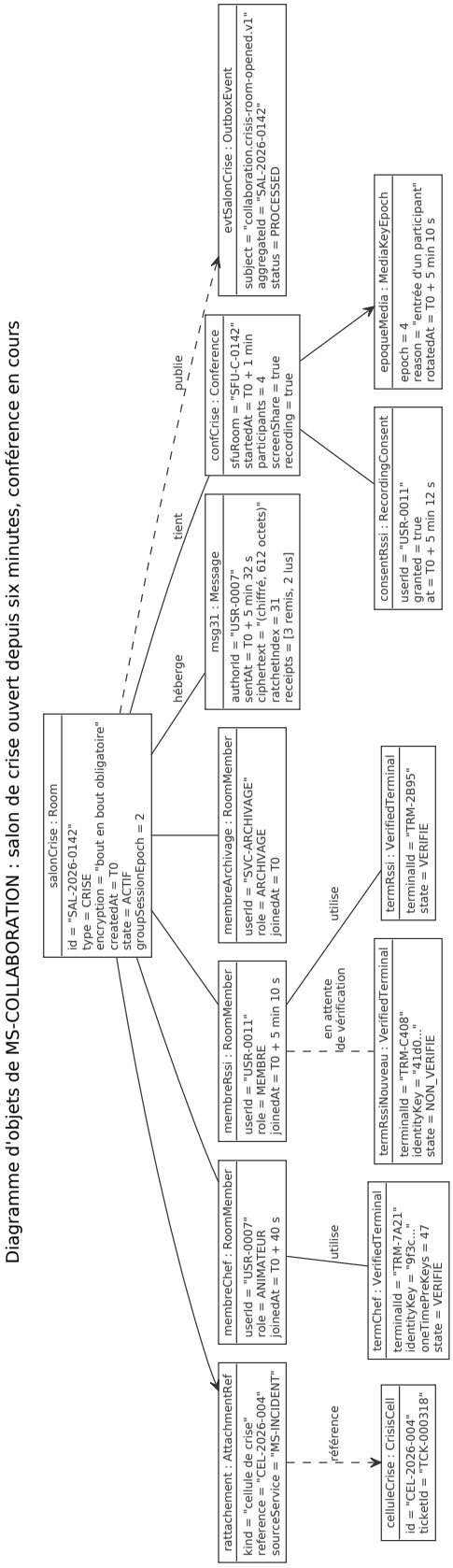


FIGURE 6.42: *Diagramme d'objets : salon de crise ouvert et conférence en cours*

- `salonCrise : Room`, `SAL-2026-0142`, type `CRISE`, chiffrement de bout en bout obligatoire, créé à T_0, état `ACTIF`, deuxième époque de session de groupe, rattaché par `rattachement : AttachmentRef` à `celluleCrise : CrisisCell` (`CEL-2026-004`, ticket `TCK-000318`, service source `MS-INCIDENT`) ;
- `membreChef : RoomMember`, `USR-0007`, animateur, entré à $T_0 + 40$ s, utilisant `termChef : VerifiedTerminal` (`TRM-7A21`, clé d'identité `9f3c...`, 47 pré-clés à usage unique disponibles, `VERIFIE`) ;
- `membreRssi : RoomMember`, `USR-0011`, entré à $T_0 + 5$ min 10 s, utilisant `termRssi : VerifiedTerminal` (`TRM-2B95`, `VERIFIE`) ; `termRssiNouveau : VerifiedTerminal` (`TRM-C408`) reste `NON_VERIFIE` et exclu de la distribution des clés ;
- `membreArchivage : RoomMember`, `SVC-ARCHIVAGE`, rôle `ARCHIVAGE`, membre dès T_0 ;
- `msg31 : Message`, émis par `USR-0007` à $T_0 + 5$ min 32 s, contenu chiffré de 612 octets, indice de cliquet 31, remis à trois membres et lu par deux ;
- `confCrise : Conference`, salle `SFU-C-0142`, ouverte à $T_0 + 1$ min, quatre participants, partage d'écran actif, enregistrement actif, avec `consentRssi : RecordingConsent` (accordé à $T_0 + 5$ min 12 s) et `epoqueMedia : MediaKeyEpoch` (époque 4, « entrée d'un participant ») ;
- `evtSalonCrise : OutboxEvent`, sujet `collaboration.crisis-room-opened.v1`, publié et consommé par `MS-INCIDENT` qui a lié le salon au ticket.

6.1.14.5 Algorithmes fondamentaux de MS-COLLABORATION

Cette section formalise les quatre algorithmes qui régissent l'établissement d'une session à double cliquet et la distribution de la clé de session de groupe, le sur-chiffrement SFrame des trames médias et la rotation des clés médias, l'ouverture d'un salon de crise sur demande de `MS-INCIDENT`, et la constitution puis le scellement de l'archive de crise. L'escalade de crise et la remise multicanale des alertes, qui figuraient dans la première conception de ce service, relèvent respectivement de `MS-INCIDENT` et de `MS-NOTIFICATION`.

Algorithme 6.60 : Établissement d'une session à double cliquet et distribution de la clé de session de groupe Cet algorithme établit, entre deux terminaux vérifiés, une session chiffrée à double cliquet à partir des pré-clés publiées, puis l'utilise pour transmettre la clé de session

de groupe d'un émetteur à chaque terminal vérifié des membres d'un salon. Les calculs sont exécutés par le module cryptographique des terminaux ; le service fournit les pré-clés, les états de vérification et le relais des messages chiffrés.

Spécification formelle de l'algorithme 6.60 : session à double cliquet	
Entrées	Terminal A (clé d'identité IK_A) ; lot de B : IK_B, pré-clé signée SPK_B et sa signature, pré-clé à usage unique OPK_B ; état de vérification de B ; message M.
Sorties	Clé racine et chaînes d'émission et de réception ; message chiffré C ; clé de session de groupe remise aux terminaux vérifiés.
Complexité	$\mathcal{O}(1)$ par message ; $\mathcal{O}(\sum_u d_u)$ pour distribuer une clé de groupe à d_u terminaux par membre u.
Standard	X25519 (RFC 7748) ; Ed25519 (RFC 8032) ; HKDF-SHA-256 (RFC 5869) ; AES-256-GCM.

TABLE 6.67: *Fiche de spécification : session à double cliquet et clé de session de groupe*

Déroulement procédural étape par étape :

1. **Contrôle de vérification :** obtenir de `TerminalUseCase.preKeyBundle` le lot de B ; refuser si l'état de B n'est pas `VERIFIE`, si la signature croisée de IK_B par la clé maîtresse de son utilisateur est invalide, ou si la signature Ed25519 de SPK_B par IK_B est invalide. Le service consomme atomiquement OPK_B (`consumePreKey`) : une pré-clé à usage unique n'est jamais remise deux fois ; en cas d'épuisement, l'accord se fait sans elle et le terminal B est invité à réapprovisionner son lot.

2. **Accord initial :** A engendre une paire éphémère EK_A et calcule, DH désignant X25519,

$$\begin{aligned} DH_1 &= \mathrm{DH}(IK_A, SPK_B), \quad DH_2 = \mathrm{DH}(EK_A, IK_B), \\ DH_3 &= \mathrm{DH}(EK_A, SPK_B), \quad DH_4 = \mathrm{DH}(EK_A, OPK_B), \\ RK_0 &= \mathrm{HKDF}\big(DH_1 \,\|\, DH_2 \,\|\, DH_3 \,\|\, DH_4\big) \end{aligned} \tag{6.73}$$

   puis efface EK_A privée et les DH_i ; B recalcule RK_0 à la réception du premier message.

3. **Cliquet Diffie-Hellman :** à chaque changement de locuteur, l'émetteur engendre une nouvelle paire (r, R) et avance la clé racine avec la dernière clé publique reçue R' :

$$(RK_{i+1}, CK_{i+1}) = \mathrm{HKDF}\big(RK_i,\ \mathrm{DH}(r, R')\big) \tag{6.74}$$

   ce qui procure le rétablissement après compromission : un attaquant qui aurait obtenu l'état courant perd l'accès dès le tour suivant.

4. **Cliquet symétrique et chiffrement :** pour le message n de la chaîne,

$$MK_n = \mathrm{HMAC}(CK_n, \texttt{0x01}), \qquad CK_{n+1} = \mathrm{HMAC}(CK_n, \texttt{0x02}) \tag{6.75}$$

et $C = \mathrm{AEAD}(MK_n, M, \mathrm{AD})$ avec pour données associées les deux clés d'identité et l'en-tête (R, n, PN) ; MK_n est effacée après usage (confidentialité persistante). Les clés de messages sautés sont conservées au plus 1 000 et 7 jours pour absorber les arrivées désordonnées.

5. **Clé de session de groupe :** pour émettre dans un salon, le terminal engendre une chaîne G_0 aléatoire de 32 octets et une paire de signature Ed25519 ; il transmet $(G_k, k, \text{clé publique})$ par les sessions deux à deux à chaque terminal vérifié de chaque membre actif. Le service refuse de relayer ce partage vers un terminal non vérifié ou révoqué. Chaque message de groupe est chiffré avec $K_k = \mathrm{HKDF}(G_k)$, signé, puis la chaîne avance par $G_{k+1} = \mathrm{HMAC}(G_k, \texttt{0x01})$.

6. **Rotation :** une nouvelle chaîne est engendrée, et `groupSessionEpoch` incrémenté, à toute sortie d'un membre ou révocation d'un terminal, après 100 messages ou après 7 jours ; un membre entrant reçoit l'état courant G_k et ne peut remonter la chaîne, les fonctions de hachage étant à sens unique.

Algorithme 6.61 : Sur-chiffrement SFrame des trames médias et rotation des clés Cet algorithme sur-chiffre de bout en bout chaque trame audio, vidéo ou de partage d'écran avant son passage par le serveur de conférence, conformément à la RFC 9605, et renouvelle les clés médias à chaque entrée ou sortie d'un participant, de sorte qu'un entrant ne puisse pas lire ce qui a précédé et qu'un sortant ne puisse pas lire ce qui suit.

Spécification formelle de l'algorithme 6.61 : SFrame et rotation des clés médias	
Entrées	Trame encodée F ; clé de base b de l'émetteur ; identifiant de clé *KID* ; compteur *CTR* ; événements d'entrée et de sortie des participants.
Sorties	Trame protégée en-tête $\Vert$ C ; nouvelle époque de clés et `MediaKeyEpoch` consignée à chaque rotation.
Complexité	$\mathcal{O}(\lvert F\rvert)$ par trame ; à l'entrée, $\mathcal{O}(1)$ par émetteur ; à la sortie, $\mathcal{O}(p)$ remises pour p participants.
Standard	RFC 9605 (suite AES_128_GCM_SHA256_128) ; RFC 8827 ; RFC 5869.

TABLE 6.68: *Fiche de spécification : sur-chiffrement SFrame et rotation des clés médias*

Déroulement procédural étape par étape :

1. **Clé de base de l'émetteur :** à son entrée dans la conférence, chaque terminal engendre une clé de base b de 32 octets pour ses propres émissions et la transmet, par les sessions à double cliquet de l'algorithme 6.60, aux seuls terminaux vérifiés des participants ; *KID* code l'indice de l'émetteur et l'époque.

2. **Dérivation (RFC 9605) :** calculer

$$\begin{aligned} s &= \text{HKDF-Extract}(\varnothing,\ b),\\ k &= \text{HKDF-Expand}(s,\ \ell_k \parallel \mathit{KID} \parallel \text{suite},\ N_k),\\ \sigma &= \text{HKDF-Expand}(s,\ \ell_s \parallel \mathit{KID} \parallel \text{suite},\ N_n) \end{aligned} \tag{6.76}$$

   où ℓ_k et ℓ_s sont les libellés normalisés de la RFC 9605 pour la clé et pour le sel, N_k et N_n les longueurs de clé et de nonce de la suite.

3. **Chiffrement d'une trame :** incrémenter *CTR* (strictement croissant par *KID*), former l'en-tête compact $H = (\mathit{KID}, \mathit{CTR})$ et calculer

$$\text{nonce} = \sigma \oplus \mathit{CTR}, \qquad C = \text{AEAD.Encrypt}(k,\ \text{nonce},\ \text{AAD} = H,\ F) \tag{6.77}$$

   puis émettre $H \parallel C$ dans le flux protégé de saut en saut. Le serveur de conférence n'accède qu'aux en-têtes d'acheminement et ne peut ni lire ni altérer F sans rompre l'étiquette d'authentification.

4. **Réception :** lire *KID*, sélectionner la clé correspondante, rejeter toute trame dont l'étiquette est invalide ou dont *CTR* est rejoué (fenêtre anti-rejeu) ; une trame dont la clé est inconnue est ignorée, le terminal demandant la clé manquante à l'émetteur.

5. **Rotation à l'entrée d'un participant :** chaque émetteur fait avancer sa clé par cliquet de hachage, $b' = \text{HKDF-Expand}(b, \ell_r, 32)$, avec ℓ_r libellé de dérivation propre au service, sans nouvelle remise aux participants présents qui effectuent le même calcul, et remet b' au seul entrant ; l'époque est incrémentée. L'entrant ne peut pas retrouver b à partir de b'.

6. **Rotation à la sortie d'un participant :** chaque émetteur engendre une clé de base entièrement nouvelle et la remet aux seuls participants restants ; l'époque est incrémentée. Les récepteurs conservent la clé précédente pendant 2 secondes pour les trames en transit, puis l'effacent.

7. **Consignation :** le service enregistre chaque changement d'époque (`MediaKeyEpoch` : époque, motif, instant) sans aucune clé, retire le jeton de salle d'un sortant auprès du serveur de conférence et, à la fin de la conférence, publie `collaboration.conference-ended.v1` (durée, participants, époques, segments enregistrés et consentements).

Algorithme 6.62 : Ouverture d'un salon de crise sur demande de MS-INCIDENT Cet algorithme crée, dans un délai de quelques secondes, le salon chiffré d'une cellule de crise, y admet le quorum désigné par `MS-INCIDENT` et le terminal d'archivage, ouvre la conférence associée et rend à l'appelant la référence du salon, qu'il lie au ticket. Il est idempotent, afin que la demande synchrone et l'événement de reprise ne créent jamais deux salons.

Spécification formelle de l'algorithme 6.62 : ouverture d'un salon de crise	
Entrées	Cellule de crise κ ; ticket θ ; quorum Q (utilisateurs et rôles, animateur désigné) ; jeton interne réduit de l'appelant.
Sorties	Salon de type `CRISE` et conférence ouverte ; membres sans terminal vérifié ; `collaboration.crisis-room-opened.v1`.
Complexité	$\mathcal{O}(\lvert Q\rvert \cdot d)$, d étant le nombre moyen de terminaux par membre.
Performance	Réponse en moins de 5 secondes au 99e centile ; idempotence par κ.

TABLE 6.69: *Fiche de spécification : ouverture d'un salon de crise sur demande*

Déroulement procédural étape par étape :

1. **Authentification et idempotence :** vérifier que l'appelant est `MS-INCIDENT` (certificat mTLS lié au jeton interne réduit, liste d'appelants autorisés de `CrisisRoomSyncAdapter`) ; rechercher un salon rattaché à κ (`findByAttachment`) et, s'il existe, le retourner tel quel. La même recherche absorbe l'événement de cellule ouverte lorsqu'il arrive après l'appel synchrone.

2. **Création du salon :** créer sur le serveur de messagerie fédérée un salon de type `CRISE`, chiffrement de bout en bout obligatoire, fédération interdite hors des deux sites, historique visible depuis l'invitation seulement ; rattachement `(cellule de crise, κ)` avec référence du ticket θ ; rétention du type crise.

3. **Admission du quorum :** pour chaque $u \in Q$, appeler `admit`$(u,$rôle$)$, l'animateur désigné recevant le rôle `ANIMATEUR`, et compter ses terminaux vérifiés d_u ; si $d_u = 0$, porter u dans la liste des membres sans terminal vérifié, afin que `MS-INCIDENT` puisse appeler un suppléant. Le calcul et l'arbitrage du quorum restent dans `MS-INCIDENT` (algorithme 6.42).

4. **Terminal d'archivage :** admettre le terminal d'archivage avec le rôle `ARCHIVAGE` et publier dans le salon un message de service annonçant sa présence et sa finalité ; il reçoit dès lors les clés de session de groupe comme tout membre vérifié.

5. **Ouverture de la conférence :** créer la salle sur le serveur de conférence avec politique SFrame obligatoire (`createSfuRoom`), enregistrement désactivé tant que

les consentements n'ont pas été recueillis, et préparer les jetons de salle des membres dont un terminal est vérifié.

6. **Persistance et publication :** dans une transaction, enregistrer le salon, ses membres et la conférence, et insérer `collaboration.crisis-room-opened.v1` (salon, conférence, κ, θ, membres sans terminal vérifié) et `collaboration.notification-requested.v1` (invitation dans la plateforme) dans l'outbox. L'alerte multicanale des membres et leur escalade vers les suppléants demeurent le fait de `MS-INCIDENT` par `MS-NOTIFICATION`.

7. **Réponse :** retourner à `MS-INCIDENT` l'identifiant du salon, celui de la conférence et la liste des membres sans terminal vérifié ; `MS-INCIDENT` lie le salon au ticket et l'inscrit dans la main courante de crise.

Algorithme 6.63 : Constitution et scellement de l'archive de crise Cet algorithme, déclenché par la clôture de la cellule de crise, gèle le salon, compile ses messages et la chronologie de sa conférence, en calcule l'empreinte, obtient un jeton d'horodatage RFC 3161, dépose l'archive en WORM dans `MS-DOCUMENT` et en fait inscrire la référence dans le registre de `MS-AUDIT`. Il produit la trace opposable des échanges d'une crise sans que le serveur de messagerie ait jamais eu accès au contenu.

Spécification formelle de l'algorithme 6.63 : archive de crise	
Entrées	Cellule κ close (événement de `MS-INCIDENT`) ou demande du chef du DES ; salon s ; conférences de s ; clés du terminal d'archivage.
Sorties	`CrisisArchive` scellée ; document PDF/A-3 en WORM ; jeton d'horodatage ; `collaboration.crisis-archive-sealed.v1`.
Complexité	$\mathcal{O}(M)$ en temps pour M messages et événements de conférence.
Standard	RFC 3161 ; RFC 5280 ; SHA-256 ; ISO 19005-3 ; RFC 8259 ; RFC 9162 par `MS-AUDIT`.

TABLE 6.70: *Fiche de spécification : constitution et scellement de l'archive de crise*

Déroulement procédural étape par étape :

1. **Gel du salon :** si une archive existe déjà pour κ, s'arrêter (idempotence) ; sinon passer s à `GELE` (`freeze`) : plus aucun message n'est accepté, les membres conservent la lecture ; clore la conférence en cours et publier `collaboration.conference-ended.v1`.

2. **Export et déchiffrement :** exporter du serveur de messagerie fédérée les messages chiffrés de s dans l'ordre de leur horodatage serveur (`export`), puis les déchiffrer par le terminal

d'archivage (`ArchiveDecryptorPort.decrypt`), dont les clés sont utilisées dans le coffre de clés sans en sortir ; un message que ce terminal ne peut déchiffrer, faute d'avoir reçu la clé, est consigné comme « indéchiffrable » avec ses métadonnées, ce qui constitue en soi une information de preuve.

3. **Compilation et masquage :** composer, dans l'ordre chronologique, les entrées de messages (horodatage, auteur, terminal, texte, références des pièces jointes, accusés) et celles de la chronologie des conférences (ouverture, entrées et sorties, époques de clés, partages d'écran, segments enregistrés avec leurs consentements) ; masquer toute suite de chiffres vérifiant la formule de Luhn en ne conservant que les six premiers et les quatre derniers chiffres, et en compter le nombre dans `maskedSequences`. Les entrées sont chaînées :
$$h_0 = \mathrm{SHA256}(\kappa \,\|\, s), \qquad h_i = \mathrm{SHA256}\big(h_{i-1} \,\|\, \mathrm{entrée}_i\big) \tag{6.78}$$
de sorte que toute suppression ou altération d'une entrée soit détectable ; h_M figure au manifeste.

4. **Rendu et empreinte :** rendre l'archive en PDF/A-3, y joindre les entrées au format RFC 8259 et le manifeste (cellule, ticket, période, nombre de messages, messages indéchiffrables, h_M), puis calculer $H = \mathrm{SHA256}(\text{document})$.

5. **Horodatage :** obtenir $\tau = \mathrm{TSA}(H)$ par `TimestampAuthorityPort.stamp` et vérifier que l'empreinte portée par τ est égale à H et que le certificat de l'autorité est valide (RFC 5280) ; en cas d'indisponibilité, réessayer avec un délai croissant, l'archive restant en attente sans être déposée.

6. **Dépôt WORM :** déposer le document et τ dans `MS-DOCUMENT` sous le type archive de crise (algorithme 6.17), qui contrôle à nouveau le masquage et l'empreinte et le conserve en mode conformité pendant dix ans ; mémoriser `documentRef`.

7. **Scellement, publication et effacement :** appeler `CrisisArchive.seal`$(\tau, \text{documentRef})$, passer s à `ARCHIVE` et insérer `collaboration.crisis-archive-sealed.v1` (κ, H, empreinte de τ, `documentRef`) dans l'outbox : `MS-AUDIT` en fait une feuille de l'arbre de Merkle et `MS-INCIDENT` rattache l'archive au rapport post-incident. Le terminal d'archivage efface alors les clés de session de s (`forget`) ; les messages chiffrés du salon sont purgés du serveur 90 jours plus tard par la tâche de rétention.

6.2 Thème de l'application

Le thème défini ici est celui que les maquettes de la section 6.3, puis toutes les interfaces de la plateforme, devront conserver. Il répond à trois contraintes : une lecture prolongée en salle de supervision, de jour comme de nuit ; une identité institutionnelle sobre, cohérente avec les documents du groupement ; l'accessibilité (contraste, taille de police, navigation au clavier) exigée par le référentiel WCAG 2.2 au niveau AA retenu dans le cahier de charges.

6.2.1 Identité graphique et logo

Le logo officiel du GIMAC est l'unique marque visuelle de la plateforme. Il est placé en haut à gauche de chaque couche de présentation, en version monochrome sur fond clair, et n'est jamais déformé ni recoloré. Le nom de la couche (application du département, portail des participants, console d'administration et d'audit) figure à sa droite, en capitales espacées, pour que l'utilisateur sache à tout instant dans quelle couche il se trouve. Aucune illustration décorative, aucun motif de fond, aucune animation d'ambiance ne sont admis.

6.2.2 Palette chromatique

La palette est volontairement réduite. Elle se compose d'une couleur institutionnelle, de gris de structure et de trois teintes de statut, utilisées avec parcimonie et toujours doublées d'un texte ou d'un pictogramme (aucune information n'est portée par la couleur seule).

Rôle	Valeur RVB	Usage
Bleu institutionnel	21, 86, 158	Titres, boutons d'action principale, liens, en-têtes de tableaux, élément de navigation actif
Gris de structure	92, 98, 104	Textes secondaires, bordures, pictogrammes inactifs, séparateurs
Fond de page	245, 246, 248	Fond général de l'application
Fond de cartouche	234, 240, 247	Lignes alternées des tableaux, panneaux latéraux, cartes d'indicateurs
Texte principal	20, 22, 26	Corps de texte, valeurs des indicateurs
Statut nominal	34, 110, 72	Pictogramme et libellé « conforme », « en service », « acquittée »
Statut à surveiller	158, 106, 21	Pictogramme et libellé « à régulariser », « en attente », « échéance proche »
Statut critique	158, 38, 38	Pictogramme et libellé « non conforme », « S1 », « seuil franchi » ; jamais en aplat de fond

TABLE 6.71: *Palette chromatique de la plateforme*

Un mode sombre, dérivé de la même palette par inversion des fonds (fond de page 24, 26, 30 ; texte principal 236, 238, 241) et conservation des teintes de statut, est prévu pour la salle de supervision de nuit ; il est sélectionnable par l'utilisateur et mémorisé dans ses préférences.

6.2.3 Typographie et grille

La police d'interface est une police sans empattement lisible à petite taille, avec chiffres à chasse fixe pour les tableaux d'indicateurs, de montants et d'horodatages. La taille de base est de 14 points à l'écran, avec une échelle de titres à trois niveaux (24, 18 et 16 points). Les mises en page reposent sur une grille de 8 pixels : marges, espacements et hauteurs de composants en sont des multiples. Les écrans sont conçus pour une largeur minimale de 1280 pixels pour l'application du département et la console, et adaptés jusqu'à 360 pixels pour le portail des participants, consultable sur mobile.

6.2.4 Design des composants d'interface

Tous les composants partagent un principe : angles droits, bordures fines de 1 pixel, aucune ombre portée, aucun dégradé. Cette sobriété est celle des documents du groupement et facilite la lecture sur les murs d'écrans.

- **Boutons :** trois variantes seulement : principale (fond bleu institutionnel, texte blanc), secondaire (fond blanc, bordure et texte bleus) et destructrice (fond blanc, bordure et texte en teinte critique, confirmation obligatoire). Hauteur de 40 pixels, libellé en verbe d'action (« Clore l'opération », « Signer le quitus »). Les actions à effet réglementaire (signature d'un quitus, clôture d'un incident, bascule de statut) exigent une seconde étape de confirmation qui rappelle l'objet et les conséquences.
- **Zones de texte et formulaires :** étiquette permanente au-dessus du champ, bordure grise de 1 pixel, bordure bleue de 2 pixels au focus, message d'erreur sous le champ en teinte critique avec pictogramme, champs obligatoires marqués. Les formulaires longs (fiche d'institution, dossier de mise en service) sont découpés en étapes avec indicateur de progression.
- **Listes déroulantes et sélecteurs :** recherche intégrée dès dix options (sélection d'une institution parmi plus de cent vingt membres), sélection multiple par jetons, navigation au clavier complète.
- **Cases à cocher et interrupteurs :** case carrée de 18 pixels pour les choix multiples, interrupteur pour les préférences binaires (canal de notification, mode sombre), libellé cliquable.
- **Tableaux de données :** en-tête bleu à texte blanc, lignes alternées, tri par colonne, filtres persistants, pagination côté serveur, colonne d'actions à droite, ligne dépliable pour le détail ; les colonnes d'horodatage affichent l'heure locale et l'UTC au survol.
- **Cartes d'indicateurs :** une valeur, un libellé, une tendance (flèche et variation) et le seuil ; la teinte de statut n'apparaît que sur le pictogramme et le libellé, jamais sur le fond de la carte.
- **Bandeaux de notification :** centre de notifications accessible depuis la barre supérieure, notifications urgentes et critiques affichées en bandeau persistant jusqu'à acquittement, avec l'action attendue.
- **Tiroirs de détail :** panneau latéral droit ouvrant le détail d'un objet (ticket, opération, suspens) sans quitter la liste ; il porte la chronologie de l'objet et les actions permises par le rôle.
- **Pictogrammes :** un seul jeu de pictogrammes linéaires monochromes, toujours accompagnés d'un libellé ou d'une infobulle.

6.3 Maquettes des principales interfaces

La réalisation des maquettes constitue la phase qui suit la validation du présent cahier. Cette section en prépare le terrain : elle fixe la structure commune des trois couches de présentation, dresse la cartographie des écrans, module par module, et réserve l'emplacement des maquettes des écrans principaux. Chaque écran est rattaché au microservice qui le sert par l'intermédiaire de la passerelle, ce qui garantit que la cartographie ne fait apparaître aucune fonction que les services ne fournissent pas.

6.3.1 Structure commune des trois couches

Les trois couches partagent une même enveloppe applicative, servie par MS-GATEWAY selon le modèle Backend-For-Frontend : une barre supérieure (logo, nom de la couche, horloge locale et UTC, centre de notifications, identité de l'utilisateur et vacation en cours pour les opérateurs, sélecteur de langue) ; une barre latérale rétractable dont les entrées sont filtrées par les permissions du jeton, les entrées non autorisées étant absentes et non grisées ; une zone de contenu ; un pied de page rappelant la référence de la plateforme et la classification des informations affichées. Le canal poussé rafraîchit les listes, les indicateurs et le centre de notifications sans rechargement. Toute action à effet ouvre une confirmation, puis renvoie l'identifiant de corrélation de la requête, visible dans le tiroir de détail, ce qui permet de la retrouver dans le journal d'audit.

Les couches diffèrent par leur zone réseau, leur population et leurs exigences d'authentification : l'application du département, en zone applicative, pour les collaborateurs du DES et des directions, avec authentification par le fournisseur d'identité et facteur FIDO2 ; le portail des participants, en DMZ, pour les correspondants des institutions membres, avec authentification par le fournisseur d'identité, facteur fort et cloisonnement strict par institution ; la console d'administration et d'audit, en zone d'administration, pour les administrateurs, le RSSI et les auditeurs, avec authentification par certificat client, facteur FIDO2 et sessions courtes.

6.3.2 Cartographie des écrans de l'application du département

TABLE 6.72: *Cartographie des écrans de l'application du département*

Module	Écran	Contenu et actions	Service
Accueil	Tableau de bord du DES	Cartes d'indicateurs du service de l'utilisateur, alertes en attente d'acquittement, tickets S1 et S2 ouverts, échéances de la semaine, tâches assignées, liaisons en attente d'action	MS-REPORTING, MS-NOTIFICATION
Habilitations et annuaire	Mon profil et mes disponibilités	Rattachements, rôles, délégations reçues et accordées, déclaration des congés et absences (BF-ADMIN), préférences de canal et de thème	MS-IAM, MS-NOTIFICATION
Gestion documentaire	Bibliothèque des pièces	Recherche par type, institution, période ; dépôt guidé avec résultat du contrôle de masquage ; versions ; journal de consultation de la pièce	MS-DOCUMENT
Notifications	Centre de notifications	Liste par niveau d'urgence, acquittement, historique des remises, renvoi vers l'objet concerné	MS-NOTIFICATION
Institutions membres	Registre des institutions	Liste filtrable (catégorie, pays, statut, conformité), fiche institution en onglets (identité, conventions, services souscrits, correspondants, pièces légales et échéances, interactions, escalade), demande de transition de statut et validation maker-checker	MS-PARTICIPANT
Suivi de la certification	Liaisons et parcours	Liste des liaisons par type de projet et état ; vue d'une liaison : graphe des opérations avec états, périmètre contractualisé, couvertures par service, résultats repris du simulateur, dépôt de preuve et clôture par la règle des quatre éléments	MS-HOMOLOGATION

Module	Écran	Contenu et actions	Service
Suivi de la certification	Dossier de mise en service	Complétude du dossier, circuit des quatre quitus avec signature, fiche de changement lue, procès-verbal, attestation générée	MS-CERT-IFICATION
Tickets et demandes	File des tickets	Liste par état, priorité, institution ; création ; tiroir de détail avec chronologie, gel d'engagement, pièces, tâches liées	MS-INCIDENT
Incidents	Qualification et suivi d'un incident	Matrice impact et urgence, sévérité, marqueur réglementaire, escalade, critères de clôture, rapport circonstancié	MS-INCIDENT
Monitoring et astreintes	Tableau des liaisons supervisées	État de chaque liaison et plateforme, alertes en cours, acquittement, ouverture d'un ticket depuis une alerte	MS-MONITORING
Monitoring et astreintes	Grille d'astreinte et relève de quart	Grille hebdomadaire générée, révision et publication ; vacation en cours, main courante, génération et signatures du rapport de quart	MS-MONITORING
Cellule de crise	Salle de crise	Constitution, quorum, main courante de crise, décisions converties en tâches, accès au salon et à la conférence, clôture et rapport post-incident	MS-INCIDENT, MS-COLL-ABORATION
Rapprochement	Journées et suspens	Import d'un état, résultat du rapprochement, liste des suspens par ancienneté et institution, conciliation, dépôt de l'attestation de régularisation	MS-RAPP-ROCHEMENT
Tâches	Tableaux Kanban	Tableau du service avec limites d'en-cours, déplacement des cartes, dérogation, tâches issues de tickets, d'opérations et de décisions	MS-PILOTAGE

Module	Écran	Contenu et actions	Service
Projets	Portefeuille de projets	Fiche projet, jalons et chemin critique, matrice des risques, fiches d'action PDCA	MS-PILOTAGE
Réunions	Instances et décisions	Ordre du jour, présences, compte rendu déposé, décisions et tâches engendrées, taux d'exécution	MS-PILOTAGE
Reporting	Cockpits et rapports	Cockpit du DES, cockpit de la Direction Générale, vues par service, seuils et tendances, rapports hebdomadaires et mensuels	MS-REPORTING
Messagerie et visioconférence	Salons et conférences	Salons de quart, de thème, d'incident et de crise ; vérification des terminaux ; lancement d'une conférence	MS-COLLABORATION

6.3.3 Cartographie des écrans du portail des participants

Le portail n'expose à un correspondant que les objets de son institution ; les listes sont filtrées par la politique de lignes et toute tentative d'accès hors périmètre est journalisée.

TABLE 6.73: *Cartographie des écrans du portail des participants*

Module	Écran	Contenu et actions	Service
Accueil	Espace de l'institution	Statut et état de conformité, échéances à venir, liaisons en cours, tickets ouverts, suspens à régulariser, notifications	MS-PARTICIPANT, MS-REPORTING
Institutions membres	Fiche et pièces légales	Consultation de la fiche, mise à jour des correspondants (validée par le DES), dépôt des pièces légales avec contrôle de masquage	MS-PARTICIPANT, MS-DOCUMENT

Module	Écran	Contenu et actions	Service
Suivi de la certification	Ma liaison	Parcours d'opérations avec ce qui incombe à l'institution, dépôt des preuves attendues, résultats des campagnes du simulateur, couvertures, état du dossier de mise en service	MS-HOMOLOGATION, MS-CERTIFICATION
Tickets et demandes	Mes tickets	Création d'une demande ou d'un incident, suivi de l'état, échanges, pièces	MS-INCIDENT
Rapprochement	Mes suspens	Suspens ouverts par ancienneté, commentaires de conciliation, dépôt de l'attestation de régularisation	MS-RAPPROCHEMENT
Notifications	Préférences et historique	Canaux, plage horaire, historique des notifications reçues et acquittées	MS-NOTIFICATION

6.3.4 Cartographie des écrans de la console d'administration et d'audit

TABLE 6.74: *Cartographie des écrans de la console d'administration et d'audit*

Module	Écran	Contenu et actions	Service
Habilitations et annuaire	Rôles, permissions et délégations	Matrice des rôles à cinq niveaux, permissions par domaine, délégations en cours, sessions actives et révocation	MS-IAM
Habilitations et annuaire	Campagne de réexamen des accès	Lancement, répartition aux approbateurs, décisions, scellement de la campagne	MS-IAM
Journal d'audit	Vérification de l'intégrité	Recherche d'un événement, dossier de preuve d'inclusion, racines de période et jetons d'horodatage, preuve de cohérence, résultat de vérification consigné	MS-AUDIT

Module	Écran	Contenu et actions	Service
Gestion documentaire	Rétention et purges	Politiques de rétention par type, demandes de purge à quatre yeux, rapport de vérification d'intégrité	MS-DOCUMENT
Passerelle	Routes, quotas et politiques	Routes par couche, limites de débit, politiques d'accès, décisions récentes de la passerelle	MS-GATEWAY, MS-IAM
Référentiels	Référentiel d'opérations et matrices	Publication d'une version du référentiel d'opérations, matrice de criticité, engagements par sévérité, seuils des indicateurs	MS-HOMOLOGATION, MS-INCIDENT, MS-REPORTING
Exploitation de la plateforme	État des services et files	État des quatorze services, retards de consommation du bus, événements en rebut, tâches de reprise	MS-MONITORING

6.3.5 Emplacements des maquettes des écrans principaux

Les maquettes des écrans ci-dessous seront produites, validées puis intégrées à cet emplacement lors de la phase suivante ; elles devront respecter le thème de la section 6.2 et la structure commune décrite plus haut.

[EMPLACEMENT DE LA MAQUETTE : Application du département : tableau de bord du DES]

Écran cible : `maq_des_tableau_de_bord.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.43: *Application du département : tableau de bord du DES*

[EMPLACEMENT DE LA MAQUETTE : Application du département : fiche d'une institution membre]

Écran cible : `maq_des_institution.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.44: *Application du département : fiche d'une institution membre*

[EMPLACEMENT DE LA MAQUETTE : Application du département : suivi d'une liaison et de ses opérations]

Écran cible : `maq_des_liaison.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.45: *Application du département : suivi d'une liaison et de ses opérations*

[EMPLACEMENT DE LA MAQUETTE : Application du département : dossier de mise en service et circuit des quitus]

Écran cible : `maq_des_dossier_mise_en_service.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.46: *Application du département : dossier de mise en service et circuit des quitus*

[EMPLACEMENT DE LA MAQUETTE : Application du département : qualification et suivi d'un incident]

Écran cible : `maq_des_incident.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.47: *Application du département : qualification et suivi d'un incident*

[EMPLACEMENT DE LA MAQUETTE : Application du département : grille d'astreinte et relève de quart]

Écran cible : `maq_des_astreinte_quart.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.48: *Application du département : grille d'astreinte et relève de quart*

[EMPLACEMENT DE LA MAQUETTE : Application du département : journée de rapprochement et suspens]

Écran cible : `maq_des_suspens.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.49: *Application du département : journée de rapprochement et suspens*

[EMPLACEMENT DE LA MAQUETTE : Application du département : tableau Kanban du service]

Écran cible : `maq_des_kanban.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.50: *Application du département : tableau Kanban du service*

[EMPLACEMENT DE LA MAQUETTE : Application du département : cockpit de la Direction Générale]

Écran cible : `maq_des_cockpit_dg.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.51: *Application du département : cockpit de la Direction Générale*

[EMPLACEMENT DE LA MAQUETTE : Portail des participants : espace de l'institution]

Écran cible : `maq_portail_accueil.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.52: *Portail des participants : espace de l'institution*

[EMPLACEMENT DE LA MAQUETTE : Portail des participants : suivi de la liaison et dépôt des preuves]

Écran cible : `maq_portail_liaison.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.53: *Portail des participants : suivi de la liaison et dépôt des preuves*

[EMPLACEMENT DE LA MAQUETTE : Console d'administration et d'audit : vérification de l'intégrité du journal]

Écran cible : `maq_console_audit.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.54: *Console d'administration et d'audit : vérification de l'intégrité du journal*

[EMPLACEMENT DE LA MAQUETTE : Console d'administration et d'audit : rôles, délégations et réexamen des accès]

Écran cible : `maq_console_habilitations.png`

(Maquette d'interface graphique en attente d'intégration)

FIGURE 6.55: *Console d'administration et d'audit : rôles, délégations et réexamen des accès*

CHAPITRE 7

Conclusion

Ce chapitre dresse le bilan du présent cahier de conception et annonce la phase qui lui succède.

7.1 Bilan de la conception

Le cahier de conception CC-GIMAC-01 (version 1.1) clôt la phase en V du projet d'ensemble. Il prend appui sur le cahier de charges techniques CCT-GIMAC-01 et sur le cahier d'analyse CA-GIMAC-01, dont il conserve les objectifs, les sept domaines, les dix-sept modules et les règles de gestion, et il les traduit en une architecture logicielle et en une conception détaillée directement exploitables par l'équipe de développement.

La conception générale a fixé une architecture axée microservices : quatorze services, chacun propriétaire de sa base de données et de son modèle, communiquant de façon synchrone par des interfaces de service protégées en mTLS et de façon asynchrone par un bus d'événements alimenté au travers du patron Transactional Outbox. Une passerelle d'accès unique, conforme au modèle de confiance nulle, sert les trois couches de présentation et réduit la portée de chaque jeton au seul service ciblé. Le découpage a été poussé jusqu'à isoler les fonctions transverses qui, dans les versions précédentes, restaient diluées dans les services métier : le registre d'audit inaltérable, la gestion électronique des documents et les notifications sont désormais des services à part entière, et l'ancien service d'exploitation a été scindé entre les incidents, le monitoring et le rapprochement. La dissociation entre le suivi de l'homologation et la décision de certification, exigée par l'ISO/IEC 17065, est matérialisée par deux services distincts.

La conception détaillée a livré, pour chacun des quatorze services, le diagramme de composants internes, le diagramme de classes de conception, un diagramme d'objets et de trois à six algorithmes formalisés, soit soixante-trois algorithmes au total, sans nommer aucun produit : les choix technologiques restent confinés au chapitre 4 et peuvent évoluer sans remettre la conception en cause. Deux principes ont été tenus de bout en bout : la plateforme est non intrusive vis-à-vis du commutateur, du simulateur de certification et du dispositif de gestion des changements, dont elle lit et référence les données sans jamais y écrire ; et toute action à effet

produit un événement, consommé par le registre d'audit, scellé par période, horodaté et publié hors de la plateforme. Le thème de l'application et la cartographie des écrans des trois couches de présentation complètent le document et préparent la phase de maquettage.

7.2 Annonce de la phase suivante

La validation du présent cahier ouvre deux chantiers menés en parallèle. Le premier est la réalisation des maquettes des principales interfaces, aux emplacements réservés à la section 6.3, dans le respect du thème défini à la section 6.2 ; ces maquettes seront validées avec les utilisateurs du DES, des directions et de quelques institutions membres avant intégration. Le second est la constitution du carnet de produit : les besoins du cahier de charges, les cas d'utilisation et les règles de gestion du cahier d'analyse, et les services, classes et algorithmes du présent cahier sont convertis en récits utilisateur ordonnés par valeur, puis répartis dans le plan d'implémentation de la première phase (deux semaines de préparation, quatre itérations de deux semaines) décrit dans le cahier de charges. La première itération livre le socle (passerelle, habilitations, bus d'événements, registre d'audit, squelette des trois couches) ; la deuxième, la gestion documentaire, les notifications, les institutions membres et le monitoring ; les deux dernières, le suivi de la certification, le portail des participants, la console d'administration et d'audit, puis la recette sur les serveurs du groupement. Les modules d'exploitation, de pilotage et de collaboration suivent par vagues selon le même enchaînement.

Chaque itération s'achève par une revue conforme au plan de qualité du chapitre 4 : tests unitaires et d'intégration, revue de code, contrôle de la couverture des exigences, vérification de l'absence de donnée de carte et de secret dans les dépôts, et mise à jour de la traçabilité entre les récits, les services et les algorithmes du présent document.